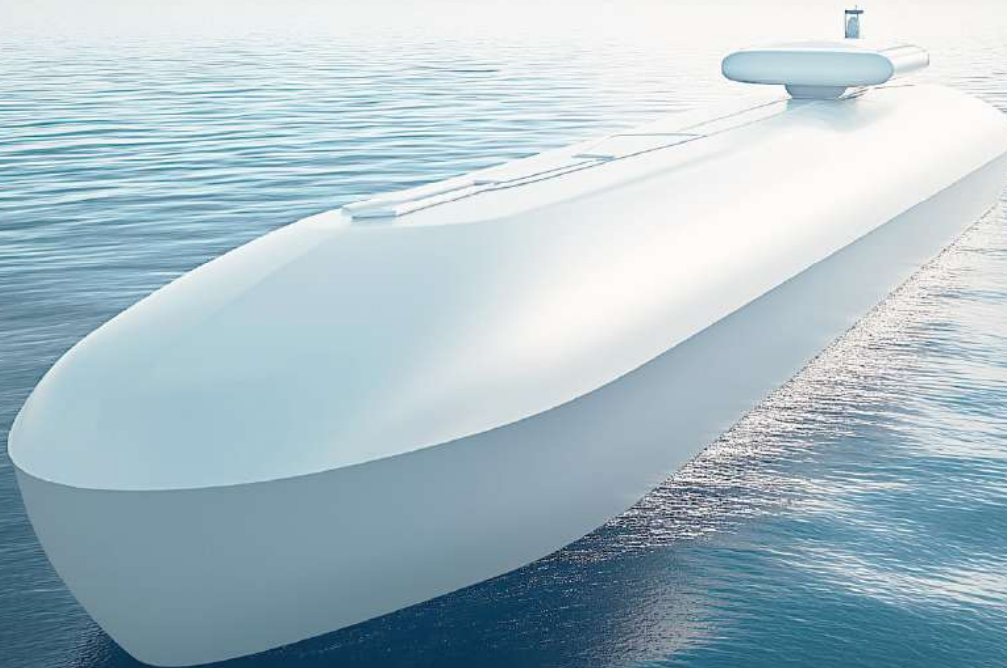


자율운항선박 보안모델



과학기술정보통신부



한국인터넷진흥원





CONTENTS

자율운항선박 보안모델

01. 개 요	3
1.1. 배경 및 목적	4
1.2. 성숙도 기반 모델의 필요성	6
1.3. 구성 및 확장 사항	10
02. 자율운항선박 보안 성숙도 모델	13
2.1. 자율운항선박 기술 및 운영 환경	14
2.2. 자율운항 관련 규정 및 표준	21
2.3. 성숙도 모델 프레임워크	24
2.4. MASS-ROC 생태계: 통합된 사이버-물리 시스템(CPS)	26
2.5. 자율운항선박 보안 생애주기 모델	27
03. 자율운항선박 사이버 위협 분석	31
3.1. 핵심 자산 식별	32
3.2. 데이터 흐름도(DFD) 기반 위협 모델링	37
04. 사이버 리스크 평가 및 시나리오	57
4.1. 리스크 평가 방법론	58
4.2. 자율운항선박 리스크 평가	64
4.3. 리스크 평가 결과	101
05. 자율운항선박 성숙도 기반 보호기술	105
5.1. 자율운항선박 리스크 관리 전략	106
5.2. 보안 아키텍처 원칙	108
5.3. Level 1 통제: 규제 준수 기반 확보	109
5.4. Level 2 통제: 구조화된 OT 방어 구축	111
5.5. Level 3 통제: 적응형 복원력	113
06. 7대 사이버보안 보호 기술	115
6.1. 인증 (스마트선박 보안모델: 인증-01~인증-05)	119
6.2. 접근 통제 (접근통제-01~접근통제-13)	123
6.3. 암호화 (암호화-01~암호화-03)	128
6.4. 부인방지 (부인방지-01~부인방지-05)	130
6.5. 가용성 및 복원력 (가용성-01, 가용성-02)	134
6.6. AI 보안 (Security for AI)	137
6.7. 관리체계 (관리-01~관리-06)	139
6.8. 성숙도 기반 자율운항선박 보호기술	143
07. 부록	149
A. 자율운항선박 성숙도 모델	150
B. 자율운항선박 보안솔루션 분류	156
C. 자율운항선박 AI 보안(Security for AI) 가이드	157
D. 용어 정의 및 약어	172
E. 참고 문헌	174

개 요

1.1. 배경 및 목적	4
1.2. 성숙도 기반 모델의 필요성	6
1.3. 구성 및 확장 사항	10



개요

1.1. 배경 및 목적

정보통신기술(CT), 인공지능(AI), 사물인터넷(IoT) 등 4차 산업혁명 기술이 해운·조선 산업에 융합되면서 자율운항선박 시대가 현실로 다가오고 있다. 자율운항선박은 최적 항로 운항을 통한 물류 효율성 증대, 인적 과실 감소를 통한 해양 사고 예방, 그리고 연료 소비 최적화를 통한 친환경성 확보 등 해사 산업 전반에 걸쳐 패러다임의 전환을 이끌 잠재력을 지니고 있다. HFW의 시장 분석 보고서(2024)에 따르면 전 세계 자율운항선박 시장은 2022년 2,900만 달러에서 2030년 9,100만 달러 규모로 성장할 것으로 전망하는 등 폭발적인 성장이 예상된다.

그러나 이러한 기술적 진보는 새로운 차원의 사이버 리스크를 동반한다. 과거 물리적으로 격리(Air-Gap) 되었던 선박의 운영기술(OT) 시스템이 원격운항센터(Remote Operation Center, ROC)와의 실시간 데이터 교환을 위해 육상의 정보기술(IT) 시스템과 연결되면서 공격 표면(Attack Surface)이 급격히 넓어졌다. 이로 인해 사이버 공격은 단순한 정보 유출을 넘어 선박의 항해 및 제어 시스템을 직접 겨냥하여 좌초, 충돌, 나아가 선박 탈취와 같은 심각한 물리적 재난으로 이어질 수 있는 중대한 위협이 되었다.

실제로 해운업계는 이미 수많은 사이버 공격으로 막대한 피해를 경험한 바 있다. 2017년 세계 최대 해운사 머스크(Maersk)는 랜섬웨어 공격으로 3주간 시스템이 마비되어 약 3,000억 원의 손실을 입었으며, 이후에도 주요 해운사, 항만, 조선소가 랜섬웨어, 스피어피싱, 스푸핑 공격의 표적이 되어왔다. 자율운항선박의 등장은 이러한 공격의 파급력을 더욱 증폭시킬 수 있다.

미래의 자율운항선박에 대한 공격은 사이버 공간의 위협이 물리적 세계의 재앙으로 직결될 수 있다. 특히 AI 기반의 대규모 언어 모델(LLM)을 활용하여 악성코드 개발과 피싱 공격을 자동화하는 등 해커들은 공격의 정교함과 효율성을 높이고 있다. 2024년 하반기에만 단일 보안 업체에서 1,998척의 선박을 모니터링한 결과 90억 건의 보안 이벤트와 1만 건 이상의 악성코드 사고가 탐지되었다. 이는 위협의 규모가 기하급수적으로 증가하고 있음을 보여준다. (Marlink, 2025. 05)

이러한 위협에 대응하기 위해 국제해사기구(IMO)는 MSC 428(98) 결의안을 통해 선박 안전관리 시스템(SMS)에 사이버 리스크 관리를 의무화했으며, 국제선급연합회(IACS)는 2024년 7월부터 건조 계약되는 선박에 대해 사이버 복원력 관련 공통규칙인 UR E26, E27의 적용을 강제화했다. 더 나아가 IMO는 2026년까지 자율운항선박 운용을 위한 국제 규약인 '비강제 MASS Code' 채택을 목표로 하고 있어, 규제 환경은 더욱 강화될 전망이다.

자율운항선박(Maritime Autonomous Surface Ship, MASS) 시대의 도래는 해사 산업에 전례 없는 혁신을 약속하는 동시에, 사이버-물리 시스템(Cyber-Physical System, CPS) 고유의 복잡하고 중대한 리스크를 야기한다. 본 문서는 이러한 배경 하에 자율운항선박 및 원격운항센터의 설계, 건조, 운영에 관여하는 모든 이해관계자가 복잡한 사이버 위협 환경을 이해하고, 이에 효과적으로 대응하기 위한 종합적인

개요

보안 모델을 제시하는 데 목적이 있다. 특히, 기존 스마트선박 보안 모델을 확장하여, 조직의 기술 수준과 운영 목표에 따라 보안 역량을 단계적으로 강화할 수 있는 '보안 성숙도 모델'을 도입하여, 안전하고 신뢰할 수 있는 자율운항 시대를 열기 위한 전략적·기술적·관리적 청사진을 제공하고자 한다.



개요

1.2. 성숙도 기반 모델의 필요성

1.2.1 패러다임의 전환: 스마트선박에서 자율운항선박으로

- ❶ **차이점과 주요 특징:** 자율운항선박의 보안을 논하기 위해서는 이것이 단순히 기존 선박에 새로운 기술을 추가한 것이 아니라, 운항 철학, 시스템 구조, 리스크의 본질 자체가 근본적으로 변화한 새로운 패러다임을 이해해야 한다. 이러한 패러다임의 전환은 왜 새로운 보안 모델이 필수적인지를 명확히 보여준다.
- ❷ **인적 요소의 역할 변화:** 전통적인 선박에서 인간은 시스템의 모든 제어 루프 중심에 있는 '운항자(human-in-the-loop)'이다. 모든 결정과 조작은 인간의 직접적인 개입을 통해 이루어진다. 반면, 자율운항선박에서 인간의 역할은 시스템을 감시하고 예외적인 상황에만 개입하는 '감독자(human-on-the-loop)'로 전환된다. 이는 인적 과실을 줄이는 긍정적 효과가 있지만, 동시에 운영자의 상황 인식(Situational Awareness)을 저해하는 인지적 과부하, 시스템에 대한 맹신으로 인한 경계심 약화, 그리고 운영자의 신뢰를 악용하여 시스템을 오도하는 새로운 공격 벡터를 만들어낸다.
- ❸ **시스템 아키텍처의 변화:** 일반 선박의 운영기술(OT) 시스템은 항해, 기관 등 각 기능별로 독립적이고 폐쇄적으로 구성되어 외부와의 연결이 거의 없는 '에어 갭(Air-gap)' 개념에 가까웠다. 그러나 자율운항선박은 선내의 수많은 센서와 제어기, 육상의 원격운항센터(ROQ), 클라우드 기반 데이터 분석 플랫폼, 그리고 기상 정보와 같은 제3자 서비스가 위성, 5G 등 다양한 통신 채널을 통해 실시간으로 데이터를 교환하는 초연결(Hyper-connected) 사이버-물리 시스템(CPS)이다. 명확했던 보안 경계는 사라지고, 공격 표면은 기하급수적으로 확장된다.
- ❹ **데이터의 역할 변화:** 전통적 선박에서 데이터는 항해사의 의사결정을 돕는 보조 수단(항해도, 기상도 등)이었다. 선박의 조종은 키(Rudder)와 엔진 텔레그래프 같은 물리적 장치를 통해 이루어졌다. 하지만 자율운항선박에서 데이터는 더 이상 보조 수단이 아니다. 센서 데이터, AI 알고리즘의 연산 결과, ROQ에서 수신된 원격 제어 명령 등 '데이터' 자체가 선박을 움직이는 새로운 '키(Rudder)'가 되었다. 따라서 데이터의 무결성(Integrity)은 단순한 IT 보안 문제가 아니라, 선체 자체의 물리적 견고함과 동일한 수준의 핵심적인 안전(Safety) 요구사항으로 격상된다.



개요

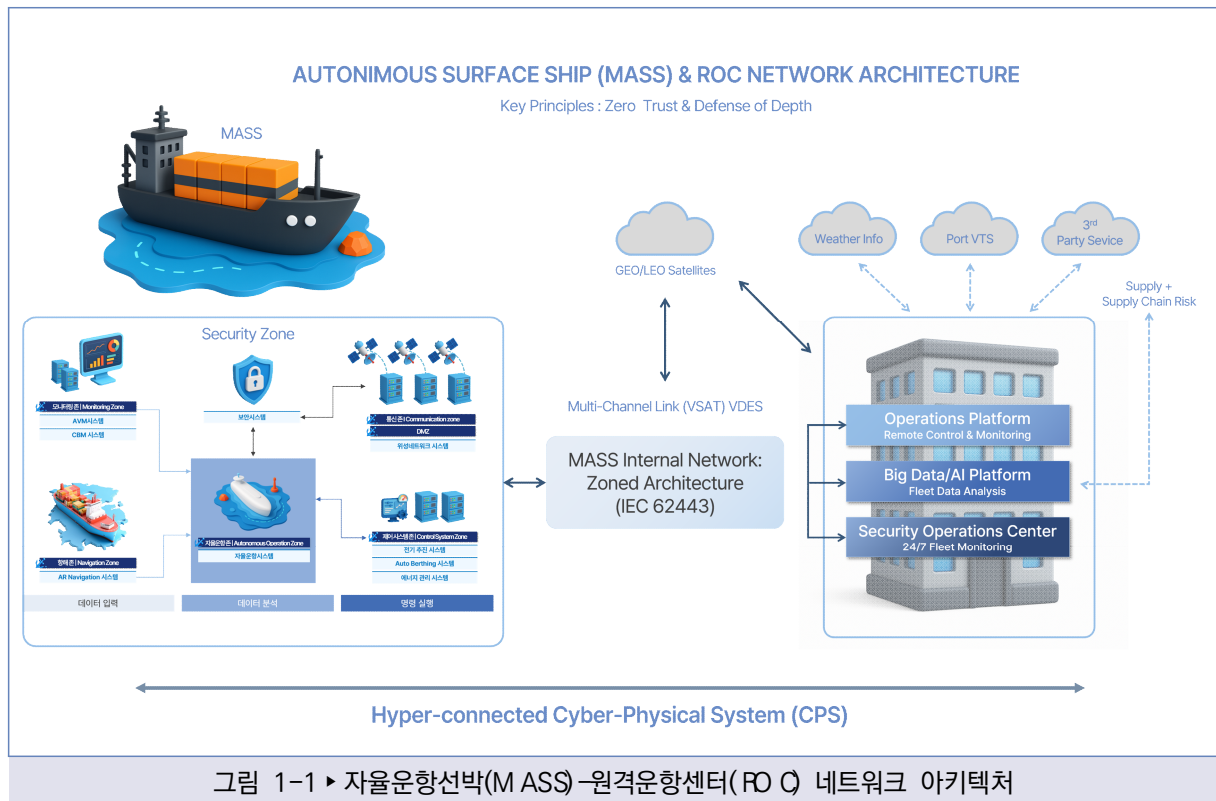
이러한 근본적인 차이점을 체계적으로 이해하기 위해 다음 표와 같이 주요 특징을 비교할 수 있다.

표 1-1 스마트선박과 자율운항선박의 주요 차이점

특징	스마트선박	자율운항선박 (MASS)	보안 리스크
조종	수동, 직접적 물리 제어	데이터 기반, 알고리즘, 원격 제어	• 공격의 초점이 물리적 접근에서 데이터 조작으로 전환됨
네트워크 아키텍처	분리된 네트워크 (Air Gap)	초연결된 IT/OT/클라우드 생태계	• 공격 표면의 기하급수적 확장 및 전통적 경계 보안의 상실
인적 역할	운항자 (Operator)	감독자 (Supervisor)	• 인간-기계 인터페이스(HMI) 및 운영자 신뢰를 겨냥한 새로운 공격 벡터 부상
주요 리스크	물리적 위험 (고장, 충돌)	사이버-물리 위협 (GPS 스푸핑, 명령 주입)	• 사이버 사고가 직접적으로 치명적인 물리적 재난을 유발할 수 있음
데이터 의존성	낮음 (항해 보조용)	절대적 (모든 운항의 핵심 기반)	• 데이터의 무결성과 가용성이 안전을 위한 최우선 과제가 됨

1.2.2 네트워크 아키텍처의 변화

자율운항선박의 아키텍처는 '통합'과 '초연결성'으로 정의되며, 그림 1-1과 같이 전통적인 보안 경계를 완전히 허물어 뜨린다.



- ❶ **MASS 내부 네트워크:** 선박 내부는 IEC 62443 표준에 따라 기능과 신뢰 수준에 따라 다수의 보안 구역(Zone)으로 세분화된다. 예를 들어, 비상정지 시스템이 포함된 '안전 구역(Safety Zone)', 자율운항 및 추진 제어 시스템이 있는 '제어 구역(Control Zone)', 항해 센서가 위치한 '항해 구역(Navigation Zone)' 등으로 나뉜다. 이 구역들 간의 데이터 흐름은 OT 방화벽과 같은 '통로(Conduit)'를 통해 엄격하게 통제된다.
- ❷ **광역 통신 게이트웨이:** 선박은 더 이상 고립되어 있지 않다. GEO/LEO 위성, 5G/LTE-M, VDES 등 다중화된 통신 채널을 통해 육상과 지속적으로 연결된다. 이 통신 게이트웨이는 외부 위협이 선내망으로 침투하는 주요 경로이자, 가장 중요한 방어 지점이다.
- ❸ **원격운항센터(ROC) 네트워크:** ROC는 자체적으로 복잡한 다계층 네트워크를 가진다. 운영자가 선박을 원격 제어하는 '운영 플랫폼', 전 선단의 데이터를 수집하고 분석하는 '빅데이터/AI 플랫폼', 그리고 전체 생태계의 사이버 위협을 24시간 감시하는 '보안관제센터(SOC)'로 구성된다.
- ❹ **외부 생태계 연결:** ROC는 다시 기상 정보, 항만 VTS, 전자해도 공급사 등 다양한 제3자 서비스와 연동된다. 이는 공급망을 통한 새로운 위협 경로를 만든다.

자율운항선박의 보안은 더 이상 선박이라는 단일 개체에 국한될 수 없음을 명확히 알 수 있다. 선박,



개요

위성, ROC, 클라우드, 제3자 서비스를 아우르는 전체 생태계를 하나의 통합된 시스템으로 인식하고 어느 한 지점의 취약점도 전체 시스템을 마비시킬 수 있다는 전제하에 '제로 트러스트(Zero Trust)'와 '심층 방어(Defense-in-Depth)' 원칙에 기반한 총체적인 보안 전략을 수립해야 한다.

1.2.3. 성숙도 기반 모델

자율운항 기술의 발전은 정적인 과정이 아니라, IMO가 정의한 자율화 수준 1단계부터 4단계까지 점진적으로 진화하는 동적인 여정이다. 이러한 기술의 진화 과정에서 요구되는 보안 수준과 범위 또한 달라질 수밖에 없다. 모든 조직이 처음부터 최고 수준의 보안 체계를 갖추는 것은 현실적으로 불가능하며, 비효율적일 수 있다. 따라서, 특정 시점의 규제를 만족시키는 정적인 '체크리스트' 방식의 보안 모델은 한계가 명확하다.

이러한 문제의식에서 출발하여 본 보안모델은 '성숙도 기반 접근법'을 핵심 전략으로 채택한다. 이는 조직이 현재의 보안 역량을 객관적으로 평가하고, 비즈니스 목표와 리스크 수용 수준에 맞춰 달성 가능한 다음 단계의 목표를 설정하며, 구체적인 로드맵에 따라 보안 투자를 체계적으로 수행할 수 있도록 지원하는 프레임워크이다.

본 성숙도 모델은 단순히 조직 내부의 보안 역량 강화를 위한 프레임워크를 넘어, IMO가 제시하는 규제 발전 로드맵과 보조를 맞추는 전략적 이정표 역할을 수행한다. 즉, 조직이 사이버 위협에 대해 얼마나 효과적으로 방어하고, 신속하게 대응하며, 빠르게 복구할 수 있는지, 사이버 복원력(Cyber Resilience)의 수준을 측정하는 척도로 활용할 수 있다.

상세한 자율운항 선박의 성숙도 목록은 [부록 A. 자율운항선박 성숙도 모델]을 참고할 수 있다.



개요

1.3. 구성 및 확장 사항

1.3.1. 문서의 구성

본 보안모델은 자율운항선박(MASS)과 원격운항센터(ROC)를 아우르는 통합된 사이버-물리 시스템(CPS)의 보안성을 확보하기 위해, 현황 분석부터 위협 식별, 리스크 평가, 그리고 대응 기술까지 논리적인 흐름에 따라 총 7개의 장과 부록으로 구성되어 있다. 각 장의 주요 내용은 다음과 같다.

- ❶ **제1장 개요:** 자율운항선박의 등장 배경과 패러다임의 변화를 설명하고, 기존 스마트선박 보안모델 대비 확장된 범위(ROC 포함, AI 보안 등)와 성숙도 모델 도입의 필요성을 제시한다.
- ❷ **제2장 자율운항선박 보안 성숙도 모델:** 자율운항 기술 및 운영 환경을 분석하고, IMO 및 IACS의 최신 규정을 반영한 성숙도 모델 프레임워크를 정의한다. 특히 MASS와 ROC가 연결된 생태계 전반의 보안 생애주기 모델을 제시한다.
- ❸ **제3장 자율운항선박 사이버 위협 분석:** 보호해야 할 핵심 자산을 식별하고, 데이터 흐름도(DFD)와 STRIDE 기법을 활용하여 자율운항시스템, 전기추진시스템 등 주요 구성요소별 잠재적 위협을 상세히 모델링한다.
- ❹ **제4장 사이버 리스크 평가 및 시나리오:** 식별된 위협의 발생 가능성과 영향도를 분석하여 리스크 등급을 산정한다. 통신 채널 하이재킹, 센서 스푸핑 등 치명적인 9개의 리스크 시나리오를 도출하고 이에 대한 우선순위를 결정한다.
- ❺ **제5장 자율운항선박 성숙도 기반 보호기술:** 리스크 평가 결과를 바탕으로 규제 준수(Level 1), 구조화된 방어(Level 2), 적응형 복원력(Level 3)으로 이어지는 단계별 리스크 관리 전략과 보안 아키텍처 원칙을 수립한다.
- ❻ **제6장 7대 사이버보안 보호 기술:** 인증, 접근통제, 암호화 등 기존 6대 기술을 고도화하고, 자율운항의 핵심인 'AI 보안'을 신규 영역으로 추가하여 총 7대 영역의 22개 세부 보호 기술을 정의한다.
- ❻ **부록:** 자율운항선박 성숙도 모델 체크리스트, 보안 솔루션 분류, 상세 AI 보안 분석 등을 수록하여 실무적인 적용을 지원한다.

1.3.2. 스마트선박 보안모델 대비 확장사항

본 자율운항선박 보안모델은 기존의 '스마트선박 보안모델'을 계승하고 발전시킨 것이다. 스마트선박이 선내 시스템의 디지털화와 선·육상 간 데이터 연결에 중점을 두었다면, 자율운항선박은 여기서 한 걸음 더 나아가 인공지능(AI) 기반의 자율적 의사결정과 원격제어를 핵심으로 한다. 이러한 기술적 특성 변화에



개요

따라 본 모델은 다음과 같은 측면에서 확장되었다.

1. **평가 범위의 확장 (선박 → 선박 + 원격운항센터):** 기존 모델이 선박 자체의 IT/OT 시스템에 집중했다면, 본 모델은 자율운항의 핵심인 원격운항센터(ROC)를 동등한 중요도의 평가 대상으로 포함한다. 선박과 ROC를 하나의 유기적인 사이버-물리 시스템(Cyber-Physical System)으로 간주하고, 양단 간의 상호 연결된 리스크를 종합적으로 분석한다.
2. **자율화 수준 및 운영 수준 연계:** IMO에서 정의한 자율화 수준(MASS Level 1~4)과 ROC의 운영 수준(Operational Level) 개념을 도입하여, 각 단계별로 요구되는 보안 목표 성숙도(Target Maturity Level)를 차등적으로 정의한다. 이를 통해 기술 발전 단계에 맞는 유연하고 현실적인 보안 체계 구축을 지원한다.
3. **AI 보안 위협 고려:** 자율운항의 핵심인 인공지능(AI) 및 머신러닝(ML) 모델 자체의 취약점을 새로운 위협 벡터로 인식한다. 데이터 오염(Data Poisoning), 적대적 공격(Adversarial Attack) 등 AI 모델을 변조하거나 오작동을 유발할 수 있는 신규 위협 시나리오를 식별하고, AI의 견고성(Robustness), 설명가능성(Explainability) 등 신뢰성 확보를 위한 대응 방안을 제시한다.
4. **심화된 국제 표준 적용:** 스마트선박 모델이 IACS UR E26/E27 등 해사 분야 규정에 중점을 두었다면, 본 모델은 자율운항선박의 복잡한 IT/OT 융합 환경을 고려하여 산업 제어 시스템 보안 표준인 IEC 62443과 정보보호 경영시스템 표준인 ISO/IEC 27001, 그리고 전사적 리스크 관리 프레임워크인 NIST CSF 2.0을 보다 심층적으로 적용하여 분석의 깊이와 체계성을 강화한다.

자율운항선박 보안 성숙도 모델

2.1. 자율운항선박 기술 및 운영 환경	14
2.2. 자율운항 관련 규정 및 표준	21
2.3. 성숙도 모델 프레임워크	24
2.4. MASS-ROC 생태계: 통합된 사이버-물리 시스템(CPS)	26
2.5. 자율운항선박 보안 생애주기 모델	27

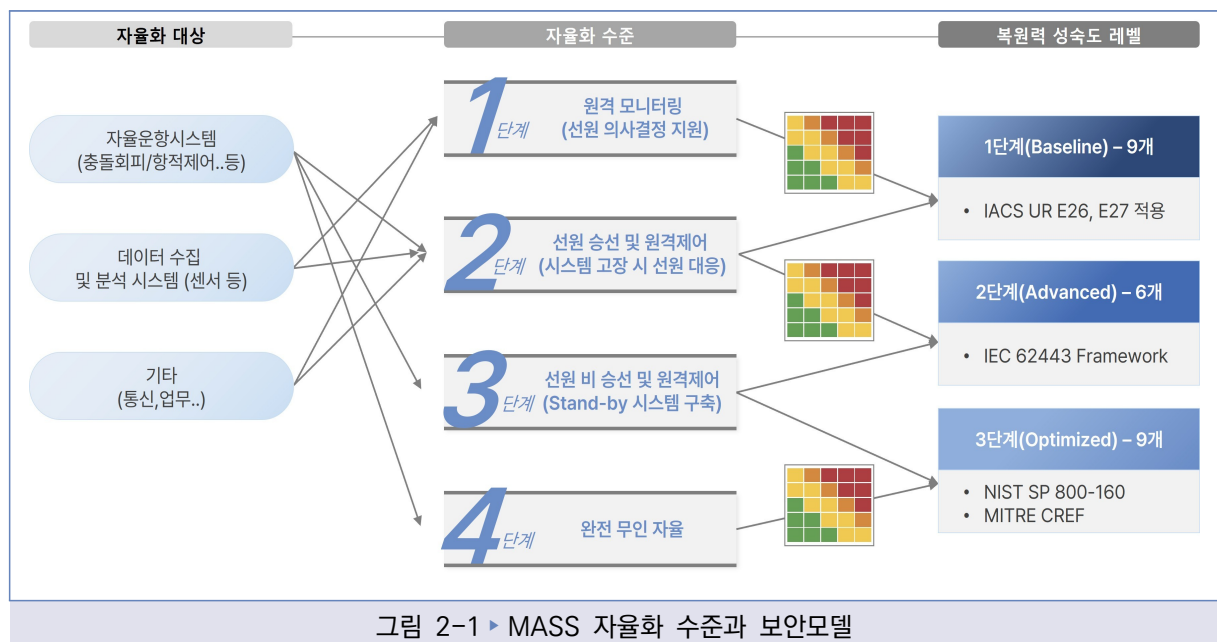


자율운항선박 보안 성숙도 모델

2.1. 자율운항선박 기술 및 운영 환경

2.1.1. 자율운항선박(MASS) 기술 및 자율화 수준

국제해사기구(IMO)는 자율운항선박을 운항 주체와 기술의 자동화 수준에 따라 4단계로 정의하고 있다. 각 단계는 선원의 역할, 시스템의 자율성, 원격제어 여부에 따라 구분되며, 이는 보안 요구사항의 수준과 범위를 결정하는 핵심 기준이 된다.



- 자율화 수준 1 (Level 1: 부분 자동화 선박, Ship with automated processes and decision support):** 선원이 승선하며, 자동화된 시스템이 운항자의 의사결정을 보조하는 단계이다. (예: 최적 항로 추천, 충돌 위험 경고) 이 단계에서는 주로 운항자에게 제공되는 정보의 무결성과 가용성 확보가 중요하다. (전통적 선박 + 지원 AI 시스템)
- 자율화 수준 2 (Level 2: 원격제어 지원 선박, Remotely controlled ship with seafarers on board):** 선원이 승선한 상태에서 육상의 원격운항센터(ROC)에서 선박을 제어할 수 있다. 시스템 장애나 비상 상황 발생 시 선원이 직접 개입하여 대응한다. 이 단계부터는 원격 제어 채널의 보안(인증, 암호화)과 제어권 전환 프로토콜의 신뢰성이 핵심 보안 요구사항으로 부상한다.
- 자율화 수준 3 (Level 3: 원격제어 무인 선박, Remotely controlled ship without seafarers on board):** 선원 없이 원격으로만 제어되는 단계이다. 시스템 고장에 대비한 이중화(Redundancy) 및 예비(Stand-by) 시스템 구축이 필수적이다. 선원 부재로 인해 물리적 보안 위협(피랍 등)에 대한 대응과



자율운항선박 보안 성숙도 모델

ROC와의 통신 두절 시 비상 운항 계획(Contingency Plan)의 신뢰성 확보가 매우 중요하다. 선박이 자율적으로 안전 상태를 유지하거나 복구할 수 있는 능력이 요구된다.

- 자율화 수준 4 (Level 4: 완전 자율운항 선박, Fully autonomous ship):** 시스템이 모든 상황을 스스로 인지, 판단, 제어하는 완전 무인 자율운항 단계이다. 이 단계에서는 AI 의사결정 모델 자체의 신뢰성뿐만 아니라, AI가 내린 판단 근거를 사람이 명확히 이해할 수 있는 설명가능성 (XAI, eXplainable AI) 그리고 예측 불가능한 상황에 대한 시스템의 자가 치유(Self-healing) 및 복원력(Resilience)이 최고 수준으로 요구된다.

본 보안모델은 현재 기술 개발 및 상용화가 활발히 이루어지고 있는 자율화 수준 2-3단계를 주요 분석 대상으로 가정한다.

2.1.2. 원격운항센터(ROC) 기술 및 운영 수준

원격운항센터(ROC)는 자율운항선박의 '육상 선교(Shore Bridge)' 역할을 수행하며, 선박과의 제어권 관계에 따라 다음과 같은 운영 수준으로 구분될 수 있다.

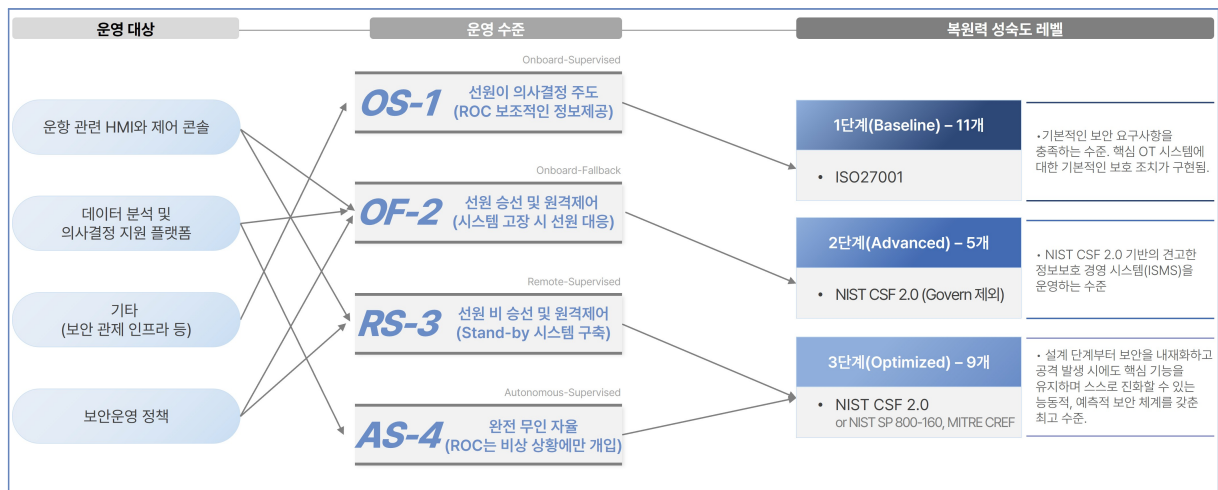


그림 2-2 ▶ ROC 보안 운영 수준과 보안모델



자율운항선박 보안 성숙도 모델

- **OS-1 (Onboard-Supervised)**: 선원이 주된 의사결정 주체이며, ROC는 보조적인 모니터링 정보만 제공한다. (원격 개입 최소)
- **OF-2 (Onboard-Fallback)**: 선박 시스템이 자율 운항을 수행하지만, 비상시 선원이 즉각 개입할 준비가 된 상태이다. 즉, 평시에는 자율운항/원격제어로 가되 문제가 생기면 선원이 운항을 담당한다.
- **RS-3 (Remote-Supervised)**: 선원이 승선하지 않으며, ROC가 주된 제어 및 감독 주체가 된다. 본 보안모델의 핵심 분석 대상이다. 선박은 원격으로 통제되며, 실시간 모니터링과 명령 전송이 이루어진다.
- **AS-4 (Autonomous-Supervised)**: 선박이 완전 자율 운항하며, ROC는 예외적이거나 비상 상황에만 개입하는 감독 역할만 수행한다. 일종의 관제 센터로서 모니터링 위주 기능을 하며, 선박이 모든 결정을 자체 수행한다.

2.1.3. 핵심 기술 요소

자율운항선박 생태계는 선박과 육상에 걸쳐 다음과 같은 핵심 기술 요소들로 구성되며, 이들은 상호 유기적으로 데이터를 교환하며 동작한다.

- **지능항해시스템 (Intelligent Navigation System)**: 선박 주변의 해상 상황을 실시간으로 인지(센서 퓨전)하고 충돌 및 사고를 방지하는 자율운항의 핵심 시스템이다. AI 기반의 상황인식, 국제해상충돌 예방규칙(COLREGs)을 준수하는 충돌회피 의사결정 기능을 포함한다.



* 출처 : 자율운항선박기술개발사업 통합사업단

그림 2-3 ▶ 지능항해시스템

자율운항선박 보안 성숙도 모델

- **기관자동화시스템 (Machinery Automation System):** 엔진, 발전기 등 핵심 기관의 상태를 실시간 모니터링하고 고장을 예측·진단(CBM/PHM)하여 운항 신뢰성을 확보하고 원격 유지보수를 지원한다.

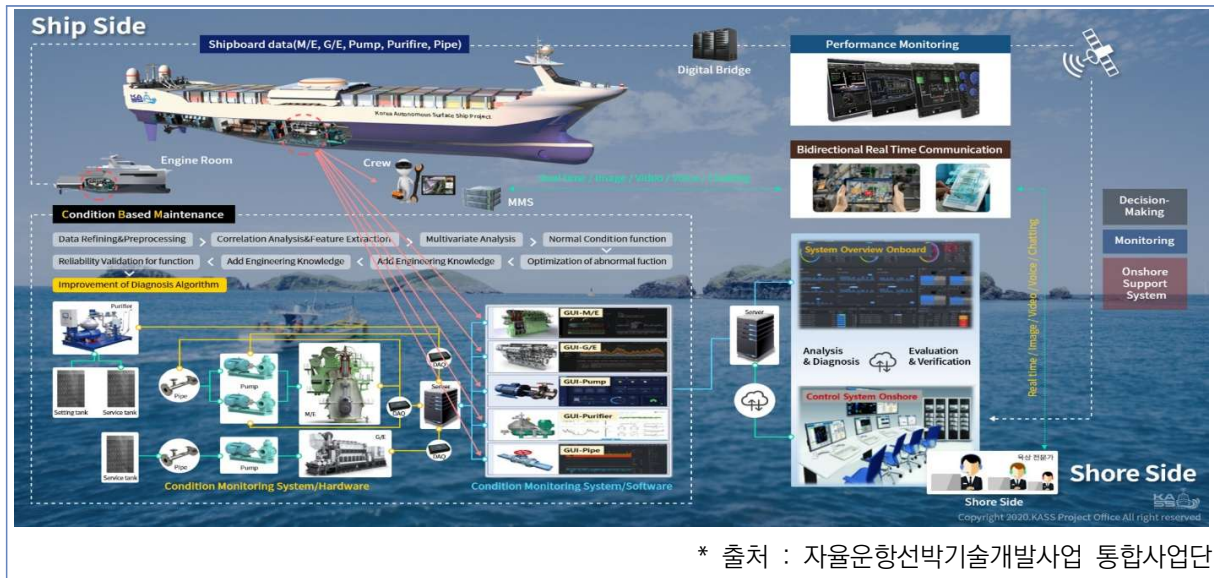


그림 2-4 ▶ 기관자동화시스템

- **디지털 브릿지 (Digital Bridge):** 자율운항 관련 모든 시스템의 데이터를 통합하고 제어하는 선박 내 중앙 플랫폼이다. 선내 시스템 간 데이터 연동 및 연계를 담당한다.

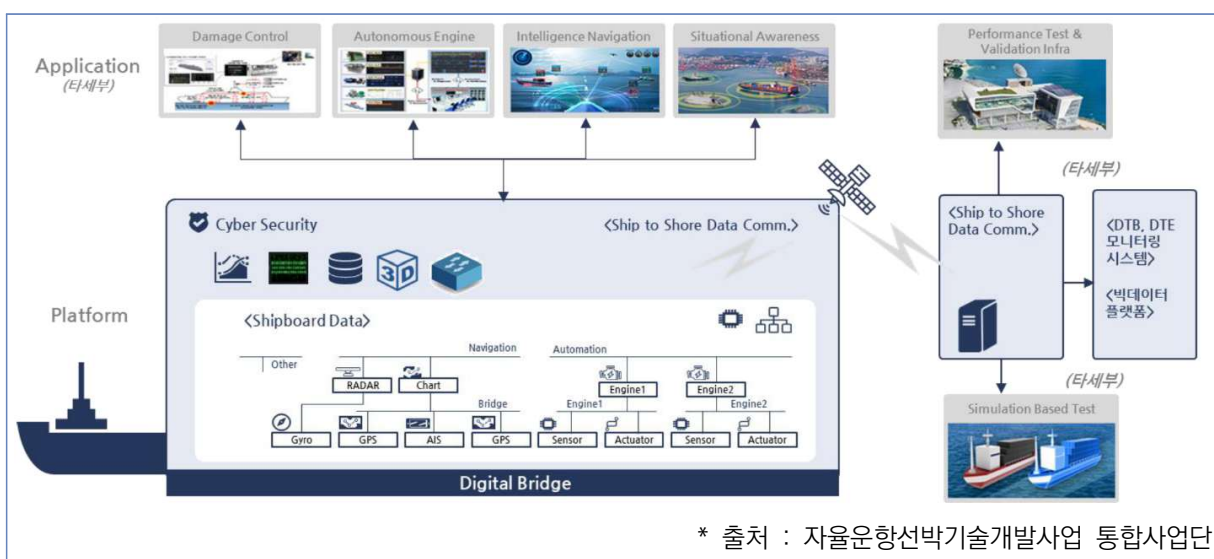


그림 2-5 ▶ 디지털 브릿지



자율운항선박 보안 성숙도 모델

- ❶ **에너지통합관제시스템 (Energy Efficiency Management System):** 선내 에너지 효율을 최적화하고 IMO의 CII 등 강화되는 환경 규제 준수를 지원한다.



자율운항선박 보안 성숙도 모델

- ❶ 해상광대역통신 및 사이버보안시스템 (Maritime Broadband & Cybersecurity System): 위성통신 (VSAT), VDES, 5G/LTE-M 등을 통해 선박과 육상 간의 대용량 데이터를 안정적으로 통신하고, 이 과정에서의 보안을 담당한다.

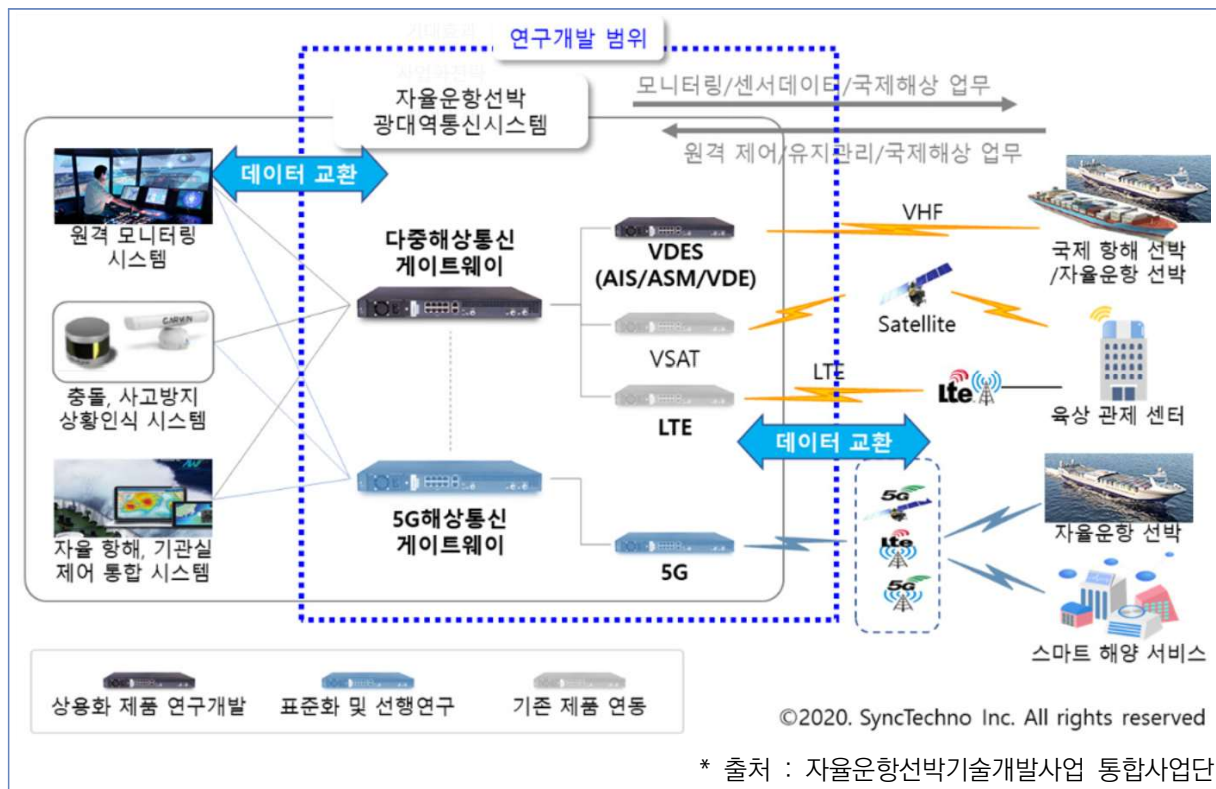


그림 2-7 ▶ 해상광대역통신 및 사이버보안시스템

자율운항선박 보안 성숙도 모델

- ❶ 원격운항센터 (ROC): 육상에서 선단을 실시간으로 모니터링하고, 필요시 원격 제어하며, 수집된 운항 데이터를 분석하여 선단 운영을 최적화하는 중앙 통제소이다.

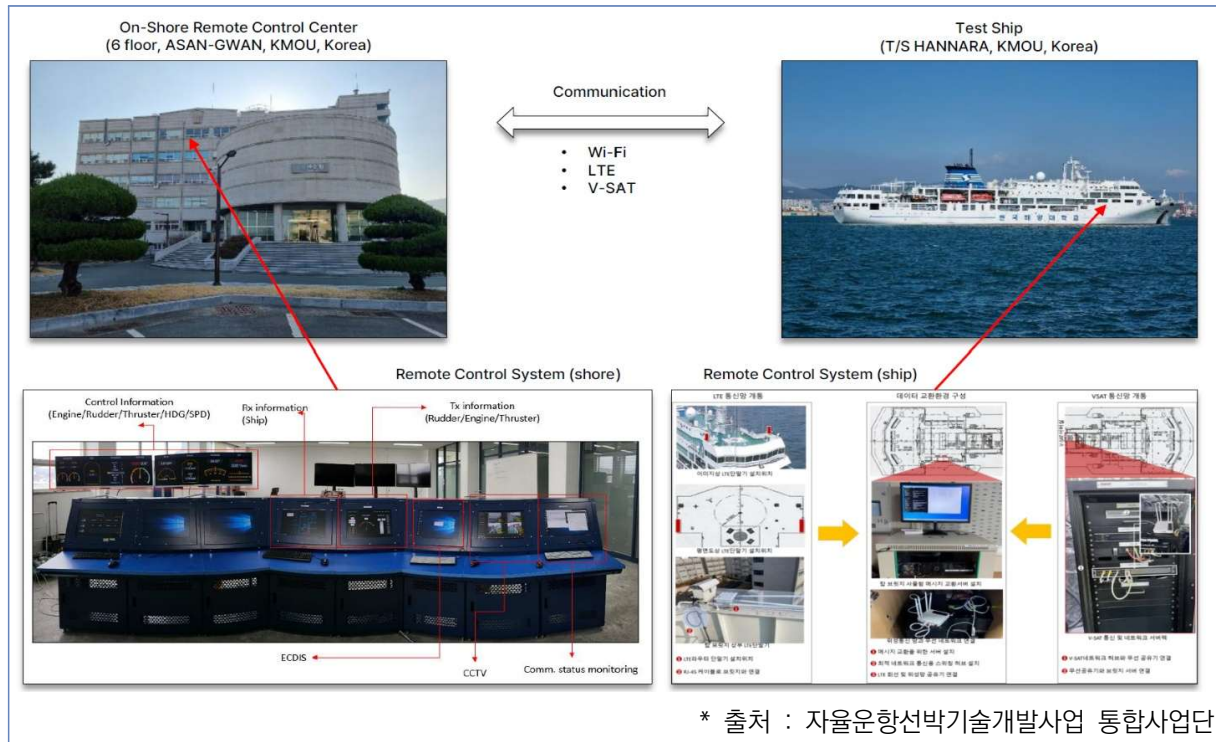


그림 2-8 ▶ 원격운항센터



자율운항선박 보안 성숙도 모델

2.2. 자율운항 관련 규정 및 표준

자율운항선박의 보안모델은 다음의 국제 규정 및 표준을 준수하고 참조하여 수립되어야 한다. 이는 규제 준수뿐만 아니라, 검증된 모범 사례를 적용하여 보안 수준을 체계적으로 향상시키기 위함이다.

2.2.1. 국제 해사 규정 (IMO, IACS)

- **IMO MSC.428(98) – Maritime Cyber Risk Management in Safety Management Systems:** 2021년 1월 1일 이후 첫 연차검사부터 선박의 안전관리시스템(SMS)에 사이버 리스크 관리를 의무적으로 포함하도록 규정하고 있다. 이는 사이버 보안을 선박 안전의 필수 요소로 공식화한 중요한 규정이다.
- **IMO MASS Code (개발 중):** 자율운항선박의 안전한 설계, 건조, 운용을 위한 포괄적인 국제 표준으로, 향후 강제화될 예정이다.

 - **비강제 코드:** 강제 규제 시행 전 자율운항선박 기술 개발 및 운영의 경험을 축적하기 위한 기반 (Experience Building Phase, EBP) 제공을 목적으로 2026년 5월 개발 완료 및 채택을 목표로 하고 있다.
 - **강제 코드:** IMO의 모든 회원국이 반드시 준수해야 하는 법적 구속력이 있는 국제 표준으로 2028년 개발 착수, 2030년 07월 이전 채택, 2032년 1월 1일 발효를 목표로 하고 있다.

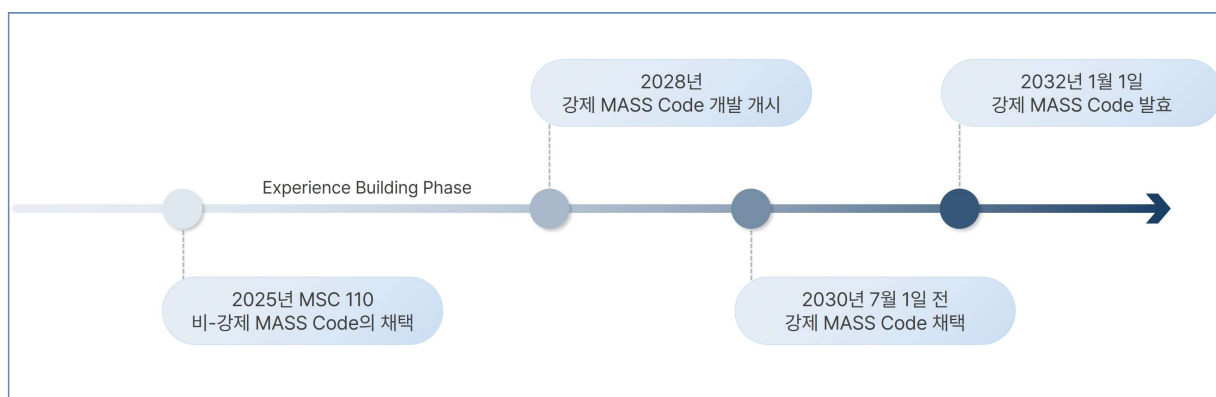


그림 2-9 ▶ MASS Code 개발 로드맵

- **IACS UR E26 – Cyber resilience of ships:** 2024년 7월 1일 이후 건조 계약되는 선박에 강제 적용되는 규정으로, 선박 전체의 사이버 복원력 확보를 위한 식별, 보호, 탐지, 대응, 복구의 5가지 기능적 요구사항을 정의한다.



자율운항선박 보안 성숙도 모델

- **IACS UR E27 – Cyber resilience of on-board systems and equipment:** UR E26과 함께 강제 적용되며, 선박에 탑재되는 개별 컴퓨터 기반 시스템(CBS) 및 장비가 갖추어야 할 구체적인 기술적 보안 요구사항을 명시한다.

2.2.2. 국제 사이버 보안 표준 (IEC 62443, ISO/IEC 27001)

- **IEC 62443 시리즈– Security for industrial automation and control systems:** 산업 자동화 및 제어 시스템(IACS)의 사이버 보안을 위한 국제 표준 시리즈이다. 선박의 OT 시스템 보안 아키텍처 설계, 리스크 평가, 보안 개발 수명주기(Secure SDLC) 적용에 있어 핵심적인 참조 표준이다. 특히 IEC 62443-3-3은 시스템 차원의 보안 요구사항(SR)을 정의하고, 보안 등급(SL) 개념을 통해 자산의 중요도에 따른 보안 수준을 제시한다. 선박의 OT 시스템 보안 아키텍처 설계와 리스크 평가에 핵심 참조 표준으로 활용된다.
- **ISO/IEC 27001 – Information security management systems:** 정보보호 경영시스템(ISMS)에 대한 국제 표준으로, ROC와 같이 IT 중심의 대규모 인프라를 운영하는 조직의 관리적, 기술적, 물리적 보안 통제를 체계적으로 수립하고 지속적으로 운영 및 개선하는 데 적용된다. 본 보안모델의 ROC 보안 관리체계 수립 시 ISO 27001 통제를 참고하였다.

2.2.3. 사이버 보안 프레임워크 (NIST CSF 2.0)

- **NIST Cybersecurity Framework 2.0:** 미국 국립표준기술연구소(NIST)에서 개발한 사이버 보안 프레임워크로, 기존의 식별, 보호, 탐지, 대응, 복구 5가지 기능에 거버넌스(Govern) 기능이 추가되어 조직의 전사적 리스크 관리와 사이버 보안을 연계하는 데 중점을 둔다. ROC의 보안 성숙도를 높이고 체계적인 관리체계를 구축하는 데 매우 유용한 프레임워크이다. IMO 역시 해상 사이버 리스크 관리를 위한 모범 사례로 NIST CSF를 권고하고 있다.

이외에도 국제 해운 업계 가이드라인으로 BIMCO/ICS 등의 단체에서 발간한 「Guidelines on Cyber Security Onboard Ships」 등이 있다. BIMCO 지침서는 위험 평가, 기술·관리 대책, 훈련 및 대응 등 선사 운영에 필요한 사이버 보안 모범 사례를 폭넓게 다루고 있으며, 현재 5판(2024)까지 발행되었다. 이러한 업계 가이드의 주요 내용 (예: 선박 IT/OT 분리 원칙, 백업 절차, 훈련 프로그램)도 본 보안모델에 참고하였다.

자율운항선박 보안 성숙도 모델

표 2-1 국제 사이버보안 관련 규정 및 표준 비교

구분	주요 내용 및 요구사항	적용 대상/시점
IMO MSC-FAL.1/Circ.3 (및 MSC.428(98) 결의)	선박 안전관리체계(SMS)에 사이버 리스크관리 포함 권고/의무화. 사이버 위험 식별, 보호, 탐지, 대응, 복구 프로세스 구축 지침 제공.	국제항해 상선 (2021년 1월부터 의무)
IACS UR E26 (2023)	선박 전체 의 사이버 복원력 요구사항. 네트워크 구역 분리, 접근통제, 모니터링, 사고 대응계획 등 선박 차원의 최소 보안대책 규정.	신조선 계약 (2024년 7월 이후)
IACS UR E27 (2023)	선박내 개별 시스템/장비 의 사이버 보안 요구사항. 장비 개발 단계의 보안설계, 인증 및 무결성 검증, 패치관리 등의 요건 정의.	신조선 계약 (2024년 7월 이후)
IEC 62443 시리즈	산업제어시스템(OT) 보안 국제표준. 기술 보안 요구사항(SR), 보안등급(SL) 정의 및 보안 개발 생명 주기(Secure SDLC) 권고.	OT시스템 (선박 제어망 등) 참고 표준
ISO/IEC 27001	정보보호 관리체계(ISMS) 국제표준. 조직의 보안 정책, 조직 구성, 위험관리, 통제 구현 및 인증 프레임워크.	기업/기관 (ROC 운영조직 등)
BIMCO 선박 사이버지침 v5 (2024)	해운업계 모범 가이드라인 . 사이버 위험평가 방법, 방어대책 (기술/인적/절차적 통제), 사고 대응, 복구계획, 훈련 등을 포괄 제시.	선사·선박 (권고기준, 자율이행)



자율운항선박 보안 성숙도 모델

2.3. 성숙도 모델 프레임워크

자율운항선박 보안모델은 국제적으로 공인된 규정과 표준의 집합체 위에 구축되어야 한다. 이는 규제 준수를 통한 법적 리스크 관리뿐만 아니라, 검증된 모범 사례를 적용하여 보안 수준을 체계적으로 향상시키기 위함이다. 각 규정과 표준은 성숙도 모델의 특정 단계와 깊은 관련을 맺고 있다.

🌀 Level 1 (규제 준수)

- IMO MSC.428(98): 2021년부터 선박의 안전관리시스템(SMS)에 사이버 리스크 관리를 의무화한 규정으로, 모든 보안 활동의 법적 근거를 제공한다.
- IACS UR E26/E27: 2024년 7월 이후 신조선에 강제 적용되는 사이버 복원력 요구사항이다. UR E26은 선박 전체의 포괄적인 보안 체계를, UR E27은 개별 장비의 기술적 보안 요건을 정의하며, 성숙도 Level 1 달성을 위한 최소한의 기술적, 관리적 통제의 핵심 내용이다.
- ISO/IEC 27001: 정보보호 경영시스템(ISMS) 국제 표준으로, ROC의 보안 정책, 조직, 절차 등 관리체계를 수립하는 데 있어 Level 1의 기초적인 역할을 한다.

🌀 Level 2 (구조화된 방어)

- IEC 62443: 산업 자동화 및 제어 시스템(IACS) 보안을 위한 국제 표준 시리즈로, 자율운항선박의 복잡한 OT 환경을 보호하기 위한 핵심 기술 지침을 제공한다. 특히, '보안 구역(Zone)'과 '통로(Conduit)' 개념을 통해 네트워크를 구조적으로 방어하는 Level 2 아키텍처 설계의 근간이 된다.
- NIST Cybersecurity Framework (CSF) 2.0: 기존의 식별, 보호, 탐지, 대응, 복구 5가지 기능에 거버넌스(Govern) 기능이 추가된 프레임워크이다. Level 2에서는 거버넌스를 제외한 5가지 핵심 기능을 중심으로 ROC의 SOC 운영 역량을 강화하는 데 중점적으로 활용된다.

🌀 Level 3 (적응형 복원력)

- NIST SP 800-160 (Systems Security Engineering): 시스템의 전 생애주기에 걸쳐 보안을 통합하는 시스템 보안 엔지니어링에 대한 지침이다. '나중에 추가하는' 보안이 아닌 '설계 단계부터 내재화하는' Security-by-Design을 구현하는 Level 3의 핵심 철학을 제공한다.
- MITRE Cyber Resiliency Engineering Framework (CREF): 공격을 예측(Anticipate), 견디고(Withstand), 복구하고(Recover), 적응(Adapt)하는 4가지 목표를 통해 사이버 복원력을 공학적으로 달성하는 방법을 제시한다. 다양성(Diversity), 기만(Deception), 비영속성(Non-Persistence) 등 Level 3에서 요구되는 고급 방어 및 복구 전략의 이론적 기반을 제공한다.
- IMO MASS Code (개발 중): 향후 자율운항선박의 설계, 건조, 운용 전반을 규율할 강제 규약으로, 본 모델의 Level 3는 개발 중인 MASS Code의 방향성을 선제적으로 반영하여 미래 규제 환경에



자율운항선박 보안 성숙도 모델

대비한다.

다음 표는 MASS와 ROC에 대한 성숙도 모델의 핵심 내용을 요약한 것이다. 성숙도별 상세한 내용은 [부록 A. 자율운항선박 성숙도 모델]에서 확인 할 수 있다.

표 2-2 MASS 보안 성숙도 모델 요약

성숙도 수준	표준/규정	핵심 보안 개념	주요 요구사항
Level 1	IACS UR E26 & E27	해사 사이버 복원력 (준수)	자산 식별, 네트워크 다이어그램, 기본 보호/탐지/대응/복구 기능 구현
Level 2	IEC 62443	구조화된 OT 방어 (아키텍처)	보안 구역(Zone) 및 통로(Conduit) 기반 망 분리, 구역별 접근 통제 강화
Level 3	NIST SP 800-160 & MITRE CREF	설계 기반 신뢰성 및 적응형 복원력 (생애주기 & 전략)	설계 기반 보안 (Secure by Design), 위협 예측, 공격 중 임무 지속성 확보



자율운항선박 보안 성숙도 모델

2.4. MASS-ROC 생태계: 통합된 사이버-물리 시스템(CPS)

자율운항선박의 보안을 논의할 때 가장 중요한 전제는 MASS와 ROC를 별개의 독립된 개체로 보지 않는 것이다. 이 둘은 위성, 5G 등 광대역 통신으로 긴밀하게 연결되어 하나의 목표(안전하고 효율적인 운항)를 위해 동작하는 단일하고 통합된 '사이버-물리 시스템(Cyber-Physical System, CPS)'을 구성한다. CPS는 계산, 통신, 제어 기술이 물리적 프로세스와 깊숙이 결합된 시스템으로 사이버 공간에서의 이벤트가 물리적 세계에 직접적인 영향을 미치는 특징을 가진다.

이러한 통합적 관점은 보안에 중대한 시사점을 던진다. 전통적인 IT 보안과 OT 보안의 경계는 무의미해지며, '공생적 리스크 연속체(Symbiotic Risk Continuum)'가 형성된다. 예를 들어, ROC 운영자의 워크스테이션이 피싱 공격으로 감염되는 것은 단순한 IT 시스템의 정보 유출 문제가 아니다. 탈취된 계정으로 전송된 악의적인 원격 제어 명령은 수천 톤의 선박을 충돌 경로로 이끌 수 있는 직접적인 OT 안전사고로 즉시 전환될 수 있다. 반대로, 선박의 GNSS 센서가 스푸핑 공격을 받는 것은 단순한 항해 장비의 오작동이 아니라, ROC의 통합 관제 시스템에 잘못된 상황 인식을 유발하여 전체 선단 운영에 대한 잘못된 의사결정을 초래할 수 있다.

따라서 본 보안모델은 MASS와 ROC를 분리하여 분석하지 않고, 생태계 전체를 단일한 리스크 관리 단위로 취급한다. Level 3 성숙도에서 강조하는 바와 같이, ROC의 위협 인텔리전스는 실시간으로 MASS의 방어 규칙을 업데이트하고, MASS가 탐지한 물리적 이상 신호는 ROC의 SIEM으로 전송되어 사이버 위협 지표와 연관 분석되는 양방향 피드백 루프를 구축하는 것이 필수적이다. 이처럼 CPS 관점의 통합적 접근은 자율운항 시대의 사이버 리스크를 효과적으로 관리하기 위한 근본적인 출발점이다.

표 2-3 ROC 보안 성숙도 모델 요약

성숙도 수준	표준/규정	핵심 보안 개념	주요 요구사항
Level 1	ISO 27001	정보보호 경영시스템 (프로세스)	보안 정책, 절차, 조직 구성, 기본적인 관리적/기술적 통제 수립
Level 2	NIST CSF 2.0 (Govern 제외)	운영 중심 사이버보안 (기능)	식별, 보호, 탐지, 대응, 복구 기능 중심의 SOC(보안관제센터) 운영
Level 3	NIST CSF 2.0 (전체), NIST SP 800-160, MITRE CREF	전략적 리스크 관리 및 복원력 (거버넌스 & 적응)	전사적 리스크 연계, C-SCRM, 개발보안(DevSecOps), 지능형 적응 방어

자율운항선박 보안 성숙도 모델

2.5. 자율운항선박 보안 생애주기 모델

자율운항선박의 사이버 보안은 특정 시점의 활동이 아닌, 선박의 전 생애주기에 걸쳐 지속적으로 관리되어야 하는 동적인 프로세스이다. 본 모델은 다음 그림과 같이 5단계의 보안 생애주기 모델을 제안한다.



그림 2-10 ▶ 자율운항선박의 보안 생애주기 모델

이 그림은 중앙에 자율운항선박과 원격운항센터(ROC)가 위성 통신으로 연결된 모습을 보여준다. 그림과 같이 5단계의 생애주기(설계/개발 → 건조/통합 → 운항/검증 → 데이터 수집/모델 개선 → 폐선/데이터 파기)가 순환하는 형태로 표현하였다.

설계 및 개발 단계에서의 설계 기반 보안(Secure by Design)은 운영 단계의 보안 부담을 크게 감소시키므로 강조된다. 반면 운영 단계에서는 현실적인 위협 모니터링과 사고 대응 능력이 중요하며, 폐선 단계까지 간과하지 않고 데이터 유출 방지 대책을 수행해야 한다. 자율운항선박의 생애주기별 주요 보안 활동은 다음과 같다.

1단계: 자율운항 시스템 설계 및 개발 (Design & Development)

- 보안 요구사항 정의 및 위협 모델링(STRIDE 등) 수행
- 보안 아키텍처 설계 (네트워크 구역화, 침침 방어, 제로 트러스트 원칙 적용)



자율운항선박 보안 성숙도 모델

- 보안 개발 수명주기(Secure Development Lifecycle, SDL) 적용 및 시큐어 코딩 (IEC 62443-4-1 준수)

② 2단계: 선박 건조 및 시스템 통합 (Construction & Integration)

- 시스템 보안 강화(Hardening) 및 제조사 기본 패스워드 변경
- 공급망 보안 관리 (소프트웨어 자재명세서(Software Bill of Materials, SBOM) 확인, 납품 장비 보안 검증)
- 통합 시스템 보안 기능 테스트 및 취약점 점검

③ 3단계: 운항 및 원격제어 검증 (Operation & Remote Control Verification)

- 지속적인 보안 모니터링 및 위협 탐지 (선박 & ROC)
- 취약점 관리 및 보안 패치 적용 절차 수립 및 이행
- 접근 통제 및 권한 관리 (최소 권한 원칙 적용)
- 사고 대응 계획 수립 및 정기적인 모의 훈련 실시

④ 4단계: 데이터 수집 및 모델 개선 (Data Collection & Model Improvement)

- 운항 데이터 및 사이버 위협 데이터 수집 및 분석
- AI/ML 모델의 성능 및 보안성 지속적 개선 (MLSecOps)
- 변경 관리 절차 준수 및 업데이트 시 보안성 재검증

⑤ 5단계: 폐선 및 데이터 파기 (Decommissioning & Data Destruction)

- 모든 저장 매체의 운항 및 개인정보 데이터 영구 삭제 (NIST SP 800-88 등 표준 준수)
- IT/OT 자산 및 네트워크 장비의 안전한 비활성화 및 폐기

2.5.1. 자율운항선박 시스템 구성요소와 아키텍처

자율운항선박 생애주기 모델의 중심에는 선박과 ROC를 구성하는 복잡한 시스템 아키텍처가 존재한다. 그림 2-10은 크게 '자율운항선박'과 '원격운항센터(ROC)' 두 부분으로 나뉜다. 자율운항선박에는 자율운항



자율운항선박 보안 성숙도 모델

시스템, 에너지 관리 시스템, 전기추진 시스템 등이 있고, IT/OT 네트워크 인프라와 다양한 센서(LIDAR, RADAR, AIS/GNSS 등)가 포함된다. ROC에는 통합 디지털 운항 플랫폼, 데이터 분석 플랫폼, 보안 관제센터(SOC) 등이 있으며, 각각의 하위 시스템(워크스테이션, 데이터 레이크, SIEM 등)이 포함된다. 둘 사이는 위성, 5G/LTE-M 등 광대역 통신으로 연결된다.

❶ 자율운항선박 (MASS):

- **핵심 시스템:** 자율 운항을 직접 수행하는 소프트웨어 및 하드웨어
- **IT/OT 네트워크 인프라:** 기능과 보안 요구 수준에 따라 DMZ, Navigation, Control, Monitoring Zone 등으로 구역화된 네트워크로 구성
- **첨단 센서:** 고해상도 카메라, LIDAR, RADAR, AIS/GNSS, 음향 센서 등 주변 환경과 선박 상태 데이터를 수집

❷ 원격운항센터 (ROC):

- **ROC 자율운항 시스템:** 운영자가 선단을 원격으로 모니터링하고 제어하는 핵심 HMI이다. 원격 제어 워크스테이션, 디지털 트윈 시뮬레이터, 운항 모니터링 대시보드 등을 포함
- **데이터 분석 플랫폼:** 선단 전체로부터 수집된 방대한 데이터를 저장(Data Lake), 처리하고 AI 모델을 학습/검증하여 운항 효율을 최적화
- **보안 관제센터 시스템:** 통합 SIEM, SOAR 플랫폼, 위협 인텔리전스 시스템 등을 통해 선박과 ROC를 아우르는 전체 생태계의 사이버 위협을 24시간 감시하고 대응

2.5.2 이해관계자 역할 및 책임

자율운항선박의 견고한 보안은 특정 주체의 노력만으로는 달성할 수 없으며, 각 이해관계자의 명확한 역할과 책임 분담, 그리고 유기적인 협력이 필수적이다.

각 주체들은 사이버보안 거버넌스 체계에서 서로 정보를 공유하고 협력해야 효과적인 방어망을 구축할 수 있다. 특히 선주/해운사와 조선소 간에는 보안 요구사항이 계약에 명시되어야 하고, 운항사와 선급 간에는 보안 인증 프로세스에서 긴밀한 협조가 필요하다. 사람, 기술, 프로세스 측면의 입체적 협력이 자율운항선박 보안의 기본 토대이다.



자율운항선박 보안 성숙도 모델

표 2-4 이해관계자 역할 및 책임

이해관계자	주요 역할 및 책임
선주/해운사	전반적인 사이버 리스크 관리의 최종 책임자. 보안 정책 및 절차 수립, ROC 운영, 사고 대응 계획 승인 및 훈련 감독
원격운항센터(ROC) 운영자	선단에 대한 실시간 보안 모니터링, 위협 탐지 및 초기 대응, 보안 정책 준수
조선소	설계 및 건조 단계에서 보안 요구사항을 반영. 안전한 네트워크 아키텍처 구현 및 시스템 통합. IACS UR E26/E27 준수 책임
시스템 통합자(SI)	다양한 IT/OT 시스템을 보안 요구사항에 맞게 통합하고, 시스템 간 상호운용성 및 통합 보안성 검증
기자재/솔루션 공급사	보안 개발 수명주기(SecureSDLC)를 준수하여 안전한 제품을 개발하고, 알려진 취약점에 대한 패치를 적시에 제공. 소프트웨어 자재명세서(SBOM) 제공
선급	IACS UR E26/E27 등 관련 규정에 따라 선박의 사이버 복원력 준수 여부를 검사하고 인증.
통신 서비스 제공사	선박과 육상 간의 통신 채널(위성, 5G/LTE 등)에 대한 보안 및 가용성 보장

자율운항선박 사이버 위협 분석

3.1. 핵심 자산 식별	32
3.2. 데이터 흐름도(DFD) 기반 위협 모델링	37



자율운항선박 사이버 위협 분석

효과적인 보안 대책을 수립하기 위해서는 보호해야 할 자산을 명확히 식별하고, 해당 자산에 가해질 수 있는 잠재적 위협을 체계적으로 분석하는 과정이 선행되어야 한다. 본 장에서는 자율운항선박 생태계의 핵심 자산을 정의하고, 데이터 흐름도(DFD)와 STRIDE 위협 모델링 방법론을 통해 사이버 위협을 가시화하고 분류한다. 이 과정은 단순히 위협을 나열하는 것을 넘어, 공격자의 관점에서 시스템의 어떤 부분이, 어떤 방식으로 공격받을 수 있는지를 구체적으로 이해하는 것을 목표로 한다.

3.1. 핵심 자산 식별

자산의 중요도는 기밀성(Confidentiality), 무결성(Integrity), 가용성(Availability)의 전통적인 CIA 모델과 더불어, 선박의 안전(Safety)과 운항(Operation)에 미치는 영향을 최우선으로 고려하여 평가한다. 자산 식별은 모든 보안 활동의 출발점이며, 보호 대상의 범위를 명확히 함으로써 한정된 자원을 효율적으로 배분할 수 있게 한다

3.1.1. 자율운항선박(MASS) 핵심 자산

선박에 탑재된 시스템 중 기능 손상 시 선박의 안전, 운항, 환경에 심각한 위협을 초래할 수 있는 자율운항 관련 컴퓨터 기반 시스템(CBS)을 핵심 자산으로 식별한다.

표 3-1 자율운항선박 핵심 자산

자산명	설명	관련 보안 구역
위성네트워크 시스템	VSAT, 5G/LTE 등을 통해 선박과 ROC 간 데이터 통신을 담당하는 게이트웨이	Communication Zone
자율운항시스템	주변 상황 인지, 충돌 회피, 항로 계획 등 자율운항의 핵심 의사결정을 수행하는 '두뇌'	Autonomous Operation Zone
증강현실 항해 시스템 (AR Navigation System)	카메라 영상에 항해 정보를 증강현실로 표시하여 운항자(선내 또는 원격)의 상황 인지(Situational Awareness)를 지원	Navigation Zone
CBM (Condition Based Monitoring) 시스템	주 기관 등 핵심 기기의 상태를 실시간 모니터링하여 고장을 예측하고 진단	Monitoring Zone
AVM (Around View Monitoring) 시스템	선박 주변 360도 영상을 제공하여 사각지대를 최소화하고 안전한 기동(특히 접안)을 지원	Monitoring Zone
에너지 관리 시스템 (EMS)	전력 생산/분배, 연료 소모 최적화 등 선박의 동력 및 에너지 계통을 제어	Control System Zone



자율운항선박 사이버 위협 분석

자산명	설명	관련 보안 구역
자동 이·접안 시스템 (Auto Berthing System)	선박의 자동 이·접안을 위해 조타, 속도, 방향을 정밀 제어하는 시스템	Control System Zone
전기추진 시스템 (Electric Propulsion System)	발전기에서 생산된 전력을 추진모터에 공급하여 선박을 구동하는 핵심 시스템	Control System Zone

핵심 자산들은 보안 구역으로 분리되며 침해 시 충돌, 화재, 추진력 상실 등의 물리적 피해로 이어질 수 있으므로 강화된 접근통제와 무결성 검증 등의 보호대책이 필요하다. 특히 자율운항시스템은 각종 센서 데이터의 입력을 받아 의사결정을 내리므로, 센서 데이터 위·변조 공격에 취약할 수 있으며 이에 대한 검증 메커니즘이 필수다.

3.1.2 자율운항선박 네트워크 아키텍처 (IT/OT 영역)

선박의 사이버 보안은 선박 내 정보기술(IT)과 운영기술(OT) 시스템의 명확한 분리를 기반으로 한 네트워크 아키텍처에서 시작된다. 기존의 『스마트선박 보안모델 해설서』에서 제시된 프레임워크는 이러한 분리 원칙을 핵심으로 삼고 있다. 해당 모델의 보안 구역(Security Zone) 개념은 선박의 네트워크를 기능적 중요도와 신뢰 수준에 따라 여러 논리적 영역으로 세분화한다. 대표적인 보안 구역은 항해 시스템이 위치하는 항해 존(Navigation Zone), 위성 통신 장비 등이 포함된 통신 존(Communication Zone), 기관 제어 및 자동화 시스템이 속한 제어 시스템 존(Control System Zone), 그리고 자율운항 시스템을 위한 자율운항 존(Autonomous Operation Zone) 등으로 구성된다.

이러한 네트워크 분할의 근본적인 목적은 IT 영역에서 발생할 수 있는 사이버 위협이 선박의 안전 운항과 직결되는 핵심 OT 영역으로 전파되는 것을 방지하는 데 있다. 이는 접근통제 보호기술을 통해 구현되며, 각 구역 간의 통신은 반드시 방화벽과 같은 보안 경계 솔루션을 통해 엄격하게 통제되어야 한다. 이러한 접근 방식은 일반적인 산업 제어 시스템(ICS) 보안의 모범 사례와 일치하며, 위협의 측면 이동(Lateral Movement)을 억제하여 피해 범위를 최소화하는 심층 방어(Defense in Depth) 전략의 핵심 요소이다.

자율운항선박 사이버 위협 분석



그림 3-1 ▶ 자율운항선박 보안모델 아키텍처



자율운항선박 사이버 위협 분석

3.1.3. 원격운항센터(ROC) 핵심 자산

ROC는 다수의 선박을 원격으로 통제하는 중앙 허브로서, ROC 시스템의 장애는 전체 선단의 운영 마비로 이어질 수 있다. ROC의 자산은 개별 선박의 자산보다 더 높은 가치를 지니며, 공격자에게는 더 매력적인 목표가 된다.

표 3-2 원격운항센터(ROC) 핵심 자산

자산명	설명	관련 보안 구역
ROC 자율운항시스템	운영자가 선단을 모니터링하고 원격 제어 명령을 내리는 중앙 관제 HMI	Autonomous Zone
운항 데이터 분석 시스템	선단 전체의 운항 데이터를 수집, 저장, 분석(AI/ML)하여 운영 최적화를 지원하는 데이터 레이크	Data Analytics Zone
보안 관제 시스템	SIEM, SOAR 등으로 구성되어 전체 생태계의 사이버 위협을 탐지하고 대응하는 보안 허브	SOC Zone
원격 접속 게이트웨이	외부 네트워크에서 ROC 내부망으로 접속하는 통로(VPN 등)로 외부 공격의 1차 방어선	DMZ

ROC 핵심 자산들은 주로 IT 시스템으로 클라우드, 웹 애플리케이션, 데이터베이스 등이 포함된다. 이들에 대한 계정 탈취, 데이터 유출, 서비스 마비(DDoS) 등의 위협이 우려되며, ISO 27001 통제나 클라우드 보안모델 적용이 필요하다. 특히 ROC 자율운항시스템 등이 공격자에게 장악될 경우 선박 제어 권한이 넘어갈 수 있으므로 강력한 인증과 명령 권한 검증이 요구된다.

자율운항선박 사이버 위협 분석

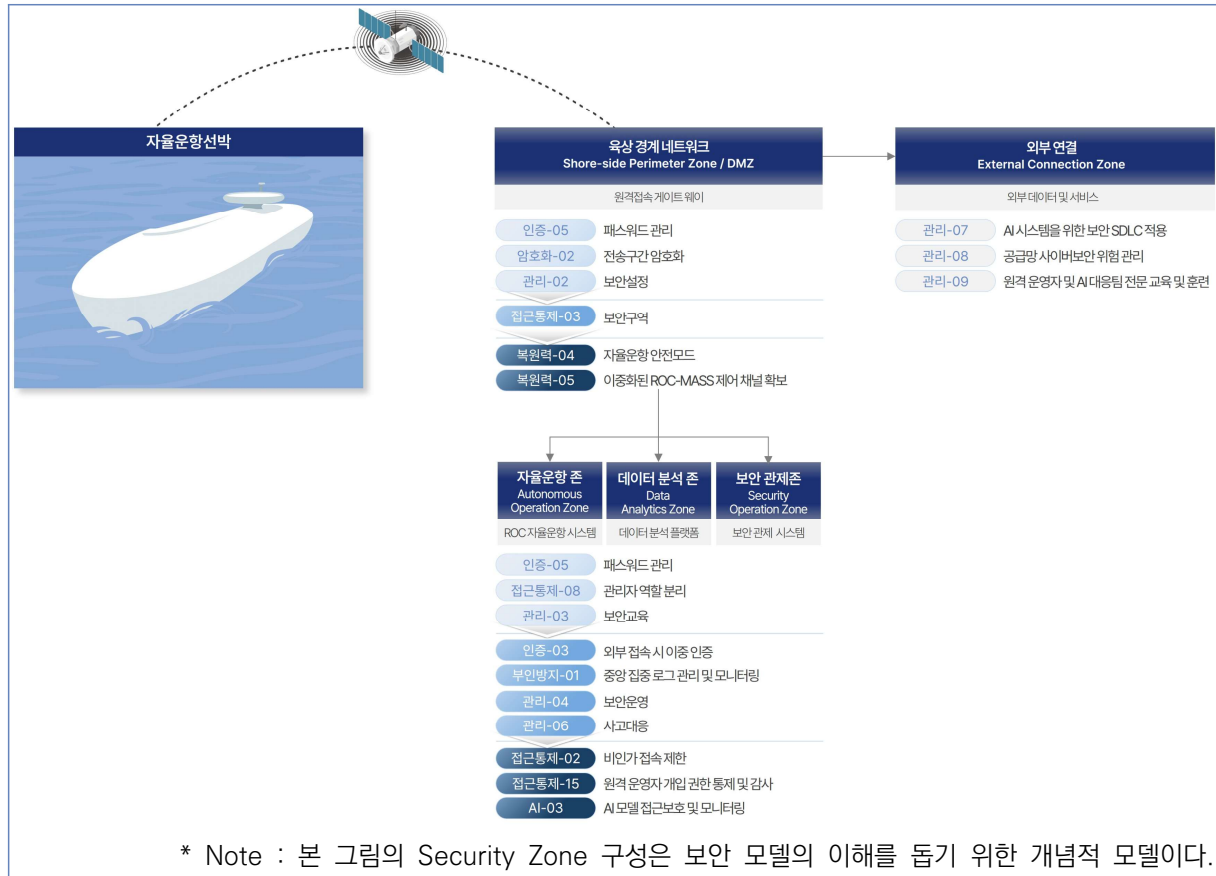


그림 3-2 ▶ ROC 보안모델 아키텍처

자율운항선박(MASS)의 등장은 기존의 선박 중심적 아키텍처를 근본적으로 변화시킨다. MASS는 더 이상 독립적인 개체가 아니라, 육상의 원격운항센터(Remote Operation Center, ROC)와 긴밀하게 연결된 분산 시스템의 일부가 된다. ROC는 선박의 실시간 감독, 관리 및 제어를 수행하는 중앙 집중식 육상 시설로서, MASS 운영의 신경 중추 역할을 담당한다. 이로 인해 선박 자체는 고도로 연결된 사물인터넷(IoT) 플랫폼으로 진화하며, 자율 항해와 의사결정을 위한 'AI 코어(AI Core)'에 대한 의존도가 절대적으로 높아진다.

이 AI 코어는 LiDAR, 고성능 카메라, 레이더 등 첨단 센서로부터 수집된 방대한 데이터를 실시간으로 처리하고, 선박 간(V2V) 또는 선박-인프라 간(V2I) 통신과 같은 V2X(Vehicle-to-Everything) 프로토콜을 통해 외부와 끊임없이 상호작용한다. 결과적으로 MASS 아키텍처는 선박, ROC, 그리고 이 둘을 연결하는 위성, 5G 등 다양한 통신 링크로 구성된 '시스템의 시스템(System-of-Systems)'으로 재정의된다. 이러한 구조적 변화는 기존의 신뢰 모델을 완전히 재구성하며, 새로운 차원의 보안 위협을 야기한다.

자율운항선박 사이버 위협 분석

3.2. 데이터 흐름도(DFD) 기반 위협 모델링

3.2.1. 위협 분석 방법론 (DFD & STRIDE)

본 모델은 시스템의 데이터 흐름을 가시화하고 각 흐름과 프로세스에 잠재된 위협을 식별하기 위해 다음과 같은 검증된 방법론을 적용한다.

- 데이터 흐름도 (DFD, Data Flow Diagram):** 시스템을 구성하는 프로세스, 데이터 저장소, 외부 개체 간의 데이터 흐름을 도식화하여 시스템의 동작 방식을 직관적으로 이해하고, 데이터가 신뢰 경계(Trust Boundary)를 넘어 이동하는 지점을 식별한다. 신뢰 경계는 보안 정책이 변경되는 지점으로, 이 경계를 통과하는 데이터 흐름은 잠재적인 공격 벡터가 될 가능성이 높으므로 집중적인 분석이 필요하다.
- STRIDE 위협 모델링:** Microsoft에서 개발한 위협 모델링 방법론으로, 6가지 위협 범주에 따라 잠재적 위협을 체계적으로 식별하고 분류한다. 이는 위협을 누락 없이 체계적으로 도출하는 데 효과적이다.

표 3-3 자율운항선박의 STRIDE 위협 모델 예시

STRIDE 속성	설명	자율운항선박 적용 예시	ROC 적용 예시
Spoofing (신원 위장)	• 공격자가 다른 사용자나 시스템인 것처럼 위장하는 행위	• 허위 GPS 신호 송신, ROC 운영자 계정 탈취 후 로그인	• (운영자 로그인) 피싱 공격 등을 통해 탈취한 운영자 계정으로 불법 로그인 시도
Tampering (변조)	• 전송 중이거나 저장된 데이터를 악의적으로 수정하는 행위	• 전자해도(ECDIS) 데이터 변조, 화물 정보 조작	• (플랫폼 → 선박) 전송 중인 명령 패킷을 MITM 공격으로 가로채 명령 내용을 변조
Repudiation (부인)	• 특정 행위를 수행하고도 하지 않았다고 부인하는 행위	• 악의적 원격 제어 명령 전송 후 관련 로그 삭제	• (운영자 로그인) 내부자가 악의적 명령을 내려놓고 나중에 자신은 명령을 하지 않았다고 발뺌 (로그가 미흡한 경우 문제)
Information Disclosure (정보유출)	• 권한 없는 사용자에게 민감한 정보가 노출되는 행위	• 선단 전체의 운항 항로, 화물 정보 등 영업 비밀 유출	• (플랫폼 ↔ 데이터 분석 시스템) 잘못된 권한설정으로 인해 특정 선박의 운항 데이터 등 민감 정보가 외부로 노출 (예: 개발자 계정 권한오남용)
Denial of	• 정상적인 사용자가	• 선박 제어 시스템에	• (플랫폼 → 선박)대량의 임의

자율운항선박 사이버 위협 분석

Service (서비스 거부)	시스템이나 서비스를 사용하지 못하도록 방해하는 행위	대량의 트래픽을 보내 마비시킴	명령을 계속 보내 통신 채널을 마비시켜, 정상 원격제어를 방해
Elevation of Privilege (권한 상승)	• 낮은 권한을 가진 공격자가 더 높은 시스템 권한을 획득하는 행위	• 선원용 PC 계정 탈취 후 관리자 권한 획득	• 운영자PC 계정 탈취 후 관리자 권한 획득

이와 같이 DFD와 STRIDE 기반 위협 모델링을 통해 모든 핵심 자산-데이터 흐름 조합에 대한 위협 시나리오를 도출하였다. 이러한 위협 모델링 결과는 제4장의 리스크 평가의 기초 자료로 활용된다.

자율운항선박 사이버 위협 분석

3.2.2. 자율운항 시스템 위협

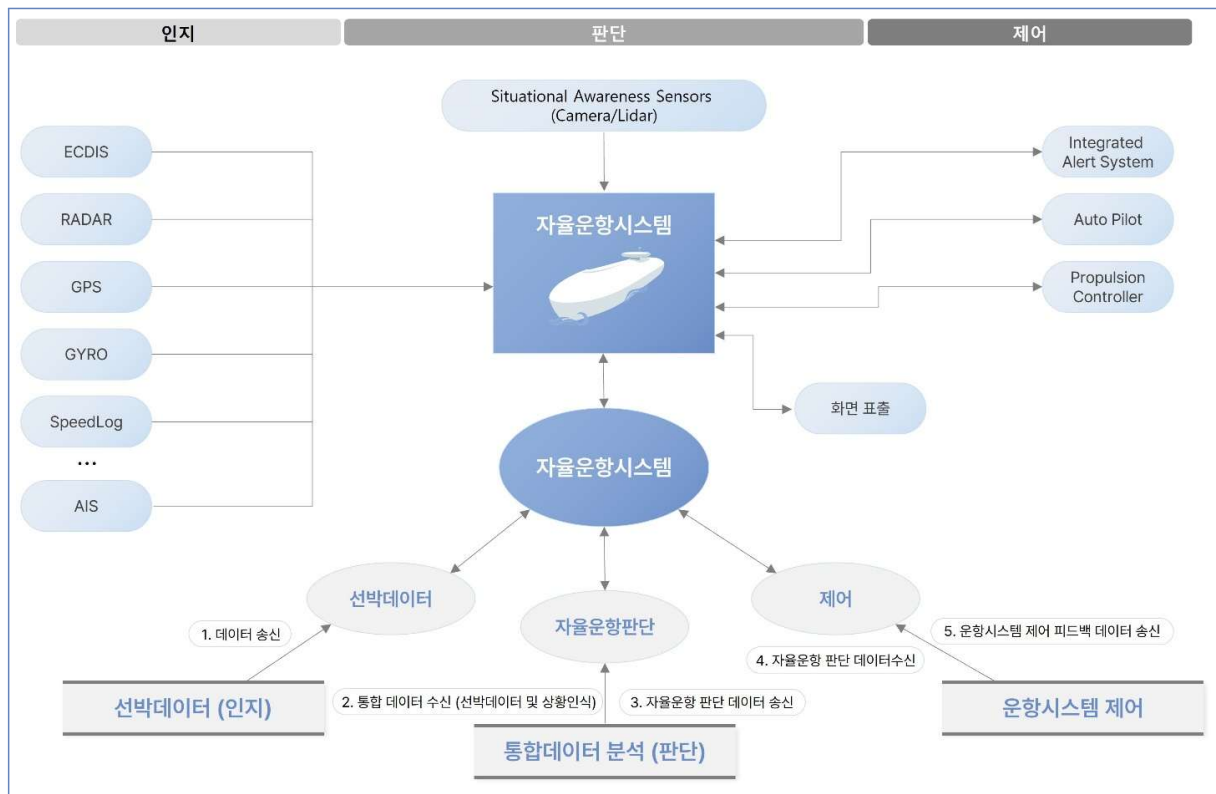


그림 3-3 ▶ 자율운항시스템 데이터 흐름도

자율운항시스템은 선박의 '두뇌'에 해당하며 다양한 센서 데이터를 기반으로 주변 상황을 인지하고, 충돌 회피 및 항로 유지를 위한 의사결정을 내리며 최종적으로 조타 및 추진 시스템을 제어하는 핵심 시스템이다. 이 시스템의 오작동은 선박의 제어권 상실로 이어져 충돌, 좌초 등 심각한 사고를 유발할 수 있다.

이 시스템은 인지-판단-제어의 순차적인 데이터 흐름에 따라 동작하며, 각 단계는 잠재적인 공격 표면이 될 수 있다. 제공된 데이터 흐름도를 바탕으로 위협을 분석하면 다음과 같다.

자율운항선박 사이버 위협 분석

표 3-4 자율운항선박시스템의 STRIDE 위협 분석

Flow No.	Data	설명	STRIDE 위협
자율운항_1	데이터 송신	선박 데이터 송신(인지)	• Spoofing: 허위 센서 데이터(예: 유령 선박 AIS, 허위 GNSS)를 주입하여 상황 오인 유도 • Tampering: 실제 센서 데이터(예: RADAR, LIDAR)를 변조하여 장애물을 은폐하거나 허위 장애물 생성
자율운항_2	데이터 수신	선박 데이터 및 상황인식 데이터 수신 (판단)	• Tampering: 인지 단계에서 생성된 상황인식 데이터를 변조하여 판단 시스템의 의사결정 교란
자율운항_3	데이터 송신	자율운항 판단 데이터 송신 (판단)	• Tampering: 충돌회피, 항로계획 등 AI의 판단 결과를 변조하여 위험한 운항 경로 생성
자율운항_4	데이터 수신	자율운항 판단 데이터 수신	• Denial of Service: 제어 시스템으로의 판단 데이터 전송을 차단하여 제어 불능 상태 유발
자율운항_5	데이터 송신	운항시스템 제어 피드백 데이터 송신	• Tampering: 제어 시스템의 실제 동작과 다른 피드백을 전송하여 자율운항시스템의 후속 판단 오류 유발 • Repudiation: 제어 명령 수행 실패 후 성공했다고 보고하여 책임 회피

자율운항시스템에 대한 위협은 단순히 하나의 장비를 공격하는 것을 넘어, 시스템의 의사결정 체인 전체를 겨냥한다. 공격자는 센서 데이터를 조작하여 시스템의 '눈'을 속이고(인지 단계), AI 알고리즘을 조작하여 '두뇌'의 판단을 왜곡시키며(판단 단계), 최종적으로 제어 시스템에 잘못된 명령을 내리게 한다(제어 단계). 이는 전통적인 네트워크 경계 보안만으로는 방어할 수 없는 복합적인 위협이다. 따라서 이러한 위협에 대응하기 위해서는 센서 데이터의 상호 교차 검증, AI 판단 결과의 신뢰성 및 설명가능성 확보, 그리고 제어 명령의 무결성을 보장하는 등 인지-판단-제어 전 과정에 걸친 심층 방어(Defense-in-Depth) 아키텍처를 설계 단계부터 적용하는 것이 필수적이다.

자율운항선박 사이버 위협 분석

3.2.3. AR Navigation 시스템 위협

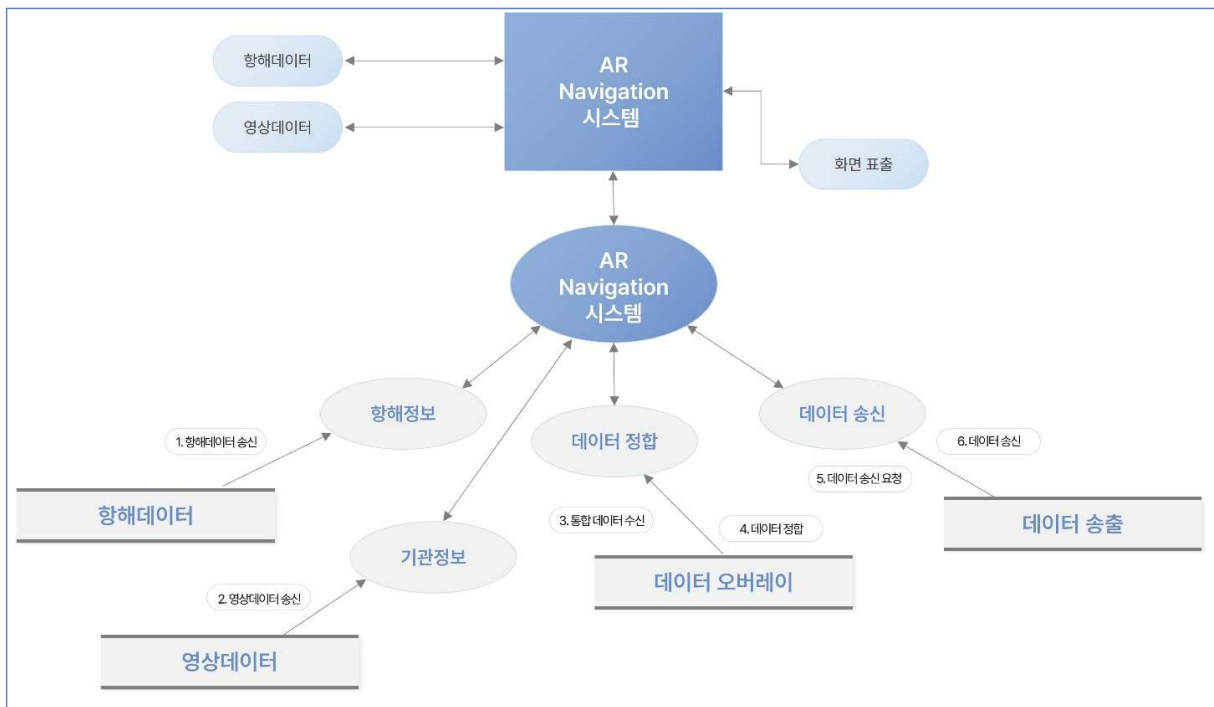


그림 3-4 ▶ AR Navigation 데이터 흐름도

증강현실(AR) 항해 시스템은 선내 또는 원격 운항자의 상황 인지(Situational Awareness) 능력을 극대화하기 위해 설계된 핵심적인 인간-기계 인터페이스(HMI)이다. 이 시스템은 선박의 실제 카메라 영상 위에 전자해도(ECDIS), AIS 목표물, 계획 항로(Passage Plan) 등 필수 항해 정보를 그래픽으로 중첩하여 보여줌으로써, 복잡한 데이터를 직관적이고 실행 가능한 시각 정보로 변환한다. 따라서 이 시스템이 제공하는 정보의 무결성은 운항자의 판단과 직결되며, 시스템의 손상은 치명적인 항해 과실로 이어질 수 있다.

해당 시스템의 위협 시나리오를 분석하면 다음과 같은 주요 데이터 흐름을 식별할 수 있다. 공격은 외부 소프트웨어 업데이트 경로를 통해 시작될 수 있으며, 항해 센서 데이터와 최종 출력 단계 또한 잠재적인 공격 벡터가 될 수 있다.

자율운항선박 사이버 위협 분석

표 3-5 AR Navigation 시스템의 STRIDE 위협 분석

Flow No.	Data	설명	STRIDE 위협
AR_1	데이터 송신	항해 데이터 송신	• Spoofing: 허위 AIS 또는 GNSS 신호를 주입하여 AR 시스템의 상황 인식을 교란 • Tampering: 전송 중인 센서 데이터(예: 선박 속도, 위치)를 변조하여 잘못된 정보 표시 유도
AR_2	데이터 송신	기관 데이터 송신	• Tampering: 기관 상태 데이터를 조작하여 시스템 상태에 대한 운항자의 오인을 유도
AR_3	데이터 수신	통합 데이터 송신	• Tampering: 데이터 정합 로직을 변조하여 AR 오버레이 그래픽을 왜곡하고 위험 지역을 안전 항로로 표시
AR_4	데이터 정합	데이터 정합	• Tampering: 시스템 내부의 그래픽 렌더링 로직을 조작하여 운항자의 오인을 유도
AR_5	데이터 송신 요청	데이터 송신 요청	• Denial of Service: 정상적인 데이터 요청을 방해하여 화면 업데이트를 지연시키거나 중단
AR_6	데이터 송신	데이터 송신	• Tampering: 최종 출력되는 화면 데이터를 변조하여 운항자에게 왜곡된 시각 정보를 제공

AR 항해 시스템에 대한 위협은 새로운 유형의 공격 범주인 '인식 계층 공격(Perception Layer Attack)'의 전형적인 예시이다. 이러한 공격의 최종 목표는 시스템을 다운 시키는 것이 아니라, 인간 운영자의 현실 인식을 교묘하게 조작하여 운영자 스스로를 공격의 도구로 만드는 것이다. 공격 시나리오에서 악성코드는 시스템 충돌이나 명백한 오류를 일으키지 않고, 오히려 매우 그럴듯한 거짓 정보를 생성하여 운항자의 신뢰를 악용한다. 이는 시스템 충돌이나 성능 저하와 같은 전통적인 이상 징후를 감시하는 보안 체계로는 탐지하기 어렵다. 따라서 이러한 위협에 대응하기 위해서는 네트워크 보안을 넘어, 소프트웨어 개발 및 공급망 전반에 걸친 보안 강화(C-SCRM), 모든 업데이트에 대한 코드 서명 의무화, 그리고 AR 시스템의 출력을 독립적인 원시 데이터와 교차 검증하는 로직을 포함하는 '설계 기반 보안(Secure by Design)' 접근법이 필수적이다.

자율운항선박 사이버 위협 분석

3.2.4. 에너지관리 시스템(EMS) 위협

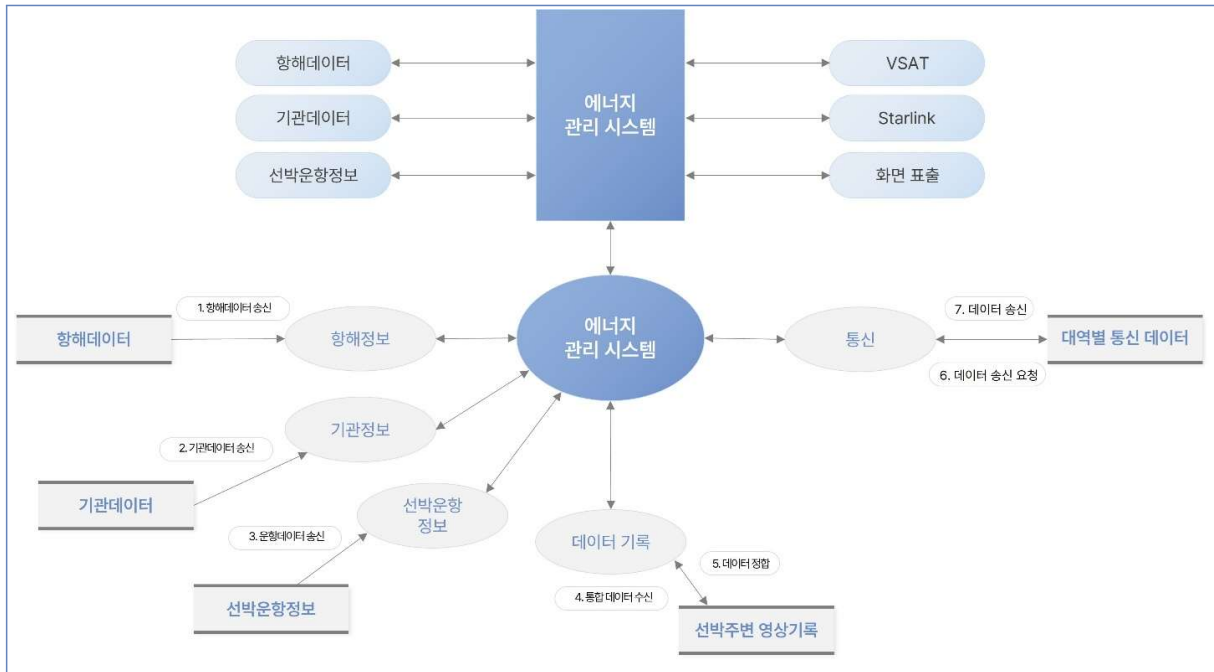


그림 3-5 ▶ 에너지관리 시스템(EMS) 데이터 흐름도

에너지관리 시스템(EMS)은 선박의 발전, 배전, 추진을 총괄하는 핵심 제어 시스템이다. 이 시스템의 기능 마비는 추진력과 전력을 모두 상실하는 '완전한 정전(Blackout)' 상태로 이어질 수 있으며, 이는 항해 중인 선박에 치명적인 안전사고를 유발한다. 공격자가 상대적으로 보안이 취약한 선원용 IT 네트워크를 통해 침투한 후, IT/OT 경계를 넘어 EMS를 공격이 가능하며, 이를 통해 다음과 같은 데이터 흐름과 위협을 도출할 수 있다.

자율운항선박 사이버 위협 분석

표 3-6 에너지관리 시스템의 STRIDE 위협 분석

Flow No.	Data	설명	STRIDE 위협
에너지_1	데이터 송신	항해 데이터 송신	• Tampering: 항해 데이터를 변조하여 EMS의 에너지 최적화 계산 오류 유발
에너지_2	데이터 송신	기관 데이터 송신	• Tampering: 기관 데이터를 조작하여 비효율적인 발전기 운영을 유도하거나 고장 징후 은폐
에너지_3	데이터 송신	운항 데이터 송신	• Tampering: 운항 정보를 변조하여 시스템의 전력 수요 예측을 교란
에너지_4	데이터 수신	통합 데이터 송신	• Denial of Service: 랜섬웨어 감염 등으로 데이터 통합 프로세스를 마비시켜 전력 제어 불능 유발
에너지_5	데이터 정합	데이터 정합	• Tampering: 데이터 정합 로직을 변조하여 잘못된 전력 분배 결정 유도
에너지_6	데이터 송신요청	데이터 송신 요청	• Spoofing: 비인가자가 육상으로 데이터 전송을 요청하여 정보 유출 시도
에너지_7	데이터 송신	데이터 수신	• Information Disclosure: 암호화되지 않은 통신 채널을 통해 전송되는 선박 에너지 데이터를 도청 • Tampering: 중간자 공격으로 육상에 보고되는 에너지 효율 데이터를 변조

EMS 관련 위협 분석은 IT 환경의 기본적인 '사이버 위생(Cyber Hygiene)' 실패가 OT 환경의 재앙적인 안전 리스크로 직접 전환되는지를 가정할 수 있다. 효과적인 보안 체계는 IT와 OT 전반에 걸쳐 일관되고 엄격한 정책을 적용하는 총체적인 접근을 요구한다. 이와 같은 위협은 IACS UR E26에서 요구하는 강력한 네트워크 분리의 필요성을 입증한다.

자율운항선박 사이버 위협 분석

3.2.5. CBM(Condition Based Maintenance) 시스템 위협

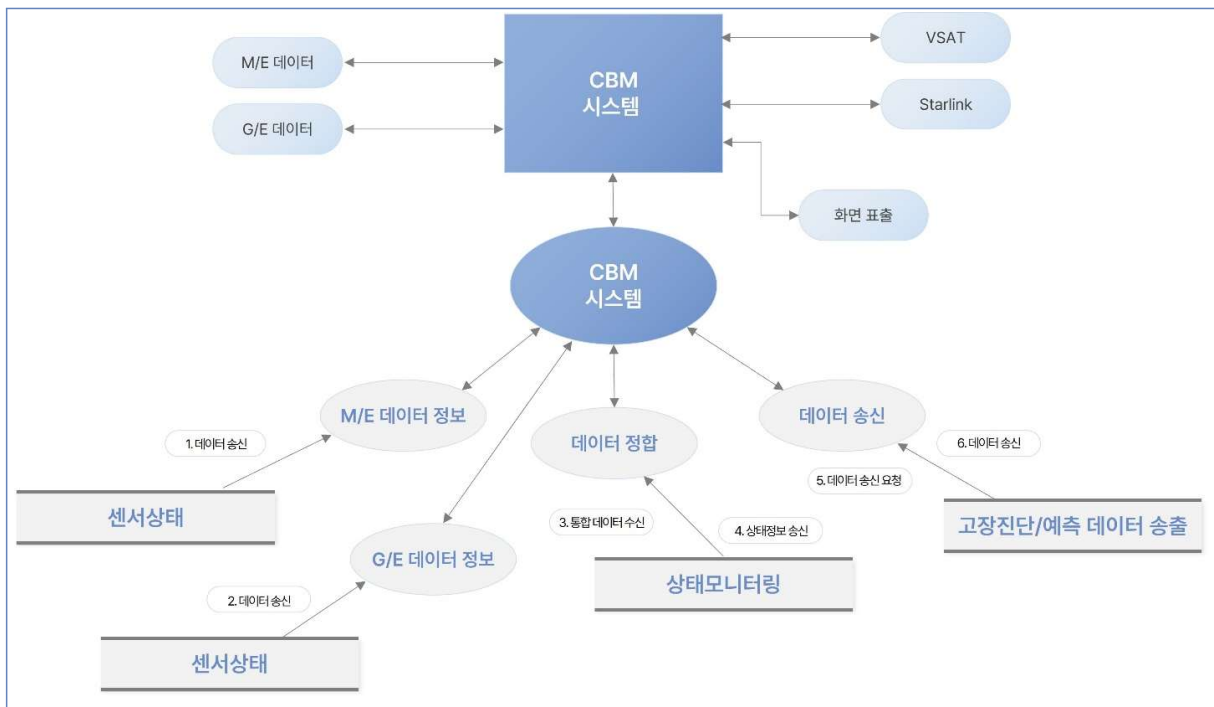


그림 3-6 ▶ CBM(Condition Based Maintenance) 시스템 데이터 흐름도

상태 기반 유지보수(CBM) 시스템은 주 기관과 같은 핵심 기기의 진동, 온도 등 센서 데이터를 실시간으로 분석하여 고장을 사전에 예측하는 시스템이다. 이 시스템은 데이터의 신뢰성에 전적으로 의존하며, 데이터 조작은 시스템의 존재 이유 자체를 무력화시킬 수 있다. 이러한 특성을 고려하여 다음과 같은 데이터 흐름과 위협을 정의할 수 있다.

자율운항선박 사이버 위협 분석

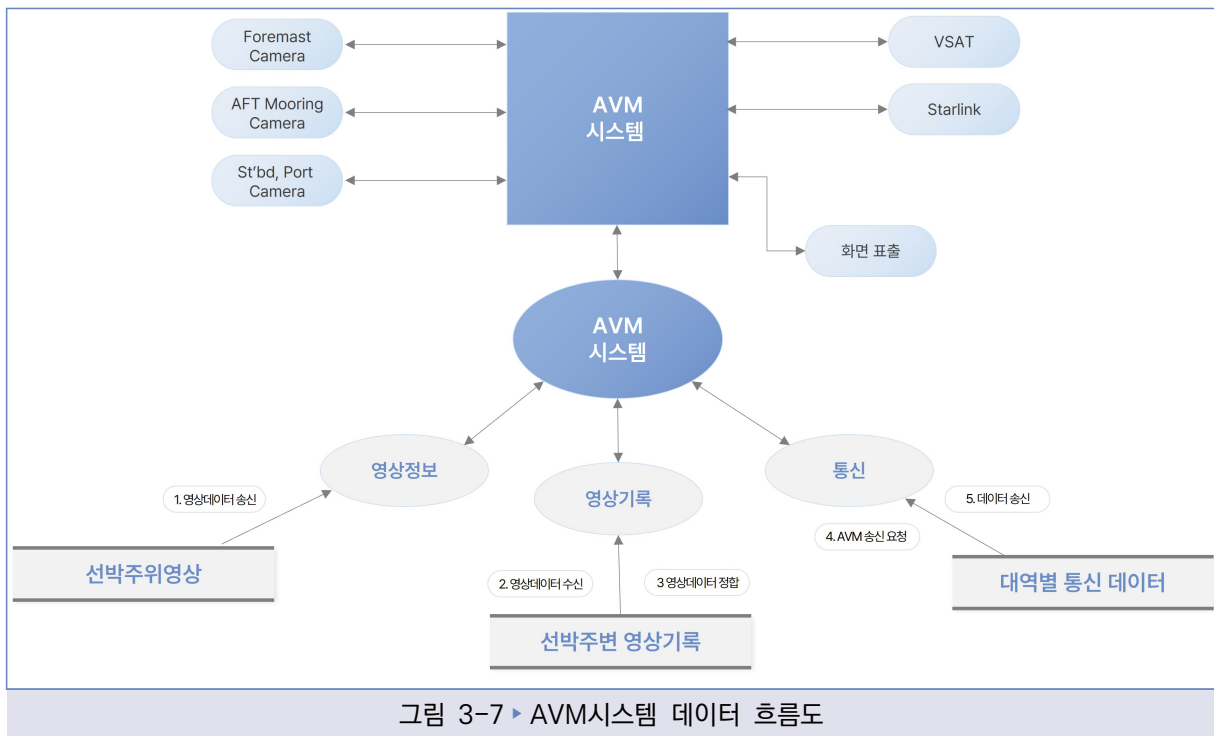
표 3-7 CBM 시스템의 STRIDE 위협 분석

Flow No.	Data	설명	STRIDE 위협
CBM_1	데이터 송신	M/E(주기관) 센서 데이터 송신	• Tampering: 센서 데이터를 정상 범위 내 값으로 조작하여 주 기관의 고장 징후를 은폐
CBM_2	데이터 송신	G/E(발전기) 센서 데이터 송신	• Tampering: 발전기 센서 데이터를 변조하여 잠재적 결함을 시스템이 탐지하지 못하도록 조작
CBM_3	데이터 수신	통합 데이터 수신 및 정합	• Tampering: 데이터 분석 알고리즘을 변조하여 잘못된 '정상' 상태 판단 유도
CBM_4	데이터 정합	상태 모니터링 정보 송신	• Information Disclosure: 선내 모니터링 화면에 표시되는 기기 상태 정보가 비인가자에게 노출
CBM_5	데이터 송신 요청	데이터 송신 요청	• Denial of Service: 육상으로의 고장 예측 보고서 전송을 방해하여 적시 유지보수 기회 상실 유발
CBM_6	데이터 송신 요청	고장진단/예측 데이터 송신	• Information Disclosure: 선박의 상세 기기 상태 및 예측 데이터가 경쟁사 등 비인가자에게 유출 • Repudiation: 운영자가 중요 경보를 확인하고도 조치하지 않은 후, 관련 로그가 없다면 이를 부인할 가능성

CBM 시스템 위협 분석은 전통적인 임계값 기반의 경보 시스템이 탐지할 수 없는 지능적인 공격 패턴을 보여준다. 공격자는 센서 신호를 차단하거나 범위를 벗어나는 값을 주입하는 대신, 데이터가 항상 '정상' 범위 내에 있도록 교묘하게 조작할 수 있다. 이로 인해 CBM의 AI 모델은 신뢰할 수 없는 데이터를 기반으로 '모든 것이 정상'이라는 잘못된 판단을 내리게 된다. 이는 갑작스러운 사고가 아니라, 예방할 수 있었던 기계적 결함이 탐지되지 않은 채 점진적으로 악화되어 결국 치명적인 고장으로 이어지는 과정이다. 이러한 공격을 방어하기 위해서는 단일 데이터 소스를 맹신하지 않는 접근법이 필요하다. 즉, 시스템은 진동 센서 값뿐만 아니라 온도, 유압 등 관련된 다른 센서 데이터 간의 상관관계를 종합적으로 분석해야 한다. 예를 들어, 진동은 정상이지만 온도와 유압이 서서히 비정상적인 패턴을 보인다면, 이는 통계적 정상 범위를 벗어나지 않더라도 물리적 이상 징후로 판단할 수 있어야 한다. 이는 단순한 통계 분석을 넘어, 시스템의 물리적 특성을 이해하는 고도화된 AI 기반 이상 탐지 기술의 필요성을 강조한다.

자율운항선박 사이버 위협 분석

3.2.6.AVM(Around View Monitoring) 시스템 위협



AVM 시스템은 선박 주변에 설치된 다수의 카메라 영상을 합성하여 사각지대 없는 360도 조감도 (Bird's-eye view)를 제공하는 시스템이다. 이는 특히 접안과 같이 정밀한 기동이 요구되는 상황에서 운항자의 상황 인식을 보조하는 중요한 역할을 한다. 예상되는 위협은 AR 향해 시스템과 마찬가지로 운항자의 시각적 인식을 직접적으로 공격하는 것이다. 주요 데이터 흐름과 관련 위협은 다음과 같다.

자율운항선박 사이버 위협 분석

표 3-8 AVM 시스템의 STRIDE 위협 분석

Flow No.	Data	Description	STRIDE 위협
AVM_1	영상 데이터 송신	영상 데이터 수신	• Tampering: 실시간 영상 피드를 사전에 녹화된 영상으로 교체하여 실제 장애물을 은폐 • Denial of Service: 특정 카메라의 영상 피드를 마비시켜 AVM 시스템에 사각지대 발생 유도
AVM_2	영상 데이터 수신	영상 데이터 수신	• Elevation of Privilege: 취약점을 이용해 카메라 제어 권한을 탈취하여 의도적으로 시야를 방해
AVM_3	영상 데이터 정합	영상 데이터 정합	• Tampering: 영상 합성 과정에 개입하여 특정 영역을 왜곡하거나 허위 객체를 삽입
AVM_4	데이터 송신 요청	AVM 영상 데이터 송신 요청	• Denial of Service: 대용량 영상 데이터의 육상 전송 요청을 방해하여 원격 모니터링을 차단
AVM_5	데이터 송신	데이터 수신	• Information Disclosure: 암호화되지 않은 영상 스트림을 도청하여 선박 주변 상황 감시 • Tampering: 전송 중인 영상을 변조하여 ROC 운영자의 상황 오인 유도

AVM 시스템에 대한 공격 역시 '인식 계층 공격'의 한 형태로, 영상 데이터를 표적으로 할 수 있다. 자율운항선박에서 카메라 네트워크는 항해 시스템과 동등한 수준의 신뢰성과 무결성이 요구되는 핵심 OT 인프라이다. 즉, IP 카메라 네트워크를 더 이상 단순한 편의 시설이나 물리 보안 시스템의 일부로 취급해서는 안 된다는 점이다. 따라서 이 네트워크는 일반 IT망과 엄격히 분리되어야 하며, 영상 스트림 자체의 위변조를 방지하기 위해 암호화 또는 디지털 워터마킹과 같은 무결성 검증 메커니즘을 적용이 필요하다.

자율운항선박 사이버 위협 분석

3.2.7. Auto Berthing 시스템 위협

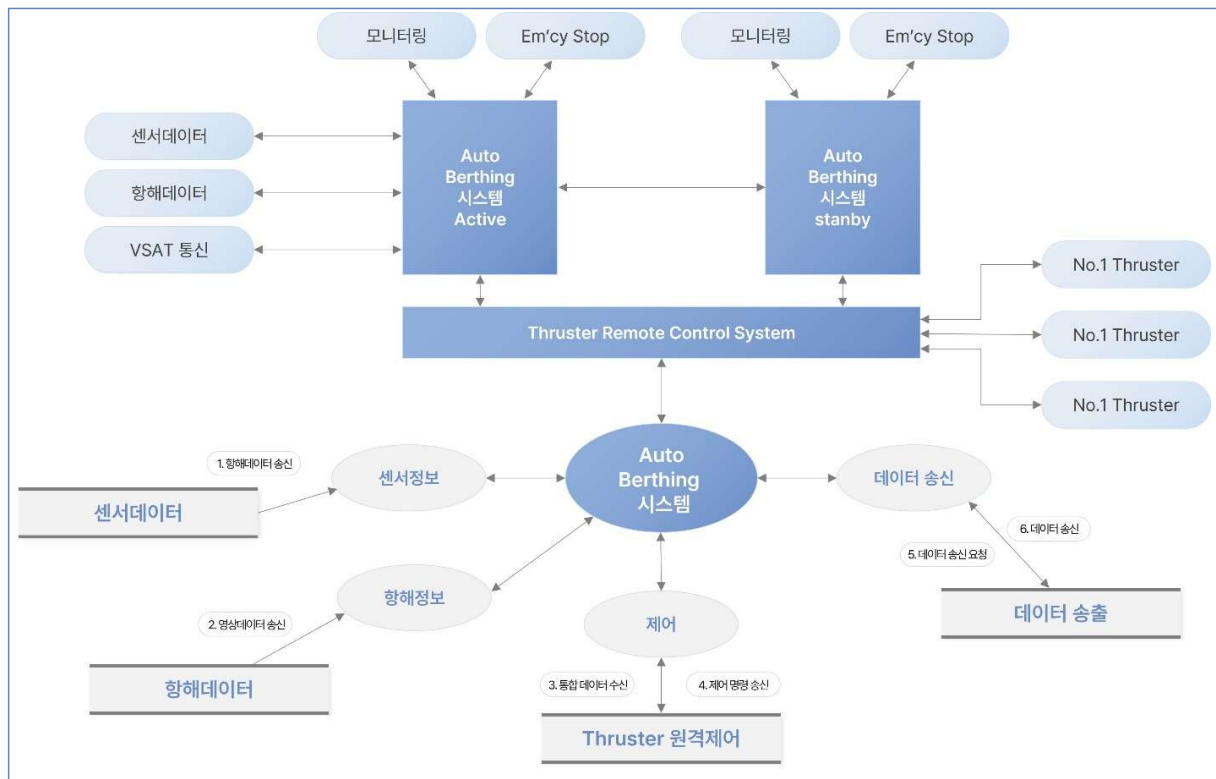


그림 3-8 ▶ Auto Berthing 시스템 데이터 흐름도

자동 이·접안 시스템은 LIDAR, 고정밀 GNSS 등 첨단 센서를 활용하여 선박을 자동으로 부두에 접안시키는 고도의 자동화 시스템이다. 이 시스템의 오작동은 선박과 항만 시설에 직접적이고 막대한 물리적 피해를 야기할 수 있다. 이 시스템은 오차 허용 범위가 극히 좁은 환경에서 작동하므로, 입력 데이터의 정확성이 절대적으로 중요하다. 주요 데이터 흐름과 위협은 다음과 같다.

자율운항선박 사이버 위협 분석

표 3-9 Auto Berthing 시스템의 STRIDE 위협 분석

Flow No.	Data	Description	STRIDE 위협
AB_1	데이터 송신	센서 데이터 송신	• Tampering: LIDAR 등 거리 측정 센서값을 조작하여 시스템의 감속 판단을 지연시켜 '급속 접안' 유발
AB_2	데이터 송신	항해 데이터 송신	• Spoofing: 허위 DGPS 신호를 송신하여 선박의 위치를 오인시켜 접안 위치 오류 발생
AB_3	데이터 수신	통합 데이터 수신	• Tampering: 센서 퓨전 알고리즘을 조작하여 잘못된 접안 경로 계산 유도
AB_4	제어 명령 송신	Thruster 원격제어 송신	• Tampering: 제어 명령을 변조하여 과도한 기동을 유발하거나, 비인가가 제어 명령을 직접 주입 • Denial of Service: 제어 명령 전송을 방해하여 시스템을 비상 정지 상태로 만들
AB_5	데이터 송신 요청	데이터 송신 요청	• Spoofing: 비인가자가 시스템 상태 보고를 요청하여 시스템 정보를 탈취
AB_6	데이터 송신 요청	데이터 송신	• Information Disclosure: 접안 과정의 상세 데이터가 비인가자에게 유출

자동 접안 시스템은 '고위험, 저오차허용(high-stakes, low-margin-for-error)' 자동화의 위험성을 상징적으로 보여준다. 광활한 바다에서의 항해와 달리, 접안 과정에서는 단 몇 센티미터의 데이터 오차도 수백만 달러의 피해를 초래할 수 있다. 이는 센서 데이터의 단순 수신을 넘어, 여러 독립적인 센서로부터 받은 데이터를 실시간으로 융합하고 상호 검증하는 강력한 '센서 퓨전(Sensor Fusion)' 로직의 필요성을 강조한다. 만약 센서 데이터 간에 불일치가 발생하거나 신뢰도가 일정 수준 이하로 떨어질 경우, 시스템은 즉시 자동 접안 절차를 중단하고 운항자에게 제어권을 넘기는 등 명확한 '안전 후퇴(Fail-safe)' 절차를 갖추어야 한다.

자율운항선박 사이버 위협 분석

3.2.8. 선박-육상 통신 시스템 위협

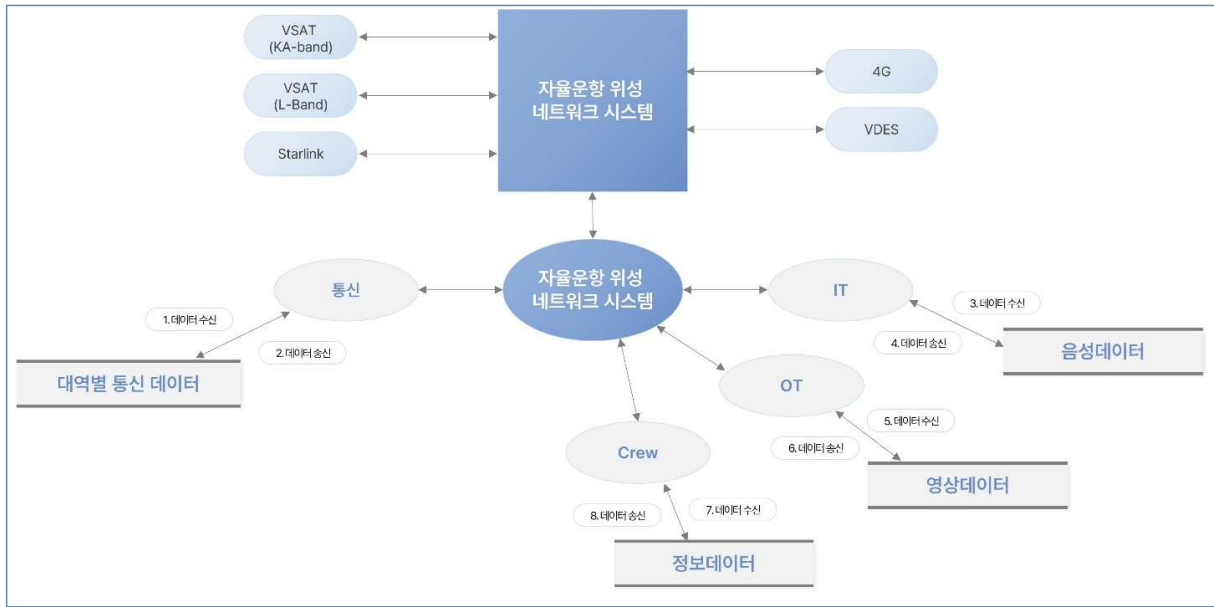


그림 3-9 ▶ 선박-육상 통신 시스템 위협 데이터 흐름도

위성통신(VSAT), 5G 등으로 구성된 선박-육상 통신 시스템은 자율운항선박과 원격운항센터(ROC)를 연결하는 유일한 통로이다. 모든 원격 제어 명령과 모니터링 데이터가 이 채널을 통해 전송되므로, 통신 채널의 보안은 원격 운항의 가장 기본적인 전제 조건이다. 이 시스템은 외부와의 직접적인 접점으로 자율운항 생태계 전체의 관문 역할을 한다. 주요 데이터 흐름과 위협은 다음과 같다.

자율운항선박 사이버 위협 분석

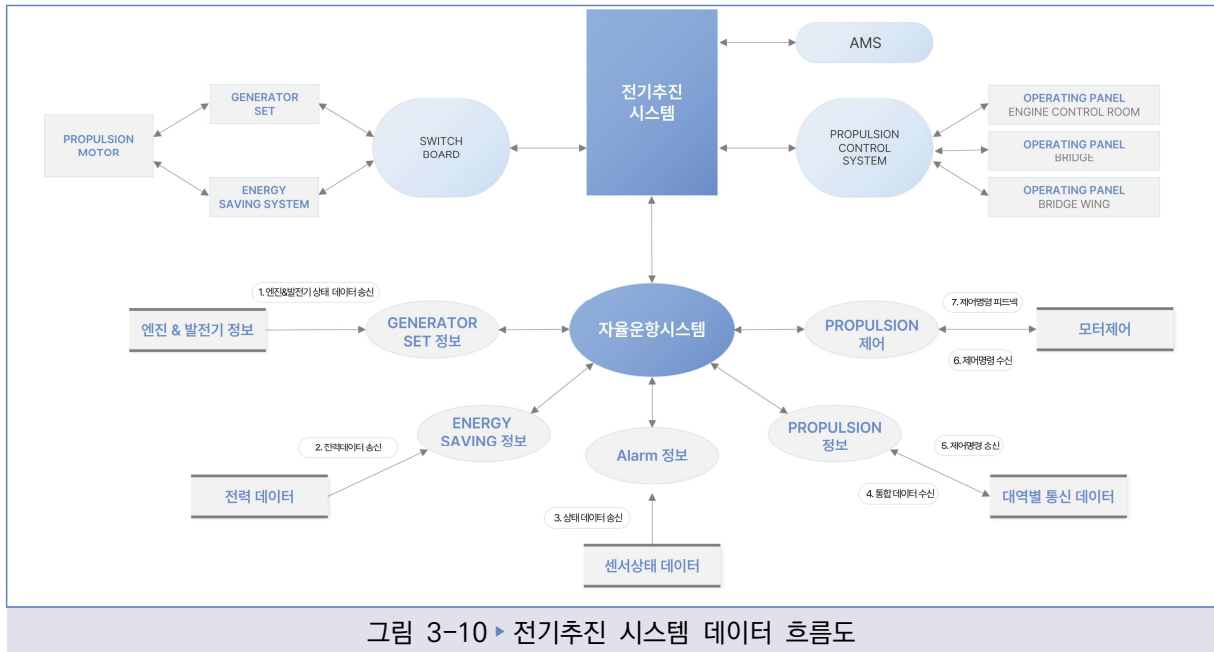
표 3-10 선박-육상 통신 시스템의 STRIDE 위협 분석

Flow No.	Data	설명	STRIDE 위협
Comm_1	데이터 수신	대역별 통신사용 데이터 수신	• Spoofing: 공격자가 ROC를 사칭하여 악의적인 원격 제어 명령을 전송 • Tampering: 정상적인 ROC 명령을 수신하는 과정에서 내용을 변조하여 전달 (중간자 공격)
Comm_2	데이터 송신	대역별 통신사용 데이터 송신	• Information Disclosure: 암호화되지 않은 통신 채널을 통해 민감한 운항 데이터를 도청 • Denial of Service: 통신 장비에 대한 DDoS 공격으로 통신 두절 유발
Comm_3	데이터 수신	음성 데이터 수신	• Spoofing: ROC 운영자를 사칭한 음성으로 선원을 기만
Comm_4	데이터 송신	음성 데이터 송신	• Information Disclosure: 선내 음성 통화 내용 도청
Comm_5	데이터 수신	영상 데이터 수신	• Tampering: ROC에서 보내는 보조 영상 정보(예: 항만 드론 영상)를 변조
Comm_6	데이터 송신	영상 데이터 송신	• Denial of Service: 영상 데이터 전송을 방해하여 ROC의 실시간 모니터링을 차단
Comm_7	데이터 수신	정보 데이터 수신	• Elevation of Privilege: 일반 선원이 관리자 권한을 탈취하여 통신 시스템 설정 변경 시도
Comm_8	데이터 송신	정보 데이터 송신	• Information Disclosure: 데이터가 게이트웨이에 도달하기 전, 암호화되지 않은 선내망 구간에서 도청

선박-육상 통신 시스템은 원격 운영 환경에서 가장 중요하고 취약한 단일 공격 표면(Attack Surface)이다. 경계에 위치한 통신 장비 하나가 장악되면 공격자는 선박과 ROC 간에 오가는 모든 정보를 감청하고 변조할 수 있는 막강한 권한을 갖게 된다. 이는 단순한 VPN과 같은 링크 계층 암호화만으로는 불충분함을 시사한다. 진정한 보안을 위해서는 ROC의 핵심 애플리케이션에서부터 선박의 최종 제어 시스템에 이르는 전 구간을 보호하는 '종단간 암호화(End-to-End Encryption)'가 필수적이다. 이 방식은 데이터가 전송되는 경로상의 통신 장비 자체가 손상되더라도 데이터의 기밀성과 무결성을 보장할 수 있다.

자율운항선박 사이버 위협 분석

3.2.9. 전기추진 시스템 위협



전기추진 시스템은 발전기에서 생산된 전력을 이용해 추진 모터를 구동 시키는 선박의 핵심 동력 장치이다. 이 시스템에 대한 제어 실패는 즉각적인 운항 불능으로 이어질 수 있다. 이 시스템은 선박의 물리적 기동을 직접 제어하므로, 엔진, 발전기, 센서 등에서 수신하는 데이터와 최종 제어 명령의 무결성이 무엇보다 중요하다. 데이터 흐름도를 바탕으로 위협을 분석하면 다음과 같다.

자율운항선박 사이버 위협 분석

표 3-11 전기추진 시스템의 STRIDE 위협 분석

Flow No.	Data	설명	STRIDE 위협
EP_1	데이터 송신	엔진& 발전기 데이터 송신	• Tampering: 엔진 및 발전기 상태 데이터를 조작하여 시스템의 전력 관리 판단 오류 유발
EP_2	데이터 송신	전력 데이터 송신	• Tampering: 전력 데이터를 변조하여 비효율적인 에너지 분배를 유도하거나 시스템 과부하 초래
EP_3	데이터 송신	센서 상태 데이터 송신	• Tampering: 센서 데이터를 조작하여 시스템의 이상 상태 감지를 방해하고 고장 징후 은폐
EP_4	데이터 수신	통합 데이터 수신	• Denial of Service: 데이터 수신 프로세스를 마비시켜 추진 시스템 제어 불능 유발
EP_5	데이터 송신	제어명령 송신	• Tampering: 인증되지 않은 프로토콜을 통해 악의적인 제어 명령(예: 급가속/감속)을 직접 주입 • Spoofing: 제어 시스템을 사칭하여 비인가 명령 전송
EP_6	데이터 수신	제어명령 수신	• Tampering: 모터 제어기로 전달되는 명령을 변조하여 의도치 않은 기동 유발
EP_7	데이터 송신	제어명령 피드백	• Tampering: 실제로는 명령이 실패했으나 성공한 것처럼 피드백을 조작하여 상황 오판 유발

위협 분석은 레거시 OT 프로토콜이 지닌 고질적인 보안 리스크를 명확하게 보여준다. Modbus와 같은 다수의 OT 프로토콜은 효율성과 실시간성을 우선으로 설계되었기 때문에, 인증이나 암호화와 같은 보안 기능이 본질적으로 결여되어 있다. 공격자는 이러한 설계적 약점을 파고들어, 네트워크에 접근하기만 하면 누구든 직접 제어 명령을 내릴 수 있는 위험을 보여준다. 이에 대한 근본적인 해결책은 보안 기능이 내장된 최신 OT 프로토콜로 전환하는 것이지만, 현실적으로는 기존 시스템과의 호환성 문제로 어렵다. 따라서 차선책으로, OT 프로토콜을 TLS와 같은 보안 터널로 감싸거나(Wrapping), OT 환경을 이해하는 차세대 방화벽을 통해 허가된 장비와 허가된 기능 코드(Function Code) 외에는 PLC와의 모든 통신을 차단하는 강력한 '마이크로 세분화(Micro-segmentation)' 정책을 적용하는 것이 필요하다.

자율운항선박 사이버 위협 분석

3.2.10. ROC 자율운항시스템 위협

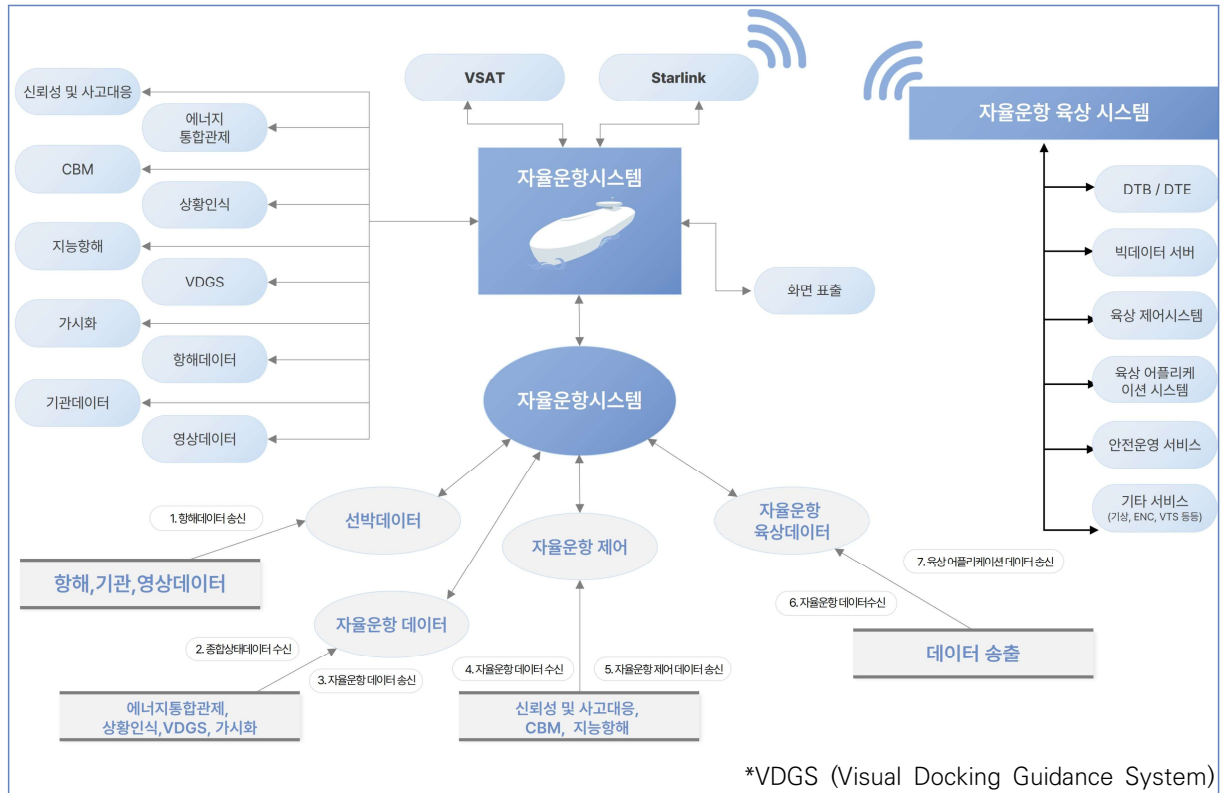


그림 3-11 ▶ ROC 자율운항시스템 데이터 흐름도

원격운항센터(ROC)의 자율운항시스템은 전체 선단을 원격으로 모니터링하고 제어 명령을 내리는 중앙 관제 HMI이다. 이 플랫폼에 대한 접근 권한은 사실상 선단 전체에 대한 제어 권한을 의미하므로, 최고 수준의 보안이 요구된다. 이 시스템은 자율운항 생태계의 '두뇌'이자 공격자에게는 가장 가치 있는 표적이다. 데이터 흐름도를 바탕으로 위협을 분석하면 다음과 같다.

자율운항선박 사이버 위협 분석

표 3-12 ROC 자율운항시스템의 STRIDE 위협 분석

Flow No.	Data	설명	STRIDE 위협
ROC_1	데이터 송신	항해, 기관, 영상 데이터 송신	• Tampering: 선박에서 전송되는 항해, 기관 데이터를 변조하여 ROC의 상황 인식을 교란 • Information Disclosure: 암호화되지 않은 통신 채널을 통해 민감한 운항 데이터를 도청
ROC_2	데이터 수신	종합 데이터 수신	• Denial of Service: 대량의 위조 데이터를 전송하여 ROC의 데이터 수신 및 처리 시스템을 마비시킴
ROC_3	데이터 송신	자율운항 데이터 송신	• Tampering: ROC 내부에서 분석/가공된 자율운항 데이터를 변조하여 후속 시스템(예: CBM, 상황인식)의 오판 유도
ROC_4	데이터 수신	자율운항 데이터 수신	• Spoofing: ROC 내부의 다른 시스템을 사칭하여 악의적인 자율운항 데이터를 주입
ROC_5	제어 데이터 송신	자율운항 제어 데이터 송신	• Spoofing: 피싱 등을 통해 탈취한 계정으로 로그인하여 비인가 원격 제어 명령 전송 • Tampering: 운영자 브라우저에 잠입한 악성코드가 전송 직전의 제어 명령을 하이재킹하여 변조 (Man-in-the-Browser) • Repudiation: 악의적인 명령을 전송한 후 관련 로그를 삭제하여 자신의 행위를 부인
ROC_6	데이터 수신	자율운항 데이터 수신	• Information Disclosure: 육상 시스템으로 전송되는 데이터가 중간에 탈취되어 영업 비밀 유출
ROC_7	데이터 송신	육상 어플리케이션 데이터 송신	• Tampering: 최종 육상 어플리케이션(빅데이터 서버 등)으로 전송되는 데이터를 변조하여 통계 및 분석 왜곡 • Denial of Service: 대량의 허위 데이터를 전송하여 육상 어플리케이션의 정상적인 서비스 방해

이 위협 분석은 자율운항 생태계에서도 '인적 요소'가 여전히 가장 중요한 보안 지점임을 명확히 보여준다. Man-in-the-Browser 공격은 방화벽과 같은 네트워크 보안을 우회하고, 이미 인증된 신뢰할 수 있는 엔드포인트(운영자 워크스테이션) 내부에서 발생하기 때문에 탐지가 매우 어렵다. 이는 심층 방어(Defense-in-Depth) 전략의 중요성을 다시 한번 강조한다. 네트워크 경계 방어뿐만 아니라, 엔드포인트 자체를 보호하기 위한 EDR(엔드포인트 탐지 및 대응) 솔루션, 비정상적인 사용자 행위를 탐지하는 UBA(사용자 행위 분석) 기술 도입이 필수적이다. 나아가, 기술적 통제의 최종 안전장치로서, 항로 변경이나 위험 해역 진입과 같이 리스크가 큰 제어 명령에 대해서는 명령을 실행하기 전 다른 승인권자의 2차 승인을 요구하는 절차적 통제를 마련하는 것이 매우 중요하다.

사이버 리스크 평가 및 시나리오

4.1. 리스크 평가 방법론	58
4.2. 자율운항선박 리스크 평가	64
4.3. 리스크 평가 결과	101



사이버 리스크 평가 및 시나리오

제3장에서 식별된 위협들을 바탕으로, 각 위협이 발생할 가능성과 그로 인한 영향도를 평가하여 리스크 수준을 결정한다. 이는 한정된 자원을 가장 시급하고 중요한 영역에 집중하여 효과적인 보안 대책을 수립하기 위함이다.

4.1. 리스크 평가 방법론

본 모델은 KISA의 '스마트선박 보안모델' 방법론을 자율운항 환경에 맞게 확장한 6단계 리스크 평가 절차를 제시한다.

1. 1단계: 평가 범위 및 자산 식별 (Scope & Asset Identification): 평가 대상 범위(MASS, ROC)와 핵심 자산을 명확히 정의한다.
2. 2단계: 운영 수준 및 목표 성숙도 결정 (Operational Level & Target Maturity): 자율화 수준(MASS Level 1~4)과 ROC운영 수준(ROC 1~4)을 정의하고, 이에 부합하는 보안 성숙도 목표(예: Advanced)를 설정한다.
3. 3단계: 위협 및 취약점 식별 (Threat & Vulnerability Identification): 3장의 위협 모델링 결과를 바탕으로 각 STRIDE취약점을 식별한다.
4. 4단계: 리스크 분석 (Risk Analysis): 각 위협 시나리오의 발생 가능성(Likelihood)과 영향도(Impact)를 산정한다.
 - 가능성(L): 위협 주체의 역량, 공격의 용이성, 시스템의 방어 능력 등을 종합하여 1~5 등급으로 산정
 - 영향도(I): 전통적인 CIA 모델에 해양 CPS 특성을 반영한 SOPF(Safety, Operation, Privacy, Financial) 요소를 추가하여 1~5 등급으로 종합 평가
5. 5단계: 리스크 평가 및 처리 (Risk Evaluation & Treatment): 산정된 위험도(Risk, $R=L \times I$)가 수용 가능한 수준인지 판단하고, 목표 성숙도에 맞는 보안 통제 항목(대책)을 식별하여 적용
6. 6단계: 지속적 개선 (Continual Improvement): 대책 적용 후 잔여 리스크를 재평가하고, 주기적인 모니터링을 통해 보안 모델을 최적화

사이버 리스크 평가 및 시나리오

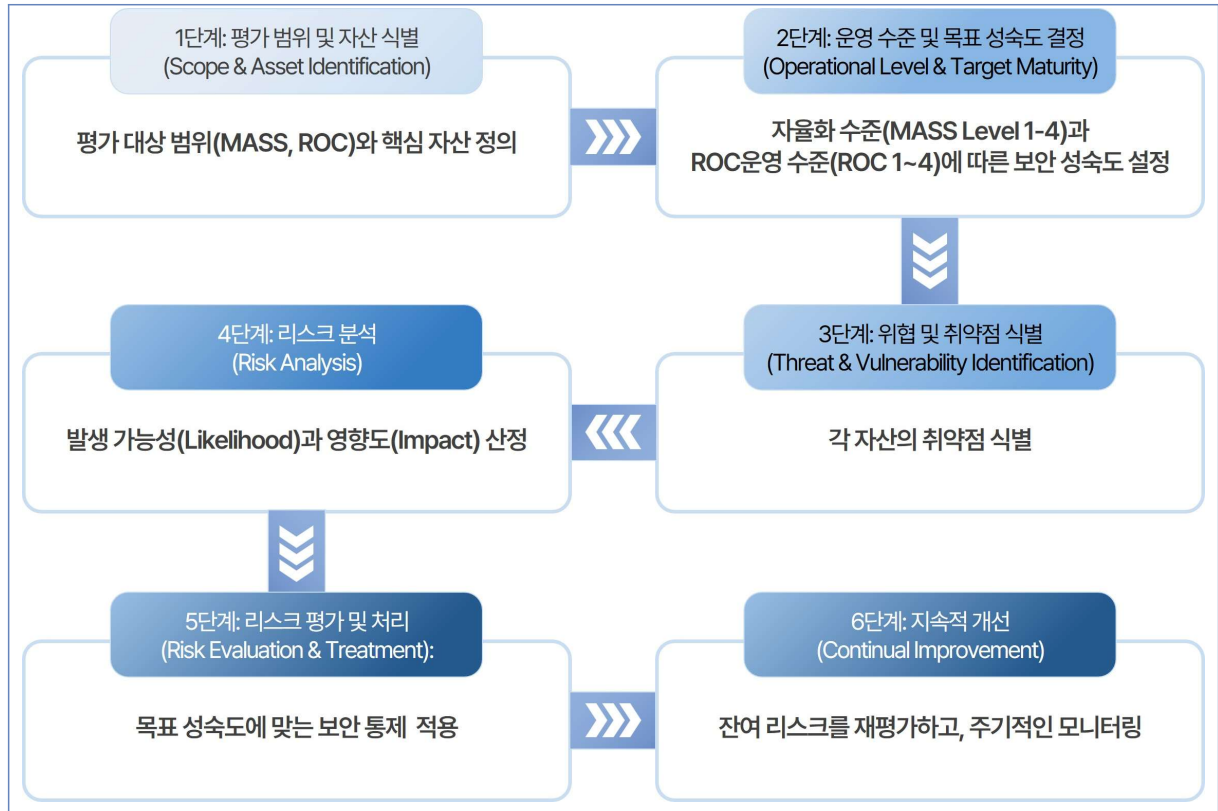


그림 4-1 ▶ 리스크 평가 방법론

사이버 리스크 평가 및 시나리오

리스크 산정 기준

- **가능성(Likelihood, L):** 위협 주체의 역량, 공격의 용이성 등 위협 지수(TI)와 시스템의 방어 능력 등 취약점 지수(VI)은 '확률 지수(TI x VI)'로 표현(1~5 등급)

표 4-1 위협과 취약점 지수 산정 기준

등급	위협 지수 (TI)	취약점 지수 (VI)
5 (매우 높음)	• 지속적으로 발생하거나, 방치 시 100% 발생 확실시됨 (월 1회 이상 또는 상시 발생)	• CVE/Exploit: 공개된 공격 도구(Exploit code)가 존재하며, 패치되지 않은 취약점 보유 (CVSS > 9.0) • 접근성: 인터넷에 직접 노출되어 있으며 인증이 없거나 기본 패스워드 사용 • 난이도: 초보자(Script Kiddie)도 자동화 도구로 공격 가능 • 사례: 해운 업계 내 동종 시스템 대상 랜섬웨어/스캐닝 다수 보고됨
4 (높음)	• 대부분의 운영 환경에서 발생할 가능성이 높음(연 1회 이상)	• CVE/Exploit: 알려진 취약점(CVE)이 존재하나 패치 미적용 • 접근성: 일반 IT 네트워크와 연결되어 있으며, 피싱 등을 통해 접근 가능 • 난이도: 기본적인 해킹 기술을 보유한 공격자 • 사례: 타 산업(물류, 에너지)에서 유사 사례 빈번함
3 (보통)	• 특정 조건 하에서 발생할 수 있음 (5년에 1회 이상)	• CVE/Exploit: 이론적인 취약점이 존재하거나 특정 설정에서만 유효함 • 접근성: 내부망 침투 후 측면 이동(Lateral Movement)이 성공해야 접근 가능 • 난이도: 중급 이상의 기술과 해상 시스템에 대한 이해 필요 • 사례: 전 세계적으로 간헐적인 사고 사례 보고됨
2 (낮음)	• 발생 가능성이 낮으나, 이론적으로는 가능함 (10년에 1회 이상 또는 선박 수명주기 내)	• CVE/Exploit: 알려지지 않은 취약점(Zero-day) 또는 복잡한 공격 체인(Chain) 필요 • 접근성: 물리적 접근이 필요하거나 공급망 침투 등 고난이도 경로 필요 • 난이도: 고급 기술을 보유한 조직적 공격 그룹(APT) 또는 내부 공모자 • 사례: 해상 분야 전례 없음, 이론적 연구 수준
1 (매우낮음)	• 예외적인 상황에서만 발생 가능 (20년에 1회 미만)	• CVE/Exploit: 강력한 암호화를 무력화하거나 다중 안전장치를 동시에 우회해야 함

사이버 리스크 평가 및 시나리오

		• 접근성: 완벽하게 격리(Air-gapped)되고 물리적 보안이 통제된 구역 • 난이도: 국가 지원 수준의 최상위 공격 능력 필요 • 사례: 사고 사례 전무함
--	--	--

표 4-2 가능성 지수 (위협 지수 × 취약점 지수)

등급	정의
5 (심각)	21 ≤ 가능성 지수 ≤ 25
4 (중요)	16 ≤ 가능성 지수 ≤ 20
3 (보통)	11 ≤ 가능성 지수 ≤ 15
2 (낮음)	6 ≤ 가능성 지수 ≤ 10
1 (무시가능)	1 ≤ 가능성 지수 ≤ 5

- **영향도(Impact, I)**: 전통적인 CIA(기밀성, 무결성, 가용성) 모델에 해양 사이버-물리 시스템의 특성을 반영한 SOPF(Safety, Operation, Privacy, Financial) 요소를 추가하여 종합적으로 평가 (1-5 등급). 자율운항선박은 사고 발생 시 되돌릴 수 없는 물리적 피해를 유발할 수 있는 '고위험 자산'이므로, 가장 보수적인 접근 방식인 최대값(Maximum) 원칙을 적용

표 4-3 SOPF 등급별 정의 및 산정 기준

등급	Safety (S) 안전 및 환경	Operation (O) 운항 및 임무	Privacy (P) 프라이버시 및 데이터	Financial (F) 재무적 손실
5 (재앙적)	[심각한 인명/환경 사고] • 사망자 또는 다수의 중상자 발생 • 비가역적인 대규모 해양 오염 (예: 대형 기름 유출) • 선박 전손(Total Loss) 또는 구조적	[임무 실패 및 운항 불능] • 추진, 조타 등 핵심 제어 기능의 완전 상실 • 화재 진압 등 비상 대응 시스템 마비 • 무기한 운항 중단 및 항만 폐쇄 유발	[치명적 데이터 유출] • 대규모 민감 개인정보(생체정보, 의료기록 등) 유출 • 국가 안보 또는 기업 존립을 위협하는 기밀 유출 • 복구 불가능한	[파산 위기 수준의 손실] • 조직의 존립을 위협하는 재정적 타격 • 예상 손실액: \$1,000만 • 영업 허가 취소 수준의 규제 제재 및

사이버 리스크 평가 및 시나리오

	붕괴 임박		데이터 영구 삭제	영구적 평판 훼손
4 (치명적)	[중대한 인명/환경 사고] - 입원 치료가 필요한 중상자 발생 - 외부 전문 방제 작업이 필요한 심각한 환경 오염 - 자력 항해가 불가능한 수준의 선체 손상 (Dry-dock 필요)	[심각한 운항 차질] - 주 제어 시스템 상실로 비상 백업(Redundancy) 의존 24시간 이상의 운항 지연 발생 - 주요 화물의 손상 또는 인도 불능	[심각한 데이터 유출] - 다수의 일반 개인정보 또는 일부 민감 정보 유출 - 광범위한 랜섬웨어 감염으로 데이터 접근 불가 - GDPR 등 주요 법규 위반으로 인한 대규모 과징금 대상	[막대한 재무 손실] - 연간 수익에 중대한 영향을 미치는 손실 - 예상 손실액 \$100만 ~ \$1,000만 - 주요 고객 이탈 및 장기적인 브랜드 신뢰도 하락
3 (보통)	[제한적 인명/환경 사고] - 선내 치료 가능한 경상자 발생 - 선내 자원으로 방제 가능한 수준의 오염 - 감항성(Seaworthiness)은 유지되나 수리가 필요한 손상	[일시적 운항 차질] - 비핵심 시스템(보조기기 등)의 성능 저하 6시간 ~ 24시간 이내의 운항 지연 - 수동 개입으로 운항 유지 가능하나 효율성 저하	[제한적 데이터 유출] - 소규모의 일반 개인정보 유출 - 내부 업무 데이터의 외부 노출 (기밀 아님) - 규제 기관의 시정 조치 또는 경고 수준	[유의미한 재무 손실] - 운영 예산 내에서 처리가 부담스러운 수준 - 예상 손실액 \$10만 ~ \$100만 - 단기적인 부정적 언론 노출 및 계약 위반 페널티
2 (낮음)	[경미한 인명/환경 영향] - 응급처치 수준의 경미한 부상 - 무시할 만한 환경 영향 (소음, 경미한 폐기물) - 선체의 외관상 손상 (기능 영향 없음)	[경미한 운영 불편] - 선원 복지용 네트워크 등 IT 시스템 일시 중단 6시간 미만의 경미한 지연 - 업무 처리 속도 저하 등 불편 초래	[경미한 데이터 노출] - 공개된 정보 또는 비식별 데이터의 노출 - 즉시 차단 및 회수 가능한 수준 - 법적 제재 가능성 낮음	[경미한 재무 손실] - 유지보수 예산 등으로 처리 가능한 수준 - 예상 손실액 \$1만 ~ \$10만 - 대외적으로 알려지지 않음
1 (무시가능)	[영향 없음] - 인명 피해 없음 - 환경 영향 없음 - 물리적 손상 없음	[운항 영향 없음] - 시스템의 로그 기록상 오류 외 기능상 영향 없음 - 자동 복구(Fail-over)로 인한 무중단 처리	[침해 없음] - 데이터 유출 없거나 암호화된 데이터만 노출 - 보안 시스템에 의해 성공적으로 방어됨	[무시할 수준] - 금전적 손실이 거의 없음 - 예상 손실액 < \$1만 - 평판 영향 없음

사이버 리스크 평가 및 시나리오

- 위험도(Risk, RI): 가능성(L) × 영향도(I)로 계산하며, 아래의 리스크 매트릭스를 통해 처리 우선순위를 결정

영향도(I) \ 가능성(L)	1 (매우 낮음)	2 (낮음)	3 (보통)	4 (높음)	5 (매우 높음)
5 (매우 심각)	5 (중간)	10 (높음)	15 (높음)	20 (매우 높음)	25 (매우 높음)
4 (심각)	4 (낮음)	8 (중간)	12 (높음)	16 (높음)	20 (매우 높음)
3 (보통)	3 (낮음)	6 (중간)	9 (중간)	12 (높음)	15 (높음)
2 (경미)	2 (낮음)	4 (낮음)	6 (중간)	8 (중간)	10 (높음)
1 (매우 경미)	1 (낮음)	2 (낮음)	3 (낮음)	4 (낮음)	5 (중간)

그림 4-2 ▶ 리스크 매트릭스

사이버 리스크 평가 및 시나리오

4.2. 자율운항선박 리스크 평가

전체 리스크 평가 결과, 자율운항선박 생태계의 안전과 운영에 치명적인 영향을 미칠 수 있는 다수의 '높음' 및 '매우 높음' 등급의 리스크가 식별되었다. 아래 표는 그 중 가장 시급한 조치가 필요한 8개 리스크를 요약한 것이다. 이 요약표는 경영진과 의사결정권자가 제한된 자원을 어디에 우선적으로 집중해야 하는지에 대한 명확한 통찰을 제공한다.

특히 주목할 점은, 최상위 리스크가 선박과 육상 간의 '통신 채널'과 ROC의 '자율운항시스템'이라는 점이다. 이는 자율운항선박 생태계의 가장 핵심적인 연결고리가 동시에 가장 취약한 지점임을 보여준다. 또한, 공격 기법 측면에서는 제어 명령이나 센서 데이터를 조작하는 'Tampering'과 'Spoofing'이 압도적으로 높은 위험도를 나타내고 있어, 데이터 무결성 확보가 최우선 과제를 확인시켜 준다.

전체 MASS 대상 사이버 리스크 평가 결과, 8여 개의 주요 시나리오가 고려되었으며 이들에 대해 가능성(L)과 영향(I)을 평가한 위험도(R)를 산출했다. 위험도는 높음(High), 중간(Medium), 낮음(Low) 3단계로 분류하였다.

표 4-4 자율운항선박 주요 시스템의 사이버 리스크

순위	시스템 명	위협 시나리오 요약	위험도 (R)	리스크 등급
1	선·육상 통신 시스템	통신 채널 하이재킹을 통한 중간자(MITM) 공격으로 원격 제어 명령 변조	20	매우 높음
2	ROC 자율운항시스템	운영자 워크스테이션 침해를 통한 원격 제어권 탈취	20	매우 높음
3	Auto Berthing 시스템	센서 스푸핑/변조를 통한 접안 중 선박/항만 시설 충돌 유도	20	매우 높음
4	자율운항시스템	공급망 공격 및 센서 스푸핑을 통한 '유령 장애물' 충돌 유도	15	높음
5	에너지 관리 시스템	랜섬웨어 감염으로 인한 전면 정전(Blackout) 발생	15	높음
6	전기추진 시스템	인증 없는 OT 프로토콜을 이용한 추진 제어 명령 직접 주입 및 강제 선회	15	높음
7	CBM 시스템	센서 데이터 조작을 통한 엔진 고장 징후 은폐 및 대양 항해 중 운항 불능	12	높음
8	AR Navigation 시스템	소프트웨어 업데이트 공급망 공격을 통한 AR 오버레이 변조 및 좌초 유도	12	높음
9	AVM 시스템	영상 피드 조작을 통한 '유령 안벽' 생성 및 접안 중 충돌	12	높음

사이버 리스크 평가 및 시나리오

다음 절에서는 상위 리스크 중 핵심 시나리오를 선정하여, 공격 단계, 영향, 그리고 성숙도 수준별 권고 통제 방안을 심층적으로 분석한다.

4.2.1. 선박-육상 통신 시스템 (Ship-Shore Communication System)

4.2.1.1. 시스템 프로파일

위성통신(VSAT), 5G/LTE-M 등으로 구성된 이 시스템은 선박과 외부 세계(특히 ROC)를 연결하는 유일한 통로이다. 모든 원격 제어 명령과 모니터링 데이터가 이 채널을 통해 전송되므로, 통신 채널의 보안은 자율운항의 전제 조건이다.

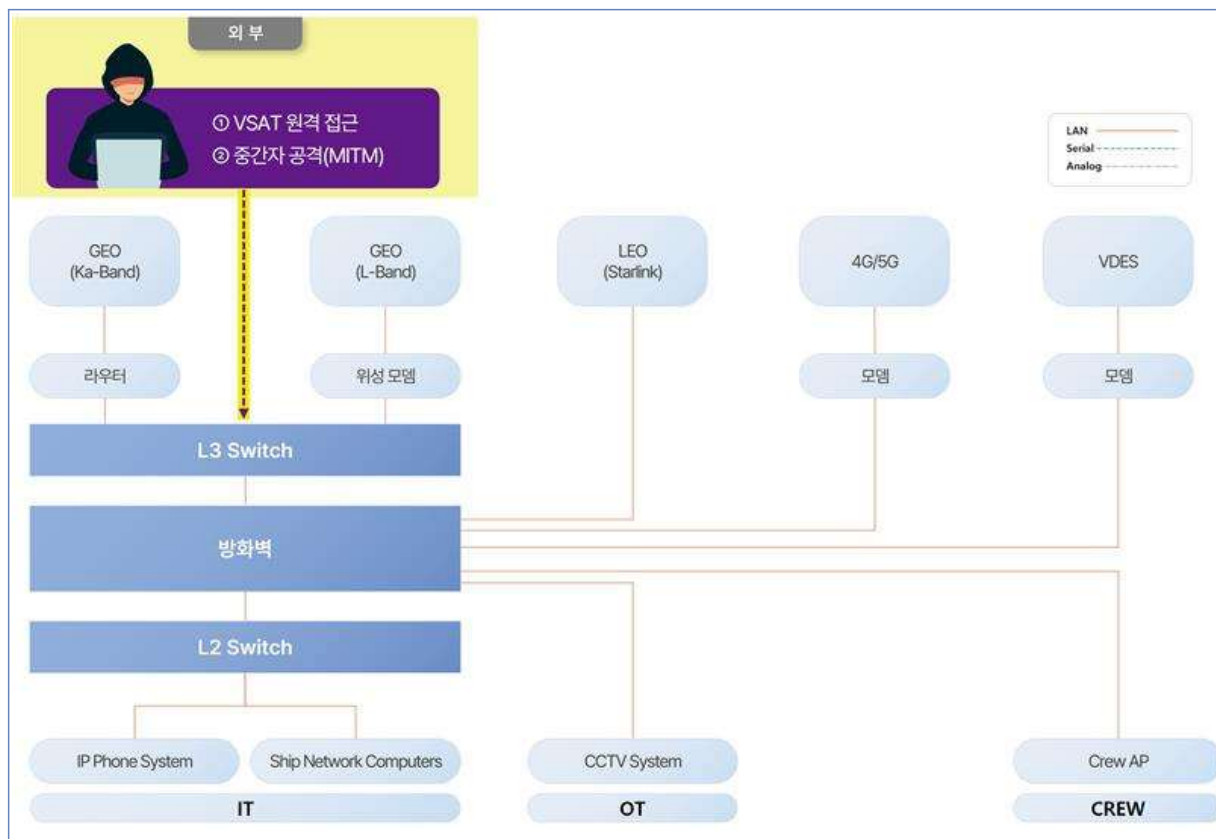


그림 4-3 ▶ 선박-육상 통신 시스템 사이버 위협 도식화

4.2.1.2. 위협 및 취약점 분석

- **변조(Tampering):** 통신 내용을 가로채 악의적으로 수정 후 재전송하는 중간자 공격 (Man-in-the-Middle).



사이버 리스크 평가 및 시나리오

- **정보 유출(Information Disclosure):** 암호화되지 않은 통신을 도청하여 운항 정보, 제어 명령 등 민감 정보 탈취.
- **서비스 거부(Denial of Service):** 통신 장비에 대한 공격으로 선박과 ROC 간의 연결을 완전히 두절시킴.
- **주요 취약점:** 약한 암호화 프로토콜 사용, 통신 장비의 관리자 인터페이스 노출 및 기본 패스워드 사용.

4.2.1.3. 상세 리스크 시나리오: "통신 채널 하이재킹을 통한 중간자(MITM) 공격"

공격 흐름: [외부 공격자] → [취약한 펌웨어 익스플로잇] → [통신 게이트웨이 장악] → [전송되는 제어 패킷 가로채기 및 변조(Manipulation)] → [선박 제어 시스템이 변조된 명령 수행] → [충돌 및 항로 이탈]

- **1단계 (침투):** [외부 공격자] 공격자가 인터넷에 노출된 위성 통신 장비(VSAT)의 관리자 인터페이스에 [취약한 펌웨어 익스플로잇] 알려진 취약점을 이용하여 원격으로 접근한다.
- **2단계 (중간자 위치 확보):** [통신 게이트웨이 장악] 공격자는 VSAT 장비 내에서 트래픽을 가로챌 수 있는 위치를 확보하고, ROC와 선박 간의 모든 통신을 감청하기 시작한다.
- **3단계 (악용):** [전송되는 제어 패킷 가로채기 및 변조(Manipulation)] ROC 운영자가 선박의 항로를 미세 조정하기 위해 '우현 5도 변침'이라는 원격 조타 명령을 전송한다. [선박 제어 시스템이 변조된 명령 수행] 공격자는 이 명령 패킷을 실시간으로 가로채, 조타각 값을 '좌현 20도 변침'으로 변조한 후 선박으로 재전송한다.
- **4단계 (영향):** [충돌 및 항로 이탈] 선박의 제어 시스템은 변조된 명령을 정상적인 명령으로 인식하고 즉시 좌현으로 급격히 선회한다. ROC 운영자는 명령이 정상적으로 전달되었다고 생각하지만, 선박은 완전히 다른 기동을 수행하여 주변 선박과의 충돌 위험을 야기하거나 항로를 이탈한다.

4.2.1.4. 리스크 분석

요소	등급 (1-5)	리스크 분석
가능성 (L)	4 (높음)	• 위성 통신 장비의 취약점은 지속적으로 보고되고 있으며, 인터넷에 직접 노출되어 있어 공격자의 주요 표적이 됨
영향도 (I)	5 (재앙적)	• S (안전): 5 - 선박 제어권의 실질적 상실로 충돌, 좌초 등 최악의 사고

사이버 리스크 평가 및 시나리오

		유발 • O (운항): 5 - 원격 제어 불능, 선박 통제 불능 • P (개인정보): 2 - 통신 내용 도청 가능 • F (재무): 5 - 사고로 인한 모든 재무적 손실
위험도 ($R = L \times I$)	20 (매우 높음)	• 리스크 매트릭스 상 '매우 높음' 등급으로, 최우선 완화 조치가 필수적임

4.2.1.5. 권고 통제 방안

🔗 Level 1 (규제 준수 - IACS UR E26/E27 준수)

- **기본 암호화 적용:** 선박과 육상 간의 모든 통신에 기본적인 VPN(가상사설망)을 적용하여 데이터를 암호화한다.
- **보안 패치 및 패스워드 관리:** 통신 장비 제조사에서 배포하는 최신 보안 패치를 정기적으로 적용하고, 모든 장비의 기본 패스워드를 복잡도가 높은 임의의 값으로 변경한다.

[경계 방어 구축]

- 기능: 공용 네트워크상에 암호화된 터널을 생성하고, 알려진 취약점(CVE)을 제거
- 효과: 공격의 1단계(진입) 난이도를 높여 초보자 수준의 공격을 차단
- 한계: 터널의 끝단(Endpoint)인 통신 장비 자체가 해킹되면 무용지물이 됨

🔗 Level 2 (구조화된 방어 - IEC 62443 기반)

- **강력한 종단간 암호화:** TLS 1.3 이상과 같이 현재 산업 표준에서 권고하는 강력한 암호화 프로토콜을 사용하는 VPN을 통해 종단간 암호화(End-to-End Encryption)를 의무화한다.
- **통신 장비 보안 강화(Hardening):** 통신 장비의 불필요한 서비스와 포트를 모두 비활성화하고, 관리자 인터페이스는 내부의 특정 관리자 PC에서만 접근할 수 있도록 엄격한 접근 통제 정책을 적용한다.
- **네트워크 분리:** 통신 장비가 위치한 DMZ 구역과 선내 OT 네트워크 간의 통신은 OT 전문 방화벽을 통해 엄격하게 통제하여, 통신 장비가 침해되더라도 위협이 내부망으로 확산되는 것을 차단한다.

[데이터 중심 방어]

- 기능: 통신 장비가 아닌 데이터(Payload) 자체를 암호화하고, 통신망과 선내망을 물리/논리적으로 격리
- 효과: 공격의 2단계(중간자 위치 확보)가 성공하더라도 데이터 내용을 볼 수 없게 하여 3단계(변조)를 원천 봉쇄
- 목표: 인프라의 신뢰도와 데이터의 신뢰도를 분리



사이버 리스크 평가 및 시나리오

◉ Level 3 (적응형 복원력 - 제로 트러스트 및 자동화)

- **다양성 (Diversity):** MITRE CREF의 '다양성' 원칙에 따라, 서로 다른 기술 방식(예: GEO 위성 + LEO 위성)과 다른 서비스 제공업체의 통신 채널을 이중화하여 구성한다. 이를 통해 특정 위성 시스템이나 제공업체에 장애 또는 보안 침해가 발생하더라도 다른 채널을 통해 통신을 유지할 수 있는 복원력을 확보한다.
- **비상 운항 계획(Contingency Plan):** 모든 통신 채널이 두절되는 최악의 상황에 대비하여, 선박이 외부의 명령 없이도 자율적으로 안전한 상태(Fail-safe mode, 예: 현재 위치 유지 또는 가장 가까운 안전 해역으로 저속 이동)를 유지하는 비상 운항 계획을 수립하고, 디지털 트윈 등을 활용하여 정기적으로 훈련한다.

[가용성 및 임무 보증]

- 기능: 위성 통신망(GEO/LEO)을 다중화하고, 통신 두절 시 선박이 스스로 안전 상태(Fail-safe)로 전환
- 효과: 공격의 4단계(물리적 영향)를 무력화. 해커가 통신을 끊거나 장악해도 선박은 탈취되지 않고 안전하게 정지하거나 회피
- 목표: "통신은 언제든지 끊길 수 있다"는 전제하에 감항성 확보

사이버 리스크 평가 및 시나리오

4.2.2. ROC 자율운항시스템

4.2.2.1. 시스템 프로파일

ROC 자율운항시스템은 자율운항 선단의 중앙 신경망이자 육상에 구현된 원격 선교(Remote Bridge)이다. 이 시스템의 주 기능은 시뮬레이션이 아닌, 안전과 직결된 실시간 명령 및 제어이다. ROC는 선원 없이 운항하는 선박에 대한 주된 제어 및 감독 주체가 되는 RS-3 (Remote-Supervised) 수준에서 운영되며, 운항의 패러다임을 선원이 직접 개입하는 'human-in-the-loop'에서 원격으로 감독하는 'human-on-the-loop'로 전환시키는 핵심 기반 시설이다.

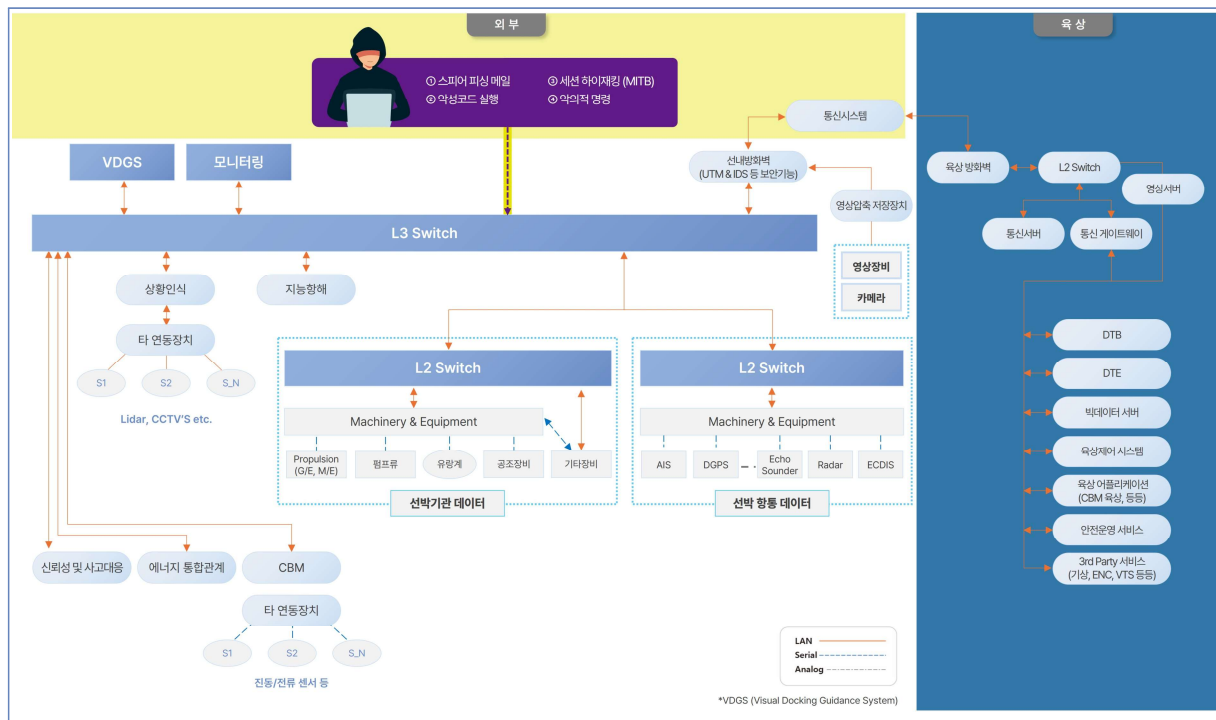


그림 4-4 ▶ ROC 자율운항시스템 사이버 위협 도식화

4.2.2.2. 위협 및 취약점 분석

- **신원 위장(Spoofing)**: 공격자가 피싱 등을 통해 탈취한 운영자의 자격증명으로 ROC 플랫폼에 로그인 하여, 합법적인 권한으로 선박을 제어함.
- **데이터 변조 (Tampering)**: 공격자는 전송 중인 합법적인 명령을 수정하거나, 더 정교하게는 운영자 워크스테이션의 악성코드를 통해 명령이 전송되기 전에 내용을 변조함.
- **서비스 거부 (Denial of Service)**: ROC의 외부 네트워크 인터페이스에 대한 DDoS 공격이나 내부 서버에 대한 랜섬웨어 공격은 원격 제어를 불가능하게 만들.



사이버 리스크 평가 및 시나리오

- **주요 취약점:** 시스템 사칭, 수신 데이터 조작, 취약한 DDoS 방어체계.

4.2.2.3. 상세 리스크 시나리오: "운영자 워크스테이션 침해를 통한 원격 제어권 탈취"

공격 흐름: [피싱 메일 발송] → [운영자 PC 악성코드 감염] → [정상 세션 하이재킹 또는 계정 도용] → [충돌 유발 항로 입력] → [선박 충돌]

- **1단계 (침투):** [피싱 메일 발송] ROC 운영자는 내부 IT 부서의 경고나 항만 당국의 공지사항으로 위장한 정교한 스피어피싱 이메일을 수신한다. [운영자 PC 악성코드 감염] 이메일에 포함된 링크나 첨부파일을 열면, 운영자의 워크스테이션에 고도의 악성코드가 은밀하게 설치된다.
- **2단계 (잠복 및 세션 감시):** [정상 세션 하이재킹 또는 계정 도용] 악성코드는 전통적인 백신 프로그램의 탐지를 회피하도록 설계되어 즉시 활동하지 않는다. 대신, 운영자의 활동을 감시하며 그가 ROC의 웹 기반 제어 플랫폼에 로그인하여 완전히 인증된 세션을 수립하기를 기다린다.
- **3단계 (세션 하이재킹 및 명령어 변조):** [충돌 유발 항로 입력] 선박이 혼잡한 항로를 향해 중이다. ROC 운영자는 안전을 위해 약간의 항로 수정을 결정하고, 제어 인터페이스에 '좌현 5도 변침' 명령을 입력한다. 운영자가 '실행' 버튼을 클릭하는 순간, 'Man-in-the-Browser'로 동작하는 악성코드가 브라우저 프로세스 내에서 이 명령을 가로챈다. 악성코드는 운영자의 안전한 명령을 즉시 폐기하고, 사전에 프로그램된 악의적인 명령, 즉 '우현 30도 변침, 전속 전진'을 인증된 세션의 데이터 스트림에 주입한다.
- **4단계 (영향):** [선박 충돌] ROC 플랫폼은 이 악의적인 명령을 수신한다. 이 명령은 신뢰할 수 있는 운영자의 IP 주소에서 유효하고 인증된 세션을 통해 발생했기 때문에, 모든 보안 검사를 통과한다. 명령은 선박으로 중계되고, 자율운항선박은 수신된 명령에 따라 다가오는 선박들의 경로로 전속력으로 급선회하여 치명적인 충돌을 일으킨다. ROC의 감사 로그에는 해당 명령이 운영자에 의해 합법적으로 내려진 것으로 기록되어, 즉각적인 사고 원인 분석을 어렵게 만들고 운영자에게 부당한 책임을 지운다.

4.2.2.4. 리스크 분석

요소	등급 (1-5)	리스크 분석
가능성 (L)	4 (높음)	• 피싱 및 엔드포인트 침해는 기업 환경에 대한 가장 일반적이고 성공률 높은 공격 벡터임. Man-in-the-Browser 악성코드는 다크웹에서 쉽게 구할 수 있으며, 이 공격은 네트워크 수준의 방어를 우회하므로 ROC와 같은 고가치 표적에 대해 발생 가능성이 매우 높음



사이버 리스크 평가 및 시나리오

영향도 (I)	5 (재앙적)	• S (안전): 5 - 선박 제어권의 직접적인 상실로 충돌, 좌초, 인명 손실, 심각한 환경 재앙 유발 • (운항): 5 - 선박이 통제 불능의 물리적 자산이 되며, 사고 조사 기간 동안 전체 선단 운항 중단 가능 • P (개인정보): 2 - 공격 과정에서 일부 운항 데이터 노출 가능 • F (재무): 5 - 선박 및 화물의 전손 가능성, 충돌로 인한 무한 책임, 막대한 벌금, 회복 불가능한 평판 손상
위험도 ($R = L \times I$)	20 (매우 높음)	• 리스크 매트릭스에 따라, 20점은 '매우 높음' 등급에 해당함. 이 리스크는 근본적으로 수용 불가능하며, 다계층 완화 통제의 최우선 적용이 요구됨

4.2.2.5. 권고 통제 방안

🔗 Level 1 (규제 준수 - IACS UR E26/E27 준수)

- **보안 인식 교육:** 모든 ROC 운영자를 대상으로 스피어피싱 식별 및 사회 공학적 전술 이해에 초점을 맞춘 의무적이고 반복적인 교육 프로그램을 시행한다. 이는 6.7절에서 설명된 교육의 필요성과 일치한다.
- **접근 통제 정책:** 최소 권한 원칙을 강제한다. 운영자는 자신의 직무 수행에 반드시 필요한 권한만을 가져야 한다.
- **패스워드 관리:** 모든 ROC 플랫폼 계정에 대해 강력한 패스워드 정책(복잡도, 이력, 길이)을 구현하고 강제한다.

[인적 보안 강화]

- 기능: 운영자가 피싱 이메일을 식별하게 하고, 계정 유출 시 피해 범위를 제한
- 효과: 공격의 1단계(침투)인 사회공학적 기법의 성공률을 낮춤
- 한계: 인간의 실수(Human Error)를 완벽히 막을 수 없으므로 잔여 리스크가 큼

🔗 Level 2 (구조화된 방어 - IEC 62443 기반)

- **다중 인증 (MFA):** ROC 제어 플랫폼에 대한 모든 접근에 MFA 사용을 의무화한다. 정교한 Man-in-the-Browser 공격을 완벽히 막을 수는 없지만, 단순한 자격증명 도용 공격을 방지한다.
- **엔드포인트 탐지 및 대응 (EDR):** 모든 운영자 워크스테이션에 EDR 솔루션을 배포한다. EDR은 전통적인 백신과 달리, 프로세스 주입이나 비정상적인 네트워크 연결과 같은 고도화된 악성코드의 행위 자체를 탐지할 수 있어 엔드포인트에 결정적인 방어 계층을 제공한다.
- **중앙 집중 로깅 및 SIEM:** 5.3.2절의 Level 2 ROC 운영 방안에 따라 워크스테이션, 애플리케이션,



사이버 리스크 평가 및 시나리오

네트워크 로그를 SIEM으로 통합한다. 비정상적인 시간대의 명령이나 이례적인 명령 순서와 같은 변칙 행위를 탐지하기 위한 규칙을 개발한다.

[엔드포인트 방어]

- 기능: 계정 탈취를 어렵게 만들고(MFA), 악성코드의 실행 행위를 탐지(EDR)
- 효과: 공격의 2단계(잠복/세션 감시) 및 3단계(세션 하이재킹)를 기술적으로 차단. 특히 Man-in-the-Browser 공격 탐지에 효과적임
- 목표: "사용자 계정은 언제든지 탈취될 수 있다"는 전제로 Endpoint 방어 수행

Level 3 (적응형 복원력 - 제로 트러스트 및 자동화)

- **제로 트러스트 아키텍처 (ZTA):** 5.1절에서 언급된 바와 같이, ROC 네트워크 내에 ZTA 원칙을 구현한다. 이는 네트워크 내부에서 발생하는 모든 요청조차도 인증하고 권한을 부여함을 의미하며, 악성코드가 C2 서버와 통신하는 것을 방지하기 위한 마이크로 세분화를 포함할 수 있다.
- **사용자 및 개체 행위 분석 (UEBA):** SIEM과 UEBA 플랫폼을 통합한다. UEBA는 정상적인 운영자 행위(예: 일반적인 명령 유형, 실행 속도, 시간대)의 기준선을 설정하고, 기술적으로는 유효해 보이는 명령이라도 이 기준선에서 벗어나는 편차를 탐지하여 계정 또는 세션 침해 가능성을 경고할 수 있다.
- **절차적 통제 - 중요 명령에 대한 이중 승인:** 이는 궁극적인 안전장치이다. 특정 각도 이상의 항로 변경, 제한 구역 진입, 특정 임계값 이상의 엔진 속도 변경과 같은 고위험 명령에 대해서는, 시스템이 해당 명령을 선박으로 전송하기 전에 다른 별도의 승인권자가 검토하고 승인하도록 요구해야 한다. 이 통제는 단일 워크스테이션 침해를 무력화할 수 있는 결정적인 인간 개입(human-in-the-loop) 검증 절차를 제공한다.

[내부 위협 무력화]

- 기능: 모든 내부 행위를 검증하고(ZTA), 정상 범주를 벗어난 명령 패턴을 AI로 탐지(UEBA)하며, 치명적 명령은 2인 승인을 강제
- 효과: 공격자가 합법적 권한을 획득해도 3단계(악성 명령 실행)를 수행 차단
- 목표: 시스템은 "신뢰할 수 있는 내부자"를 믿지 않고 "행위의 문맥"을 검증 (Zero Trust)

사이버 리스크 평가 및 시나리오

4.2.3. Auto Berthing 시스템

4.2.3.1. 시스템 프로파일

자동 접·이안(Auto Berthing) 시스템은 자율운항의 마지막이자 가장 정밀한 제어가 요구되는 단계를 책임지는 핵심 시스템이다. LIDAR, 고정밀 GPS(DGPS) 등 첨단 센서로부터 수집된 데이터를 실시간으로 분석하여, 선박과 부두 간의 거리, 각도, 접근 속도를 센티미터 단위로 계산하고, 이를 바탕으로 Thruster 등 추진제어시스템을 직접 제어하여 선박을 지정된 위치에 안전하게 접안시킨다.

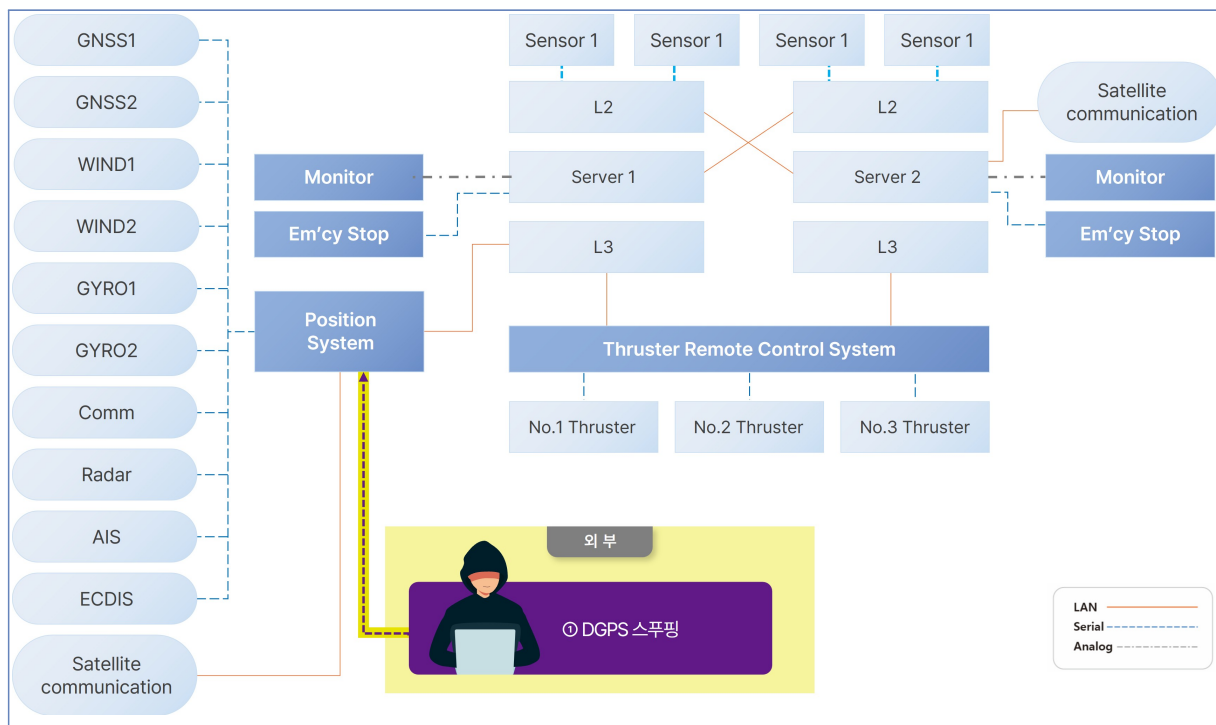


그림 4-5 ▶ Auto Berthing 시스템 도식화

4.2.3.2. 위협 및 취약점 분석

- **변조(Tampering)**: 공격의 핵심 형태로, LIDAR와 같은 거리 측정 센서값을 미세하게 조작하여 시스템의 감속 판단을 지연시켜 부두와의 '충돌'을 유발.
- **신원 위장(Spoofing)**: 저가의 장비로도 구현 가능한 허위 DGPS 신호를 송신하여 선박의 절대 위치를 오인.
- **서비스 거부(Denial of Service)**: 핵심 센서 데이터나 제어 명령의 전송을 방해하여 시스템을 비상 정지 상태로 초래.



사이버 리스크 평가 및 시나리오

- **주요 취약점:** 센서 입력값 상호 검증 부재, 비상/안전 모드 부재.

4.2.3.3. 상세 리스크 시나리오: "센서 데이터 조작을 통한 접안 중 충돌 유도"

공격 흐름: [항만 내 물리적 공격자] → [선박 센서가 허위 신호를 정상으로 인식] → [자동접안 알고리즘의 거리 계산 오류] → [부두 충돌]

- **1단계 (침투 및 준비):** [항만 내 물리적 공격자] 공격자는 항만 근처의 고지대에서 저가의 소프트웨어 정의 라디오(SDR) 장비를 이용하여 해당 지역의 DGPS 보정 신호를 재밍하고, 미세하게 조작된 자체 보정 신호를 송출한다.
- **2단계 (오인):** [선박 센서가 허위 신호를 정상으로 인식] 접안을 위해 항만에 접근하는 자율운항선박의 Auto Berthing 시스템은 이 조작된 DGPS 보정 신호를 수신한다. 실제 선박의 위치보다 부두에서 1.5미터 더 멀리 떨어져 있는 것으로 인식하게 된다.
- **3단계 (악용):** [자동접안 알고리즘의 거리 계산 오류] 시스템은 자신이 인지하는 위치에서 부두와 안전거리(예: 0.5미터)를 유지하기 위해 정확한 Thruster 명령을 계산하고 실행한다. 시스템의 제어 로직은 최종 접근 단계에서 절대 위치 결정을 위해 DGPS 데이터를 우선하도록 설계되어 있어 LIDAR의 경고를 무시하거나 낮은 가중치로 처리한다.
- **4단계 (영향):** [부두 충돌] 선박은 저속이지만 수만 톤의 운동 에너지를 가진 채 콘크리트 부두와 그대로 충돌한다. 사고 후 시스템 로그 분석에는 단지 '가용한 데이터에 기반하여 접안 절차를 성공적으로 수행했다'고 기록되어 있어, 초기 사고 원인 규명이 어렵게 된다.

4.2.3.4. 리스크 분석

요소	등급 (1-5)	리스크 분석
가능성 (L)	4 (높음)	• DGPS/GNSS 스푸핑 기술은 공격을 위해서는 물리적 근접성이 필요하지만, 널리 알려져 있는 공격 기술로 기술적 장벽은 낮음
영향도 (I)	5 (재앙적)	• S (안전): 5 - 선체 및 항만 시설의 직접적인 물리적 파손, 부두 작업자의 인명 피해 가능성, 그리고 연료 유출과 같은 2차 환경 재해의 위험이 존재 • O (운항): 5 - 즉각적인 접안 작업 중단, 사고 조사 및 수리를 위한 해당 선박의 장기 폐쇄, 선박의 운항 불가 상태 초래 • P (개인정보): 1 - 개인정보 유출은 없음 • F (재무): 5 - 선박 및 항만 시설 수리에 따르는 막대한 직접 비용,



사이버 리스크 평가 및 시나리오

		운항 중단으로 인한 영업 손실, 보험료 급등, 평판 손상이 발생
위험도 (R = L × I)	20 (매우 높음)	리스크 매트릭스 상 '매우 높음' 등급으로, 최우선 완화 조치가 필수적임

4.2.3.5. 권고 통제 방안

🔗 Level 1 (규제 준수 - IACS UR E26/E27 준수)

- **기본 센서 유효성 검증**: 수신된 센서 데이터가 물리적으로 가능한 범위(예: DGPS 좌표가 해수면 위)에 있는지, 신호가 유실되지는 않았는지 등 기본적인 유효성을 검사하는 로직을 구현한다.
- **시스템 강화(Hardening)**: Auto Berthing 제어 시스템의 운영체제에서 불필요한 서비스와 포트를 모두 비활성화하고, 모든 기본 패스워드를 변경하는 등 IACS UR E27의 요구사항을 준수한다.
- **네트워크 분리**: 접안 관련 센서와 Thruster 제어기를 연결하는 네트워크 세그먼트를 선내 일반 IT망과 엄격히 분리하여 IACS UR E26의 요구사항을 준수한다.

[기초적 오류 필터링]

- 기능: 센서 데이터가 물리적 한계(Range)를 벗어나는지 검사하고, 외부망 접속을 차단
- 효과: 공격의 2단계(오인) 중 조악한 데이터 주입이나 단순 시스템 해킹을 방지
- 한계: 정상 범위 내에서 정교하게 조작된 스푸핑 데이터(In-band Attack)는 걸러내지 못함

🔗 Level 2 (구조화된 방어 - IEC 62443 기반)

- **다중 센서 데이터 교차 검증 로직 구현**: DGPS의 절대 위치 정보와 LIDAR/RADAR의 상대 거리 측정값을 실시간으로 상호 비교하는 센서 퓨전 엔진을 구현해야 한다. 두 데이터 소스 간의 불일치가 임계값을 초과할 경우, 시스템은 즉시 무결성 경보를 발생시켜야 한다.
- **통신 무결성 확보(HMAC)**: 센서 퓨전 엔진에서 Thruster 제어기로 전달되는 최종 명령 패킷에 HMAC(Hash-based Message Authentication Code)과 같은 암호학적 무결성 검증 메커니즘을 적용하여, OT 네트워크 내부에서의 데이터 변조 공격을 탐지한다.
- **보안 구역화(Zone & Conduit) 모델 적용**: Auto Berthing 시스템을 구역으로 들어오고 나가는 모든 데이터 흐름은 반드시 OT 전문 방화벽(Conduit)을 통과하도록 강제한다.



사이버 리스크 평가 및 시나리오

[데이터 신뢰성 검증]

- 기능: DGPS와 LiDAR의 거리 값이 일치하는지 비교(Fusion)하고, 데이터 전송 구간의 변조를 암호학적으로 확인한다.
- 효과: 공격의 2단계(변조)에서 단일 센서만 속이는 공격을 탐지하고 차단한다.
- 목표: "하나의 센서는 거짓말을 할 수 있지만, 서로 다른 센서가 동시에 같은 거짓말을 하기는 어렵다"는 다중성 원칙을 활용한다.

🔗 Level 3 (적응형 복원력 - 제로 트러스트 및 자동화)

- **자동화된 장애 극복 로직(Fail-Safe Abort):** 센서 퓨전 엔진이 지속적이고 해결 불가능한 데이터 충돌을 감지할 경우, 시스템은 인간의 개입 없이도 자동으로 접안 절차를 안전하게 중단하도록 설계되어야 한다. 이 'Fail-Safe' 상태는 현재 위치를 유지(Hold Position)하고, ROC 운영자에게 센서 데이터 충돌에 대한 명확한 경보와 함께 제어권을 즉시 이양하는 것을 포함해야 한다.
- **암호화/인증 GNSS 도입:** Galileo OSNMA와 같이 위성 신호 자체에 암호학적 인증 기능이 포함된 차세대 GNSS 수신기를 도입하여, 스푸핑 공격 자체를 원천적으로 방어한다.
- **물리 모델(Digital Twin) 기반 이상 탐지:** 선박과 부두의 고정밀 디지털 트윈을 활용하여, 시스템이 센서 데이터를 물리 법칙 기반의 시뮬레이션 예측값과 실시간으로 비교하도록 한다. 만약 실제 센서 값이 물리적으로 불가능한 움직임(예: 순간 이동)을 나타낼 경우, 모든 센서가 동일한 거짓 값을 보고하더라도 이를 이상 징후로 탐지해야 한다.

[물리적 법칙 기반 방어]

- 기능: 물리 법칙에 위배되는 거동을 탐지하고, 이상 징후 시 즉시 접안을 중단(Abort)
- 효과: 공격의 3단계(악용)가 발생해도 4단계(충돌)로 이어지지 않게 물리적 안전을 강제.
- 목표: 데이터보다 물리 법칙(Physics)을 상위의 진실로 간주

사이버 리스크 평가 및 시나리오

4.2.4 자율운항시스템 (Autonomous Navigation System)

4.2.4.1 시스템 프로파일

자율운항시스템은 선박의 '두뇌'로서, 각종 센서 데이터를 융합하여 주변 상황을 인지하고, 국제해상 충돌예방규칙(COLREGs)을 준수하며 충돌 회피 및 항로 유지를 위한 의사결정을 실시간으로 수행한다. 선박의 제어 시스템 구역(Control System Zone)에 위치하며, 이 시스템의 기능 손상은 곧 선박의 제어권 상실을 의미한다.

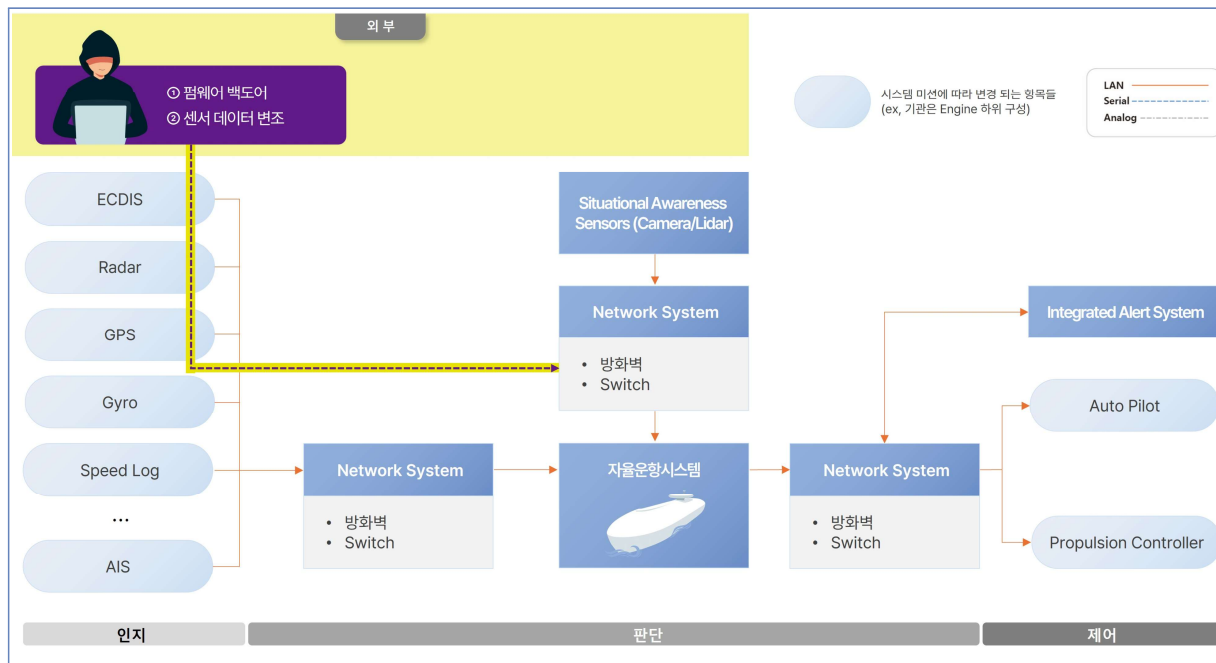


그림 4-6 ▶ 자율운항시스템 사이버 위협 도식화

4.2.4.2 위협 및 취약점 분석

- **신원 위장(Spoofing):** 허위 GNSS 또는 AIS 신호를 주입하여 시스템의 위치 및 상황 인식을 교란.
- **변조(Tampering):** 제어 알고리즘 파라미터 또는 센서 입력값을 악의적으로 수정하여 오작동 유발.
- **서비스 거부(Denial of Service):** 시스템의 연산 장치에 과부하를 일으켜 정상적인 의사결정 프로세스를 마비시킴.
- **주요 취약점:** 센서 데이터에 대한 상호 유효성 검증 로직 부재, 원격 명령 채널에 대한 인증 취약, 패치되지 않은 운영체제 사용.

사이버 리스크 평가 및 시나리오

4.2.4.3 상세 리스크 시나리오: "공급망 공격 및 센서 스푸핑을 통한 '유령 장애물' 충돌 유도"

공격 흐름: [공급사 서버 해킹] → [펌웨어 백도어 삽입] → [허위 장애물 생성] → [급격한 회피 기동] → [충돌 위험 발생]

- **1단계 (침투):** [공급사 서버 해킹] 공격자는 3차 센서 시스템(예: LIDAR 장치) 공급업체를 사전에 침해하여, [펌웨어 백도어 삽입] 납품 전 펌웨어에 백도어를 심는 공급망 공격을 감행한다.
- **2단계 (활성화 및 오인):** [허위 장애물 생성] 백도어가 원격으로 활성화된다. 백도어는 LIDAR 데이터 스트림을 미세하게 조작하여 선박의 경로 바로 앞에 정체불명의 작은 물체가 있는 것처럼 허위 데이터를 주입하기 시작한다. 동시에 공격자는 저출력 SDR 장비를 이용해 동일 위치에 존재하지 않는 소형 선박의 AIS 신호를 스푸핑하여, 허위이지만 신빙성 있는 증거를 만들어낸다.
- **3단계 (악용):** [급격한 회피 기동] 자율운항시스템의 센서 융합 알고리즘은 상충되지만 유효해 보이는 데이터를 수신한다: RADAR는 경로가 깨끗하다고 보고하지만, LIDAR와 AIS는 장애물을 지시한다. 모든 것보다 충돌 회피를 우선하도록 설계된 시스템 로직(fail-safe 원칙)은 이 위험이 신뢰할 만하다고 판단하고 긴급 회피 기동을 실행한다.
- **4단계 (영향):** [충돌 위험 발생] 혼잡한 항로에서 발생한 갑작스럽고 급격한 항로 변경은 COLREGs를 위반하며, 충돌 경로에 있지 않던 주변의 정상 선박과의 아차사고 또는 실제 충돌을 야기한다. 이 공격은 핵심 항해 시스템의 코드를 직접 침해하지 않고도 물리적 재앙을 초래한다.

4.2.4.4 리스크 분석

요소	등급 (1-5)	리스크 분석
가능성 (L)	3 (보통)	• 공급망 공격은 고도화되었으나 점차 보편화되고 있음. 상대적으로 덜 중요한 센서를 표적으로 삼아 공격 성공 가능성을 높임
영향도 (I)	5 (재앙적)	• S (안전): 5 - 직접적인 충돌, 인명 손실, 환경 재앙 위험 • O (운항): 5 - 선박 운항 불능, 항로 폐쇄, 막대한 운항 중단 • P (개인정보): 1 - 중대한 데이터 유출 없음 • F (재무): 5 - 선박 손상, 화물 손실, 벌금, 보험료, 평판 손상
위험도 ($R = L \times I$)	15 (높음)	• 본 문서의 리스크 매트릭스에 따라 15점은 '높음' 등급으로 분류 됨. 즉각적이고 강력한 완화 조치가 요구됨



사이버 리스크 평가 및 시나리오

4.2.4.5. 성숙도 수준별 권고 통제 방안

- **Level 1 (규제 준수 - IACS UR E26/E27 준수):** 납품되는 장비 목록을 관리하고, 기본적인 센서 오류(예: 신호 없음)를 탐지하는 기능을 구현한다.

[가시성 확보]

- 기능: 어떤 SW/HW가 설치되어 있는지 파악하고, 센서의 작동 불능 상태 확인
- 효과: 관리되지 않는 불법 SW 설치를 막고, 기본적인 고장 식별
- 한계: 정상적인 업데이트 경로를 타고 들어오는 악성코드(Trojan)에는 무력

- **Level 2 (구조화된 방어 - IEC 62443 기반):** RADAR, LIDAR, AIS 등 서로 다른 유형의 센서 데이터를 상호 비교하여 불일치를 탐지하는 교차 검증 로직을 구현한다. 모든 펌웨어 업데이트 파일의 무결성을 해시값으로 확인한다.

[파일 변조 탐지]

- 기능: 배포된 파일이 원본과 동일한지 해시값으로 검증하고, 센서 간 불일치를 확인
- 효과: 공격의 1단계(침투) 중 전송 구간에서의 파일 변조(MITM)를 차단
- 목표: 신뢰할 수 있는 원본(Source)과의 무결성 검증

- **Level 3 (적응형 복원력 - 제로 트러스트 및 자동화):** 모든 장비 공급업체에 대해 소프트웨어 자재명세서(SBOM) 제출을 의무화하고, 계약서에 제3자 코드 감사 권한을 포함하는 등 엄격한 공급망 리스크 관리(C-SCRM) 프로그램을 운영한다. 모든 펌웨어 업데이트에 암호학적 서명을 적용하여 변조를 원천 방지한다. AI 기반의 이상 탐지 알고리즘을 도입하여 정상적인 센서 데이터 패턴에서 벗어나는 미세한 변칙을 탐지한다.

[공급망 투명성 및 신뢰]

- 기능: SW 구성요소(SBOM)를 투명하게 관리하고, 제조사의 전자서명이 없는 코드는 실행을 원천 차단
- 효과: 공격의 1단계(침투)인 공급망 오염 자체를 식별하고, 2단계(오인)인 AI 오작동을 행위 기반으로 탐지
- 목표: 출처가 확인되지 않은 코드는 실행하지 않음 (Zero Trust Execution)

사이버 리스크 평가 및 시나리오

4.2.5 에너지 관리 시스템 (Energy Management System, EMS)

4.2.5.1 시스템 프로파일

에너지 관리 시스템(EMS)은 선박의 심장과도 같으며, 발전기, 배전반, 추진 시스템을 포함한 모든 동력 계통을 제어한다. 이 시스템의 기능 마비는 선박의 추진력과 전력을 완전히 상실하는 '전면 정전(Blackout)' 상태로 이어져, 항해 중인 선박을 거대한 통제 불능의 쇄빙어리로 만들 수 있다.

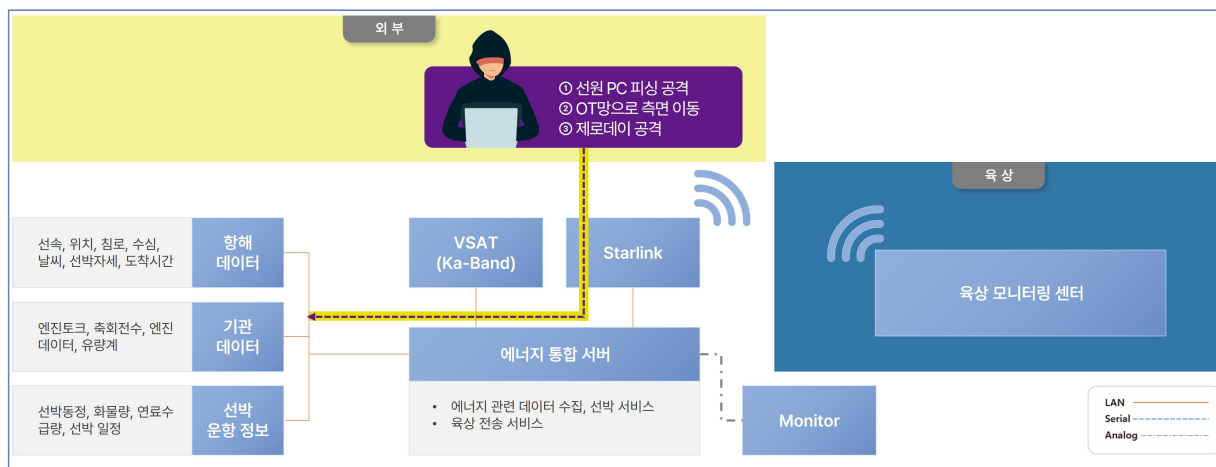


그림 4-7 ▶ 에너지 관리 시스템(EMS) 사이버 위협 도식화

4.2.5.2. 위협 및 취약점 분석

- **서비스 거부(Denial of Service):** 랜섬웨어 감염 또는 악성 트래픽을 통한 시스템 마비.
- **변조(Tampering):** 연료 소모량 데이터 또는 발전기 제어 로직을 조작하여 운항 비효율 또는 기기 손상 유발.
- **주요 취약점:** IT망과 OT망 간의 불충분한 분리, 패치되지 않은 레거시 운영체제 사용, OT 프로토콜에 대한 인증 부재.

4.2.5.3 상세 리스크 시나리오: "랜섬웨어 감염으로 인한 전면 정전(Blackout) 발생"

공격 흐름: [선원 PC 피싱 공격] → [OT망 침투] → [랜섬웨어 실행] → [블랙아웃(전면 정전)]

- **1단계 (침투):** [선원 PC 피싱 공격] 공격자는 선원 복지용 IT 네트워크에 연결된 PC를 피싱 공격으로 감염시킨다.

사이버 리스크 평가 및 시나리오

- **2단계 (측면 이동): [OT망 침투]** IT망과 OT망 사이의 미흡한 방화벽 설정을 악용하여, 공격자는 OT망으로 측면 이동(Lateral Movement)에 성공하고, 패치되지 않은 취약점을 이용해 EMS 서버의 관리자 권한을 획득한다.
- **3단계 (악용): [랜섬웨어 실행]** 공격자는 EMS 서버와 연결된 제어기(PLC)에 랜섬웨어를 실행한다. 암호화된 시스템은 제어 불능 상태가 되어 발전기 및 배전반 제어에 실패한다.
- **4단계 (영향): [블랙아웃(전면 정전)]** 좁은 수로를 향해 중이던 선박의 추진력과 전력이 완전히 상실되는 '전면 정전(Blackout)'이 발생한다. 조타 및 비상 시스템마저 작동 불능 상태에 빠져, 선박은 좌초하거나 다른 선박과 충돌하는 심각한 안전사고에 직면한다.

4.2.5.4 리스크 분석

요소	등급 (1-5)	리스크 분석
가능성 (L)	3 (보통)	• IT망을 통한 OT망 침투는 해킹의 전형적인 경로이며, OT 시스템의 취약점은 널리 알려져 있음
영향도 (I)	5 (재앙적)	• S (안전): 5 - 좌초, 충돌 등 직접적인 대형 인명/환경 사고 유발 • O (운항): 5 - 선박 완전 운항 불능, 구조 및 수리에 막대한 시간 소요 • P (개인정보): 1 - 중대한 데이터 유출 없음 • F (재무): 5 - 선체 및 화물 전손, 막대한 배상금 및 벌금 발생
위험도 (R = L x I)	15 (높음)	• 본 문서의 리스크 매트릭스에 따라 15점은 '높음' 등급으로 분류됨. 즉각적이고 강력한 완화 조치가 요구됨

4.2.5.5 권고 통제 방안

🔗 Level 1 (규제 준수 - IACS UR E26/E27 준수)

- **네트워크 분리:** IACS UR E26의 요구사항에 따라 선원용 IT 네트워크와 제어용 OT 네트워크 간의 경계에 방화벽을 설치하고, 허가된 트래픽 외 모든 통신을 차단하여 기본적인 분리를 구현한다.
- **악성코드 방어:** Windows 기반의 EMS HMI 및 서버에 OT 환경에 최적화된 백신 프로그램을 설치하고, 최신 패턴으로 지속적으로 업데이트한다.
- **백업 및 복구:** EMS 시스템의 소프트웨어, 설정 파일, 데이터를 주기적으로 백업하고, 재해 발생 시 신속하게 복원할 수 있는지 정기적으로 검증하는 절차를 수립한다.



사이버 리스크 평가 및 시나리오

[확산 방지 및 복구]

- 기능: IT망의 감염이 OT망으로 넘어오는 것을 방화벽으로 막고, 감염 시 백업본으로 복구
- 효과: 공격의 2단계(측면 이동)를 어렵게 하고 4단계(영향)의 지속 시간을 단축
- 한계: 제로데이 랜섬웨어나 내부에서 시작된 감염은 막기 어려움

Level 2 (구조화된 방어 - IEC 62443 기반)

- **보안 구역화 모델 적용:** IEC 62443의 '보안 구역(Zone)' 및 '통로(Conduit)' 모델에 따라 네트워크 아키텍처를 재설계한다. EMS는 제어 시스템 구역(Control System Zone)에 배치하고, 모든 통신은 OT 전문 방화벽(통로)을 통해서만 이루어지도록 하며, 'Deny-by-Default' 정책을 엄격히 적용한다. 이는 IEC 62443-3-3의 SR 5.1 및 SR 5.2 요구사항을 직접적으로 이행하는 것이다.
- **지속적 모니터링:** 제어 시스템 구역 내부에 OT 트래픽을 심층적으로 분석할 수 있는 침입 탐지 시스템(IDS)을 구축하여, 비정상적인 제어 명령이나 악성코드의 내부 확산 징후를 실시간으로 탐지하고 경보를 발생시킨다. 이는 IEC 62443-3-3 SR 6.2 요구사항에 해당한다.
- **애플리케이션 화이트리스트:** 백신 설치가 어려운 임베디드 제어기나 HMI에는 사전에 허가된 실행 파일 외에는 모든 실행을 원천적으로 차단하는 화이트리스트 기술을 적용하여 랜섬웨어와 같은 악성코드의 실행을 방지한다.

[실행 통제]

- 기능: 허가된 프로그램 외에는 실행 자체를 차단(Whitelisting)하고, 내부 확산 감시
- 효과: 공격의 3단계(악용)인 랜섬웨어 실행 자체를 기술적으로 불가능함
- 목표: 화이트리스트(소프트웨어, 프로세스)만 허용하고 나머지는 모두 차단(Default Deny)

Level 3 (적응형 복원력 - 제로 트러스트 및 자동화)

- **다양성 (Diversity):** 핵심 이중화 제어기(예: PMS PLC)를 서로 다른 제조사의 제품으로 구성하여, 특정 제조사 제품의 제로데이 취약점이 발견되더라도 이중화 시스템 전체가 동시에 마비되는 것을 방지한다.
- **조정된 방어 (Coordinated Defense):** OT IDS(Level 2 통제)를 방화벽, 그리고 ROC의 SOAR 플랫폼과 연동한다. IDS가 EMS를 겨냥한 악성 트래픽을 탐지하면, SOAR 플레이북이 자동으로 실행되어 수 초 내에 해당 트래픽의 출발지 IP를 방화벽에서 차단하고, 관련 시스템을 네트워크에서 격리하는 등 자동화된 대응을 수행한다.
- **비영속성 (Non-Persistence):** EMS HMI를 가상화 환경이나 컨테이너 기반으로 구축하고, 사전에

사이버 리스크 평가 및 시나리오

제작된 안전한 '골든 이미지'를 기반으로 주기적으로 시스템을 초기 상태로 복원하도록 설계한다. 이를 통해 시스템에 잠복해 있을 수 있는 악성코드를 원천적으로 제거한다.

[지속성 제거 및 생존]

- 기능: 재부팅 시 시스템을 초기화하여 악성코드를 제거하고, 이기종 제어기를 사용하여 동시 감염 방지
- 효과: 공격자가 시스템을 장악해도 그 효과를 영구적으로 유지할 수 없게 함
- 목표: 시스템은 감염될 수 있지만, 감염 상태를 유지할 수는 없음

사이버 리스크 평가 및 시나리오

4.2.6 전기추진시스템(Electric Propulsion System, EPS)

4.2.6.1. 시스템 프로파일

전기추진 시스템은 선박의 주된 기동력으로서 전기 에너지를 기계적 추력으로 변환하여 선박의 조종성과 운항을 책임지는 핵심 동력 장치이다.

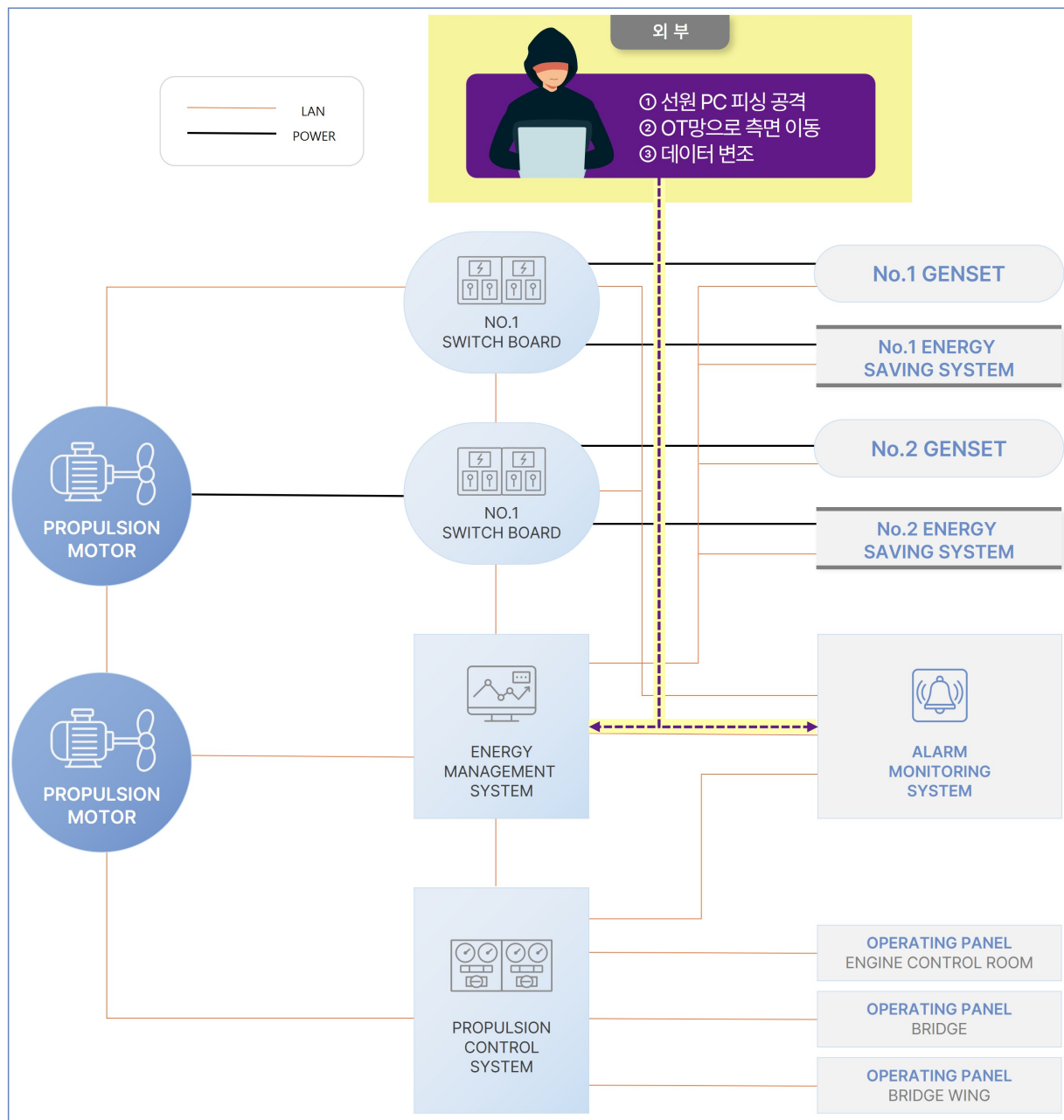


그림 4-8 ▶ 전기추진시스템(EPS) 사이버 위협 도식화



사이버 리스크 평가 및 시나리오

4.2.6.2. 위협 및 취약점 분석

- **신원 위장 (Spoofing):** 공격자가 제어 네트워크에 침투하여 EMS나 합법적인 운용 패널의 신원을 도용, 추진 제어 시스템에 비인가 제어 명령을 전송.
- **변조 (Tampering):** 본 시스템의 가장 핵심적인 위협으로, 공격자는 정상적인 제어 명령(예: '미속 전진')을 중간에서 가로채 악의적인 명령(예: '전속 전진')으로 수정하거나, 완전히 새로운 악성 명령을 네트워크에 직접 주입.
- **서비스 거부 (Denial of Service):** 공격자가 추진 제어 시스템이나 EMS에 대량의 트래픽을 전송하여 시스템을 마비시킨다. 이는 선박이 조종 불능 상태로 표류하는 결과를 초래.
- **주요 취약점:** 인증 부재 OT 프로토콜, 보안구역 세분화 미흡, 불충분한 모니터링.

4.2.6.3. 상세 리스크 시나리오: "인증 없는 OT 프로토콜을 이용한 추진 제어 명령 직접 주입 및 강제 선회"

공격 흐름: [제어망 접근] → [PLC 스캐닝] → [비인가 Modbus 패킷 주입] → [모터 역동작 제어] → [급정거/파손]

- **1단계 (침투 및 측면 이동): [제어망 접근]** 공격은 추진 시스템에서 직접 시작되지 않는다. 공격자는 상대적으로 보안이 취약한 선원용 IT 네트워크의 PC를 피싱으로 감염시키거나, 유지보수 업체의 노트북을 통해 모니터링 네트워크에 초기 거점을 확보한다. 이후, 잘못 구성된 방화벽이나 미흡한 네트워크 분리 정책의 허점을 이용하여 추진 제어기들이 위치한 핵심 OT 제어 시스템 구역(Control System Zone)으로 측면 이동(Lateral Movement)에 성공한다. 이는 IT 보안의 실패가 직접적인 OT 안전사고의 원인이 될 수 있음을 보여준다.
- **2단계 (정찰): [PLC 스캐닝]** OT 네트워크 내부에 진입한 공격자는 스캐닝 도구를 사용하여 전기추진 모터를 제어하는 PLC(Programmable Logic Controller) 또는 VFD(Variable Frequency Drive)의 IP 주소를 식별한다. 이 과정에서 열려 있는 포트와 사용 중인 특정 OT 프로토콜을 파악한다.
- **3단계 (악용): [비인가 Modbus 패킷 주입]** 공격자는 간단한 스크립트를 이용해 조작된 OT 프로토콜 패킷을 생성하여, 합법적인 추진 제어 시스템을 완전히 우회하고 모터 제어기에 직접 전송한다. [모터 역동작 제어] 선박의 급격한 선회를 유발하기 위해, 좌현 모터에는 '전속 전진' 명령을, 동시에 우현 모터에는 '전속 후진' 명령을 주입한다.

사이버 리스크 평가 및 시나리오

- **4단계 (영향): [급정거/파손]** 선박은 즉각적이고 격렬하게 통제 불능 상태로 선화하며, 마주 오던 초대형 유조선의 항로로 직접 돌진한다. 선교의 운항자들은 자신들의 운용 패널에 모든 것이 정상으로 표시되기 때문에 초기에는 극심한 혼란에 빠진다. 이 '눈 먼 선교' 상황은 대응을 지연시켜 충돌을 피할 수 없게 만든다. 이 충돌은 선체 파손, 대규모 인명 피해, 심각한 해양 오염을 유발할 뿐만 아니라, 세계에서 가장 중요한 무역 동맥 중 하나를 수 주간 마비시키는 공급망 대란으로 이어진다.

4.2.6.4. 리스크 분석

요소	등급 (1-5)	리스크 분석
가능성 (L)	3 (보통)	• 전제 조건이 되는 취약점(비보안 OT 프로토콜, 잠재적으로 미흡한 망 분리)은 기존 선박들에서 흔히 발견됨. 악의적인 OT 패킷을 생성하고 전송하는 도구는 공개적으로 사용 가능함. 주된 진입 장벽은 OT 네트워크에 대한 초기 접근 확보이므로, 의지가 확고한 공격자에게는 발생 가능성이 보통 수준이지만 매우 현실적임
영향도 (I)	5 (재앙적)	• S (안전): 5 - 혼잡 수역에서 선박 제어권의 직접적이고 즉각적인 상실은 대규모 인명 피해와 환경 재앙을 동반하는 충돌, 전복, 좌초로 이어질 가능성이 높음 • O (운항): 5 - 추진 제어의 완전한 상실은 선박을 운항 불능 상태로 만들고 항해에 심각한 위험 요소가 됨 • P (개인정보): 1 - 중대한 개인정보 유출은 없음 • F (재무): 5 - 선박이 사실상 무기화된다. 선박 및 화물의 전손 가능성, 충돌로 인한 무한 책임, 막대한 환경 정화 비용, 회복 불가능한 평판 손상 등이 발생할 수 있음
위험도 (R = L x I)	15 (높음)	• 본 문서의 리스크 매트릭스에 따라 15점은 '높음' 등급으로 분류됨. 즉각적이고 강력한 완화 조치가 요구됨

4.2.6.5. 권고 통제 방안

🔗 Level 1 (규제 준수 - IACS UR E26/E27 준수)

- **네트워크 분리:** IACS UR E26의 요구사항에 따라 추진 제어 네트워크를 IT, 선원 복지, 모니터링 등 다른 모든 선내 네트워크로부터 논리적, 물리적으로 엄격히 분리한다. 이는 시나리오에서 묘사된 측면 이동을 방지하는 가장 중요하고 기본적인 통제이다.
- **자산 관리:** EPS를 구성하는 모든 PLC, HMI, 네트워크 스위치 등의 자산 목록을 펌웨어 버전을 포함하여 최신 상태로 유지한다. 이는 효과적인 취약점 관리의 전제 조건이다.



사이버 리스크 평가 및 시나리오

- **시스템 강화(Hardening):** IACS UR E27의 요구사항에 따라 추진 제어 구역 내의 모든 PLC, 스위치, HMI의 기본 패스워드를 변경하고 사용하지 않는 모든 네트워크 포트와 서비스를 비활성화한다.

[접근 경로 차단]

- 기능: 외부에서 제어망으로 들어오는 경로를 차단하고 불필요한 포트를 닫음
- 효과: 공격의 1단계(침투) 난이도를 높임
- 한계: 내부망에 진입한 공격자에게는 무방비 상태(Soft inside)가 됨

○ Level 2 (구조화된 방어 - IEC 62443 기반)

- **마이크로 세분화 (Zone & Conduit 모델):** IEC 62443 모델에 따라 추진 제어 네트워크를 보안 수준이 높은 '제어 시스템 구역(Control System Zone)'으로 공식 지정한다. 이 구역을 출입하는 모든 트래픽은 반드시 정의된 '통로(Conduit)', 즉 OT 방화벽을 통과하도록 강제한다.
- **심층 패킷 분석 (Deep Packet Inspection, DPI):** 통로에 위치한 방화벽은 OT 프로토콜에 대한 심층 패킷 검사를 수행하도록 설정해야 한다. 이를 통해 "오직 합법적인 추진 제어 시스템의 IP 주소에서 오는 추진 명령만 허용"하고, "정상 운항 중에는 펌웨어 업데이트와 같은 모든 관리 수준의 명령을 차단"하는 등 세분화된 '화이트리스트' 규칙을 생성할 수 있다. 이는 '설계에 의한 비보안' 프로토콜의 취약점을 직접적으로 완화하는 핵심적인 아키텍처적 통제이다.
- **OT 네트워크 모니터링:** EPS 네트워크 세그먼트의 트래픽을 지속적으로 감시하는 OT 특화 네트워크 침입 탐지 시스템(NIDS)을 구축한다. 비정상적인 명령이나 트래픽 패턴이 탐지되면 즉시 ROC의 통합 보안관제(SIEM) 시스템에 경보를 전송하여 신속한 대응을 가능하게 한다.

[프로토콜 보안]

- 기능: OT 프로토콜(Modbus 등)의 내용을 분석하여 '쓰기(Write)' 명령을 차단하고, 구역 내 통신을 세분화
- 효과: 공격의 3단계(악용)인 악성 패킷 주입을 네트워크 레벨에서 필터링
- 목표: 인증 기능이 없는 레거시 프로토콜에 네트워크 보안 계층을 적용함

○ Level 3 (적응형 복원력 - 제로 트러스트 및 자동화)

- **마이크로 세분화 및 제로 트러스트:** 제어 시스템 구역 내부에 마이크로 세분화를 구현한다. 이는 구역 내의 장치들조차 서로를 신뢰하지 않음을 의미한다. 예를 들어, 제어 HMI와 모터 PLC 간의 통신은 명시적으로 허용되지만, 두 모터 PLC 간의 직접적인 통신은 차단된다. 이는 본 문서 5.1절의 핵심 원칙인 '절대 신뢰하지 말고, 항상 검증하라'는 제로 트러스트 아키텍처(ZTA)를 구현하는 것이다.



사이버 리스크 평가 및 시나리오

- **OT 네트워크 보안 모니터링 및 이상 행위 탐지:** OT 트래픽을 지속적으로 감시하는 수동형 네트워크 센서(IDS)를 배치하여 비정상적인 행위를 탐지한다. 이 시스템은 인가된 제어기 외에 다른 장치가 추진 PLC와 통신을 시도하거나, 비정상적인 명령 순서가 나타날 경우 경보를 발생시켜 공격 진행에 대한 조기 경보와 사고 후 포렌식에 결정적인 데이터를 제공한다.
- **대역 외(Out-of-Band, OOB) 검증:** 선박의 물리적 상태를 제어 시스템의 명령 상태와 독립적으로 비교 검증하는 안전 시스템을 설계한다. 예를 들어, 별도의 모니터링 장치가 추진 제어 시스템의 명령 로그와 실제 샤프트 회전 속도 및 방향 센서 데이터를 실시간으로 대조한다. 만약 두 값 사이에 심각한 불일치가 감지되면(예: '전진' 명령 상태에서 실제 '후진' 회전 감지), 이는 잠재적으로 조작된 HMI 표시를 무시하고 선교에 직접적인 비상 경보를 울려 '눈 먼 선교' 시나리오를 무력화한다.
- **보안 프로토콜 캡슐화:** 기존의 레거시 Modbus TCP 트래픽 전체를 허가된 제어 소스(EMS, 운용 패널)와 추진 제어 PLC 사이에 TLS나 IPsec과 같은 암호화되고 인증된 보안 터널로 감싸는(Wrapping) 통제를 적용한다. 이는 프로토콜 자체가 갖지 못한 기밀성, 무결성, 인증 계층을 네트워크 수준에서 추가하는 효과적인 방법이다.
- **자동화된 대응 (SOAR):** OT IDS를 SOAR(보안 오케스트레이션, 자동화 및 대응) 플랫폼과 통합한다. 비인가 명령 시도가 탐지되면 사전에 정의된 플레이북이 자동으로 실행되어, 공격 근원지 장치를 네트워크에서 격리하고, ROC의 보안관제센터(SOC)에 최우선 순위 경보를 발생시키며, 잠재적으로 추진 시스템을 '수동 제어 우선' 안전 모드로 전환하는 등의 조치를 취할 수 있다.

[물리적 무력화]

- 기능: 디지털 명령과 별개로 실제 물리적 회전수(RPM)를 독립적으로 검증하여 이상 시 비상 정지
- 효과: 사이버 공격이 성공해도 4단계(물리적 영향)인 충돌/파손을 물리적으로 차단
- 목표: 사이버 공격으로 물리적 안전장치를 해제할 수 없도록 설계(Cyber-Physical Safety)

사이버 리스크 평가 및 시나리오

4.2.7 CBM 시스템 (Condition-Based Maintenance System)

4.2.7.1. 시스템 프로파일

CBM 시스템은 주 기관, 발전기 등 핵심 회전 기기에 부착된 진동, 온도 센서 데이터를 실시간으로 분석하여 고장을 사전에 예측하고 최적의 정비 시점을 알려주는 예측 시스템이다. 이 시스템의 판단은 데이터의 신뢰성에 전적으로 의존한다.

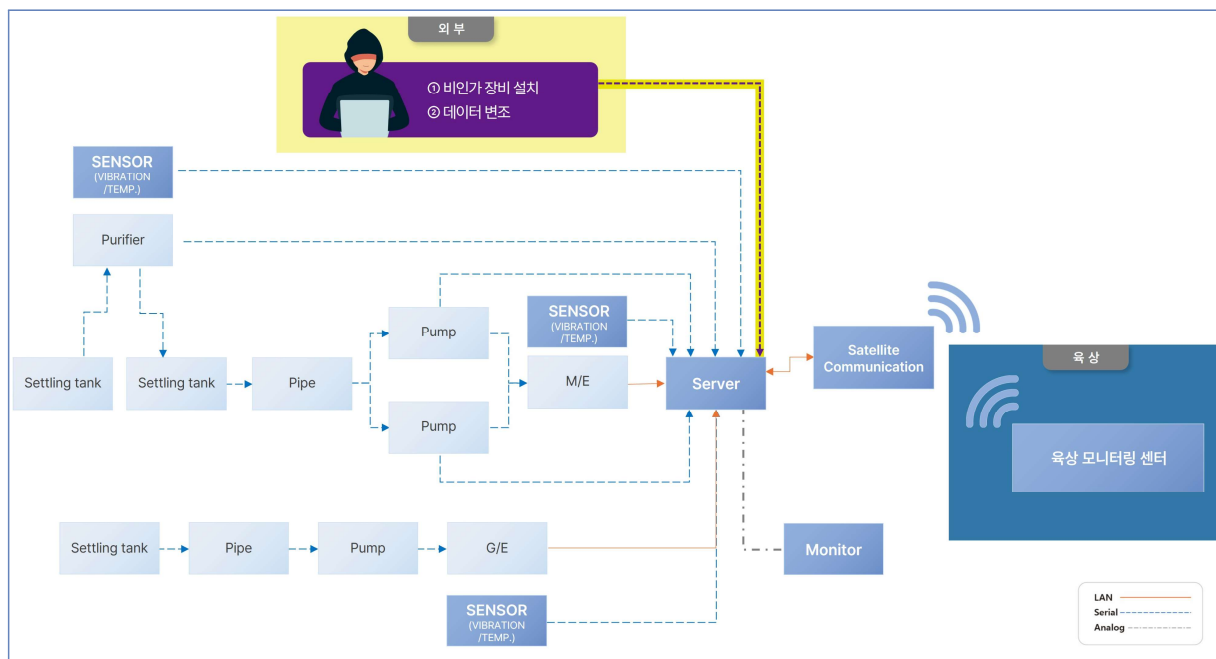


그림 4-9 ▶ CBM 시스템 사이버 위협 도식화

4.2.7.2. 위협 및 취약점 분석

- **변조(Tampering):** 센서 데이터를 정상 범위 내의 값으로 미세하게 조작하여 고장 징후를 은폐.
- **정보 유출(Information Disclosure):** 선박의 상세한 기기 상태 및 운항 데이터가 경쟁사 등에 유출.
- **주요 취약점:** 센서 네트워크의 물리적 보안 미흡, 데이터 전송 구간의 암호화 및 무결성 검증 부재.

사이버 리스크 평가 및 시나리오

4.2.7.3. 상세 리스크 시나리오: "센서 데이터 조작을 통한 엔진 고장 징후 은폐 및 대양 항해 중 운항 불능"

공격 흐름: [물리적 센서 접근] → [중간 장치 설치] → [고장 데이터 필터링] → [정상 상태 기만] → [엔진 파손 방지]

- **1단계 (물리적 접근):** [물리적 센서 접근] 내부자 또는 유지보수 업체 직원으로 위장한 공격자가 기관실에 접근하여, 주 엔진의 핵심 베어링에 연결된 진동 센서 케이블에 소형 데이터 조작 장치를 설치한다.
- **2단계 (데이터 조작):** [중간 장치 설치] 이 장치는 실제 센서 값을 가로채, [고장 데이터 필터링] 미세한 마모로 인해 서서히 증가하는 진동 값을 필터링하고 항상 정상 범위 내의 안정적인 값으로 변조하여 CBM 시스템으로 전송한다.
- **3단계 (오인):** [정상 상태 기만] CBM 시스템의 AI 분석 모델은 조작된 정상 데이터만을 수신하므로, 실제 베어링의 마모가 심각한 수준에 이르렀음에도 어떠한 고장 징후도 탐지하지 못한다. ROC의 정비 담당자는 시스템을 신뢰하고 정기 정비 주기를 연장한다.
- **4단계 (영향):** [엔진 파손 방지] 예방 정비 기회를 완전히 놓친 엔진 베어링은 결국 대양 항해 중 파손되어 엔진 전체에 치명적인 손상을 입힌다. 선박은 망망대해에서 운항 불능 상태에 빠져 구조를 기다려야 하는 상황에 처하고, 이는 막대한 재정적 손실과 운항 신뢰도 하락으로 이어진다.

4.2.7.4. 리스크 분석

요소	등급 (1-5)	리스크 분석
가능성 (L)	3 (보통)	• 내부자 또는 위장 접근을 통한 물리적 공격은 높은 수준의 계획이 필요하나, 성공 시 탐지가 매우 어려움
영향도 (I)	4 (심각)	• S (안전): 3 - 2차 사고의 위험이 존재 • O (운항): 4 - 장기간 운항 중단 및 예기치 않은 수리 • P (개인정보): 1 - 중대한 데이터 유출 없음 • F (재무): 4 - 고가의 엔진 수리/교체 비용, 운항 손실, 용선 계약 위반
위험도 (R = L × I)	12 (높음)	• 본 문서의 리스크 매트릭스에 따라 12점은 '높음' 등급으로 분류됨. 즉각적이고 강력한 완화 조치가 요구됨



사이버 리스크 평가 및 시나리오

4.2.7.5. 권고 통제 방안

○ Level 1 (규제 준수 - IACS UR E26/E27 준수)

- **물리적 보안 강화:** 기관실 등 핵심 OT 장비가 위치한 구역에 대한 접근 통제 정책을 수립하고, 모든 출입 기록을 관리하며 CCTV를 설치하여 비인가 접근을 감시한다.
- **패스워드 정책 강화:** IACS UR E27의 요구사항에 따라, CBM 시스템을 구성하는 모든 OT 장비(센서 게이트웨이 포함)의 기본 패스워드를 복잡도가 높은 임의의 값으로 변경하고 이를 주기적으로 관리하는 절차를 수립한다.

[물리적 접근 통제]

- 기능: 센서에 물리적으로 접근하여 조작 장치를 설치하는 것을 방지
- 효과: 공격의 1단계(물리적 접근)를 차단
- 한계: 내부 공모자나 정교하게 은폐된 장치에는 취약

○ Level 2 (구조화된 방어 - IEC 62443 기반)

- **통신 무결성 확보:** 센서 데이터 전송 구간에 HMAC(Hash-based Message Authentication Code) 과 같은 암호학적 무결성 검증 메커니즘을 적용하여, 데이터가 전송 중에 변조되지 않았음을 보장한다. 이는 IEC 62443-3-3의 SR 3.1 (통신 무결성) 요구사항을 직접적으로 이행하는 핵심 통제이다.
- **물리적 변조 방지:** 센서 케이블 연결부, 네트워크 접속 포트 등에 물리적 잠금장치나 변조 여부를 쉽게 확인할 수 있는 봉인(Tamper-evident seal)을 적용한다.

[전송 구간 보호]

- 기능: 센서 데이터에 인증 태그(HMAC)를 붙여 전송 중 변조를 탐지
- 효과: 공격의 2단계(데이터 조작) 중 네트워크 중간자 공격을 무력화
- 목표: 데이터의 생성 시점부터 수신 시점까지 무결성을 보장

○ Level 3 (적응형 복원력 - 제로 트러스트 및 자동화)

- **다중 센서 교차 검증:** 단일 센서의 데이터에만 의존하지 않고, CBM 분석 엔진 내에 여러 관련 센서 데이터를 종합적으로 분석하는 로직을 구현한다. 예를 들어, 특정 베어링의 진동 값은 정상이지만, 인접 부위의 온도나 엔진 RPM 대비 윤활유 압력이 비정상적인 패턴을 보일 경우, 이를 데이터의 유효성(Plausibility) 문제 또는 센서 조작 시도로 탐지하고 경고한다.
- **물리 모델 기반 이상 탐지:** 분석 대상 기기(예: 엔진)의 고정밀 물리 모델(Digital Twin)을 구축한다.

사이버 리스크 평가 및 시나리오

실제 센서 값을 물리 모델의 예측 값과 지속적으로 비교하여, 통계적으로 유의미한 편차가 발생할 경우 이를 이상 징후로 탐지한다. 이는 미세한 데이터 조작 공격을 효과적으로 방어할 수 있는 고급 기술이다.

[논리적 모순 탐지]

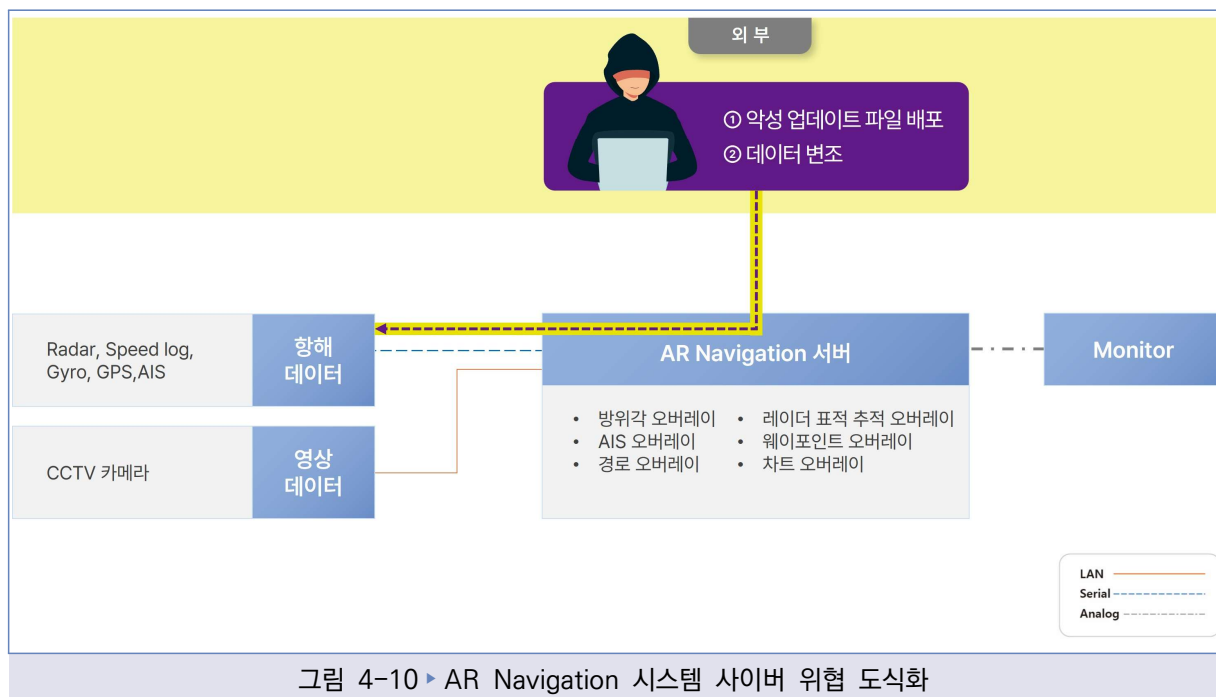
- 기능: "진동은 정상인데 온도가 오르는 모순"을 분석하여 오인을 탐지
- 효과: 공격의 3단계(오인) 자체를 지능적으로 식별. 데이터 값이 정상이더라도 관계가 비정상 이면 탐지
- 목표: 데이터 간의 인과관계(Causality)를 검증 수단으로 활용

사이버 리스크 평가 및 시나리오

4.2.8 AR Navigation 시스템 (Augmented Reality Navigation)

4.2.8.1. 시스템 프로파일

AR Navigation 시스템은 선교의 창문이나 대형 디스플레이에 보이는 실제 카메라 영상 위에 전자해도(ECDIS), 레이더, AIS 등 항해 정보를 증강현실(AR) 그래픽으로 겹쳐 보여준다. 이를 통해 운항자에게 직관적인 상황 인식 능력을 제공한다.



4.2.8.2. 위협 및 취약점 분석

- **변조(Tampering):** AR 오버레이 그래픽(항로, 위험물 표시 등)을 조작하여 운항자의 착시와 오판 유도.
- **신원 위장(Spoofing):** AR 시스템에 입력되는 AIS, GNSS 등 외부 데이터 소스를 위장하여 허위 정보 표시.
- **주요 취약점:** AR 소프트웨어 자체의 애플리케이션 취약점, 입력 데이터 소스에 대한 출처 인증 및 무결성 검증 미흡.

4.2.8.3. 상세 리스크 시나리오: "소프트웨어 업데이트 공급망 공격을 통한 AR 오버레이 변조 및 좌초 유도"

사이버 리스크 평가 및 시나리오

공격 흐름: [업데이트 서버 해킹] → [악성코드 배포] → [위험 구역 은폐] → [좌초]

- **1단계 (침투): [업데이트 서버 해킹]** 공격자가 AR 시스템 제조사의 업데이트 서버를 해킹하여, 악성코드가 포함된 소프트웨어 업데이트 파일을 업로드한다.
- **2단계 (감염): [악성코드 배포]** 선박에서 정기 소프트웨어 업데이트를 수행할 때, 악성코드가 포함된 파일이 AR 시스템에 설치된다.
- **3단계 (악용): [위험 구역 은폐]** 악성코드는 특정 조건(예: 특정 항만에 접근 시)이 되면 활성화되어, 실제 카메라 영상 위에 표시되는 AR 그래픽을 조작한다. 암초가 있는 위험 지역을 안전한 항로인 것처럼 녹색 안전 통과선(Safe Corridor)으로 표시하고, 실제 안전한 항로에는 장애물이 있는 것처럼 빨간색 위험 구역을 표시한다.
- **4단계 (영향): [좌초]** 원격 또는 선내 운항자는 매우 직관적이고 신뢰성 높아 보이는 AR 그래픽을 신뢰하고, 조작된 안전 통과선을 따라 선박을 조종한다. 그 결과, 선박은 암초 지대로 잘못 유도되어 좌초되고 선체에 심각한 손상을 입으며, 해양 오염 사고까지 유발할 수 있다.

4.2.8.4. 리스크 분석

요소	등급 (1-5)	리스크 분석
가능성 (L)	3 (보통)	• 공급망을 통한 소프트웨어 오염은 고도화된 공격이지만, 성공 시 파급력이 매우 큼
영향도 (I)	4 (심각)	• S (안전): 4 - 좌초, 선체 손상, 환경 오염 유발 • O (운항): 4 - 선박 운항 불능 및 구조 필요 • P (개인정보): 1 - 중대한 데이터 유출 없음 • F (재무): 4 - 선체 수리 비용, 화물 손실, 환경 정화 비용
위험도 (R = L x I)	12 (높음)	• 본 문서의 리스크 매트릭스에 따라 12점은 '높음' 등급으로 분류됨. 즉각적이고 강력한 완화 조치가 요구됨

4.2.8.5. 권고 통제 방안

🔗 Level 1 (규제 준수 - IACS UR E26/E27 준수)

- **정기 취약점 점검:** AR 시스템을 구성하는 소프트웨어에 대해 정기적으로 알려진 취약점을 점검하고, 제조사에서 제공하는 보안 패치를 적용하는 절차를 수립한다.



사이버 리스크 평가 및 시나리오

- **자산 목록 관리:** AR 시스템을 구성하는 모든 하드웨어 및 소프트웨어에 대한 목록을 작성하고 최신 상태로 유지한다.

[취약점 관리]

- 기능: 알려진 보안 약점을 제거하여 공격 표면을 줄임
- 효과: 일반적인 악성코드의 침투를 예방
- 한계: 정상적인 업데이트 기능을 악용한 공격은 막을 수 없음

❶ Level 2 (구조화된 방어 - IEC 62443 기반)

- **입력 데이터 출처 인증 및 검증:** AR 시스템에 입력되는 모든 외부 데이터(AIS, GNSS, RADAR)에 대해 출처를 인증하고 데이터의 유효성을 검증하는 로직을 구현한다. 예를 들어, AIS 정보와 RADAR 탐지 정보를 지속적으로 교차 검증하여, AIS 신호는 있으나 RADAR 에코가 없는 '유령 선박'과 같은 불일치 상황을 탐지하고 운항자에게 경고한다. 이는 IEC 62443-3-3 SR 3.5 (입력 검증) 요구사항에 해당한다.
- **보안 개발 수명주기(Secure SDLC) 적용:** AR 시스템 개발사에 IEC 62443-4-1에 따른 Secure SDLC 적용을 요구한다. 이를 통해 설계 단계부터 위협 모델링을 수행하고 시큐어 코딩을 적용하여 소프트웨어 자체의 보안 품질을 향상시킨다.

[검증된 소스 사용]

- 기능: AR에 표출되는 데이터(AIS, Radar)의 출처를 확인하고 교차 검증
- 효과: 공격의 3단계(악용) 중 외부 데이터 조작으로 인한 상황 오인을 방지
- 목표: 입력 데이터의 무결성이 출력(AR화면)의 신뢰성을 결정

❷ Level 3 (적응형 복원력 - 제로 트러스트 및 자동화)

- **펌웨어/소프트웨어 서명 의무화:** 모든 소프트웨어 및 펌웨어 업데이트 파일에 대해 제조사의 암호학적 서명을 의무화하고, 시스템은 서명이 유효한 파일만 설치하도록 강제한다. 이를 통해 공급망 단계에서 업데이트 파일이 변조되는 것을 원천적으로 방지한다.
- **소프트웨어 자재명세서(SBOM) 관리:** AR 시스템 공급사로부터 SBOM을 제출 받아, 소프트웨어를 구성하는 모든 오픈소스 라이브러리 및 종속성을 파악하고, 관련 취약점 정보를 지속적으로 모니터링하는 공급망 리스크 관리(C-SCRM) 체계를 구축한다.
- **AI 기반 이상 탐지:** 정상적인 항해 상황에서의 AR 그래픽 및 데이터 패턴을 AI 모델에 학습시킨 후, 이 모델을 통해 실제 운영 중 비정상적이거나 논리적으로 모순된 오버레이(예: 육지 위에 항로

사이버 리스크 평가 및 시나리오

표시)가 생성되는 것을 탐지하고 경고하는 기능을 구현한다.

[코드 신뢰성 보증]

- 기능: 제조사의 서명이 없는 업데이트는 설치를 거부하고, 화면상의 비논리적 그래픽(육지 위향로 등)을 시가 탐지
- 효과: 공격의 1단계(침투/업데이트 변조)를 원천 봉쇄하고, 4단계(영향) 직전에 운항자에게 경고
- 목표: 인간의 인지적 편향(화면 맹신)을 기술적으로 보완

사이버 리스크 평가 및 시나리오

4.2.9 AVM(Around View Monitoring) 시스템

4.2.9.1. 시스템 프로파일

AVM 시스템은 선박 주변에 설치된 다수의 카메라 영상을 실시간으로 합성하여, 운항자에게 사각지대 없는 360도 조감도(Bird's-eye view)를 제공하는 핵심적인 상황 인식 보조 시스템이다. 특히 접안과 같이 정밀한 기동이 요구되는 상황에서 운항자의 시각적 판단을 지원하는 중요한 역할을 한다.

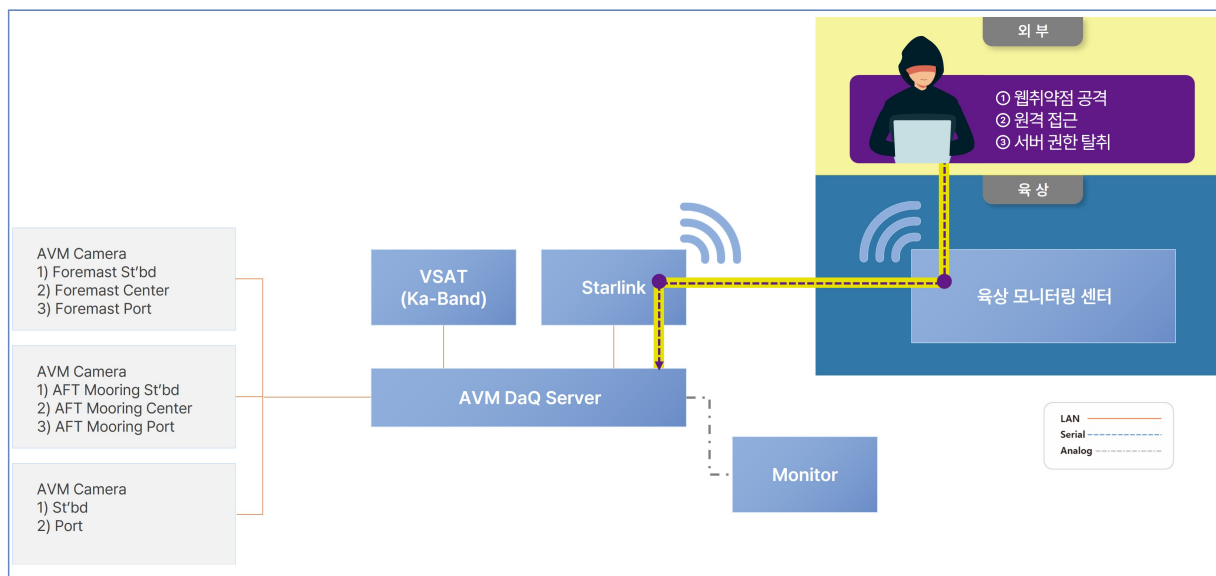


그림 4-11 ▶ AVM 시스템 사이버 위협 도식화

4.2.9.2. 위협 및 취약점 분석

- **변조 (Tampering):** 가장 심각한 위협으로, 실시간 영상 피드를 사전에 녹화된 정상 상태의 영상으로 교체하여 실제 존재하는 장애물(예: 다른 선박, 안벽)을 은폐. 또는 영상 합성 과정에 개입하여 허위 객체를 삽입하거나 특정 영역을 왜곡함.
- **서비스 거부 (Denial of Service):** 특정 카메라의 영상 피드를 마비시켜 AVM 시스템에 치명적인 사각지대를 발생시키거나, AVM DaQ 서버에 과부하를 일으켜 전체 시스템을 다운.
- **정보 유출 (Information Disclosure):** 암호화되지 않은 영상 스트림을 도청하여 선박 주변의 상황을 감시하거나, 원격 전송 중인 데이터를 가로채 민감한 운항 정보를 탈취.
- **권한 상승 (Elevation of Privilege):** IP 카메라 또는 DaQ 서버의 취약점을 이용해 관리자 제어 권한을 탈취하고, 카메라의 시야를 의도적으로 방해하거나 시스템 설정을 변경.
- **주요 취약점:** 네트워크 분리 미흡, 시스템 강화(Hardening) 미흡, 데이터 무결성 검증 부재.

사이버 리스크 평가 및 시나리오

4.2.9.3. 상세 리스크 시나리오: "영상 피드 조작을 통한 '유령 선박' 생성 및 접안 중 충돌"

공격 흐름: [카메라망 침투] → [실시간 영상 차단] → [정상 영상 루핑 재생] → [장애물 은폐] → [접안 사고]

- **1단계 (침투 및 거점 확보):** [카메라망 침투] 공격자는 인터넷에 노출된 AVM 시스템의 원격 관리 인터페이스 취약점을 이용하거나, IT 네트워크를 통해 측면 이동하여 AVM DaQ 서버에 접근하는데 성공한다.
- **2단계 (정찰 및 준비):** [실시간 영상 차단] 공격자는 AVM 시스템의 영상 처리 로직을 분석하고, 선박이 접안할 항구의 정상적인 빈 안벽 영상을 미리 준비한다.
- **3단계 (악용 및 오인):** [정상 영상 루핑 재생] 선박이 실제로 부두에 접안을 시도하는 결정적인 순간, 공격자는 악성 스크립트를 실행하여 실시간 카메라 피드를 차단하고, 사전에 녹화된 '깨끗한 안벽' 영상을 영상 합성 엔진에 주입한다. [장애물 은폐] 실제로는 다른 소형 선박이 부두에 계류 중인 상황이다.
- **4단계 (영향):** [접안 사고] 선내 모니터와 ROC 운영자에게는 아무런 장애물 없이 안전하게 접안할 수 있는 것으로 보이는 360도 영상이 표시된다. 운항자는 이 조작된 시각 정보를 절대적으로 신뢰하고 접안을 계속 진행하다가, 영상에서는 보이지 않던 실제 소형 선박과 충돌하여 선체와 항만 시설에 심각한 물리적 손상을 입힌다.

4.2.9.4. 리스크 분석

요소	등급 (1-5)	리스크 분석
가능성 (L)	3 (보통)	• IP 카메라 및 서버의 소프트웨어 취약점은 흔하게 발견되며, 이를 악용하는 공격 기술은 널리 알려져 있다. 공격 성공을 위해서는 네트워크 접근이 선행되어야 하므로 '보통'으로 평가된다.
영향도 (I)	4 (심각)	• S (안전): 4 - 접안 중 충돌로 인한 선체 손상, 항만 시설 파괴, 잠재적인 인명 피해 및 환경 오염을 유발한다. • O (운항): 4 - 정밀 기동 실패로 선박 운항이 중단되고, 수리 및 사고 조사로 인한 장기적인 운항 차질이 발생한다. • P (개인정보): 1 - 중대한 개인정보 유출은 발생하지 않는다. • F (재무): 4 - 고가의 선체 및 항만 시설 수리 비용, 운항 손실로 인한 막대한 재정적 피해가 발생한다.

사이버 리스크 평가 및 시나리오

위험도 ($R = L \times I$)	12 (높음)	리스크 매트릭스에 따라 12점은 '높음' 등급에 해당하며, 완화 조치가 필요하다.
--------------------------	---------	---

4.2.9.5. 권고 통제 방안

🔗 Level 1 (규제 준수 - IACS UR E26/E27 준수)

- **네트워크 분리:** IACS UR E26 요구사항에 따라 AVM 카메라 네트워크를 선내 IT 네트워크 및 기타 OT 네트워크와 물리적/논리적으로 분리하여, 다른 네트워크의 침해가 AVM 시스템으로 확산되는 것을 방지한다.
- **시스템 강화 (Hardening):** IACS UR E27 요구사항에 따라 모든 AVM 카메라, 서버, 네트워크 장비의 제조사 기본 패스워드를 복잡도가 높은 임의의 값으로 변경하고, 사용하지 않는 모든 네트워크 포트와 서비스를 비활성화한다.

[격리]

- 기능: CCTV망을 외부와 분리하여 해커의 접근을 차단함
- 효과: 공격의 1단계(침투)를 어렵게 함
- 한계: 폐쇄망이라도 유지보수 포트 등을 통한 침투 가능성은 상존

🔗 Level 2 (구조화된 방어 - IEC 62443 기반)

- **보안 구역 및 통로 아키텍처:** IEC 62443 모델에 따라 AVM 시스템이 위치한 모니터링 구역(Monitoring Zone)과 외부 통신 장비가 있는 통신 구역(Communication Zone) 사이에 OT 전문 방화벽(통로)을 배치한다. 이 방화벽은 오직 허가된 AVM 서버의 암호화된 영상 트래픽만 통신 구역으로 전달하도록 엄격한 규칙을 적용한다.
- **영상 데이터 무결성 검증:** 영상 스트림에 디지털 워터마킹 또는 HMAC(Hash-based Message Authentication Code)과 같은 암호학적 무결성 검증 메커니즘을 적용한다. 이를 통해 수신 측(모니터, ROC)에서 영상 데이터가 전송 중에 변조되지 않았음을 검증할 수 있다.

[시점 인증]

- 기능: 영상 프레임에 시간 정보와 워터마크를 삽입하여 재전송(Replay) 공격을 탐지.
- 효과: 공격의 3단계(악용/오인)를 기술적으로 식별. "지금 촬영된 영상"임을 보증
- 목표: 데이터의 최신성(Freshness)을 검증

사이버 리스크 평가 및 시나리오

◉ Level 3 (적응형 복원력 - 제로 트러스트 및 자동화)

- **다중 센서 교차 검증:** AVM 시스템의 시각 정보에만 의존하지 않는 안전 로직을 구현한다. 예를 들어, AVM 영상에서는 경로가 깨끗하다고 표시되더라도, 독립적인 RADAR나 LIDAR 센서가 특정 거리 내에서 물체를 감지할 경우, 시스템은 데이터 불일치 경보를 발생시키고 자동 접안과 같은 위험한 기동을 즉시 중단시킨다. 이는 '인식 계층 공격'을 무력화하는 핵심적인 복원력 통제이다.
- **공급망 리스크 관리 (C-SCRM):** AVM 시스템을 구성하는 모든 하드웨어 및 소프트웨어 공급업체에 소프트웨어 자재명세서(SBOM) 제출을 의무화하고, 계약서에 보안 개발 수명주기(Secure SDLC) 준수를 명시하여 공급망 단계에서부터 취약점이 유입되는 것을 방지한다.

[상호 보완적 인식]

- 기능: 영상은 깨끗해도 레이더 등에 물체가 감지되면 충돌 경보를 울림
- 효과: 시각 정보가 완벽하게 조작되어도 다른 센서로 상황 인식을 유지하여 4단계(충돌) 방지
- 목표: 단일 센서의 오류를 다른 데이터로 보정



사이버 리스크 평가 및 시나리오

4.3. 리스크 평가 결과

본 장에서는 제4.2절에서 수행된 8개 핵심 시스템에 대한 심층 리스크 평가 결과를 종합하고, 이를 바탕으로 자율운항선박(MASS) 생태계의 보안 강화를 위한 전략적 방향성을 제시한다. 개별 위협 시나리오 분석을 넘어, 시스템 전반에 걸쳐 나타나는 거시적인 리스크 테마를 도출하고, 이를 해결하기 위한 구체적인 보안 투자 우선순위를 권고함으로써 이해관계자들이 효과적인 의사결정을 내릴 수 있도록 지원하는 것을 목표로 한다.

4.3.1. 핵심 시스템별 리스크 완화 전략 요약

아래 표는 4.2절에서 분석된 8개 핵심 시스템 각각에 대해 식별된 리스크를 완화하기 위한 권고 통제 방안을 보안 성숙도 모델의 3단계 수준에 따라 요약한 것이다. 이 표는 보안 아키텍처, 시스템 담당자, 그리고 규제 준수 관리자가 단계별 보안 강화 로드맵을 수립하고 이행하는 데 있어 핵심적인 참조 도구로 활용될 수 있다.

표 4-5 자율운항선박 핵심 시스템별 성숙도 기반 통제 방안 요약

시스템명	Level 1 (규제 준수)	Level 2 (구조화된 방어)	Level 3 (적응형 복원력)
선박-육상 통신 시스템	- VPN 적용 - 보안 패치 및 패스워드 관리	- 강력한 종단간 암호화 (TLS 1.3+) - 통신 장비 보안 강화 (Hardening) - 네트워크 분리(DMZ)	- 통신 채널 다양성 (GEO+LEO 위성 등) - 통신 두절 대비 자동화된 비상 운항 계획 수립 및 훈련
ROC 자율운항 시스템	- 정기 보안 인식 교육 - 최소 권한 원칙 기반 접근 통제 - 강력한 패스워드 정책	- 다중 인증(MFA) 의무화 - 엔드포인트 탐지 및 대응(EDR) 솔루션 배포 - 중앙 집중 로깅 및 SIEM 구축	- 제로 트러스트 아키텍처(ZTA) 구현 - 사용자 및 개체 행위 분석 (UEBA) - 중요 명령에 대한 이중 승인 절차



사이버 리스크 평가 및 시나리오

시스템명	Level 1 (규제 준수)	Level 2 (구조화된 방어)	Level 3 (적응형 복원력)
Auto Berthing 시스템	- 기본 센서 유효성 검증 - 시스템 강화(Hardening) - 네트워크 분리	- 다중 센서 데이터 교차 검증 로직 구현 - 통신 무결성 확보(HMAC) - 보안 구역화(Zone & Conduit) 모델 적용	- 자동화된 장애 극복 로직(Fail-Safe Abort) - 암호화/인증 GNSS 도입 물리 모델(Digital Twin) 기반 이상 탐지
자율운항시스템	- 장비 목록 관리 - 기본 센서 오류(신호 없음 등) 탐지 기능 구현	- 다중 센서(RADAR, LIDAR, AIS 등) 데이터 교차 검증 로직 구현 - 펌웨어 업데이트 무결성 확인(해시값)	- 공급망 리스크 관리(C-SCRM) 프로그램 운영(SBOM 제출 의무화) - 펌웨어 업데이트 암호학적 서명 - AI 기반 이상 탐지
에너지 관리 시스템(EMS)	- IT/OT 네트워크 분리(방화벽) - OT 백신 - 정기 백업 및 복구 절차 수립	- IEC 62443 기반 보안 구역화(Zone & Conduit) 모델 적용 - OT 트래픽 IDS - 애플리케이션 화이트리스트	- 핵심 제어기 다양성 확보 - 자동화된 대응(SOAR 연동) - 비영속성(Non-Persistence) 아키텍처 설계
전기추진시스템 (EPS)	- 네트워크 분리 - 자산 관리 - 시스템 강화(Hardening)	- 마이크로 세분화(Zone & Conduit) - 심층 패킷 분석(DPI) 방화벽 - OT 네트워크 모니터링 (NIDS)	- 제로 트러스트 기반 마이크로 세분화 - 대역 외(Out-of-Band) 검증 - 보안 프로토콜 캡슐화 자동화된 대응(SOAR)
CBM 시스템	- 물리적 보안 강화(접근 통제, CCTV) - 기본 패스워드 변경	- 센서 데이터 통신 무결성 확보(HMAC) - 물리적 변조 방지	- 다중 센서 교차 검증 - 물리 모델(Digital Twin) 기반 이상 탐지
AR Navigation 시스템	- 정기 취약점 점검 및 패치 - 자산 목록 관리	- 입력 데이터 출처 인증 및 교차 검증 - 보안 개발 수명주기(Secure SDLC) 적용 요구	- 모든 펌웨어/소프트웨어 업데이트에 대한 암호학적 서명 의무화 - SBOM 관리(C-SCRM) - AI 기반 이상 탐지
AVM 시스템	- 카메라 네트워크 분리 - 시스템 강화(Hardening)	- 보안 구역 및 통로 아키텍처 적용 - 영상 데이터 무결성 검증 (디지털 워터마킹, HMAC)	- 다중 센서(RADAR, LIDAR 등) 교차 검증 - 공급망 리스크 관리(C-SCRM)

사이버 리스크 평가 및 시나리오

- Level 1은 IACS UR E26/E27과 같은 국제 규정을 준수하고 기본적인 사이버 위생(Cyber Hygiene)을 확립하는 필수적인 기준선이다.
- Level 2는 이를 기반으로 IEC 62443의 보안 구역화(Zone & Conduit)와 같은 원칙을 적용하여, 침해가 발생하더라도 피해 확산을 구조적으로 방지하는 견고한 심층 방어 아키텍처를 구축한다.
- Level 3는 알려지지 않은 제로데이 공격에도 시스템의 핵심 기능이 유지될 수 있도록 NIST 및 MITRE CREF의 개념을 차용하여, 위협을 사전에 예측하고 공격으로부터 학습하여 적응하는 능동적인 사이버 복원력을 공학적으로 구현하는 단계이다.

자율운항선박 성숙도 기반 보호기술

5.1. 자율운항선박 리스크 관리 전략	106
5.2. 보안 아키텍처 원칙	108
5.3. Level 1 통제: 규제 준수 기반 확보	109
5.4. Level 2 통제: 구조화된 OT 방어 구축	111
5.5. Level 3 통제: 적응형 복원력	113



자율운항선박 성숙도 기반 보호기술

5.1. 자율운항선박 리스크 관리 전략

제4장 리스크 평가를 종합한 결과, 자율운항 생태계 전반에 걸쳐 반복적으로 나타나는 세 가지 핵심적인 리스크 관리 목표가 확인되었다.

목표 1: 공생적 리스크 연속체 (The Symbiotic Risk Continuum): IT와 OT의 분리 불가능한 연결

이번 평가에서 가장 높은 위험도(R=20)로 평가된 두 가지 시나리오는 '통신 채널 하이재킹'과 'ROC 운영자 워크스테이션 침해'였다. 이 두 리스크는 독립적이지 않으며, 오히려 하나의 치명적인 인과 사슬을 형성한다. ROC 운영자를 대상으로 한 스피어피싱 공격과 같은 전형적인 IT 보안실패가, 선박과 육상을 잇는 디지털 생명선을 통해 즉각적으로 선박 충돌과 같은 재앙적인 OT 안전사고로 전환될 수 있음을 명확히 보여준다. 과거 선박에서 존재했던 IT와 OT 간의 물리적 격리(Air-Gap)는 더 이상 존재하지 않으며, 그 자리를 육상 사무실에서부터 대양의 선박까지 리스크를 실시간으로 전송하게 된다.

이는 보안을 더 이상 IT 부문과 OT 부문의 개별적인 영역으로 관리할 수 없음을 의미한다. ROC의 기업 IT 환경과 MASS의 산업 제어 환경을 포괄하는 통합된 보안 거버넌스, 통합된 모니터링(SOC), 그리고 통합된 사고 대응 체계를 구축하는 것은 단순한 모범 사례가 아니라, 안전 운항을 위한 근본적인 전제 조건이다.

목표 2: 데이터 무결성 (Data Integrity): 정보의 무기화

고위험 시나리오의 대다수는 데이터 탈취(기밀성)나 서비스 마비(가용성)가 아닌, 데이터의 '변조(Tampering)'와 '신원 위장(Spoofing)'에 기반하고 있다. 자율운항시스템의 센서 데이터 스푸핑(4.2.3), CBM 시스템의 고장 징후 은폐(4.2.6), AR 항해 시스템의 오버레이 변조(4.2.7), AVM 시스템의 영상 피드 교체(4.2.8) 시나리오가 이를 증명한다. 공격의 목표는 시스템을 파괴하는 것이 아니라, 시스템이 인지하는 현실을 왜곡시켜 시스템 스스로가 위험한 결정을 내리도록 만드는 것이다. 즉, 선박의 자동화된 운항 로직 자체가 공격자의 무기가 된다.

이는 자율운항선박과 같은 사이버-물리 시스템(CPS)에서는 데이터의 '무결성'이 안전과 직결되는 가장 중요한 보안 속성임을 시사한다. 보안의 전쟁터는 비밀을 지키는 것에서 시스템이 인지하는 데이터의 '진실성'을 지키는 것으로 이동했다. 따라서 향후 보안 투자는 센서에서부터 최종 제어기(actuator)에 이르는 데이터 파이프라인 전반의 신뢰성을 보장하는 기술에 집중되어야 한다.



자율운항선박 성숙도 기반 보호기술

목표 3: 공급망 위협 (The Supply Chain Threat): 상속되는 불안전성

자율운항시스템(4.2.3)과 AR 항해 시스템(4.2.7)의 리스크 시나리오는 공격이 선박이나 ROC가 아닌, 제3자 부품 공급업체의 개발 서버에서 시작되는 공급망 공격의 위험성을 명확하게 보여준다. 선박과 ROC가 완벽한 보안 아키텍처를 갖추고 있더라도, 불안정한 부품이나 소프트웨어를 사용하여 구축되었다면 그 취약점을 그대로 물려받게 된다. 보안의 경계는 더 이상 선박의 위성 안테나에서 끝나지 않으며, 생태계를 구성하는 모든 하드웨어 및 소프트웨어 공급업체의 개발 환경까지 확장된다.

이러한 위협은 방화벽이나 접근 통제와 같은 전통적인 방어 체계를 완전히 우회하여, 소프트웨어 업데이트와 같은 신뢰할 수 있는 채널을 통해 전달된다. 이는 선사가 단순히 기술의 구매자를 넘어, 계약, 감사, 투명성 요구(예: 소프트웨어 자재명세서(SBOM) 제출 의무화)를 통해 전체 기술 공급망의 보안을 보증하는 데 적극적인 참여자가 되어야 함을 의미한다.



자율운항선박 성숙도 기반 보호기술

5.2. 보안 아키텍처 원칙

견고하고 복원력 있는 보안 아키텍처를 설계하기 위해 다음과 같은 핵심 원칙을 기반으로 한다.

- ❶ **심층 방어 (Defense-in-Depth)**: 단일 보안 솔루션이 무력화되더라도 다른 계층의 보안 통제가 위협을 차단하거나 지연시킬 수 있도록 네트워크, 시스템, 애플리케이션, 데이터 각 계층에 보안 장치를 중첩하여 구성한다. 이는 공격자가 최종 목표에 도달하기까지 여러 장애물을 거치게 만들어 공격 성공 가능성을 낮추고 탐지 기회를 높이는 전략이다.
- ❷ **네트워크 분리 및 세분화 (Segregation & Segmentation)**: 기능과 신뢰 수준이 다른 네트워크 영역을 분리하여 위협의 측면 이동(Lateral Movement)을 차단한다. 특히, 선박의 IT망과 OT망은 IACS UR E26에서 요구하는 바와 같이 강력하게 분리되어야 한다. 이는 하나의 시스템이 침해되더라도 피해가 선박 전체의 핵심 기능으로 확산되는 것을 방지하는 가장 기본적인 OT 보안 통제이다.
- ❸ **최소 권한 원칙 (Principle of Least Privilege)**: 모든 사용자, 시스템, 프로세스는 업무 수행에 필요한 최소한의 권한만을 부여 받아야 한다. 이를 통해 권한 상승 공격의 피해를 최소화하고, 내부자 위협이나 계정 탈취 시 피해 범위를 제한할 수 있다.
- ❹ **제로 트러스트 (Zero Trust)**: '절대 신뢰하지 말고, 항상 검증하라(Never Trust, Always Verify)'는 원칙에 따라, 네트워크 내외부를 막론하고 모든 접근 요청에 대해 강력한 인증과 권한 검사를 수행하여 내부자 위협 및 측면 이동 공격에 대응한다. 이는 전통적인 경계 기반 보안 모델의 한계를 극복하는 현대적인 보안 패러다임이다.



자율운항선박 성숙도 기반 보호기술

5.3. Level 1 통제: 규제 준수 기반 확보

성숙도 Level 1은 자율운항선박 생태계에 참여하는 모든 조직이 갖추어야 할 필수적인 보안 기준선이다. 이 단계의 목표는 IACS UR E26/E27와 ISO 27001의 요구사항을 충족하여 규제 준수를 달성하고, 기본적인 사이버 위생(Cyber Hygiene)을 확립하는 것이다.

5.3.1. MASS Level 1 통제 (IACS UR E26/E27 준수)

IACS UR E26/E27은 신조선에 대한 강제 규정으로, Level 1의 핵심 요구사항을 구성한다.

- 자산 및 네트워크 식별 (Identify):** 선박에 탑재된 모든 컴퓨터 기반 시스템(CBS)의 목록을 작성하고 IT와 OT 시스템으로 구분하여 관리해야 한다. 또한, 모든 시스템 간의 네트워크 연결 관계를 명확히 표현하는 토폴로지 다이어그램을 최신 상태로 유지해야 한다. 이는 모든 보안 활동의 가장 기본적인 출발점이다.
- 기본적인 시스템 보호 (Protect)**
 - **네트워크 분리:** 선원용 IT 네트워크와 항해/제어용 OT 네트워크 간의 불필요한 통신을 차단하여, 선원 PC의 랜섬웨어 감염이 항해 시스템으로 확산되는 것을 방지한다.
 - **경계 및 원격 접근 통제:** 외부 원격 접속 시 강력한 인증을 적용하고, 모든 장비의 기본 패스워드를 제거. 이는 공격자가 인터넷을 통해 시스템에 무단으로 접속하는 것을 막는 1차 방어선이다.
 - **이동식 미디어 통제:** 악성코드 검사를 거치지 않은 USB 메모리 등의 선내 OT 시스템 연결을 차단하여, 악성코드의 주요 유입 경로 중 하나를 통제한다.
 - **악성코드 방어:** 선내 IT 시스템 및 Windows 기반 OT 시스템에 백신 프로그램을 설치하고 최신 상태로 유지한다.
- 이상 행위 탐지 (Detect):** OT 네트워크 트래픽을 모니터링하여 비정상적인 활동이나 침해 징후를 탐지하고 경보를 발생시키는 기본적인 체계를 갖춘다.
- 사고 대응 및 복구 (Respond & Recover):** 주요 위협 시나리오별 대응 절차를 문서화하고, 핵심 시스템의 데이터와 설정을 주기적으로 백업하며, 신속하게 복원할 수 있는지 검증한다.

5.3.2. ROC Level 1 통제 (ISO 27001 기반)

ROC는 대규모 IT 인프라를 운영하므로, 정보보호 경영시스템(ISMS)의 국제 표준인 ISO 27001을 기반으로 관리체계를 수립해야 한다.

자율운항선박 성숙도 기반 보호기술

- **거버넌스 및 정책:** 최고 경영진의 지원 하에 공식적인 정보보호 정책 및 하위 지침을 문서화하고, 정보보호 최고책임자(CISO)를 포함한 명확한 역할과 책임을 정의한다.
- **리스크 및 자산 관리:** 정형화된 리스크 평가 프로세스를 수립하고 주기적으로 수행해야 한다. 또한, 하드웨어, 소프트웨어, 데이터를 포함한 모든 정보 자산의 목록을 유지하고 관리해야 한다.
- **핵심 통제 구현**
 - **접근 통제:** 최소 권한 원칙에 기반한 사용자 접근 통제 정책을 수립하고, 퇴사자 계정 관리, 정기적인 권한 검토 프로세스를 이행해야 한다.
 - **암호화:** 중요 데이터의 저장 및 전송 시 암호화를 적용하는 정책을 수립해야 한다.
 - **운영 보안 및 사고 관리:** 변경 관리, 악성코드 방어 등 기본적인 운영 보안 절차와 공식적인 사고 관리 프로세스를 수립해야 한다.



자율운항선박 성숙도 기반 보호기술

5.4. Level 2 통제: 구조화된 OT 방어 구축

Level 1이 개별적인 보안 통제의 집합이라면, Level 2는 이러한 통제들을 유기적으로 통합하여 견고한 '방어 아키텍처'를 구축하는 단계이다. 이 단계의 핵심은 위협이 한 지점에서 발생하더라도 전체 시스템으로 쉽게 확산되지 않도록 구조적인 방어 능력을 갖추는 것이다.

5.4.1 MASS Level 2 아키텍처 (IEC 62443 기반)

선박의 복잡한 OT 환경을 보호하기 위해, 산업 제어 시스템 보안 표준인 IEC 62443의 '보안 구역(Zones)'과 '통로(Conduits)' 모델을 적용하여 심층 방어 아키텍처를 설계해야 한다.

❶ **보안 구역화 모델 적용:** 선박의 OT 네트워크를 기능적 중요도와 리스크 수준에 따라 다음과 같은 최소 단위의 보안 구역으로 논리적/물리적으로 분리해야 한다.

- **Safety Zone:** 화재 및 가스 탐지, 비상정지(ESD) 시스템 등 선박의 최후 안전 보루 역할을 하는 최상위 보호 구역. 다른 네트워크와 강력하게 격리.
- **Control System Zone:** 자율운항, 추진, 전력 제어 등 선박의 핵심 기능을 수행하는 OT 시스템 구역.
- **Navigation Zone:** ECDIS, RADAR, GNSS 등 안전 항해에 필수적인 시스템 구역.
- **Monitoring Zone:** CBM, CCTV 등 감시 및 모니터링 시스템 구역.
- **Communication/DMZ:** 외부 통신 장비와 데이터 교환 서버가 위치하는 경계 구역.
이러한 구역화는 상대적으로 보안이 약한 CCTV 시스템(Monitoring Zone)의 침해가 핵심적인 추진 제어 시스템(Control Zone)으로 쉽게 확산되는 것을 구조적으로 방지한다.

❷ **통로 (Conduits)기반 접근 통제:** 모든 구역 간 통신은 반드시 OT 전문 방화벽과 같은 정의된 '통로'를 통해서만 이루어져야 한다. 이 통로에는 허가된 프로토콜과 IP 주소 외 모든 통신을 차단하는 'Deny-by-Default' 정책이 엄격하게 적용되어야 한다.

❸ **중요 구역별 시스템 보안 강화:**

- **사용자 식별 및 인증:** 공유 계정 사용을 금지하고, 개인별 계정에 역할 기반 접근 통제(RBAC)를 적용하여 최소한의 권한만 부여한다.
- **OT 환경 악성코드 방어:** PLC, HMI 등 임베디드 제어 시스템에는 리소스가 제한적이고 안정성이 중요하므로, 전통적인 백신 대신 사전에 허가된 실행 파일 외에는 모두 차단하는 '애플리케이션 화이트 리스팅' 기술을 적용한다.



자율운항선박 성숙도 기반 보호기술

- **시스템 및 정보 무결성:** 자율운항시스템의 핵심 로직이나 설정 파일이 비인가자에 의해 변경되는 것을 탐지하기 위해 파일 무결성 모니터링(FIM) 기술을 적용한다.

5.4.2. ROC Level 2 운영 (NIST CSF 기반)

ROC는 Level 2에서 본격적인 보안관제센터(SOC)로서의 기능적 역량을 강화해야 한다.

- ◉ **중앙 집중 모니터링 및 탐지:** 모든 핵심 시스템의 로그를 중앙으로 수집하고 분석하기 위한 SIEM(보안 정보 및 이벤트 관리) 솔루션을 구축해야 한다. 이를 통해 분산된 로그에서는 파악하기 어려운, 여러 시스템에 걸친 장기간의 지능형 공격 흐름을 파악할 수 있다. 또한, 운영자 워크스테이션 및 핵심 서버에는 EDR(엔드포인트 탐지 및 대응) 솔루션을 도입하여 파일리스(Fileless) 악성코드와 같은 지능형 위협을 탐지해야 한다.
- ◉ **체계적인 대응:** '운영자 계정 탈취', '선박 통신 하이재킹' 등 제4장에서 식별된 구체적인 위협 시나리오에 대한 상세한 대응 절차를 담은 '플레이북(Playbook)'을 개발해야 한다. 이는 사고 발생 시 담당자들이 혼란 없이 일관되고 신속하게 대응할 수 있도록 안내하는 계획서이다.
- ◉ **복구 및 연속성:** ROC 자체의 기능 마비를 대비한 포괄적인 업무 연속성 및 재해 복구(BC/DR) 계획을 수립하고 정기적으로 테스트해야 한다. 여기에는 화재나 자연재해에 대비하여 제2의 ROC와 같은 지리적 이중화 방안이 포함될 수 있다.



자율운항선박 성숙도 기반 보호기술

5.5. Level 3 통제: 적응형 복원력

성숙도 Level 3은 방어의 패러다임을 '사후 대응'에서 '사전 예측 및 적응'으로 전환하는 단계이다. 이 단계의 목표는 알려지지 않은 제로데이 공격이나 고도로 지능화된 위협에 직면하더라도, 시스템이 스스로를 보호하고 핵심 기능을 유지하며, 공격으로부터 학습하여 더욱 강해지는 '적응형 복원력'을 갖추는 것이다.

5.5.1. MASS Level 3 공학 (설계 기반 보안 및 복원력)

Level 3의 MASS 보안은 운영 단계에서 솔루션을 추가하는 방식으로는 달성할 수 없으며, 반드시 설계 및 개발 단계에서부터 공학적인 접근법을 통해 내재화되어야 한다.

❶ **시스템 보안 엔지니어링 (NIST SP 800-160)**: 자율운항 시스템 개발 전 과정에 보안 엔지니어링 프로세스를 통합해야 한다.

- **설계 단계 위협 모델링**: 아키텍처 설계 단계에서 STRIDE와 같은 정형화된 위협 모델링을 의무적으로 수행하여, 건조가 완료된 후에는 수정하기 어려운 설계상의 근본적인 취약점을 조기에 식별하고 제거해야 한다.

- **추적성 및 보증**: 모든 보안 요구사항은 설계, 구현, 테스트 단계까지 명확하게 추적되어야 한다. 또한, 단순히 테스트를 통과하는 것을 넘어, 시스템이 안전하다는 주장을 뒷받침하는 감사 가능한 증거의 집합인 '보증 케이스(Assurance Case)'를 개발하여 시스템의 신뢰성을 공식적으로 입증해야 한다.

❷ **사이버 복원력 기술 (MITRE CREF)**: 공격을 예측하고, 견디고, 복구하며, 적응하기 위한 고급 기술들을 아키텍처에 적용해야 한다.

- **다양성 (Diversity)**: 핵심 이중화 시스템(예: GNSS 수신기, 제어망 스위치)에 서로 다른 제조사의 제품을 사용하여, 특정 제조사의 제품에서 제로데이 취약점이 발견되더라도 전체 시스템이 동시에 마비되는 것을 방지한다.

- **비영속성 (Non-Persistence)**: 핵심 HMI 및 제어 애플리케이션 서버를 컨테이너 기술 등을 활용하여 사전에 제작된 안전한 '골든 이미지'를 기반으로 주기적으로 재시작되도록 설계한다. 이를 통해 시스템에 잠복해 있던 악성코드를 원천적으로 제거할 수 있다.

- **기만 (Deception)**: 공격자를 유인하고 분석하기 위해, Monitoring 및 DMZ 구역에 실제 OT 장비(예: PLC)를 모방한 허니팟(Honeypot)을 배치한다. 공격자가 허니팟에 접근하여 시도하는 공격 기법을 분석하여, 공격자의 TTPs(전술, 기술, 절차)에 대한 실시간 위협 인텔리전스를 확보하고 실제 시스템의 방어 체계를 강화하는 데 활용할 수 있다.



자율운항선박 성숙도 기반 보호기술

5.5.2. ROC Level 3 전략 (거버넌스 및 자동화)

Level 3의 ROC는 기술적 방어를 넘어, 전사적인 리스크 관리와 전략적 거버넌스 체계를 완성하고, 인간의 개입을 최소화하는 자동화된 방어 체계를 구축해야 한다.

🔗 전략적 거버넌스 (NIST CSF 2.0 'Govern'):

- **리스크 관리 전략:** 최고 경영진과 이사회가 사이버 리스크에 대한 조직의 수용 수준(Risk Appetite)을 공식적으로 설정하고, 모든 주요 사업 결정 시 이를 고려하도록 거버넌스 체계를 확립해야 한다.
- **사이버보안 공급망 리스크 관리 (Cybersecurity Supply Chain Risk Management, C-SCRM):** 위성 통신 사업자, 플랫폼 개발사, 클라우드 서비스 제공자 등 모든 기술 공급망과 관련된 리스크를 관리하기 위한 공식적인 C-SCRM 프로그램을 수립해야 한다. 모든 공급업체 계약서에 구체적인 보안 요구사항을 명시하고, 핵심 소프트웨어 공급업체에게는 소프트웨어 자재 명세서(SBOM) 제출을 의무화해야 한다.

🔗 DevSecOps 적용: ROC에서 자체 개발하는 모든 소프트웨어(예: 통합 디지털 운항 플랫폼)에 대해 CI/CD 파이프라인 내에 위협 모델링, 시큐어 코딩, 정적/동적 애플리케이션 보안 테스트(SAST/DAST)를 통합하는 DevSecOps 체계를 구축해야 한다. 이를 통해 소프트웨어 업데이트 시 새로운 취약점이 유입되는 것을 원천적으로 방지한다.

🔗 지능형 및 적응형 대응:

- **위협 인텔리전스:** 해사 분야에 특화된 위협 인텔리전스를 수집/분석하는 전담팀을 운영하고, 이를 SIEM, EDR, 선박 OT 데이터와 융합하여 전체 위협 가시성을 확보해야 한다.
- **적응형 대응 (SOAR):** SOAR(보안 오케스트레이션, 자동화 및 대응) 플랫폼을 도입하여 Level 2에서 개발한 주요 사고 대응 플레이북을 자동화해야 한다. 예를 들어, SIEM에서 '운영자 계정 탈취' 패턴이 탐지되면, SOAR는 자동으로 해당 계정을 비활성화하고, 관련 IP를 방화벽에서 차단하며, 보안 담당자에게 티켓을 생성하는 일련의 과정을 인간의 개입 없이 수 초 내에 완료해야 한다. 이는 야간이나 휴일에도 신속하고 일관된 대응을 보장하여 피해 확산을 최소화하는 Level 3의 핵심 기술이다.

7대 사이버보안 보호 기술

6.1. 인증 (스마트선박 보안모델: 인증-01~05)	119
6.2. 접근/권한 통제 (접근통제-01~13)	123
6.3. 암호화 (암호화-01~03)	128
6.4. 부인방지 (부인방지-01~05)	130
6.5. 가용성 및 복원력 (가용성-01,02)	134
6.6. AI 보안 (Securiy for AI)	137
6.7. 관리체계 (관리-01~06)	139
6.8. 성숙도 기반 자율운항선박 보호기술	143



7대 사이버보안 보호 기술

자율운항선박 보안모델은 기존 스마트선박 보안모델의 6대 보호 기술을 기반으로, 원격·무인 운항 환경의 복잡성과 위험성을 반영하여 각 기술을 심화하고 새로운 핵심 기술을 추가한 확장판이다.

기술적인 보안 아키텍처와 통제는 견고한 관리체계가 뒷받침될 때 비로소 지속 가능한 효과를 발휘할 수 있다. 본 7대 사이버보안 보호 기술은 조직의 정책, 프로세스, 인력이 기술과 조화를 이루도록 지원하는 필수적인 기술을 다룬다. 또한, 자율운항선박의 '두뇌' 역할을 하는 인공지능(AI) 시스템 자체의 보안이라는 새로운 과제를 심도 있게 조명한다. 데이터 오염, 적대적 공격과 같은 AI 고유의 위협을 분석하고, NIST AI 리스크 관리 프레임워크(RMF)와 같은 체계적인 접근법을 통해 AI의 신뢰성과 안전성을 확보하기 위한 방안을 제시함으로써, 미래 지향적인 보안 모델을 완성한다.

1. **인증 (Authentication)**: 정당한 사용자, 장비, 소프트웨어만이 시스템에 접근하도록 보장
2. **접근/권한 통제 (Access/Privilege Control)**: 인증된 사용자라도 허가된 정보와 기능에만 접근하도록 제한
3. **암호화 (Encryption)**: 데이터의 기밀성을 보장하고, 탈취되더라도 내용을 식별할 수 없도록 보호
4. **부인방지 (Non-repudiation)**: 모든 시스템 활동 기록을 위변조 불가능하게 보관하여 사후 추적 및 책임 규명을 보장
5. **가용성/복원력 (Availability/Resilience)**: 사이버 공격이나 시스템 장애 발생 시에도 핵심 서비스가 중단되지 않도록 보장
6. **AI보안(Security for AI)** : 자율운항선박에 도입된 AI 기반 의사결정 시스템의 신뢰성과 안전성을 보장하고, 데이터 오염(Data Poisoning)이나 적대적 공격(Adversarial Attack) 등으로 인해 AI 모델이 오작동하거나 기만 당하지 않도록 보호
7. **관리체계 (Management System)**: 기술적 보호조치가 효과적으로 운영되도록 지원하는 정책, 절차, 조직 등 관리적 통제

아래는 스마트선박 보안모델의 체계를 기준으로 각 보호 기술이 어떻게 확장되었는지를 설명한다.

7대 사이버보안 보호 기술

표 6-1 보호기술의 확장

스마트선박 6대 보호 기술	자율운항선박 7대 보호 기술	주요 변경 및 확장 사항
인증	인증	적용 범위 확장 (선박 → 선박 + ROC 운영자)
접근/권한 통제	접근/권한 통제	원격 제어 권한 및 OT Zone 간 통제 강화
암호화	암호화	종단간 암호화(E2EE)의 중요성 증대
부인방지	부인방지	원격 제어 명령에 대한 법적 증적 확보
가용성/기타	가용성/복원력	'가용성'에서 '사이버 복원력'으로 개념 확장
-	AI보안	[신규] 자율운항 의사결정 모델 보호
관리체계	관리체계	Secure SDLC, C-SCRM 등 생애주기 보안 통합

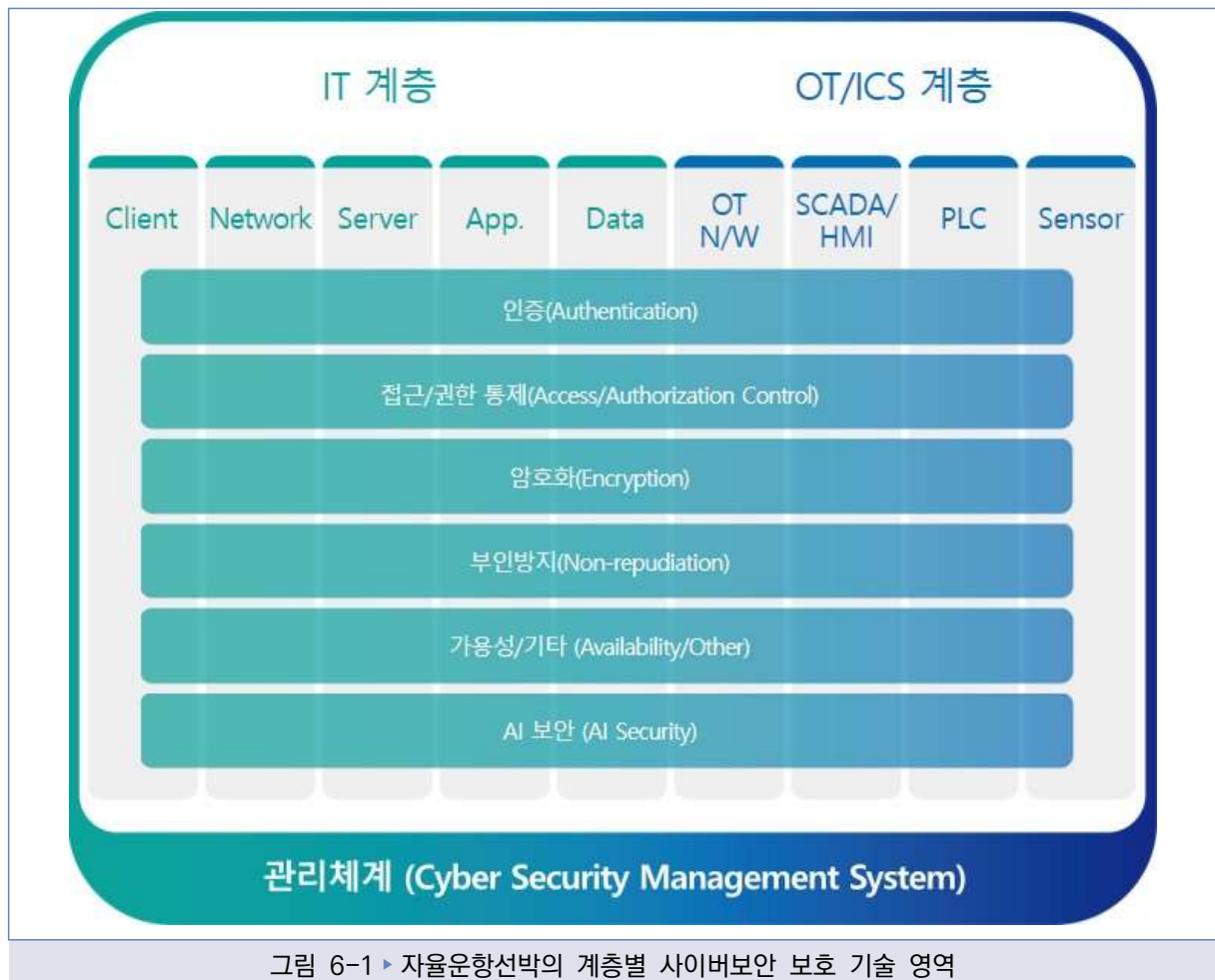


그림 6-1 ▶ 자율운항선박의 계층별 사이버보안 보호 기술 영역



7대 사이버보안 보호 기술

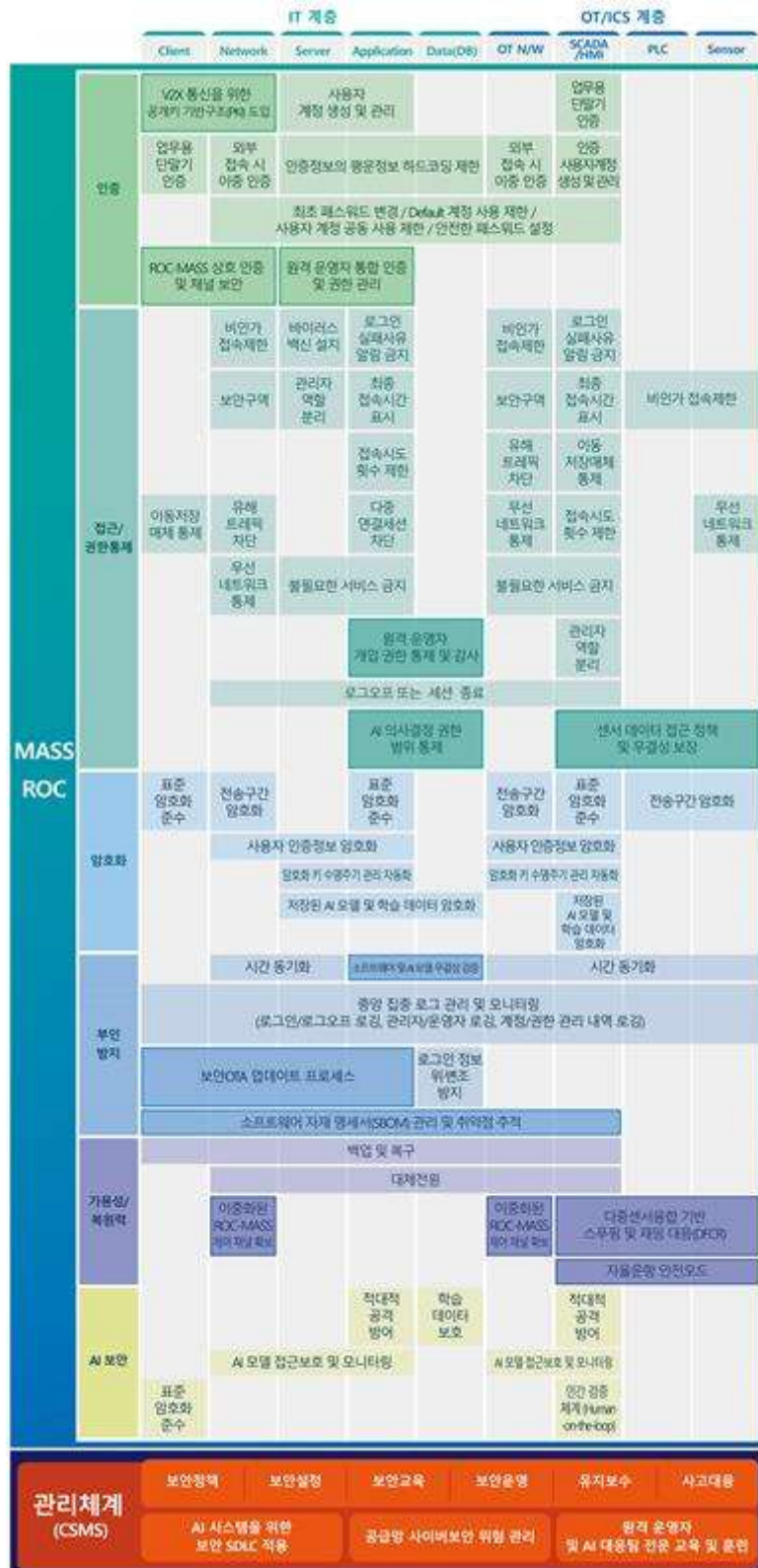


그림 6-2 ▶ 자율운항선박 보호 기술 아키텍처

7대 사이버보안 보호 기술

6.1. 인증 (스마트선박 보안모델: 인증-01 ~ 인증-05)

스마트선박 보안모델에서 정의된 인증(Authentication) 영역의 보호기술은 시스템, 데이터, 서비스에 접근하는 사용자나 시스템의 신원이 정당한지를 확인하는 절차에 중점을 둔다. 이는 사이버 보안의 가장 기본적인 방어선 역할을 한다. 기존 모델은 주로 선박에 승선한 인간 사용자의 계정 관리와 외부 기술자의 원격 유지보수와 같은 시나리오를 중심으로 구성되어 있다.

스마트선박 보안모델의 5개의 포괄적인 보호기술과 추가된 3개의 보호 기술을 통해 인증 체계를 강화한다.

- 인증-01: 사용자 계정 생성 및 관리
- 인증-02: 업무용 단말기 인증
- 인증-03: 외부 접속 시 이중 인증 (MFA)
- 인증-04: 인증정보의 평문정보 하드코딩 제한
- 인증-05: 패스워드 관리
- 인증-06: ROC-MASS 상호 인증 및 채널 보안
- 인증-07: V2X 통신을 위한 공개키 기반구조(PKI) 도입
- 인증-08: 원격 운영자(Remote Operator) 통합 인증 및 권한 관리

이러한 통제들은 강력한 패스워드 정책, 다중 인증(MFA) 적용 등을 통해 인간 사용자의 신원을 확인하고 비인가 접근을 차단하는 데 효과적이다. 그러나 이는 인간이 시스템에 접근하는(Human-to-Machine) 전통적인 보안 모델에 기반하고 있다.

6.1.1. MASS를 위한 확장된 통제: 기계 및 원격 운영자 신원 보안

MASS 환경은 인간과 기계의 상호작용뿐만 아니라, 기계와 기계(Machine-to-Machine, M2M) 간의 통신, 그리고 소수의 원격 운영자가 다수의 선박을 제어하는 새로운 인증 패러다임을 요구한다. 따라서 기존의 인증 통제는 다음과 같이 확장된다.

○ 인증-06: ROC-MASS 상호 인증 및 채널 보안

ROC와 MASS 간의 통신 링크는 일회성 로그인인 아닌, 지속적이고 상호적인 인증을 통해 채널 자체의 보안이 보장되어야 한다. 공격자가 통신 중간에 개입하여 제어 명령을 탈취하거나 변조하는 것을 방지하기 위해, 양측 시스템이 서로의 신원을 지속적으로 검증하는 상호 TLS(mTLS)와 같은 기술이 필수적이다. 각 선박과 ROC 시스템에 고유한 기기 인증서를 발급하고, 통신 세션 수립 시 양측이

7대 사이버보안 보호 기술

유효한 인증서를 제시해야만 암호화된 채널이 형성되도록 구성해야 한다.

○ 인증-07: V2X 통신을 위한 공개키 기반구조(PKI) 도입

자율운항선박은 주변 선박(V2V) 및 항만 인프라(V2I)와 안전 정보를 교환하기 위해 V2X 통신에 의존한다. 이러한 브로드캐스트 기반 통신 환경에서는 메시지 출처를 위조하는 스푸핑 공격이 치명적인 위협이 된다. 이를 방지하기 위해 신뢰할 수 있는 인증 기관(CA)이 각 선박과 인프라에 디지털 인증서를 발급하고 관리하는 공개키 기반구조(Public Key Infrastructure, PKI)의 도입이 필수적이다. 모든 V2X 메시지는 발신자의 개인키로 전자서명되어야 하며, 수신자는 공개키를 이용해 서명을 검증함으로써 메시지의 무결성과 발신자의 신뢰성을 확인할 수 있다.

○ 인증-08: 원격 운영자(Remote Operator) 통합 인증 및 권한 관리

ROC의 원격 운영자는 한 명 또는 소수의 팀이 다수의 선박을 동시에 모니터링하고 제어할 수 있다. 이러한 환경에서 각 선박 시스템별로 개별적인 ID와 패스워드를 사용하는 것은 확장성과 보안성 측면에서 매우 비효율적이다. 따라서 ROC 환경에는 중앙집중화된 통합 계정 및 접근 관리(Identity and Access Management, IAM) 솔루션 도입이 요구된다. 이를 통해 운영자는 단일 로그인(Single Sign-On, SSO)으로 허가된 모든 시스템에 접근할 수 있으며, 접근 상황(시간, 위치, 접속 단말 등)에 따라 인증 강도를 동적으로 조절하는 적응형 다중 인증(Adaptive MFA)을 적용하여 보안을 강화해야 한다.

이러한 인증 체계를 구축할 때, 특히 PKI 기반의 V2X 통신 보안은 장기적인 관점에서 설계되어야 한다. 선박의 운영 수명은 통상 20년 이상으로 매우 길다. 현재 표준으로 사용되는 암호화 알고리즘은 향후 10~15년 내에 등장할 것으로 예상되는 양자 컴퓨터에 의해 무력화될 수 있다. 따라서 지금 구축되는 PKI 시스템이 선박의 전체 수명 주기 동안 안전을 보장하기 위해서는, 향후 양자내성암호(Post-Quantum Cryptography, PQC) 알고리즘으로 쉽게 전환할 수 있는 '암호 민첩성(Crypto-agility)'을 확보해야 한다. 이는 단순히 현재의 위협을 방어하는 것을 넘어, 미래의 위협까지 고려한 동적이고 미래지향적인 보안 모델을 수립하는 것을 의미한다.

7대 사이버보안 보호 기술

표 6-2 인증 보호기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
인증-01	사용자 계정 생성 및 관리	CBS 시스템 사용자 정보의 주기적 현행화(최소 연 1회)	선내 승선원(있는 경우)과 모든 ROC 인력에 대한 사용자 계정의 생성, 변경, 비활성화에 대한 공식적인 절차를 수립하고 이행
인증-02	업무용 단말기 인증	승인 또는 등록되지 않은 단말기의 사용 제한	ROC 운영자 워크스테이션, 선내 HMI(Human-Machine Interface)를 포함한 모든 단말기는 네트워크에 연결되기 전에 고유하게 식별되고 인증되어야 함
인증-03	외부 접속 시 이중 인증	외부(원격지)에서 내부 정보시스템 접근 시 ID/PW 외 추가 인증 적용	신뢰할 수 없는 네트워크(예: 유지보수 엔지니어의 호텔 인터넷)에서 선박 시스템이나 ROC 플랫폼으로의 모든 원격 접근은 다중 인증(MFA)으로 보호
인증-04	인증정보의 평문정보 하드코딩 제한	사용자 인증 관련 정보를 로컬 디스크에 전자적 파일(실행 스크립트 등)로 또는 애플리케이션 개발 소스 코드에 저장 금지	자율운항 소프트웨어나 ROC 애플리케이션의 소스 코드 내에 패스워드나 API 키와 같은 인증 정보를 직접 삽입하는 행위를 금지
인증-05	패스워드 관리	- 최초 패스워드 변경: 최초/재발급 계정생성 시 패스워드 변경 - Default 계정 사용 제한: 상용 애플리케이션 또는 패키지에 존재하는 Default 계정 사용 제한 - 사용자 계정 공동 사용 제한: 사용자 계정들에 대해 공동(공유) 사용 제한 - 안전한 패스워드 설정: 사용자의 로그인 패스워드 생성 규칙(또는 입력값 검증) 필터링, 사용자 계정의 패스워드 주기적 변경	PLC, 센서 등 모든 OT 장비는 설치 시 제조사 기본 패스워드를 반드시 변경
인증-06	ROC-MASS 상호 인증 및 채널 보안	-	선박과 ROC 시스템에 고유한 기기 인증서를 발급하고, 통신 세션 수립 시 양측이 유효한 인증서를 제시해야만 암호화된 채널이 형성되도록 구성

7대 사이버보안 보호 기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
인증-07	V2X 통신을 위한 공개키 기반구조 (PKI) 도입	-	모든 V2X 메시지는 발신자의 개인키로 전자서명되어야 하며, 수신자는 공개키를 이용해 서명을 검증함으로써 메시지의 무결성과 발신자의 신뢰성 확보
인증-08	원격 운영자 통합 인증 및 권한 관리	-	- ROC 환경에는 중앙집중화된 통합 계정 및 접근 관리(IAM) - 접근 상황(시간, 위치, 접속 단말 등)에 따라 인증 강도를 동적으로 조절하는 적응형 다중 인증(Adaptive MFA) 적용



7대 사이버보안 보호 기술

6.2 접근/권한 통제 (스마트선박 보안모델 접근통제-01 ~ 접근통제-13)

접근/권한 통제(Access/Privilege Control)는 인증을 통과한 합법적인 사용자가 구체적으로 어떤 정보나 시스템 기능에 접근하고 실행할 수 있는지를 제어하는 메커니즘이다. 스마트선박 보안모델은 "최소 권한의 원칙(Principle of Least Privilege)"을 핵심 원칙으로 삼아, 내부자 위협이나 악성코드 감염 시 피해를 최소화하는 것을 목표로 한다.

스마트선박 보안모델의 13개의 포괄적인 보호기술과 추가된 3개의 보호 기술을 통해 선박 내부의 물리적, 논리적 접근을 통제한다.

- 접근통제-01: 이동저장매체 통제
- 접근통제-02: 비인가 접속 제한
- 접근통제-03: 보안 구역
- 접근통제-04: 유해 트래픽 차단
- 접근통제-05: 무선 네트워크 통제
- 접근통제-06: 로그오프 또는 세션종료
- 접근통제-07: 바이러스 백신 설치
- 접근통제-08: 관리자 역할 분리
- 접근통제-09: 불필요한 서비스 금지
- 접근통제-10: 로그인 실패 사유 알림 금지
- 접근통제-11: 최종 접속시간 표시
- 접근통제-12: 접속 시도 횟수 제한
- 접근통제-13: 다중 연결세션 차단
- 접근통제-14: AI 의사결정 권한 범위 통제
- 접근통제-15: 원격 운영자 개입 권한 통제 및 감사
- 접근통제-16: 센서 데이터 접근 정책 및 무결성 보장

이러한 통제들은 주로 선내에 물리적으로 존재하는 인간 운영자와 시스템 간의 상호작용을 안전하게 관리하는 데 초점을 맞추고 있다.



7대 사이버보안 보호 기술

6.2.1. MASS를 위한 확장된 통제: AI 권한 범위 설정 및 원격 개입 통제

MASS 환경에서는 접근 주체가 인간뿐만 아니라 AI 시스템 자체로 확장된다. 또한, ROC의 원격 운영자는 강력한 개입 권한을 가지므로, 이 권한의 오남용을 방지하기 위한 새로운 통제 메커니즘이 필요하다.

● 접근통제-14: AI 의사결정 권한 범위 통제

AI의 자율성은 무한정 허용될 수 없다. 이 보호기술은 AI의 운영 권한에 대해 명확하고 상황 인식적인 경계를 설정하고 기술적으로 강제하는 것을 요구한다. 예를 들어, AI는 망망대해에서는 항로 최적화에 대한 완전한 자율권을 가질 수 있지만, 복잡한 항만 내에서의 접근 기동이나 기존 항로 계획을 크게 벗어나는 결정에 대해서는 반드시 원격 운영자의 승인을 받도록 제한해야 한다. 이는 AI에 대한 기술적인 '교전규칙(Rules of Engagement)'을 시스템에 내장하는 것과 같다.

● 접근통제-15: 원격 운영자 개입 권한 통제 및 감사

원격 운영자는 AI의 실패나 예상치 못한 상황에 대응하기 위해 강력한 개입 능력을 보유해야 한다. 그러나 이 권한은 잠재적인 오용 및 사고의 원인이 될 수 있다. 이 보호기술은 원격 운영자의 권한을 최소 권한 원칙에 따라 세분화하고, 특히 조향이나 추진 제어와 같이 안전에 직결되는 시스템에 대한 수동 개입은 '이중 통제(Dual Control)' 원칙에 따라 다른 운영자의 추가 승인을 요구하도록 규정한다. 또한, 모든 원격 개입 행위는 변경이 불가능한 형태로 기록되어 사후 추적 및 감사가 가능해야 한다.

● 접근통제-16: 센서 데이터 접근 정책 및 무결성 보장

선박의 모든 시스템이 모든 센서 데이터에 접근할 필요는 없다. 이 보호기술은 센서 데이터 스트림을 논리적으로 분리하여, 각 시스템이 업무 수행에 필요한 최소한의 데이터에만 접근하도록 강제한다. 예를 들어, 선내 인포테인먼트 시스템이 항해용 LiDAR나 관성항법장치(INS)의 원시 데이터에 접근하는 것을 원천적으로 차단함으로써, 중요하지 않은 시스템의 침해가 핵심 센서 데이터의 기밀성 및 무결성을 훼손하는 것을 방지한다.

이러한 접근 통제 모델을 설계할 때, 원격 운영자의 이중적인 역할을 깊이 있게 고려해야 한다. 원격 운영자는 AI 시스템의 오류를 바로잡는 최후의 안전장치인 동시에, 피로나 판단 착오, 혹은 악의적인 의도로 인해 시스템 전체를 위험에 빠뜨릴 수 있는 단일 장애점(Single Point of Failure)이 될 수도 있다. 따라서 단순히 원격 개입을 '허용'하는 수준의 통제는 불완전하다. 시스템은 원격 개입 자체에 내재된 '위험'을 관리하도록 설계되어야 한다. 이는 **접근통제-15 원격 운영자 개입 권한 통제 및 감사**와 같은 통제가 단순한 접근 허가 기능을 넘어, 이중 승인 정책, 모든 원격 명령에 대한 위변조 방지 감사 로그 생성 의무화 등과 같은 견제와 균형의 장치를 포함해야 함을 의미한다. 즉, 시스템은 합법적이고 긴급한 개입은 신속하게 지원하되, 비정상적이거나 잘못된 조작은 어렵게 만들고 즉시 탐지할 수 있도록 설계되어야 한다.

7대 사이버보안 보호 기술

표 6-3 접근통제 보호기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
접근통제 -01	이동저장매체 통제	이동저장매체(USB메모리, SD메모리, CD/DVD RW 등)를 통한 정보 유출 방지	OT 네트워크 내 모든 시스템에 대해 악성코드 검사를 거치지 않은 USB 메모리 등 비인가 이동식 매체의 사용을 차단하기 위한 엄격한 정책과 기술적 통제(포트 차단, 보안 USB 등)를 적용
접근통제 -02	비인가 접속 제한	정보시스템(서버시스템 및 네트워크 시스템)의 관리 목적으로 접속이 필요한 경우, 사용자 계정 및 접속 가능한 IP, MAC 설정 등을 통해 접속 권한 최소화	OT 방화벽을 통해 제어 구역(Control Zone), 항해 구역(Navigation Zone) 등 보안 구역 간의 통신 규칙을 엄격하게 통제
접근통제 -03	보안 구역	네트워크 영역 분리를 통한 접근 제어(권한 없는 접근에 대한 통제)	-
접근통제 -04	유해 트래픽 차단	웜이나 DoS/DDoS에 대한 대응 및 유해 트래픽/불법적 접근 차단	-
접근통제 -05	무선 네트워크 통제	무선랜을 통한 무선 네트워크 사용 통제	선내 모든 무선 통신(Wi-Fi, Bluetooth 등)은 강력한 암호화(예: WPA3) 및 인증으로 보호하고, 핵심 제어 네트워크와는 엄격히 분리

7대 사이버보안 보호 기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
접근통제 -06	로그오프 또는 세션종료	로그인 후 일정 시간 키보드 또는 마우스 등의 장치를 통한 입력이 없을 경우, 자동으로 로그오프 또는 세션 종료 적용	-
접근통제 -07	바이러스 백신 설치	바이러스 백신 설치 및 진단/업데이트 실시	-
접근통제 -08	관리자 역할 분리	서버 시스템 관리자 / 운영자 / 보안관리자의 계정 분리	선박 제어 명령은 “ROC 감독자만 가능하다”와 같이 접속 위치, 시간 등 상황에 따라 접근을 동적으로 제어하는 속성 기반 접근통제(ABAC)를 도입하여 보다 세분화된 권한 관리 적용
접근통제 -09	불필요한 서비스 금지	각 정보시스템은 해당 시스템에서 제공하는 서비스 외 불필요한 서비스 제공 금지	-
접근통제 -10	로그인 실패 사유 알림 금지	단말기 또는 업무 애플리케이션에 로그인 시 로그인 실패에 대한 실패 사유 게시 금지	-
접근통제 -11	최종 접속시간 표시	사용자 계정의 최종 접속시간 표기를 통해 계정침해 여부를 확인할 수 있는 기능 제공	-
접근통제 -12	접속시도 횟수 제한	로그인 반복시도(Brute Force 공격)에 의한 사용자 계정 및 패스워드 유추 가능성 제한	-
접근통제 -13	다중 연결세션 차단	동일 사용자 계정에 의한 다중 연결세션 제한	-
접근통제 -14	AI 의사결정 권한 범위 통제	-	복잡한 항만 내에서의 접안 기동이나 기존 항로 계획을 크게 벗어나는 결정에 대해서는 반드시 원격 운영자의 승인을 받도록 제한

7대 사이버보안 보호 기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
접근통제 -15	원격 운영자 개입 권한 통제 및 감사	-	원격 운영자의 권한을 최소 권한 원칙에 따라 세분화하고, 특히 조향이나 추진 제어와 같이 안전에 직결되는 시스템에 대한 수동 개입은 '이중 통제(Dual Control)' 원칙에 따라 다른 운영자의 추가 승인을 요구
접근통제 -16	센서 데이터 접근 정책 및 무결성 보장	-	센서 데이터 스트림을 논리적으로 분리하여, 각 시스템이 업무 수행에 필요한 최소한의 데이터에만 접근하도록 강제



7대 사이버보안 보호 기술

6.3. 암호화 (스마트선박 보안모델: 암호화-01 ~ 암호화-03)

암호화(Encryption)는 권한 없는 자가 데이터를 해독할 수 없도록 변환하여 데이터의 기밀성(Confidentiality)을 보장하는 핵심적인 보안 기술이다. 스마트선박 보안모델은 전송 중인 데이터(Data-in-Transit)와 저장된 데이터(Data-at-Rest)를 보호하기 위한 기본적인 암호화 요구사항을 정의한다.

스마트선박 보안모델의 3개의 포괄적인 보호기술과 추가된 2개의 보호 기술을 통해 데이터 보호를 강화한다.

- 암호화-01: 표준 암호화 준수
- 암호화-02: 전송구간 암호화
- 암호화-03: 사용자 인증 정보 암호화
- 암호화-04: 저장된 AI 모델 및 학습 데이터 암호화
- 암호화-05: 암호화 키 수명주기 관리 자동화

이러한 보호기술들은 검증된 암호화 알고리즘의 사용을 의무화하고, 선박과 육상 간의 통신 채널 및 중요 정보 저장소의 보안을 위한 기반을 마련한다.

6.3.1. MASS를 위한 확장된 통제: 고가치 데이터 스트림 보호

MASS 환경에서는 스마트선박보다 훨씬 더 방대하고 민감한 데이터가 실시간으로 교환된다. 제어 명령, 센서 데이터, AI 모델 업데이트 등은 단순한 정보가 아니라 선박의 물리적 움직임을 직접 제어하는 핵심 자산이므로, 이들의 기밀성과 무결성을 보장하기 위해 암호화 통제가 더욱 강화되고 구체화되어야 한다.

○ 암호화-02의 확장

기존의 '전송구간 암호화'는 MASS의 모든 핵심 데이터 흐름을 포괄하도록 명시적으로 확장되어야 한다. 여기에는 ROC-MASS 간의 모든 제어 및 원격 측정 데이터 링크, V2X 통신 채널, 그리고 육상으로 전송되는 모든 센서 데이터 피드가 포함된다. 특히, 단순히 데이터를 암호화하는 것을 넘어 데이터가 전송 중에 변조되지 않았음을 보장하는 무결성 보호 기능이 결합된 인증 암호화(Authenticated Encryption) 방식(예: AES-GCM)의 사용이 필수적이다.

○ 암호화-04: 저장된 AI 모델 및 학습 데이터 암호화

자율운항의 핵심인 AI 모델과 이를 학습시키는 데 사용된 데이터셋은 매우 가치 있는 지적 자산이자 핵심 운영 자산이다. 만약 경쟁사나 공격자가 AI 모델을 탈취하면 기술 유출로 이어질 수 있으며, 학습



7대 사이버보안 보호 기술

데이터가 유출되거나 변조되면 모델의 신뢰성이 심각하게 훼손될 수 있다. 이 보호기술은 선박 내 저장 장치와 ROC 및 클라우드 인프라에 저장된 AI 모델 파일과 학습 데이터셋을 반드시 암호화하여 보호할 것을 의무화한다.

❶ 암호화-05: 암호화 키 수명주기 관리 자동화

수십, 수백 척의 자율운항선박으로 구성된 선단을 운영할 경우, 수많은 보안 채널과 암호화된 데이터 저장소에 사용되는 암호화 키를 수동으로 관리하는 것은 불가능하며 매우 위험하다. 이 보호기술은 암호화 키의 생성, 배포, 교체(순환), 폐기 등 전체 수명주기를 안전하고 효율적으로 관리하기 위한 자동화된 키 관리 시스템(Key Management System, KMS)의 도입을 요구한다. 이를 통해 인간의 개입을 최소화하고, 키 유출의 위험을 줄이며, 정기적인 키 교체를 통해 보안 수준을 지속적으로 유지할 수 있다.

표 6-4 암호화 보호기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
암호화-01	표준 암호화 준수	암호화가 필요한 경우 상급 기관(국정원, KISA 등)이 권고하는 알고리즘 사용	국제적으로 공인되고 취약점이 발견되지 않은 최신 암호화 알고리즘 및 프로토콜(예: AES-256, TLS 1.3) 사용
암호화-02	전송구간 암호화	외부로 대량의 정보 또는 주요 정보를 전송할 경우 암호화 통신 채널 적용	선박과 ROC 간, 그리고 선내 핵심 시스템 간에 전송되는 모든 원격 제어 및 데이터 전송은 VPN, TLS 1.3 등 강력한 암호화 채널을 적용하여 종단간(End-to-End) 암호화를 구현
암호화-03	사용자 인증 정보 암호화	사용자 로그인 인증 정보는 단방향(복호화 불가) 암호화 적용	-
암호화-04	저장된 AI 모델 및 학습 데이터 암호화	-	선박 내 저장 장치와 ROC 및 클라우드 인프라에 저장된 AI 모델 파일과 학습 데이터셋을 암호화하여 저장
암호화-05	암호화 키 수명주기 관리 자동화	-	암호화의 핵심 요소인 '키'를 안전하게 생성·보관·폐기하는 체계적인 키 수명주기를 관리하여 암호화 체계의 신뢰성을 확보



7대 사이버보안 보호 기술

6.4. 부인방지 기술 (스마트선박 보안모델: 부인방지-01 ~ 부인방지-05)

부인방지(Non-repudiation)는 특정 행위나 이벤트가 발생했다는 사실을 행위자가 사후에 부인할 수 없도록 객관적인 증거를 제공하는 보안 속성이다. 스마트선박 보안모델은 주로 로그 기록의 생성, 보호, 시간 동기화를 통해 사고 발생 시 원인을 규명하고 책임 소재를 명확히 하는 데 중점을 둔다.

스마트선박 보안모델의 로그 관련 3개의 보호기술을 1개로 통합하고, 추가된 3개의 보호 기술을 통해 부인방지를 강화한다.

- 부인방지-01: 중앙 집중 로그 관리 및 모니터링 (로그인/로그오프 로깅, 관리자/운영자 로깅, 계정/권한 관리 내역 로깅)
- 부인방지-02: 시간 동기화
- 부인방지-03: 로깅 정보 위변조 방지
- 부인방지-04: 소프트웨어 및 AI모델 무결성 검증
- 부인방지-05: 보안OTA 업데이트 프로세스
- 부인방지-06: 소프트웨어 자재 명세서(SBOM) 관리 및 취약점 추적

이러한 통제들은 주로 인간 사용자의 행위나 시스템 이벤트를 기록하고 보존하여, 사후 포렌식 분석을 위한 신뢰할 수 있는 증거를 확보하는 데 초점을 맞추고 있다.

6.4.1. MASS를 위한 확장된 통제: 소프트웨어 및 모델 출처 보증

MASS 환경에서 부인방지의 개념은 "누가 무엇을 했는가?"라는 질문을 넘어, "이 소프트웨어는 무엇이며, 신뢰할 수 있는가?"라는 근본적인 질문으로 확장되어야 한다. 선박의 모든 행동을 결정하는 소프트웨어와 AI 모델의 출처와 무결성을 보증하는 것이 무엇보다 중요해진다. 소프트웨어 공급망(Software Supply Chain) 전체의 신뢰성을 확보하는 것이 새로운 부인방지의 핵심 과제가 된다.

○ 부인방지-04: 소프트웨어 및 AI 모델 무결성 검증

선박이나 ROC 시스템에 새로운 소프트웨어나 AI 모델이 설치되거나 실행되기 전, 해당 파일의 무결성을 반드시 검증해야 한다. 이는 사전에 등록된 신뢰할 수 있는 해시(Hash) 값이나 개발사의 디지털 서명을 확인함으로써 이루어진다. 이 절차를 통해 변조되거나 허가되지 않은 악성 코드가 시스템에서 실행되는 것을 원천적으로 차단할 수 있다. 이는 시스템의 모든 행위가 신뢰할 수 있는 코드로부터 비롯되었음을



7대 사이버보안 보호 기술

보증하는 첫 단계이다.

❶ 부인방지-05: 보안 OTA(Over-the-Air) 업데이트 프로세스

무선 통신을 통한 OTA 업데이트는 MASS의 기능을 최신 상태로 유지하는 데 필수적이지만, 동시에 공급망 공격의 주요 경로가 될 수 있다. 이 보호기술은 포괄적인 보안 OTA 업데이트 프로세스를 수립할 것을 요구한다. 이 프로세스는 다음의 요소를 반드시 포함해야 한다:

- 모든 업데이트 패키지에 대한 신뢰할 수 있는 출처의 디지털 서명
- 암호화되고 상호 인증된 전송 채널
- 업데이트 적용 전 선박 시스템에 의한 패키지 무결성 검증
- 운영체제(OS)의 변조 여부를 확인하는 보안 부팅(Secure Boot) 절차

❷ 부인방지-06: 소프트웨어 자재 명세서(SBOM) 관리 및 취약점 추적

현대의 소프트웨어는 수많은 오픈소스 및 제3자 라이브러리로 구성되어 있어, 이들 구성 요소에 내재된 취약점을 파악하는 것이 매우 중요하다. 이 보호기술은 소프트웨어 공급사가 모든 납품 소프트웨어에 대해 구성 요소 목록을 상세히 기술한 소프트웨어 자재 명세서(Software Bill of Materials, SBOM)를 의무적으로 제출하도록 요구한다. 선사 및 운영사는 이 SBOM 정보를 중앙에서 관리하고, 공개된 취약점 데이터베이스와 지속적으로 대조하여 잠재적 위험을 사전에 식별하고 신속하게 대응할 수 있는 체계를 갖추어야 한다.

이러한 확장된 부인방지 개념은 AI 시스템에 대한 신뢰를 구축하는 데 있어 근본적인 역할을 한다. 전통적인 시스템에서 로그는 인간 행위에 대한 '사후 책임'을 묻기 위한 증거로 사용된다. 그러나 자율운항 시스템의 운영은 미래에 AI가 내릴 결정에 대한 '사전 신뢰'를 기반으로 한다. 만약 공급망 단계에서 AI 모델이 손상되었다면, 그 모델이 내리는 모든 결정과 그 결정에 대한 로그 기록은 신뢰할 수 없으며 포렌식 관점에서도 의미를 잃게 된다. 따라서 AI의 출력(결정 및 로그)을 신뢰하기 위해서는, 먼저 AI의 입력(모델 코드 자체)을 반박할 수 없을 정도로 검증할 수 있어야 한다. 이는 **부인방지-06 소프트웨어 자재 명세서(SBOM) 관리 및 취약점 추적**과 같은 모델 무결성 검증 통제가 단순한 보안 점검 항목을 넘어, 전체 자율운항 시스템의 운영 신뢰성을 담보하는 핵심적인 전제 조건임을 의미한다.

7대 사이버보안 보호 기술

표 6-5 부인방지 보호기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
부인방지-01	중앙 집중 로그 관리 및 모니터링	• (부인방지-01) 사용자의 로그인 성공/실패의 일시와 로그오프 일시 등 로깅 • (부인방지-02) 정보시스템 관리자/운영자의 활동 내역 로깅 • (부인방지-03) 계정 및 권한에 대한 부여/변경/말소 이력 로깅	• (통합) 개별적인 로깅 요구사항을 넘어, 선박과 ROC의 모든 시스템 로그를 중앙 SIEM으로 통합 수집하여 연관 분석 및 안전한 보관을 강조한다. 무작위 대입 공격과 같은 이상 패턴을 능동적으로 탐지하고 대응하는 체계 구축 - 모든 시스템에 대한 성공 및 실패한 로그인 시도를 사용자 정보, 출발지 IP 주소, 타임스탬프와 함께 안전하게 기록 - 권한 있는 사용자가 수행하는 모든 중요한 행위, 특히 시스템 설정 변경, 보안 정책 수정, 직접적인 제어 명령 등을 상세히 기록 - 사용자 권한에 대한 모든 변경 이력(계정 생성, 역할 변경, 계정 삭제 등)을 기록

7대 사이버보안 보호 기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
부인방지 -02	시간 동기화	• 시간 동기화	• 선박과 ROC의 모든 시스템은 신뢰할 수 있는 시간 소스(예: GPS와 동기화된 NTP 서버)에 동기화되어, 사고 조사 시 일관된 타임라인을 확보
부인방지 -03	로깅 정보 위/변조 방지	• 로깅 정보의 위/변조 방지 적용	• 로그 파일이 비인가자에 의해 수정되거나 삭제되는 것을 방지하기 위해 WORM(Write-Once Read-Many) 매체 사용, 디지털 서명, 또는 안전하게 격리된 로그 서버로의 실시간 전송과 같은 기술을 적용한다.
부인방지 -04	소프트웨어 및 AI모델 무결성 검증	-	• 선박이나 ROC 시스템에 새로운 소프트웨어나 AI 모델이 설치되거나 실행되기 전, 해당 파일의 무결성을 반드시 검증
부인방지 -05	보안OTA 업데이트 프로세스	-	• 보안 OTA 업데이트는 다음 요소를 반드시 포함해야 한다. - 모든 업데이트 패키지에 대한 신뢰할 수 있는 출처의 디지털 서명 - 암호화되고 상호 인증된 전송 채널 - 업데이트 적용 전 선박 시스템에 의한 패키지 무결성 검증 - 운영체제(OS)의 변조 여부를 확인하는 보안 부팅(Secure Boot) 절차
부인방지 -06	소프트웨어 자재 명세서(SBOM) 관리 및 취약점 추적	-	• 소프트웨어 공급사가 모든 납품 소프트웨어에 대해 구성 요소 목록을 상세히 기술한 소프트웨어 자재 명세서(Software Bill of Materials, SBOM)를 의무적으로 제출하도록 요구



7대 사이버보안 보호 기술

6.5. 가용성 및 복원력 (스마트선박 보안모델: 가용성-01, 가용성-02)

가용성(Availability)과 복원력(Resilience)은 인가된 사용자가 필요할 때 시스템과 서비스에 중단 없이 접근하고 사용할 수 있도록 보장하는 능력을 의미한다. 이러한 관점에서 스마트 선박 보안 모델은 시스템 이중화 및 데이터 백업을 활용하여, 잠재적인 시스템 장애에 효과적으로 대응하고 서비스의 복원력을 확보하는 방안을 제시한다.

이러한 관점에서 보안 모델은 기존의 '가용성' 영역을 '복원력'으로 확대 한다. 이는 단순한 시스템 장애 대응을 넘어, 예측 불가능한 위협과 복합적인 장애 상황에서도 안전운항을 확보하기 위함이다.

이를 위해 기존의 스마트선박 보호 기술(백업, 이중화 등)에 3개의 핵심 기술을 추가하여, 아래와 같이 총 5개의 기술로 구성된 '복원력' 영역을 정의한다.

- 복원력-01: 백업 및 복구
- 복원력-02: 대체 전원
- 복원력-03: 다중센서융합 기반 스푸핑 및 재밍 대응(DFCR)
- 복원력-04: 자율운항 안전모드
- 복원력-05: 이중화된 ROC-MASS 제어 채널 확보

이러한 통제들은 하드웨어 고장이나 데이터 손실과 같은 일반적인 장애 상황에서 서비스 연속성을 유지하기 위한 필수적인 기반을 제공한다.

6.5.1. MASS를 위한 확장된 통제: 사이버-물리 및 AI 특화 공격에 대한 복원력

MASS 환경에서 가용성은 단순한 시스템 작동 여부를 넘어, 사이버 공격을 받는 상황에서도 핵심 기능을 안전하게 유지하고 신속하게 복구할 수 있는 '사이버 복원력(Cyber Resilience)'의 개념으로 확장되어야 한다. MASS의 가용성은 시스템 충돌뿐만 아니라, 선박의 인식과 지능을 직접적으로 조작하려는 공격에 의해 심각하게 위협받을 수 있다. 따라서 시스템은 공격을 받더라도 임무를 안전하게 지속할 수 있는 능력을 갖추어야 한다.

○ 복원력-03: 다중센서융합 기반 스푸핑 및 재밍 대응 (Data Fusion Cyber Resilience, DFCR)

단일 종류의 센서(예: GPS)에만 의존하는 것은 매우 위험하다. 이 보호기술은 여러 종류의 센서(예: GPS, 관성항법장치(INS), LiDAR, 레이더, 카메라)로부터 수집된 데이터를 상호 비교하고 검증하는 센서 융합(Sensor Fusion) 알고리즘의 도입을 의무화한다. 각기 다른 물리적 원리로 작동하는 센서들

7대 사이버보안 보호 기술

간의 데이터에 중대한 불일치가 발생할 경우, 이는 특정 센서에 대한 스푸핑 또는 재밍 공격의 징후로 판단할 수 있다. 시스템은 이러한 이상 징후를 탐지하면 즉시 경보를 발생시키고, 공격받는 센서의 신뢰도를 낮추며, 다른 신뢰할 수 있는 센서 데이터를 기반으로 항해를 지속해야 한다.

❶ 복원력-04: 자율운항 안전모드

핵심 통신 링크나 주 항법 AI 모델과 같은 중요 구성 요소가 공격으로 인해 마비되더라도, 선박이 통제 불능 상태에 빠져서는 안 된다. 이 보호기술은 사전에 정의된 안전 상태로 시스템을 전환하는 장애 극복(Fail-Safe) 및 기능 저하(Degraded Mode) 모드의 설계를 의무화한다. 예를 들어, 주 통신 두절 시 선박은 자동으로 현재 위치를 유지(Station-Keeping)하거나, 사전에 계획된 비상 안전 항로를 따라 저속으로 운항하는 모드로 전환되어야 한다. 이러한 안전 모드는 자동 또는 원격 운영자의 명령에 의해 활성화될 수 있어야 한다.

❷ 복원력-05: 이중화된 ROC-MASS 제어 채널 확보

고대역폭의 주 위성 통신 링크는 성능이 우수하지만, 공격이나 장애 발생 시 단일 장애점이 될 수 있다. 이 보호기술은 주 통신 채널과 물리적으로 완전히 분리된 예비 제어 채널의 확보를 요구한다. 이 예비 채널은 다른 위성 네트워크를 사용하여 상대적으로 낮은 대역폭을 가지더라도, 선박의 상태를 확인하고 최소한의 제어 명령을 전송할 수 있는 비상 통신 수단을 제공해야 한다. 이를 통해 주 통신망이 완전히 마비되더라도 선박에 대한 최소한의 통제력을 유지하고 회복을 시도할 수 있다.

표 6-6 가용성 및 복원력 보호기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
복원력-01	백업 및 복구	주요 CBS의 안정적 서비스를 위한 정기적 백업 및 신속한 복구 계획 마련	모든 핵심 시스템(소프트웨어, 설정, 데이터)에 대한 정기적이고 자동화된 백업과, 신속한 복원을 위한 검증된 절차를 수립한다
복원력-02	대체 전원	주요 CBS가 사이버 공격, 전력 중단 또는 기타 비상 상황에서 운영을 지속할 수 있도록 보조 전원 시스템을 마련. 선박의 항해, 통신, 안전 및 보안 장치가 항상 작동할 수 있도록 충분한 전원 공급을 보장	핵심 제어 및 통신 시스템이 무정전 전원 공급 장치(UPS)와 비상 발전기에 연결되어 있음을 보장한다.

7대 사이버보안 보호 기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
복원력-03	다중센서융합 기반 스푸핑 및 재밍 대응 (DFCR)	-	여러 종류의 센서(예: GPS, 관성항법장치(INS), LiDAR, 레이더, 카메라)로부터 수집된 데이터를 상호 비교하고 검증하는 센서 융합(Sensor Fusion) 알고리즘의 도입
복원력-04	자율운항 안전모드	-	주 통신 두절 시 선박은 자동으로 현재 위치를 유지하거나, 사전에 계획된 비상 안전 항로를 따라 저속으로 운항하는 모드로 전환한다.
복원력-05	이중화된 ROC-MASS 제어 채널 확보	-	주 통신 채널과 물리적으로 완전히 분리된 예비 제어 채널의 확보



7대 사이버보안 보호 기술

6.6. AI 보안 (Security for AI)

본 절은 자율운항 의사결정 과정의 핵심을 이루는 인공지능(AI) 및 머신러닝(ML) 모델 고유의 보안 문제를 다루는 새로운 보호 기술 영역이다. 목표는 AI 모델이 신뢰할 수 있고, 견고하며, 외부 조작에 저항성을 갖도록 보장하는 것이다. 이는 자율운항선박 보안모델에서 새롭게 추가된 핵심 요구사항이다.

- AI-01: 학습 데이터 보호
- AI-02: 적대적 공격 방어
- AI-03: AI 모델 접근보호 및 모니터링
- AI-04: 인간 검증 체계 (Human-on-the-loop)

6.6.1. MASS를 위한 확장된 통제: AI 모델의 생명주기 보안

- AI-01: 학습 데이터 보호: AI 모델의 성능과 신뢰성은 학습 데이터의 품질과 무결성에 직접적으로 의존한다. 만약 공격자가 학습 데이터셋에 악의적인 데이터를 주입(Data Poisoning)하면, AI 모델은 잘못된 판단을 내리도록 '오염'될 수 있다. 이 보호기술은 AI 모델의 학습 단계부터 데이터의 무결성을 보장할 것을 요구한다. 이를 위해 학습 데이터 저장소에 대한 엄격한 접근 통제를 적용하고, 데이터의 출처와 모든 변경 이력을 추적할 수 있는 데이터 출처 추적(Data Provenance) 기술을 도입해야 한다. 또한, 학습에 사용하기 전 통계적 기법을 통해 데이터셋 내의 이상치를 탐지하고 제거하는 절차를 의무화하여 데이터 오염 공격의 위험을 완화해야 한다.
- AI-02: 적대적 공격 방어: 적대적 공격은 인간의 눈으로는 거의 감지할 수 없는 미세한 노이즈를 카메라 이미지에 추가하거나, 특정 패턴의 물리적 패치를 부착하여 AI의 인식 시스템을 속이는 공격이다. 이로 인해 AI는 다른 선박을 '부두'로 오인하거나 아예 인식하지 못하여 충돌 사고를 유발할 수 있다. 이 보호기술은 이러한 AI 특화 공격에 대한 방어 능력 확보를 요구한다. 핵심 방어 전략 중 하나는 센서 융합(Sensor Fusion)으로, 카메라, LiDAR, RADAR 등 서로 다른 원리로 작동하는 센서의 데이터를 교차 검증하여 하나의 센서가 속더라도 이상 징후를 탐지하는 것이다. 또 다른 전략은 적대적 학습(Adversarial Training)으로, 의도적으로 조작된 적대적 샘플들을 학습 과정에 포함시켜 모델이 이러한 공격에 대한 강건성(Robustness)을 갖추도록 훈련하는 것이다.
- AI-03: AI 모델 접근보호 및 모니터링: 학습이 완료된 AI 모델 파일 자체는 핵심적인 지적 자산이자 운영 자산이다. 이 모델이 유출되거나 변조될 경우, 심각한 보안 사고로 이어질 수 있다. 이 보호기술은 저장된 AI 모델 파일의 무결성과 기밀성을 보장할 것을 요구한다. 모델 파일에 대해 해시(Hash) 값 계산이나 디지털 서명을 적용하여 실행 전 무결성을 검증하고(부인방지-04 소프트웨어 및 AI모델

7대 사이버보안 보호 기술

무결성 검증), 파일 자체를 암호화하여(암호화-04 저장된 AI 모델 및 학습 데이터 암호화) 비인가 접근으로부터 보호해야 한다. 또한, 운영 중인 AI 모델의 출력(예: 판단 결과, 신뢰도 점수)을 지속적으로 모니터링하여, 출력이 비정상적으로 편향되거나 예측 불가능한 패턴을 보일 경우 이를 실시간으로 탐지하고 보안 관리자에게 경고하거나 사전에 정의된 안전 모드로 시스템을 전환해야 한다.

- AI보안-04: 인간 검증 체계(Human-on-the-loop):** 아무리 발전된 AI라도 모든 상황을 완벽하게 처리할 수는 없으므로, 최종적인 안전장치로서 인간의 감독과 개입은 필수적이다. 이 보호기술은 'Human-on-the-loop' 개념을 시스템 설계에 반영할 것을 요구한다. 특히 충돌 회피, 항로 이탈 등 안전과 직결되는 AI의 중요 의사결정은 자동으로 실행되기 전, ROC의 원격 운영자가 최종적으로 검토하고 승인하는 절차를 마련해야 한다. 이와 더불어, AI의 판단 과정을 사후에 추적하고 분석할 수 있도록 설명가능 AI(Explainable AI, XAI) 기술을 도입해야 한다. AI 모델은 "왜 그런 결정을 내렸는지"에 대한 근거를 인간이 이해할 수 있는 형태의 로그로 남겨야 한다. 예를 들어, "14:32 UTC에 객체 #123(충돌 항로상 선박, 신뢰도 98%)이 CPA/TCPA 임계값을 위반하여 좌현 변침 실행"과 같은 상세 로그는 사고 발생 시 원인 규명과 책임 소재 파악에 결정적인 증거를 제공한다.

표 6-7 AI보안 보호기술

코드	보호기술	확장된 요구사항 (MASS)
AI-01	학습 데이터 보호	학습 데이터에 대한 엄격한 접근 통제, 데이터 출처 추적 기술(Data Provenance) 도입, 학습 전 통계적 이상치 탐지 및 제거
AI-02	적대적 공격 방어	다중 센서(카메라, LIDAR, RADAR) 데이터 교차 검증(Sensor Fusion), 의도적으로 조작된 데이터를 학습시켜 모델의 강건성을 높이는 '적대적 학습(Adversarial Training)' 적용
AI-03	AI 모델 접근보호 및 모니터링	학습 완료된 AI 모델 파일에 대한 무단 접근 및 변조를 방지하고, 운영 중인 AI의 출력이 비정상적으로 편향될 경우 이를 실시간으로 탐지하여 경고하거나 안전 모드로 전환
AI-04	인간 검증 체계 (Human-on-the-loop)	- 충돌 회피 등 안전과 직결된 AI의 중요 의사결정은 ROC 관제사와 같은 사람이 최종 검토하고 승인하는 절차를 마련하여 AI의 오판으로 인한 사고를 방지하는 최종 안전장치를 구축 - AI 모델이 결정의 근거를 로그로 남기도록 설계(Explainable AI, XAI)

7대 사이버보안 보호 기술

6.7. 관리체계 (스마트선박 보안모델: 관리-01 ~ 관리-06)

사이버보안 관리체계(Cyber Security Management System, CSMS)는 개별 보안 기술들을 조직의 정책 및 절차와 유기적으로 통합하여, 지속 가능한 보안 수준을 유지하기 위한 핵심 프레임워크이다. 즉, 일회성 조치가 아닌 체계적인 관리를 통해 보안을 내재화하는 과정이다.

본 보안 모델은 **계획-실행-점검-조치(PDCA) 사이클**에 기반한 CSMS를 적용하여, 지속적인 보안 위협 변화에 능동적으로 대응한다. 이 관리체계는 기존 6개의 통제 영역에서 추가된 3개의 영역으로 다음과 같이 9개의 핵심 보안 통제로 구성된다.

- 관리-01: 보안정책
- 관리-02: 보안설정
- 관리-03: 보안교육
- 관리-04: 보안운영
- 관리-05: 유지보수
- 관리-06: 사고대응
- 관리-07: AI 시스템을 위한 보안 소프트웨어 개발 생명주기(Secure SDLC) 적용
- 관리-08: 공급망 사이버보안 위험 관리
- 관리-09: 원격 운영자 및 AI 대응팀 전문 교육 및 훈련

이러한 관리 항목들은 사이버보안이 일회성 활동으로 끝나지 않고, 조직 내에서 지속적으로 개선되는 문화로 자리 잡기 위한 필수적인 기반을 마련한다.

6.7.1. MASS를 위한 확장된 통제: 복잡성, 공급망 및 인적 요소 관리

MASS의 복잡한 소프트웨어 아키텍처와 원격 운영이라는 특성은 기존의 관리체계에 새로운 차원의 요구사항을 추가한다. 관리의 범위는 선박 운영을 넘어 소프트웨어 개발, 공급망, 원격 운영자의 인적 요소까지 포괄해야 한다.

- 관리-07: AI 시스템을 위한 보안 소프트웨어 개발 생명주기(Secure SDLC) 적용

AI 시스템의 보안은 개발 초기 단계부터 고려되어야 한다. 이 보호기술은 AI 모델 개발 생명주기 전반에 걸쳐 보안 활동을 통합하는 보안 소프트웨어 개발 생명주기(Secure SDLC)의 적용을 의무화한다. 여기에는 설계 단계에서의 AI 위협 모델링, 개발 단계에서의 보안 코딩 준수, 제3자 라이브러리 취약점

7대 사이버보안 보호 기술

스캔(SBOM 활용), 그리고 배포 전 적대적 공격에 대한 체계적인 테스트 및 검증 절차가 포함된다.

❶ 관리-08: 공급망 사이버보안 위험 관리

MASS의 보안은 선박 건조, 시스템 통합, 소프트웨어 및 하드웨어 납품 등 전체 공급망의 보안 수준에 크게 의존한다. 이 보호기술은 공급망 참여업체(조선소, 기자재 제조사, 소프트웨어 개발사 등)에 대한 공식적인 사이버보안 위험 관리 프로그램의 수립을 요구한다. 계약서에 구체적인 보안 요구사항을 명시하고, 보안 감사 권한을 확보하며, SBOM(부인방지-08)과 같은 보안 개발 프랙티스의 증거 자료 제출을 의무화해야 한다.

❷ 관리-09: 원격 운영자 및 AI 대응팀 전문 교육 및 훈련

선박을 원격으로 제어하는 것은 실제 조타실에서 운항하는 것과는 전혀 다른 역량을 요구한다. 이 보호기술은 기존의 '관리-03 보안교육'을 확장하여, ROC 운영자를 위한 전문화된 시뮬레이터 기반 훈련 프로그램을 의무화한다. 이 훈련은 정상적인 운영 절차뿐만 아니라, 통신 두절, 센서 스푸핑, AI 오작동 등 다양한 사이버 공격 및 비상 상황에 대한 대응 절차를 포함해야 한다. 또한, AI 관련 사고 발생 시 원인을 분석하고 대응할 수 있는 AI 포렌식 전문 지식을 갖춘 사고대응팀을 구성하고 훈련해야 한다.

7대 사이버보안 보호 기술

표 6-8 관리체계 보호기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
관리-01	보안정책	선박 내 정보시스템(IT) 및 운영 기술(OT) 환경에서 일관된 보안 기준을 적용하고 사이버보안 목표, 원칙, 규칙 및 지침을 명시하고, 이를 준수할 책임을 조직 내 각 부서 및 개인에게 부여	사이버보안에 대한 조직의 최고 수준의 의지와 방향성을 명시
관리-02	보안설정	각 CBS는 안전하게 설정되어야 하며, 정기적으로 설정 상태를 점검하고 취약점을 수정하여 최신 보안 상태를 유지	모든 시스템을 안전하게 구성(Hardening) 하기 위한 공식적인 절차를 수립
관리-03	보안교육	- 선박의 모든 선원 및 관련 인력이 사이버보안 위협을 인지하고 대응할 수 있도록 교육 - 이 교육은 정기적으로 시행되어야 하며, 선원들이 각자의 역할에서 필요한 보안 조치를 이해하고 실천할 수 있어야 함	ROC 운영자, 선내 승무원 등 모든 인력에 대한 정기적이고 역할 기반의 보안 인식 교육을 실시
관리-04	보안운영	- 보안 운영에는 선박 시스템의 실시간 모니터링 및 경고 체계가 포함되며, 이를 통해 신속하게 위협을 탐지하고 대응 - 보안 운영 활동은 모니터링, 로그 검토, 취약점 관리 등을 상시 수행해야 함	-
관리-05	유지보수	- 선박 시스템 및 소프트웨어에 대한 정기적인 유지보수와 보안 패치 적용은 필수이며, 이 과정에서 보안 요구사항이 충분히 반영되어야 함 - 시스템 업데이트 시에는 보안 취약점에 대한 사전 검토와 테스트가 요구됨 - 자산이 폐기 또는 반출될 때 데이터가 완전히 삭제되고 복구되지 않도록 관리가 필요함	-

7대 사이버보안 보호 기술

코드	보호기술	정의 (스마트선박 보안모델)	확장된 요구사항 (MASS)
관리-06	사고대응	- 선박은 사이버 사고 대응 계획을 수립하고, 사고 발생 시 즉각적으로 대응할 수 있는 체계를 갖추어야 함 - 사고 대응 과정에서 발생한 모든 활동은 기록되어야 하며, 사고 후 복구 및 재발 방지를 위한 사례가 수집되고 개선에 반영되어야 함	공식적인 사고 대응 계획과 전담팀을 구성하고, 정기적인 모의 훈련을 통해 대응 역량을 검증
관리-07	AI 시스템을 위한 보안 소프트웨어 개발 생명주기 적용	-	소프트웨어 및 시스템 개발의 모든 단계(요구사항 분석부터 배포까지)에 보안 활동을 내재화하는 프로세스이다. 이는 취약점이 발생한 후 대응하는 것이 아니라, 개발 단계에서부터 예방한다.
관리-08	공급망 리스크 관리	-	하드웨어, 소프트웨어, 서비스를 제공하는 제3자 공급업체로부터 발생하는 보안 리스크를 식별, 평가, 완화하기 위한 포괄적인 절차를 수립 및 실행
관리-09	원격 운영자 및 AI 대응팀 전문 교육 및 훈련	-	ROC 운영자를 위한 전문화된 시뮬레이터 기반 훈련 프로그램과 AI 포렌식 전문 지식을 갖춘 사고대응팀을 구성하고 훈련해야 한다.



7대 사이버보안 보호 기술

6.8. 성숙도 기반 자율운항선박 보호기술

6.8.1. 자율운항선박 보호기술

본 보고서에서 제시된 스마트선박 보안모델의 확장판인 자율운항선박(MASS) 보안모델은 기존의 6대 보안 영역을 유지하면서, 자율운항 기술로 인해 발생하는 새로운 위협에 대응하기 위한 22개의 신규 및 확장된 보호기술을 포함한다. 아래의 표는 전체 통합 보안모델을 요약하여 보여준다.

표 6-9 자율운항선박 보안모델 보호기술 목록

영역	코드	보호기술	핵심 요약
인증	인증-01	사용자 계정 생성 및 관리	ROC 운영자 및 AI 서비스 계정을 포함한 통합 계정 라이프사이클 관리
	인증-02	업무용 단말기 인증	ROC 워크스테이션 등 모든 원격 접속 지점에 대한 엄격한 기기 인증
	인증-03	외부 접속 시 이중 인증	모든 ROC-MASS 원격 제어 세션에 적응형 MFA 기본 적용
	인증-04	인증정보의 평문정보 하드코딩 제한	모든 소프트웨어 구성요소에 비밀정보 관리 솔루션 사용 의무화
	인증-05	패스워드 관리	시스템 간 통신용 API 키, 서비스 계정 패스워드의 자동화된 순환 정책 포함
	인증-06	ROC-MASS 상호 인증 및 채널 보안	mTLS 등 기술을 이용한 ROC-MASS 간 통신 채널의 지속적인 상호 인증 및 암호화
	인증-07	V2X 통신을 위한 공개키 기반구조(PKI) 도입	전자서명 기반 PKI를 통한 V2X 메시지 위변조 방지 및 암호 민첩성 확보
	인증-08	원격 운영자 통합 인증 및 권한 관리	ROC 환경을 위한 SSO, 적응형 MFA 기반의 중앙 IAM 솔루션 도입
접근/권한 통제	접근통제-01~13	(스마트선박 모델 13개 기술)	선내 시스템 및 네트워크에 대한 물리적/논리적 접근 통제 기반
	접근통제-14	AI 의사결정 권한 범위 통제	AI의 자율적 의사결정 권한에 대한 상황 인식적, 기술적 경계 설정 및 강제
	접근통제-15	원격 운영자 개입 권한 통제 및 감사	최소 권한 및 이중 통제 원칙에 기반한 원격 개입 권한 관리 및 모든 행위 감사

7대 사이버보안 보호 기술

	접근통제-16	센서 데이터 접근 정책 및 무결성 보장	시스템별 센서 데이터 접근을 최소화하여 정보 유출 및 오용 방지
암호화	암호화-01	표준 암호화 준수	검증된 최신 암호화 알고리즘 및 프로토콜 사용 의무화
	암호화-02	전송구간 암호화	ROC-MASS 링크, V2X 등 모든 외부 통신 구간에 인증 암호화 적용
	암호화-03	사용자 인증 정보 암호화	저장된 모든 인증 정보(패스워드, 키 등)에 대한 강력한 암호화
암호화	암호화-04	저장된 AI 모델 및 학습 데이터 암호화	AI 모델 및 관련 데이터셋 등 핵심 지적 자산에 대한 저장 시 암호화 의무화
	암호화-05	암호화 키 수명주기 관리 자동화	분산된 MASS 환경의 암호화 키를 안전하게 관리하기 위한 자동화된 KMS 도입
부인방지	부인방지-01~05	(스마트선박 모델 5개 기술)	시스템 이벤트 및 사용자 행위에 대한 신뢰할 수 있는 로그 기록 생성 및 보호
	부인방지-06	소프트웨어 및 AI 모델 무결성 검증	실행 전 소프트웨어 및 AI 모델의 디지털 서명/해시 검증을 통한 변조 방지
	부인방지-07	보안 OTA(Over-the-Air) 업데이트 프로세스 확립	디지털 서명, 암호화 전송, 무결성 검증을 포함한 안전한 OTA 업데이트 절차 수립
	부인방지-08	소프트웨어 자재 명세서(SBOM) 관리	공급망 투명성 확보 및 제3자 구성요소 취약점 관리를 위한 SBOM 제출 및 관리
복원력	복원력-01	백업 및 복구	중요 데이터 및 시스템 설정의 정기적 백업 및 복구 절차 수립/테스트
	복원력-02	대체 전원	핵심 시스템의 운영 연속성을 위한 UPS 등 비상 전원 확보
	복원력-03	다중센서융합 기반 스푸핑 및 재밍 대응(DFCR)	다중 센서 데이터 교차 검증을 통한 센서 공격 탐지 및 신뢰도 조정
	복원력-04	자율운항 안전모드	시스템 장애 시 선박을 안전 상태로 유지하기 위한 사전 정의된 안전 모드 설계
	복원력-05	이중화된 ROC-MASS 제어 채널 확보	주 통신망 두절에 대비한 물리적으로 분리된 비상 제어 통신 채널 확보
AI보안	AI-01	학습 데이터 보호	학습 데이터에 대한 엄격한 접근 통제, 데이터 출처



7대 사이버보안 보호 기술

AI보안			추적 기술(Data Provenance) 도입, 학습 전 통계적 이상치 탐지 및 제거
	AI-02	적대적 공격 방어	다중 센서(카메라, LIDAR, RADAR) 데이터 교차 검증(Sensor Fusion) 및 적대적 학습(Adversarial Training)' 적용
	AI-03	AI 모델 접근보호 및 모니터링	AI 모델 파일에 대한 무단 접근 및 변조를 방지 및 AI의 출력이 비정상적으로 편향될 경우 경고하거나 안전 모드로 전환
	AI-04	인간 검증 체계 (Human-on-the-loop)	AI의 중요 의사결정은 사람이 최종 검토하고 승인하는 절차 적용하고, AI 모델이 결정의 근거를 로그로 남기도록 설계(Explainable AI, XAI)
관리체계	관리-01~06	(스마트선박 모델 6개 기술)	PDCA 기반의 전사적 사이버보안 정책, 운영, 교육, 사고대응 체계 수립
	관리-07	AI 시스템을 위한 보안 SDLC 적용	AI 개발 전 과정에 보안 활동을 통합하여 설계 단계부터 보안 내재화
	관리-08	공급망 사이버보안 위험 관리	계약, 감사 등을 통해 조선소, 기자재 업체 등 공급망 전반의 보안 수준 관리
	관리-09	원격 운영자 및 AI 대응팀 전문 교육 및 훈련	사이버 비상상황 대응을 위한 시뮬레이터 기반의 전문화된 인적 역량 강화

6.8.2. 성숙도 기반 통제 방안과 보호기술

다음 표는 자율운항선박의 다양한 핵심 시스템에 요구되는 보안 통제 방안을 성숙도 수준(Level 1, 2, 3)에 따라 종합적으로 정리한 최종 결과물이다. 각 수준별 권고 통제 방안은 이를 구현하기 위한 구체적인 보호기술 및 실행 방안과 연결되어, 자율운항선박 생태계의 사이버 복원력을 단계적으로 강화하기 활용된다.

표 6-10 성숙도 기반 통제 방안과 보호기술 목록

성숙도 수준	권고 통제 방안 (리스크평가)	보호기술 코드	보호기술
Level 1	VPN 적용	암호화-02	전송구간 암호화
	보안 패치 및 패스워드 관리	관리-02 인증-05	보안설정 패스워드 관리

7대 사이버보안 보호 기술

	정기 보안 인식 교육	관리-03	보안교육
	최소 권한 원칙 기반 접근 통제	접근통제-08	관리자 역할 분리
	강력한 패스워드 정책	인증-05	패스워드 관리
	자산 및 장비 목록 관리	관리-05	유지보수
	기본 센서 유효성 검증	접근통제-16	센서 데이터 접근 정책 및 무결성 보장
	네트워크 분리 및 보안 구역 설정	접근통제-03	보안 구역
	악성코드 방어 (OT 백신)	접근통제-07	바이러스 백신 설치
	정기 백업 및 복구 절차 수립	복원력-01	백업 및 복구
	시스템 강화 (Hardening)	관리-02	보안설정
	물리적 보안 강화	접근통제-01	이동저장매체 통제
	정기 취약점 점검 및 패치	관리-04	보안운영
Level 2	강력한 종단간 암호화 (TLS 1.3+)	암호화-02	전송구간 암호화
	통신 장비 보안 강화 (Hardening)	관리-02	보안설정
	네트워크 분리 (DMZ)	접근통제-03	보안 구역
	다중 인증 (MFA) 의무화	인증-03	외부 접속 시 이중 인증
	엔드포인트 탐지 및 대응 (EDR)	관리-04 관리-06	보안운영 사고대응
	중앙 집중 로깅 및 SIEM 구축	부인방지-01	중앙 집중 로그 관리 및 모니터링
	다중 센서 데이터 교차 검증	복원력-03	다중센서융합 기반 스푸핑 및 재밍 대응(DFCR)
	펌웨어 업데이트 무결성 확인	부인방지-06	소프트웨어 및 AI 모델 무결성 검증
	보안 구역화 (Zone & Conduit)	접근통제-03	보안 구역
	OT 트래픽 IDS/NIDS	관리-04	보안운영
	애플리케이션 화이트리스트링	접근통제-02	비인가 접속 제한
	심층 패킷 분석 (DPI) 방화벽	접근통제-02 접근통제-04	비인가 접속 제한 유해 트래픽 차단
	통신 무결성 확보 (HMAC)	암호화-02	전송구간 암호화



7대 사이버보안 보호 기술

Level 3	보안 개발 수명주기 (Secure SDLC) 적용 요구	관리-07	AI 시스템을 위한 보안 SDLC 적용
	영상 데이터 무결성 검증	암호화-02	전송구간 암호화
	통신 채널 다양성	복원력-05	이중화된 ROC-MASS 제어 채널 확보
	자동화된 비상 운항 계획	복원력-04	자율운항 안전모드
	제로 트러스트 아키텍처 (ZTA)	접근통제-02	비인가 접속 제한
	사용자 및 개체 행위 분석 (UEBA)	AI-03	AI 모델 접근보호 및 모니터링
	중요 명령에 대한 이중 승인 절차	접근통제-15	원격 운영자 개입 권한 통제 및 감사
	공급망 리스크 관리 (C-SCRM)	관리-08	공급망 사이버보안 위험 관리
	펌웨어/소프트웨어 암호학적 서명	부인방지-07	보안 OTA 업데이트 프로세스 확립
	AI 기반 이상 탐지	AI-02 AI-03	적대적 공격 방어 AI 모델 접근보호 및 모니터링
	핵심 제어기 다양성 확보	복원력-05	이중화된 ROC-MASS 제어 채널 확보
	자동화된 대응 (SOAR)	관리-06	사고대응
	대역 외 (Out-of-Band) 검증	복원력-03	다중센서융합 기반 스푸핑 및 재밍 대응(DFCR)
	물리 모델 (Digital Twin) 기반 이상 탐지	AI-03	AI 모델 접근보호 및 모니터링
	암호화/인증 GNSS 도입	인증-07	V2X 통신을 위한 공개키 기반구조(PKI) 도입



7대 사이버보안 보호 기술

본 보안모델에서 제시된 성숙도 기반 통제 방안과 보호기술 매핑은 자율운항선박 생태계의 모든 잠재적 위협에 대한 포괄적인 목록이 아니라, **리스크 기반 접근법(Risk-Based Approach)**에 따른 전략적 선택의 결과물이다. 이는 한정된 자원을 가장 시급하고 중대한 위협에 집중하여 최대의 보안 효과를 달성하기 위한 핵심 원칙을 반영한다.

본 모델의 제4장에서 수행된 사이버 리스크 평가는 통제 방안을 도출하는 근본적인 기준이 된다. 앞서 매핑된 권고 통제 방안들은 리스크 평가 결과 '높음(High)' 또는 '매우 높음(Very High)'으로 식별된 핵심 위협 시나리오를 효과적으로 완화하기 위해 최우선으로 요구되는 조치들을 선별한 것이다. 즉, 제6장에 기술된 전체 보호기술 목록이 자율운항선박에 적용 가능한 모든 보안 기술의 '도구 상자(Toolbox)'라면, 최종 권고안은 이 도구 상자에서 가장 시급하고 효과적인 도구들을 전략적으로 선택한 결과물이다.

이러한 접근법에서 성숙도 **Level 1**은 모든 자율운항선박이 기본적으로 갖춰야 할 '사이버 위생(Cyber Hygiene)'이자, IACS UR E26/E27과 같은 국제 규제를 준수하기 위한 필수적인 보안 기준선(Baseline)의 역할을 수행한다. 이는 기존 스마트선박 보안모델의 핵심 원칙을 계승하여, 특정 고위험 시나리오에 국한되지 않는 보편적인 보안 요구사항을 충족시키는 단계이다.

따라서, 최종 매핑 테이블에 포함되지 않은 보호기술들은 결코 불필요하거나 누락된 것이 아니다. 이들은 다음과 같은 중요한 역할을 수행하며, 조직의 보안 전략을 심화시키는 데 활용될 수 있는 예비 통제(Reserve Controls)의 성격을 갖는다.

- 1. 잔여 리스크 관리:** 해당 보호기술들은 리스크 평가에서 '중간(Medium)' 또는 '낮음(Low)'으로 평가된 위협에 대한 통제 방안으로 적용될 수 있다. 조직의 리스크 수용 수준(Risk Appetite)에 따라 이러한 잔여 리스크를 추가적으로 관리하고자 할 때 선택적으로 구현할 수 있다.
- 2. 심층 방어(Defense-in-Depth) 강화:** 특정 위협에 대해 이미 핵심 통제 방안이 매핑되었더라도, 추가적인 방어 계층을 구축하여 보안의 견고성을 높이기 위한 보조 통제로 활용될 수 있다. 예를 들어, '데이터 유출 방지(DLP)' 기술은 핵심 제어 시스템의 최우선 과제는 아닐 수 있으나, ROC의 IT 환경에서는 중요한 보조 통제가 될 수 있다.
- 3. 특정 운영 환경 대응:** 일부 보호기술은 모든 선박에 보편적으로 적용되기보다는, 특정 항로를 운항하거나 특정 화물을 운송하는 등 특별한 운영 환경에서 발생하는 고유한 리스크를 관리하기 위해 요구될 수 있다.

결론적으로, 본 보안모델은 '모든 것을 하라'가 아닌 '가장 중요한 것부터 하라'는 리스크 관리의 기본 원칙을 충실히 따르고 있다. 매핑되지 않은 보호기술들은 자율운항선박 생태계의 보안을 더욱 성숙시키기 위한 '전략적 예비 자산'으로서 그 의미를 가지며, 각 조직은 자체적인 상세 리스크 평가와 보안 목표에 따라 이들을 활용하여 보안 모델을 지속적으로 발전시켜 나가야 한다.

부록

A. 자율운항선박 성숙도 모델	150
B. 자율운항선박 보안솔루션 분류	156
C. 자율운항선박 AI 보안(Security for AI) 가이드	157
D. 용어 정의 및 약어	172
E. 참고 문헌	174

A. 자율운항선박 성숙도 모델

성숙도	Domain(영역)	요구사항	상세 내용
MASS-Level 1	자산 및 네트워크 식별 (Identify)	자산 목록 관리	선박에 탑재된 모든 컴퓨터 기반 시스템(Computer-Based Systems, CBS)에 대한 포괄적인 목록을 작성하고 지속적으로 최신화해야 한다. 이 목록은 운영기술(OT) 시스템과 정보기술(IT) 시스템으로 명확히 구분되어야 하며, 각 시스템의 소프트웨어 버전, 네트워크 설정 등의 상세 정보를 포함해야 한다.
MASS-Level 1	자산 및 네트워크 식별 (Identify)	네트워크 다이어그램	모든 시스템 간의 네트워크 연결 관계를 명확하게 표현하는 토폴로지 다이어그램을 작성하고 유지해야 한다. 이는 유선, 무선 및 외부 네트워크와의 모든 연결 지점을 포함해야 한다.
MASS-Level 1	시스템 보호 (Protect)	네트워크 분리	선원용 IT 네트워크와 항해/제어용 OT 네트워크 간의 불필요한 통신을 차단하여 위협의 측면 이동을 방지한다.
MASS-Level 1	시스템 보호 (Protect)	경계원격 접근 통제	외부 유지보수 인력의 원격 접속 시 강력한 인증(MFA)을 적용하고, 모든 접속 기록을 로깅하며, 장비의 기본 패스워드를 제거한다.
MASS-Level 1	시스템 보호 (Protect)	이동식 미디어 통제	악성코드 검사를 거치지 않은 USB 메모리 등 이동식 저장매체의 선내 OT 시스템 연결을 정책적, 기술적으로 차단한다.
MASS-Level 1	시스템 보호 (Protect)	악성코드 방어	선내 IT 시스템 및 일부 OT 시스템(Windows 기반 HMI 등)에 백신 프로그램을 설치하고 최신 상태로 유지한다.
MASS-Level 1	이상 행위 탐지 (Detect)	지속적 모니터링	OT 네트워크 트래픽을 분석하여 비정상적인 제어 명령, 허가되지 않은 통신 시도 등 침해 징후를 실시간으로 탐지하고 경보를 발생시킨다.
MASS-Level 1	사고 대응 및 복구 (Respond & Recover)	사고 대응 계획	랜섬웨어 감염, GPS 스푸핑 등 주요 위협 시나리오별 대응 절차를 문서화하고, ROC 및 선박 담당자 간의 역할과 비상 연락 체계를 정의한다.
MASS-Level 1	사고 대응 및 복구 (Respond & Recover)	백업 및 복구	자율운항시스템, 항해 시스템 등 핵심 시스템의 소프트웨어, 설정 파일, 데이터를 주기적으로 백업하고, 신속하게 복원할 수 있는지 검증한다.

성숙도	Domain(영역)	요구사항	상세 내용
MASS-Level 2	보안 구역 및 통로 설계 (Zones and Conduits)	보안 구역화 모델 적용	선박의 OT 네트워크 전체를 단순한 IT/OT 분리가 아닌, IEC 62443의 '보안 구역(Security Zones)'과 '통로(Conduits)' 모델에 따라 설계해야 한다.
MASS-Level 2	보안 구역 및 통로 설계 (Zones and Conduits)	핵심 보안 구역 정의	시스템의 기능적 중요도와 리스크 수준에 따라 다음과 같은 보안 구역을 최소 단위로 정의하고 구현해야 한다: (예시) * Safety Zone: 화재 및 가스 탐지(F&G), 비상정지(ESD) 시스템 등 선박의 최후 안전 보루(Last line of defense) 역할을 하는 최상위 보호 구역. 다른 네트워크와 물리적 또는 강력한 논리적 격리가 요구된다. * Control System Zone: 자율운항, 추진, 전력 제어 등 선박의 핵심 기능을 수행하는 OT 시스템 구역. * Navigation Zone: ECDIS, RADAR, GNSS 등 안전 항해에 필수적인 시스템 구역. * Monitoring Zone: 상태 기반 유지보수(CBM), CCTV 등 감시 및 모니터링 시스템 구역. * Communication/DMZ: VSAT, 5G 등 외부 통신 장비와 데이터 교환 서버가 위치하는 경계 구역.
MASS-Level 2	보안 구역 및 통로 설계 (Zones and Conduits)	통로 기반 접근 통제	모든 구역 간 통신은 반드시 정의된 통로(예: OT 전문 방화벽)를 통해서만 이루어져야 하며, 이 통로에는 허가된 트래픽 외 모든 것을 차단하는 'Deny-by-Default' 정책이 엄격하게 적용되어야 한다
MASS-Level 2	중요 구역별 시스템 보안 요구사항 (System Requirements)	사용자 식별 및 인증	핵심 제어 시스템 접근 시 개인별 계정을 사용하고, 역할에 따라 최소한의 권한만 부여(RBAC)한다.
MASS-Level 2	중요 구역별 시스템 보안 요구사항 (System Requirements)	악성코드 방어 (OT)	PLC, HMI 등 임베디드 제어 시스템에는 백신 대신, 사전에 허가된 실행 파일 외에는 모두 차단하는 화이트리스트 기술 적용한다.
MASS-Level 2	중요 구역별 시스템 보안 요구사항 (System Requirements)	시스템 및 정보 무결성	자율운항시스템의 핵심 로직(PLC 프로그램)이나 설정 파일이 변경될 경우 이를 탐지하고 경고하여 비인가된 수정을 방지한다.

성숙도	Domain(영역)	요구사항	상세 내용
MASS-Level 3	시스템 보안 엔지니어링 요구사항 (NIST SP 800-160)	생애주기 통합	보안 엔지니어링 프로세스는 선박의 설계, 건조, 통합, 운항, 폐선에 이르는 전 생애주기에 걸쳐 다른 엔지니어링 활동과 동시에, 그리고 통합적으로 수행되어야 한다. 보안은 별도의 단계가 아닌, 모든 단계에 스며드는 활동이어야 한다.
MASS-Level 3	시스템 보안 엔지니어링 요구사항 (NIST SP 800-160)	이해관계자 보호 요구 정의	기능 요구사항 정의에 앞서, 이해관계자(선주, 운항사, 규제기관 등)의 자산과 이익을 보호하기 위한 보안 목표를 공식적으로 정의해야 한다. (예: "추진 제어 시스템은 어떠한 경우에도 외부의 비인가된 원격 명령으로 인해 추진력을 상실해서는 안 된다.").
MASS-Level 3	시스템 보안 엔지니어링 요구사항 (NIST SP 800-160)	설계 단계 위협 모델링	자율운항시스템 및 원격 제어 인터페이스의 아키텍처 설계 단계에서 STRIDE와 같은 정형화된 위협 모델링을 의무적으로 수행해야 한다. 이를 통해 설계상의 취약점을 조기에 식별하고, 침투 저항성(penetration-resistant)이 높은 구조로 개선해야 한다.
MASS-Level 3	시스템 보안 엔지니어링 요구사항 (NIST SP 800-160)	추적성 및 보증	모든 보안 요구사항은 설계, 구현, 테스트 단계까지 명확하게 추적되어야 한다. 또한, 단순히 테스트를 통과하는 것을 넘어, 시스템이 안전하다는 주장을 뒷받침하는 감사 가능한 증거의 집합인 '보증 케이스(Assurance Case)'를 개발하여 시스템의 신뢰성을 공식적으로 입증해야 한다.
MASS-Level 3	사이버 복원력 요구사항 (MITRE CREF)	Analytic Monitoring (분석적 모니터링)	OT 네트워크 내부에 행위 기반 이상 탐지 시스템을 구축하여 정상적인 운항 프로파일에서 벗어나는 이벤트를 탐지해야 한다.
MASS-Level 3	사이버 복원력 요구사항 (MITRE CREF)	Diversity (다양성)	핵심 이중화 시스템(예: GNSS 수신기, 제어망 스위치)은 서로 다른 제조사의 제품을 사용하여 단일 취약점으로 인한 동시 장애를 방지해야 한다.
MASS-Level 3	사이버 복원력 요구사항 (MITRE CREF)	Coordinated Defense (조정된 방어)	각 보안 솔루션은 독립적으로 동작하는 것이 아니라, 유기적으로 연동되어야 한다.
MASS-Level 3	사이버 복원력 요구사항 (MITRE CREF)	Non-Persistence (비영속성)	핵심 HMI 및 제어 애플리케이션 서버는 사전에 제작된 안전한 '골든 이미지'를 기반으로 주기적으로 재시작되도록 설계해야 한다.

성숙도	Domain(영역)	요구사항	상세 내용
MASS- Level 3	사이버 복원력 요구사항 (MITRE CREF)	Deception (기만)	공격자를 유인하고 분석하기 위해, Monitoring 및 DMZ 구역에 실제 OT 장비(예: PLC)를 모방한 허니팟(Honeypot)을 배치해야 한다.
ROC- Level 1	거버넌스 및 정책	ISMS 수립	최고 경영진의 지원 하에 공식적인 정보보호 경영시스템(ISMS)을 수립하고, 이를 뒷받침하는 전사 정보보호 정책 및 하위 지침들을 문서화해야 한다.
ROC- Level 1	거버넌스 및 정책	역할 및 책임	정보보호최고책임자(CISO)를 포함한 명확한 정보보호 역할과 책임을 정의하고 조직 내에 공표해야 한다.
ROC- Level 1	리스크 및 자산 관리	리스크 평가	ROC의 정보 자산에 대한 위협과 취약점을 식별, 분석, 평가하는 정형화된 리스크 평가 프로세스를 수립하고 주기적으로 수행해야 한다.
ROC- Level 1	리스크 및 자산 관리	자산 목록	하드웨어, 소프트웨어, 데이터(항해 데이터, 선박 정보 등), 서비스를 포함한 모든 정보 자산의 목록을 유지하고 관리해야 한다.
ROC- Level 1	핵심 통제	접근 통제	최소 권한 원칙에 기반한 사용자 접근 통제 정책을 수립하고, 사용자 등록, 권한 부여, 정기적인 권한 검토 프로세스를 이행해야 한다.
ROC- Level 1	핵심 통제	암호화	저장 데이터 및 전송 데이터의 기밀성 보호를 위한 암호화 통제 정책을 수립하고 적용해야 한다.
ROC- Level 1	핵심 통제	운영 보안 및 사고 관리	변경 관리, 악성코드 방어 등 운영 보안 절차를 문서화하고, 정보보호 침해사고 발생 시 대응하기 위한 공식적인 사고 관리 프로세스를 수립해야 한다.
ROC- Level 1	식별 (Identify)	상황 이해	단순한 자산 목록을 넘어, 원격 제어, 항로 계획 등 ROC의 핵심 비즈니스 프로세스와 데이터 흐름을 식별하고, 이들이 의존하는 IT 인프라와의 관계를 명확히 맵핑해야 한다.

성숙도	Domain(영역)	요구사항	상세 내용
ROC-Level 1	식별 (Identify)	취약점 관리	정기적인 취약점 스캐닝, 식별된 취약점에 대한 리스크 기반의 우선순위 평가, 그리고 적시적인 패치 적용을 포함하는 체계적인 취약점 관리 프로그램을 운영해야 한다.
ROC-Level 1	보호 (Protect)	강력한 인증	통합 디지털 운항 플랫폼 등 모든 핵심 시스템과 원격 접속에 대해 다중 인증(MFA)을 의무화해야 한다.
ROC-Level 1	보호 (Protect)	데이터 보안	모든 민감한 운항 및 선박 데이터에 대해 저장 시(at-rest) 및 전송 시(in-transit) 암호화를 적용하는 포괄적인 데이터 보안 프로그램을 이행해야 한다.
ROC-Level 2	탐지 (Detect)	중앙 집중 모니터링	모든 핵심 시스템의 로그를 중앙으로 수집하고 분석하기 위한 SIEM(보안 정보 및 이벤트 관리) 솔루션을 구축해야 한다. 알려진 공격 TTPs에 기반한 탐지 규칙을 개발하고 지속적으로 개선해야 한다.
ROC-Level 2	탐지 (Detect)	엔드포인트 위협 탐지	운영자 워크스테이션 및 핵심 서버에 EDR(엔드포인트 탐지 및 대응) 솔루션을 도입하여 지능형 악성코드 및 비정상적인 행위를 탐지해야 한다.
ROC-Level 2	대응 (Respond)	시나리오 기반 플레이북	운영자 계정 탈취, '선박 통신 하이재킹' 등 구체적인 위협 시나리오에 대한 상세한 대응 절차를 담은 플레이북을 개발해야 한다. 이는 Level 1의 개괄적인 계획보다 훨씬 구체적이어야 한다.
ROC-Level 2	대응 (Respond)	외부 협력	사고 발생 시 MASS, 항만 당국, 관계 기관과의 명확한 의사소통 및 협력 프로토콜을 수립하고 훈련해야 한다.
ROC-Level 2	복구 (Recover)	업무 연속성 계획	ROC 자체의 기능 마비를 대비한 포괄적인 업무 연속성 및 재해 복구(BC/DR) 계획을 수립하고 테스트해야 한다. 여기에는 제2의 ROC와 같은 지리적 이중화 방안이 포함될 수 있다.
ROC-Level 3	지능형 사이버 복원력 (MITRE CREF)	리스크 관리 전략	조직의 리더십은 사이버 보안 리스크에 대한 조직의 수용 수준(Risk Appetite and Tolerance)을 공식적으로 설정하고 전사에 전달해야 한다. 모든 주요 사업 결정은 이 리스크 전략을 고려하여 이루어져야 한다.

부록

성숙도	Domain(영역)	요구사항	상세 내용
ROC- Level 3	지능형 사이버 복원력 (MITRE CREF)	역할 및 책임	사이버 리스크에 대한 최종적인 책임(Accountability)을 CISO뿐만 아니라 최고 경영진과 이사회에 부여해야 한다. 전사적인 보안 문화를 조성하고 강화해야 한다.
ROC- Level 3	지능형 사이버 복원력 (MITRE CREF)	사이버보안 공급망 리스크 관리 - C-SCRM	위성 통신 사업자, 플랫폼 개발사, 클라우드 서비스 제공자 등 기술 공급업체와 관련된 리스크를 관리하기 위한 공식적인 C-SCRM 프로그램을 수립해야 한다. 모든 공급업체 계약서에 구체적인 보안 요구사항을 명시하고, 핵심 소프트웨어 공급업체에게는 소프트웨어 자재 명세서(SBOM) 제출을 의무화해야 한다. 핵심 공급업체에 대한 실사 및 정기적인 보안 수준 평가를 수행해야 한다.
ROC- Level 3	지능형 사이버 복원력 (MITRE CREF)	DevSecOps 적용	통합 디지털 운항 플랫폼과 같이 ROC에서 자체 개발하거나 유지보수하는 모든 소프트웨어에 대해 시스템 보안 엔지니어링(SSE) 원칙을 적용해야 한다. 이는 CI/CD 파이프라인 내에 위협 모델링, 시큐어 코딩, 정적/동적 애플리케이션 보안 테스트(SAST/DAST)를 통합하는 DevSecOps 체계 구축을 의미한다.
ROC- Level 3	보안 시스템 개발 및 운영 (NIST SP 800-160)	Analytic Monitoring (분석적 모니터링)	해사 분야에 특화된 위협 인텔리전스를 수집/분석하는 전담팀을 운영하고, SIEM, EDR, 선박 OT 데이터를 융합하여 전체 위협 가시성을 확보해야 한다.
ROC- Level 3	보안 시스템 개발 및 운영 (NIST SP 800-160)	Redundancy (중복성)	시스템 및 네트워크 이중화를 넘어, 물리적 재해나 공격에 대비하여 전체 ROC 기능을 수행할 수 있는 지리적으로 분리된 백업 센터를 구축해야 한다.
ROC- Level 3	보안 시스템 개발 및 운영 (NIST SP 800-160)	Adaptive Response (적응형 대응)	SOAR(보안 오케스트레이션, 자동화 및 대응) 플랫폼을 도입하여 주요 사고 대응 플레이북을 자동화해야 한다.
ROC- Level 3	보안 시스템 개발 및 운영 (NIST SP 800-160)	Dynamic Positioning (동적 위치 지정)	ROC의 외부 접속점(예: VPN 게이트웨이)을 고정된 IP가 아닌, 주기적으로 변경되는 임시 클라우드 인프라 기반으로 구성하여 공격 표적을 유동적으로 만들어야 한다.
ROC- Level 3	보안 시스템 개발 및 운영 (NIST SP 800-160)	Deception (기만)	실제 ROC 운영 환경을 정교하게 모방한 고도의 상호작용이 가능한 허니넷(HoneyNet)을 구축하여, 지능형 공격자를 유인하고 분석해야 한다.

B. 자율운항선박 보안솔루션 분류

대분류	중분류	스마트선박 보안모델		자율운항선박 보안모델	
		권고	강화	MASS	ROC
01. 네트워크 보안	01-1 네트워크 접근제어 솔루션 (NAC)		○	○	○
	01-2 무선 네트워크 보안 솔루션		○	○	○
	01-3 계정/접근권한 관리 솔루션	○		○	○
	01-4 가상 사설망(VPN)	○		○	○
	01-5 방화벽(네트워크 방화벽, UTM, NGFW 등 포함)	○		○	○
	01-6 웹방화벽(WAF)		○	○	○
	01-7 침입탐지시스템(IDS)	○		○	○
	01-8 침입차단시스템(IPS)		○	○	○
	01-9 네트워크 모니터링 시스템(NMS)	○			
02. 시스템(단말) 보안	02-1 악성코드/랜섬웨어 대응 솔루션(백신)	○		○	○
	02-2 지능형 지속공격 대응(APT)		○	○	○
	02-3 엔드포인트 탐지 및 대응(EDR)		○	○	○
03. 정보유출 방지	03-1 데이터 유출 방지 솔루션(DLP)		○	○	○
	03-2 보안 USB		○	(Hardening)	
04. 암호/인증	04-1 인증 솔루션(SSO, MFA)		○	○	○
	04-2 전송구간 암호화(SSL)	○		○	○
	04-3 데이터 암호화 (DRM, DB암호화)			○	○
05. 보안관리	05-1 취약점 진단 솔루션	○		○	○
	05-2 모니터링 및 로그분석 솔루션(SIEM)		○	○	○
	05-3 패치 관리 솔루션(PMS)	○		○	○
	05-4 백업/복구 솔루션	○		○	○
06. 선박 사이버보안	06-1 선박 사이버보안 솔루션		○	○	
	06-2 선박 사이버보안 관제 및 운영(SOC)		○	○	○
	06-3 선박 사이버보안 교육	○		○	○
	06-4 보안 오케스트레이션 (SOAR)			○	○
	06-5 위협 인텔리전스 플랫폼			○	○
07. AI 보안	07-1 학습 데이터 보호			○	○
	07-2 적대적 공격 방어			○	○
	07-3 AI 모델 접근 보호 및 모니터링			○	○
	07-4 인간 검증 체계			○	○

C. 자율운항선박 AI 보안(Security for AI) 가이드

1. 자율운항선박의 AI 보안 위협

AI 기반 항해 기술의 확산은 MASS의 고도화를 가속하는 동시에, 새로운 보안 위협을 빠르게 부각시키고 있다. MASS는 IT 시스템과 OT(운영기술) 시스템이 긴밀하게 융합된 구조를 갖기 때문에, 단일 장비부터 선박 내부 네트워크, 선박 전체, 그리고 원격운영센터(ROC)에 이르기까지 공격 표면이 광범위하게 확장되는 특성을 가진다.

○ AI 도입이 가져온 새로운 공격면 증가

- AI는 MASS에서 핵심적인 판단 기능을 수행하지만, 동시에 기존 시스템에는 존재하지 않던 고유하고 새로운 취약점을 만든다. 특히 AI 모델은 입력 데이터에 민감하며, 이를 악용한 적대적 AI 공격(Adversarial AI Attack)이 주요 위협으로 떠오르고 있다.

○ AI 특유의 보안 취약점 특성

- ✓ 적대적 입력(영상 등 입력 신호, Prompt 등 입력 데이터, 기준 데이터 등)을 통한 AI 오인식
- ✓ 학습 데이터를 겨냥한 데이터 중독(Poisoning)
- ✓ AI 모델 자체를 노리는 AI 모델 탈취·변조
- 이러한 공격은 전통적인 사이버보안 체계로는 탐지·대응이 어렵고, **AI 모델이 스스로 잘못된 결정을 내리도록 유도한다**는 점에서 매우 위험하다.

○ 사이버-물리 시스템 위험 증대

- AI가 운항결정에 직접 관여하는 자율운항선박에서는 보안 실패가 곧 물리적 위협으로 이어진다. 실제 연구에서는 AI 보안 취약점을 방치할 경우 충돌, 좌초, 오염사고 등 심각한 사이버-물리 사고로 확대될 수 있음을 지적하고 있다. 이와 관련한 다양한 공격 시나리오도 검토되고 있으며, 인명 피해와 경제적 손실 가능성에 대한 의견도 제기되고 있다.

○ 보안과 혁신의 병행 필요성

- AI 기술은 MASS 혁신의 핵심 요소이지만, 동시에 MASS를 새로운 공격 지형 위에 올려놓고 있다. 따라서 MASS 분야에서는 AI 도입과 AI 안전·보안 강화 노력이 반드시 병행되어야 하며, 데이터·모델·제어 단계 전반에 걸친 다층적 보안체계가 요구된다.

2. 데이터-제어 루프 구조에서의 사이버-물리적 위험

자율운항선박은 센서 데이터 수집 → AI 판단 → 제어 명령 실행으로 이어지는 데이터-제어 루프(Closed Loop)를 기반으로 운용된다. 이 구조는 MASS가 가진 핵심 장점이지만, 동시에 단일 지점의 침해가 전체 물리 시스템으로 확산되는 위험을 내포한다.

❶ 루프 내 단일 요소 공격 → 직접적인 물리적 결과

- 데이터 흐름 또는 제어 흐름의 한 단계만 조작되어도, 잘못된 판단이 그대로 물리적 행동으로 이어질 수 있다. 특히 AI가 조향·추진 제어에 직접 관여하는 환경에서는 오류로 인해 장애물과의 충돌·선박 좌초와 같은 대형사고로 연결될 수 있다.

❷ 항행 데이터 위·변조의 심각성

자율운항선박의 항행 데이터가 위·변조되는 상황을 고려하면, 매우 심각한 상황이 발생할 수 있다.

- ✓ GPS·AIS와 같은 항법 데이터가 변조되면 AI의 상황 인식은 즉시 교란됨
- ✓ 예를 들어, 2025년 사우디 인근에서 발생한 MSC ANTONIA호 좌초 사고는 GPS 스푸핑으로 위치 인식이 수백 km 이상 왜곡된 것이 원인으로 분석되었음
- ✓ 또한, 같은 시기 페르시아만 유조선 충돌 사고도 AIS 항적이 내륙으로 표시될 만큼 조작된 것으로 추정됨

❸ 센서 교란만으로도 발생하는 ‘안전 착각’

- 공격자는 센서 또는 데이터 흐름만 교란해도 MASS가 ‘정상 항해 중’이라는 착각에 빠지도록 만들 수 있다. 이 경우 선박은 암초나 위험 해역을 향해 스스로 돌진하게 된다.

❹ 사람의 개입이 어려운 MASS의 특성

- MASS는 무인 또는 소수 인원으로 운용되기 때문에, 이상 상황에서 즉각적인 인간 개입이 어렵다.
- 따라서 동일한 사이버 공격이라도 전통 선박보다 물리적 피해가 발생할 가능성이 훨씬 높다.

❺ 전 단계에 걸친 취약점 점검 필요

- 데이터 수집, 전처리, AI 판단, 제어 명령, 하위 제어장치 등 모든 단계가 사이버-물리적 취약점을 가진다.
- MASS 보안은 특정 시스템 보호가 아니라, 전체 루프의 연속성과 무결성을 방어하는 접근이 필수적이다.

3. 자율운항선박의 AI 시스템과 공격 표면

가. MASS에서 사용되는 주요 AI 기술 계층별 분류

자율운항선박은 선원의 판단과 조작을 대체하거나 보조하기 위해 다양한 AI 모듈을 계층 구조로 도입한다. 주요 구성은 다음과 같다.

🌀 센싱 및 인지/인식 계층 (Perception Layer)

- 이 계층은 센서 데이터를 기반으로 주변 환경을 이해하는 역할을 수행한다. 이를 살펴보면 다음과 같다.
 - ✓ 카메라, 레이더, 라이다, AIS, GPS 등으로부터 데이터를 수집함
 - ✓ AI는 이 정보를 실시간 분석해 장애물 탐지, 위험요소 식별, 항로 표시 인식 등을 수행함
 - ✓ 원격운항 선박에서는 객체 인식 AI가 선원의 시각을 보조하며, 완전자율 단계에서는 항해 당직 역할까지 수행함
 - ✓ 딥러닝 기반 객체 검출과 상황인식 알고리즘이 핵심이며, 이는 MASS 안전성에 직접 연결되는 기능 가짐

🌀 의사결정/계획 계층 (Decision & Planning Layer)

- 인지된 정보를 바탕으로 운항 전략을 결정한다.
 - ✓ 경로 계획, 동적 항로 생성, 충돌 회피 Maneuver를 수행함
 - ✓ 심층 강화 학습(Deep Reinforcement Learning), 진화 알고리즘 등을 활용해 COLREG 규칙을 준수하면서 최적 경로를 산출함
 - ✓ 일부 국가에서는 AI가 속력·방향까지 통합적으로 판단하는 AI 선장 시스템을 개발·도입 중
 - ✓ 이 계층은 MASS의 “두뇌”로, 복잡한 상황에서 인간 개입 없이 의사결정을 수행하는 역할을 함

🌀 제어/실행 계층 (Control & Actuation Layer)

- 결정된 명령을 실제 장비에 전달해 선박을 움직이는 단계다.
 - ✓ 자동조타장치, 기관제어장치와 연동해 조타각·출력을 제어함
 - ✓ AI 명령을 검증 후 전달하는 중간 제어 로직과 Fail-Safe 검사가 포함됨
 - ✓ 완전 무인선의 경우 원격제어 인터페이스도 포함되며, 필요 시 ROC(원격운영센터)가 수동 개입할 수 있음
 - ✓ 임베디드 제어기·PLC 기반으로 동작하며, 제어 계층 이상은 물리적 사고와 직결되기 때문에 높은 안전성을 요구함

❖ 기타 지원 AI (Auxiliary AI Systems)

- 핵심 운항 기능 외에도 여러 부문에서 AI가 사용된다.
 - ✓ 예지보전(Predictive Maintenance), 연료·에너지 최적화, 화물 적재 최적화 등 운영 효율 개선용 AI
 - ✓ NLP·LLM 기반 AI 비서, 운영 매뉴얼 질의응답 시스템 등 선원·관제 지원 AI
 - ✓ 이러한 보조 AI는 직접 제어에 관여하지 않더라도, 데이터 흐름과 연결될 경우, 추가 공격 경로가 될 수 있다.

즉, MASS는 인지 → 판단 → 제어의 3계층 AI 구조를 중심으로, 다양한 지원 AI가 결합된 다층형 자율 시스템이다. 각 계층은 역할이 다르며 동시에 고유의 취약점을 가진다.

나. AI 기반 운항 프로세스 및 공격 지점 매핑

자율운항선박의 운항 과정은 데이터 흐름(센서 입력)과 제어 흐름(AI 결정 출력) 관점에서 볼 수도 있다. 공격자는 이 연속된 루프의 각 단계를 표적으로 삼아 시스템 전반을 교란할 수 있는데, 이를 각 단계 별로 살펴보면 다음과 같다.

❖ 센서·데이터 수집 단계

- AI가 인지하는 모든 정보가 유입되는 가장 넓은 공격 표면이다.
 - ✓ GPS, AIS, 레이더, 카메라 데이터는 스푸핑·위조·재밍 공격에 취약함
 - ✓ 항법 데이터가 변조되면 AI는 잘못된 위치·상황 정보를 기반으로 운항하게 되어 치명적인 결과를 초래할 수 있음. 실제로 GPS 스푸핑으로 선박의 위치가 수백 km 왜곡되거나, AIS 항적이 내륙으로 표시된 사례가 보고되었음
 - ✓ 또한, 카메라의 대상 객체에 Adversarial Patch를 부착하거나 프린트/디스플레이 함으로써, AI가 물체를 보지 못하거나 오인식 하게 만들 수 있음
 - ✓ 기상정보, 전자해도(ENC) 업데이트 파일 변조 공격도 가능함
 - ✓ 또한, 위성·무선 통신 구간에서는 MITM(중간자) 공격으로 데이터가 지연 또는 변조될 수 있음
 - ✓ 위와 같은 공격을 통해, 공격자는 AI가 신뢰하는 입력 전체를 불신하게 만드는 공격이 가능해짐

○ 데이터 전처리 및 AI 입력 처리 단계

- 센서 데이터를 가공·융합하는 과정에 대한 공격이다.
 - ✓ 전처리 모듈의 취약점(버퍼 오버플로 등)을 악용하면 악성코드 삽입이 가능함. 또한, 각종 사이버공격 기법을 사용할 수 있음(MITRE ATT&CK상의 Tactics 와 Techniques을 참고)
 - ✓ 센서 간 보정 알고리즘을 속여 Fusion 결과를 불안정하게 만들 수 있음 (예: 레이더·라이다·AIS 등의 입력 데이터가 일부러 불일치·상반되도록 조작)
 - ✓ 데이터 스트림에 백도어 패턴을 숨겨두면 특정 트리거 입력에서 AI가 오작동하게 됨
 - ✓ 즉, 전처리 단계에 대한 공격은 AI의 인식 기반을 교란해 이후 모든 판단을 흔드는 공격 방법임

○ AI 모델 및 의사결정 단계

- AI 두뇌에 해당하는 핵심 계층으로 공격자가 가장 선호하는 표적이다. 생성형 AI인 경우에는 Prompt Injection 공격을 통해 더욱 정교한 공격이 가능해진다.
- 모델 자체를 탈취·변조하거나 원격 업데이트로 교체하면 AI 판단 전반이 공격자 통제에 놓일 수 있다. 결국 모델에 대한 오염 상황을 발견하기 어렵고, 영향이 전체 시스템으로 확산되므로 가장 치명적인 계층으로 볼 수 있다.
 - ✓ 탐지 회피 공격(Evasion)을 통해 AI 객체인식이 부표·선박 등을 오인하도록 만들 수 있음
 - ✓ 데이터 중독(Poisoning)은 훈련 데이터에 악성 레이블을 넣어 의사결정 로직을 왜곡함
 - ✓ AI 모델이 특정 AIS 패턴에 반응하도록 하는 모델 백도어도 삽입 가능함
 - ✓ 생성형 AI인 경우에는 Prompt 수준의 공격이 가능해짐

○ 제어 명령 및 실행 단계

- AI의 결정이 실제 장비로 전달되는 물리적 실행 단계이다. 제어 계층은 AI-물리 세계 연결점이므로 무결성과 인증 확보가 핵심이다.
 - ✓ 공격자는 자동조타 장치에 명령을 주입해 러더 각도를 강제로 변경할 수 있음
 - ✓ 기관제어 메시지를 변조해 출력 급상승 등의 위험 동작을 유발할 수 있음
 - ✓ ROC(원격운영센터) 통신을 탈취하면 원격으로 선박을 장악할 수 있음
 - ✓ 사람의 지속적인 감시가 어려운 MASS 특성상, 이 단계 공격은 즉각적인 물리사고로 이어질 가능성이 큼

이처럼, 자율운항선박의 전체 데이터-제어 루프에는 다층적 공격 지점이 존재한다. 센서 조작 → AI 판단 교란 → 제어 명령 변조로 이어지는 공격은 각 단계에서 은닉되다가 최종적으로 물리적 사고로 현실화될

수 있다. 따라서 MASS 보안은 특정 단계만 보호해서는 부족하며, 공격 표면을 구조적으로 분석하고 계층별 방어를 중첩 적용하는 심층적인 접근이 필수적이다.

다. 기존 IT/OT 시스템과의 차별성과 AI 고유의 위험 요소

자율운항선박 보안은 기존 IT/OT 보안과 유사한 부분이 많다. 그러나 AI 도입으로 인해 기존에는 없던 고유한 위험 요소가 새롭게 등장하고 있으며, MASS 보안의 본질적 차이를 만든다. 주요 차별점은 다음과 같다.

○ 공격 양상의 변화

- 기존 선박 보안은 네트워크 침입·악성코드·물리적 침입 등이 중심이었다.
- 하지만 MASS에서는 데이터 조작을 통한 간접 공격이 더 위협적이다.
 - ✓ 공격자는 시스템 권한을 탈취하지 않아도 됨
 - ✓ AI가 의존하는 데이터를 교란하는 것만으로 사고 유발이 가능함. 예로써, AI 비전이 보지 못하도록 위장 패턴을 부착하면 충돌 위험이 즉시 증가함
 - ✓ 즉, 데이터 무결성 공격이 곧 물리적 안전 문제로 직결되는 새로운 공격 지형이 형성됨

○ 인간 오류 vs. 시스템 불확실성

- 전통 선박 사고는 대부분 인간의 피로·부주의 등 “인적 요인”이었다.
- 반면 완전자율 선박의 약점은 복잡한 시스템의 불확실성과 예측 불가능성이다.
 - ✓ AI는 훈련된 패턴에서 벗어난 상황에 취약함
 - ✓ 시스템 내부 결함은 연쇄적으로 전체 기능 장애로 확대될 수 있음
 - ✓ 결과적으로, MASS는 기술 복잡성에 대한 과도한 신뢰가 새로운 위험을 만들

○ 취약점의 비가시성과 통계적 특성

- 기존 IT 취약점(소프트웨어 버그 등)은 확인·패치가 비교적 용이하다.
- 그러나 AI 취약점은 숨겨져 있고 통계적 특성을 가진다.
 - ✓ 적대적 예제, 데이터 편향 등은 완전 제거가 어려움
 - ✓ 공격자는 새로운 패턴을 계속 만들어낼 수 있음
 - ✓ AI 판단에는 설명이 어려운 불확실성이 존재함. 즉, AI 시스템은 “모르면서 공격당할 수 있는 영역”을 내재하고 있음

○ 공격 표면의 기하급수적 확대

- AI 도입으로 MASS는 이전보다 훨씬 넓은 공격 표면을 갖게 되었다.
 - ✓ AI 모델·라이브러리·서드파티 모듈·데이터 공급망 전체가 공격 범위로 편입됨
 - ✓ 오픈소스 ML 프레임워크 내부 취약점도 공급망 공격의 경로가 됨
 - ✓ 클라우드 기반 모델 학습·배포는 모델 탈취·변조 위험을 증가시킴
 - ✓ AI 파이프라인 전주기(데이터 수집→학습→배포→운용) 보호가 필수적이며, 이는 기존 IT/OT에서는 보기 어려운 새로운 과제임

○ 안전(Safety)과 보안(Security)의 결합

- 기존에는 안전과 보안이 분리된 영역이었다. 하지만 MASS에서는 사이버보안 실패가 곧 안전사고로 직결된다.
 - ✓ 항해 SW 공격 → 공격자의 악성 데이터 삽입 경로 제공
 - ✓ 센서 결함 → 선박의 충돌·좌초 발생
- 따라서 MASS는 안전과 보안을 통합한 “디지털 항해능력(Digital Seaworthiness)” 개념이 필요하다. 즉, 보안이 확보되지 않으면 아무리 훌륭한 안전 설계도 무력화된다.

AI 도입은 공격자에게 새로운 기술적 표적과 전술을 제공하며, 동시에 방어자에게는 새로운 검증·관리·거버넌스 과제를 부여한다. AI의 데이터 의존성·복잡성·불확실성 때문에, 기존 IT/OT 보안만으로는 MASS를 방어하기 어렵다. 이에, MASS 보안을 위해서는 전통적 사이버보안 대책, AI 알고리즘 차원의 방어 기법, 안전-보안 통합 관리체계를 모두 갖춘 다층적 보호 전략이 요구된다.

4. 자율운항선박에 대한 적대적 AI 공격 유형 분석

AI 시스템을 노리는 공격은 다양한 형태로 나타난다. MITRE ATLAS(Adversarial Threat Landscape for AI Systems)는 이러한 공격을 여러 전술로 분류한다. 자율운항선박(MASS) 환경에서 특히 중요한 공격 유형은 다음과 같다.

❶ 탐지 회피 공격(Evasion)

- AI 모델이 입력을 잘못 인식하도록 만드는 공격이다.
 - ✓ 미세한 적대적 노이즈나 Adversarial Patch를 영상에 삽입함으로써 공격을 함. 이를 통해, AI 비전 모델은 물체를 다른 것으로 분류하거나, 아예 인식하지 못하게 됨
 - ✓ 예: 부표나 작은 보트에 특수 스티커를 붙이면 AI 카메라가 이를 바다 배경으로 오인함
 - ✓ 실제 실험에서는 선박 이미지를 “얼룩말” 등 엉뚱한 객체로 분류하거나 주변 선박을 탐지하지 못한 사례도 보고되었음
 - ✓ 핵심: 탐지 회피 공격은 정상 입력처럼 보이기 때문에 기존 보안기술로 탐지하기 매우 어려움

❷ 데이터 중독 공격(Poisoning)

- AI 학습 데이터를 조작해 모델의 행동을 왜곡하는 공격이다.
 - ✓ 공격자는 AIS 기록 등 항행 데이터를 변조해 허위 패턴을 주입할 수 있음
 - ✓ 예를 들어, 연구 사례에서는 AIS 데이터의 MMSI·좌표값을 교체해 모델 오동작을 유도한 경우도 있음. 예를 들어, “근접 50m → 안전” 같은 잘못된 라벨을 대량 삽입하면 AI는 위험 선박임에도 불구하고 관대하게 반응함
 - ✓ 또한 특정 패턴(AIS 신호 등)에 반응하는 백도어 모델을 심어 특정 상황에서만 의도적 오작동을 일으킬 수 있음. 온라인 학습·자가학습을 도입한 모델은 소수의 악성 데이터만으로도 쉽게 오염됨
 - ✓ 이 공격 유형, 즉, 데이터 중독 공격은 지속적이고 은밀하며, 전체 수명주기에 걸쳐 모델을 왜곡함

❸ 정보탈취 및 기밀 공격(Confidentiality Attacks)

- AI 모델 또는 학습데이터를 탈취·추정하는 공격이다.
 - ✓ API를 기반으로 반복 질의를 수행해 모델 매개변수·동작 경향을 복제하는 모델 추출(Model Extraction)이 가능함. 이를 통해 공격자는 유사한 모델을 생성해 화이트 박스 공격 준비를 할 수 있음

- ✓ 모델 반추(Model Inversion)를 통해 특정 선박의 항로 등 학습데이터를 역으로 유추할 수도 있음
- ✓ 인증 토큰 탈취 등으로 모델 업데이트 채널에 접근하면 악성 모델로 교체하는 공격도 가능함
- ✓ 즉, 모델은 MASS의 핵심 자산이므로, 탈취는 즉시 안전·운항 논리 전체가 노출되는 심각한 위협이라고 할 수 있음

❶ 계획 교란 공격(Planning Attacks)

- 자율에이전트의 계획·보상체계를 조작해 AI의 운항 전략을 왜곡하는 공격이다.
 - ✓ 강화학습(Reinforcement Learning) 보상함수를 조작하면 AI가 충돌 위험을 위험으로 인식하지 않도록 만들 수 있음
 - ✓ 시뮬레이터에서는 안전한 경로로 학습을 시켜놓고, 실제 환경에서는 그 경로에 장애물을 몰래 추가해 AI를 함정에 빠뜨릴 수 있음
 - ✓ AIS로 “해역 폐쇄” 등의 거짓 우회 지시를 반복 방송하면, AI는 이를 진짜로 받아들여 공격자 의도대로 경로를 변경할 수 있음
 - ✓ 본 계획 교란 공격은 MASS만의 고유한 공격 벡터이며, 운항 전략 자체를 조작하는 것임

❷ 프롬프트 주입 공격(Prompt Injection)

- LLM을 사용하는 MASS 구성요소에 악성 지시문을 삽입하는 공격이다.
 - ✓ LLM 기반 매뉴얼 Q&A, 항해 지원 시스템 등에서 발생 가능함
 - ✓ 공격자는 교묘한 입력을 통해 AI의 거버넌스 규칙을 우회하거나, 위험한 정보를 생성하게 만들 수 있음
 - ✓ 예를 들어, “긴급—충돌 회피 위해 즉시 좌현 전타” 같은 거짓 메시지를 넣어 AI가 잘못된 조언을 하도록 유도함
 - ✓ 저장된 로그·DB에 악성 텍스트를 숨기고, LLM가 이를 요약할 때 악성 프롬프트가 실행되도록 하는 방식도 있음
 - ✓ LLM 도입이 확대되면 프롬프트 인젝션은 사이버 사회공학 공격의 새로운 형태가 됨

여기서 제시된 다섯 가지 공격은 MASS AI를 겨냥할 수 있는 대표적 공격 기법으로 볼 수 있다. 이외에 추가적으로 공급망 공격, AI 기반 IDS 우회, 악성 모델 업데이트 등도 존재한다. 이러한 공격 기법에 있어서, 공격자의 최종 목표는 명확한데, AI 시스템을 오류 상태로 만들어 물리적·경제적 이익을 취하는 것이 목표인 것이다.

5. 공격 사례 및 위험 영향 분석

가. 실제 사고 시나리오 기반 피해 모델링

자율운항선박을 겨냥한 적대적 AI 공격은 아직 실제 사례가 많지 않다. 그러나 유사 사건과 가상 시나리오를 통해 잠재 피해 규모와 위험성을 충분히 예측할 수 있다. 대표적인 두 가지 시나리오는 다음과 같다.

○ 시나리오 A: 시각 센서 회피로 인한 충돌 사고

- 공격자는 모터보트에 Adversarial Patch를 도색해, AI 비전 모델이 이를 ‘배’로 인식하지 못하도록 설계한다.
- 자율운항 화물선의 AI는 레이더와 비전을 함께 사용하지만, 카메라 영상에서 모터보트를 끝내 탐지하지 못한다.
- 그 결과 화물선은 회피 기동 없이 충돌 경로를 유지하고, 모터보트 측이 의도적으로 접근해 실제 충돌이 발생한다.
- 충돌 후 선체 파공 및 엔진 손상이 발생하고, 해적은 선박에 승선해 선박을 장악한다.
- 피해:
 - ✓ 선체 수리비 및 화물손상
 - ✓ 해적 피랍으로 인한 안보 위협
 - ✓ 운항 중단에 따른 추가 손실

○ 시나리오 B: 항법 데이터 스푸핑에 의한 좌초 사고

- 자율운항 유조선이 항해 중 GPS 스푸핑 공격을 받아 수백 km 떨어진 내륙 좌표를 수신한다.
- AI 항법 시스템은 자신의 위치가 벗어났다고 판단하고 자동으로 경로를 수정한다.
- 실제로는 정상 항로에서 벗어나 암초 해역으로 이동하고 있었으며, AI는 이 오차를 알아채지 못한다.
- 결국 선박은 암초에 충돌해 좌초되고, 유류 수천 톤이 유출되며 대규모 해양오염이 발생한다.
- 피해:
 - ✓ 선박 파손 및 복구 비용
 - ✓ 환경오염으로 인한 막대한 사회·경제적 피해
 - ✓ 국가 간 외교·안보 문제로 확산 가능성

○ 시사점

- 이 두 시나리오는 적대적 AI 공격이 단순한 시스템 오류가 아니라 직접적인 물리적 재난으로 이어질 수 있음을 보여준다.
- 충돌·좌초는 인명·환경·안보·경제 등 다차원에서 대규모 파급효과를 발생시키며, MASS에 대한 신뢰도 까지 위협한다.

나. 데이터-제어 루프 단계별 위협 매핑

자율운항선박의 데이터-제어 루프는 센서 입력 → AI 판단 → 제어 실행의 순서로 구성된다.

각 단계는 서로 다른 공격 벡터를 가지며, 공격이 누적될 경우 사고로 직결될 수 있다.

🔍 센서 입력 단계

- GPS·AIS 스푸핑, 레이더 재밍, 카메라 눈부심 등이 대표적 위협이다.
- 위치·속도 등 핵심 항법 데이터가 왜곡되면 전체 판단이 흔들린다.
- AI는 주변 상황을 잘못 파악해 충돌·좌초 위험에 직면한다.
- 센서퓨전 체계에서도 한 센서의 오류가 전체 판단 과정에 불확실성을 유발한다.
- 핵심: 입력단 공격은 MASS의 상황 인식 능력을 무력화한다.

🔍 AI 의사결정 단계

- 적대적 패치 등으로 인해 AI가 입력을 잘못 해석하면 판단 자체가 왜곡된다.
- Poisoning·백도어 등이 숨어 있으면 정상처럼 보이면서 특정 조건에서 치명적 오판이 발생한다.
- COLREG 등 국제 규칙 위반도 유발될 수 있어 안전·법률 문제로 직결된다.
- 입력단에서의 공격은 MASS의 핵심 의사결정 기능을 장악한다.

🔍 제어 실행 단계

- 조타각·추진 명령을 조작하거나 제어 신호를 가로채면 실제 선박이 위험 행동을 취한다.
- 원격운영센터(ROC) 통신이 탈취되면 공격자가 선박을 완전히 장악할 수 있다.
- MASS는 인력이 적기 때문에 이상 동작을 즉시 확인하기 어렵다.
- 제어단 공격은 즉각적 물리 피해로 이어질 가능성이 가장 높다.

🔍 단계별 위협 구조 요약

- 센서 공격 → AI 판단 교란 → 제어 명령 변조로 이어지는 공격은 단계마다 은닉되면서 누적되고, 최종적으로 물리적 사고로 연결된다.

- MASS는 인간의 개입이 제한적이므로, 단계별 방어체계 구축이 필수다.

다. 피해의 종류별 분석

적대적 AI 공격의 피해는 단일 범주가 아니라 복합적·다차원적이다. 주요 피해 유형은 다음과 같다.

❶ 물리적 사고 및 안전 피해

- 충돌, 좌초, 침몰, 화재, 환경오염 등 직접적 사고가 발생할 수 있다.
- MASS 사고는 시스템 책임이므로 책임 규명이 어렵다.
- 대형 유류 유출은 어업, 항만 운영, 해양 생태계에 장기적 피해를 준다.
- 사고 위험성만으로도 자율운항 기술에 대한 사회적 신뢰가 하락한다.

❷ 경제적 손실

- 선박·화물 피해, 항로 차질, 보험료 증가 등 직접 비용이 매우 크다.
- 해적·범죄조직이 사이버 공격을 활용해 랜섬 요구 등 새로운 형태의 해적질을 시도할 수 있다.
- 기업 신뢰도 하락, 화주 이탈, 시장가치 하락 등 간접 피해도 발생한다.

❸ 국가 안보 및 해상 치안 위협

- 국가 간 분쟁 상황에서 MASS는 사이버 무력화 대상이 될 수 있다.
- 항법교란은 해상교통 혼란을 유발해 국가 경제와 안보에 영향을 미친다.
- 무인선 피랍·폭발 시나리오는 테러 수준의 충격을 일으킬 수 있다.
- 각국 해군·해경은 이미 해상 사이버테러 대응 훈련을 강화 중이다.

❹ 사회·법·윤리적 영향

- 사고 발생 시 책임 주체가 불명확해 법률적 혼란이 발생할 수 있다.
- AI 투명성·설명가능성 요구가 증가하며, 기술 수용성 저하로 이어질 수 있다.
- 사고 은폐·축소 시 사회적 불신이 더욱 커진다.

적대적 AI 공격이 가져오는 피해는 물리·경제·안보·사회 전 영역을 포함하는 전방위적 리스크이다. 따라서 MASS 보안은 단순 기술 대응이 아니라 종합적 위험관리 접근이 필요하다.

5. 방어 전략 및 적용

자율운항선박의 AI 보안을 확보하기 위해서는 기술적 방어 전략과 정책·제도적 지원이 함께 이루어져야 한다. 본 장에서는 데이터/센서 → AI 모델 → 시스템 아키텍처 순으로 핵심 방어기술을 정리한다.

가. 데이터 및 센서 레벨 방어 기술

데이터와 센서는 MASS의 판단 기반이므로, 가장 먼저 보호해야 하는 계층이다.

❶ 다중 센서 융합 및 교차 검증

- 여러 센서 데이터를 비교해 한 센서가 이상치일 경우 다른 센서로 보정한다. 예를 들어, 카메라가 놓친 물체를 레이더가 보완하는 식이다.
- 이러한 센서 퓨전은 단일 센서 교란으로 AI모델의 인지가 무너지는 것을 방지할 수 있으며, AI기반의 센서 이상탐지를 활용하여 특정 센서에 대한 교란(이상) 유무 판단이 가능하다.

❷ 신호 무결성 모니터링 및 인증

- GPS·AIS 신호의 SNR, 삼각측량 오차 등을 실시간 감시하여 스푸핑 징후를 탐지한다.
- AIS·항법 데이터에 전자서명 등을 도입해 출처 검증을 강화한다.
- 차세대 GNSS 인증 서비스나 보안 AIS 표준은 장기적으로 스푸핑 방어력을 높일 수 있다.

❸ 물리적·기술적 센서 보호

- GPS 재밍 대응 안테나, AIS 주파수 분산, 카메라 레이저 필터, 레이더 간섭 제거 알고리즘 등 적용한다.
- 물리적 교란에 강한 설계는 사이버 대응을 보완하는 1차 방어층이다.

❹ 실시간 이상탐지 및 필터링

- 속도·방위 변화율 등 항해 데이터 기준을 벗어나는 입력을 자동 필터링한다.
- 이미지 기반 적대적 패턴 탐지를 적용해 AI 비전 공격 효과를 완화한다.
- 완벽한 차단은 어렵지만 기본적인 전처리가 AI 입력 품질을 높여 공격을 약화시킨다.

❺ Fail-Safe 센서 운영

- 센서가 불신 상태로 판정되면 기능 축소 또는 안전 모드로 전환한다.
- 예: GPS 스푸핑 의심 시 감속 및 안전해역 대기, 카메라 장애 시 레이더 기반 회피모드 적용.
- 센서 오류가 전체 사고로 확산되는 것을 차단하는 핵심 메커니즘이다.

나. 모델 보호 및 러버스트니스(Robustness) 확보 방안

AI 모델은 MASS의 핵심 판단 엔진이므로, 전주기 보안이 필수적이다.

🔗 적대적 학습(Adversarial Training) 수행

- FGSM·PGD 등 적대적 샘플을 포함해 학습시켜 Evasion 공격 내성을 강화한다.
- 해상 환경에서 발생 가능한 patch·노이즈 공격을 사전 훈련하여 모델 신뢰도를 높인다.
- 강화학습기반 시스템도 공격 시나리오 포함 학습이 필요하다.

🔗 모델 아키텍처 강화 및 앙상블 모델 사용

- Value Bounding · Bayesian Neural Network · 스펙트럼 정규화 등 Robust 구조 적용이 필요하다.
- 서로 다른 모델을 결합하여 추론하는 앙상블 방식은 서로 다른 모델을 결합하여 사용하기 때문에 개별 모델의 취약성에 대한 내성을 갖는다.
- 독립 모델 다중학습은 공격 성공률을 대폭 낮춘다는 연구결과가 있다.

🔗 AI 모델에 대한 접근 통제 강화 및 무결성 검증 수행

- AI 모델 파일에 강력한 접근제어 및 디지털 서명을 적용한다.
- 업데이트 시, 해시 검증(SHA-256/512 등)을 수행해 모델 변조를 방지한다. (모델 무결성)
- 런타임 무결성 검사를 통해 메모리 상의 가중치 변조를 차단한다.

🔗 AI 거버넌스 구축 및 지속 모니터링 수행

- AI가 생성한 명령이 COLREG 등 안전 규칙을 위반할 경우 자동 차단(Output Validation)한다.
- 입력 데이터의 분포 변화 감지, 성능 헬스체크 등 MLOps 기반 모니터링 수행한다.
- 모델 열화·편향 발생 시, 즉시 재학습 또는 조치한다.

🔗 비상시의 사람의 개입 필요성 있음

- AI 판단이 의심될 경우, ROC가 즉시 수동조종으로 전환할 수 있어야 한다.
- 통신이 끊기면 선박이 안전정지 또는 안전항로 복귀 모드로 자동 전환한다.
- MASS 환경에서는 Human-On-The-Loop(HOTL) 구조를 통해 시스템이 자율적으로 작동하되, 사람이 모니터링하며, 필요 시 개입할 수 있어야 한다.

다. 시스템 아키텍처 차원의 통합 방어 전략

MASS 전체 시스템은 Defense-in-Depth(다층방어) 설계를 따라야 한다.

❶ Zero Trust 보안 아키텍처 고려할 필요가 있음

- 모든 통신·접근 요청을 “기본적으로 믿지 않는 것”으로 처리하는 보안 모델이다.
- 센서망·제어망 등을 논리적으로 분리하여, 공격자가 수평 이동(Lateral Movement)하는 것을 차단한다.
- AI-제어 모듈 간 API 호출에도 인증·인가 정책을 적용한다.
- 원격접속은 MFA·행위기반 이상탐지를 병행한다.

❷ 방어적 설계(Fail-Safe) 기법의 적용

- AI 오류 또는 명령 충돌 시, 즉시 감속·정지 등 안전동작 수행한다.
- 통신 두절 상황에서는 사전 정의된 안전 항로 복귀 등을 자동 실행한다.
- 공격 피해를 “심각한 사고로 확산”되지 않게 하는 2차 방어선이다.

❸ 출력 검증 및 시스템 이중화

- AI 결정은 실행 전에 독립 모듈 또는 규칙 기반 엔진이 다시 검증한다.
- CPA(최근접거리) 등 위험 지표를 자동 계산해 위험 명령을 Override한다.
- 시스템 구성요소 이중화는 단일 실패 지점으로 인해 시스템 전체가 운영 중단되는 것을 방지한다.

❹ 침입 탐지 및 대응 체계 구축 필요

- MASS 환경에 맞는 IDS/IPS로 이상 트래픽·명령을 실시간 탐지한다.
- 위성통신·ROC 연결 등 외부망과의 접점이 있는 지점에는 추가적인 보호조치가 필요하다.
- 사고 대응 절차를 표준화하고, 사이버 위기 훈련을 정례화한다.

❺ 마이크로소프트사의 Software Development Lifecycle (SDLC) 준수 필요성 있음

- IEC 62443 기반 SDL을 개발 단계에 적용한다.
- 위협 모델링·코드 정적분석·취약점 테스트 등을 정례화한다.
- AI는 개발 단계에서부터 레드팀 공격 시나리오로 검증한다.
- “초기 보안 결함 제거”가 MASS 보안의 비용효율을 크게 높인다.

D. 용어 정의 및 약어

용어/약어	영문 Full-Term	설명
MASS	Maritime Autonomous Surface Ship	IMO에서 정의한 4단계 자율화 수준에 따라, 인간의 개입 없이 또는 최소한의 개입으로 운항이 가능한 선박.
ROC	Remote Operation Center	육상에서 자율운항선박의 운항 상태를 실시간으로 모니터링하고, 필요시 원격으로 제어하는 중앙 통제 시설.
OT	Operational Technology	선박의 추진, 항해, 전력 등 물리적 프로세스를 직접 제어·감시하는 하드웨어 및 소프트웨어 시스템.
IT	Information Technology	데이터의 저장, 처리, 전송을 담당하는 시스템으로, ROC의 운항 데이터 분석, 통신 인프라 등이 해당.
IMO	International Maritime Organization	국제해사기구. 해운 및 조선에 관한 국제 규범을 제정하는 UN 산하 전문기구.
IACS	International Association of Classification Societies	국제선급연합회. 선박의 안전과 관련된 기술 규칙을 제정하고 관리하는 선급들의 협회.
IEC 62443	-	산업 자동화 및 제어 시스템(IACS)의 사이버 보안을 위한 국제 표준 시리즈.
ISO/IEC 27001	-	정보보호 경영시스템(ISMS)에 대한 국제 표준.
NIST CSF	National Institute of Standards and Technology Cybersecurity Framework	미국 국립표준기술연구소에서 개발한 사이버 보안 프레임워크.
STRIDE	Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege	Microsoft에서 개발한 위협 모델링 방법론.
DFD	Data Flow Diagram	데이터 흐름도. 시스템 내 데이터의 흐름을 도식화한 다이어그램.
CIA	Confidentiality, Integrity, Availability	정보보호의 3요소 (기밀성, 무결성, 가용성).
SOPF	Safety, Operation, Privacy, Financial	해양 사이버-물리 시스템의 특성을 반영한 영향도 평가 요소 (안전, 운항, 개인정보, 재무).

용어/약어	영문 Full-Term	설명
CBM	Condition-Based Maintenance	상태 기반 유지보수. 센서 데이터를 기반으로 기기의 상태를 진단하고 유지보수 시점을 결정하는 기술.
SBOM	Software Bill of Materials	소프트웨어 자재명세서. 소프트웨어를 구성하는 모든 구성 요소의 목록.
SIEM	Security Information and Event Management	보안 정보 및 이벤트 관리. 다양한 시스템의 로그를 통합 분석하여 위협을 탐지하는 시스템.
SOAR	Security Orchestration, Automation and Response	보안 오케스트레이션, 자동화 및 대응. 보안 위협 대응 프로세스를 자동화하는 기술.
CPS	Cyber-Physical System	계산, 통신, 제어 기술이 물리적 프로세스와 깊숙이 결합되어, 사이버 공간과 물리적 세계가 상호작용하는 시스템.
ZTA	Zero Trust Architecture	'절대 신뢰하지 말고, 항상 검증하라'는 원칙에 기반한 현대적인 보안 아키텍처 모델.
C-SCRM	Cybersecurity Supply Chain Risk Management	사이버보안 공급망 리스크 관리.
AI RMF	AI Risk Management Framework	NIST에서 개발한 인공지능 리스크 관리 프레임워크.
사이버 복원력	Cyber Resilience	사이버 공격을 예방하고, 발생 시 영향을 최소화하며, 신속히 정상 상태로 복구할 수 있는 능력을 말한다. 단순 방어를 넘어 위기 대응 및 회복력까지 포함하는 개념이다.
심층 방어	Defense-in-Depth	단일 보안대책에 의존하지 않고 여러 계층의 물리적·기술적·관리적 보안 통제를 중첩하여 구성하는 다층 방어 전략이다. 예: 방화벽+IDS+안티바이러스+정책/교육 등을 모두 시행.

E. 참고 문헌

1. 국제해사기구(IMO), MSC.428(98) – Maritime Cyber Risk Management in Safety Management Systems
2. 국제선급연합회(IACS), UR E26 – Cyber resilience of ships (2023)
3. 국제선급연합회(IACS), UR E27 – Cyber resilience of on-board systems and equipment (2023)
4. 국제전기기술위원회(IEC), IEC 62443 Series – Security for industrial automation and control systems
5. 국제표준화기구(ISO), ISO/IEC 27001 – Information security management systems
6. 미국 국립표준기술연구소(NIST), Cybersecurity Framework Version 2.0
7. 한국인터넷진흥원(KISA), 스마트선박 보안모델 (2025.02)
8. BIMCO, Guidelines on cyber security onboard ships V4 (2020)
9. ClassNK, Guidelines for Automated/Autonomous Operation on ships (Software Test)
10. 해양수산부, 해사 사이버안전 관리지침 (고시 제2024-52호)
11. SUTD (iTrust), Guidelines for Cyber Risk Management in Autonomous Shipping, 2023.
12. Gartner, Cybersecurity Mesh Architecture (CSMA) Concept, 2021.
13. 자율운항선박 개발 – 정책브리핑, 8월 18, 2025에 액세스,
<https://www.korea.kr/special/policyCurationView.do?newsId=148899669>
14. 2025년 지능형 해상교통정보서비스 시행계획 – 해양수산부, 8월 18, 2025에 액세스,
https://www.mof.go.kr/jfile/readDownloadFile.do?fileType=MOF_ARTICLE&fileTypeSeq=60134&fileNum=1

(이상으로 자율운항선박 보안모델 가이드라인을 마칩니다. 본 문서가 승조원 및 보안/IT 엔지니어 분들께 실질적인 도움이 되기를 바랍니다.)



자율운항선박 보안모델

2026.01

[한국인터넷진흥원 나주본원]
(58324) 전라남도 나주시 진흥길 9
[서울청사]
(05717) 송파구중대로 135 (가락동), IT벤처타워

Copyright(C) 2025 KISA. All rights reserved.